DIGITAL HEALTH · CYBERSECURITY · CTAM+



Cybersecurity in Digital Health Technology

ความมั่นคงปลอดภัยไซเบอร์ สำหรับเทคโนโลยีสุขภาพดิจิทัล

คู่มือฉบับปฏิบัติได้จริง สำหรับโรงพยาบาล สสจ. และหน่วยบริการสาธารณสุข

พ.ร.บ.ไซเบอร์ · PDPA · CTAM+ 17 ข้อ · Wazuh SIEM · MITRE ATT&CK · Zero Trust · Incident Response · NIST CSF 2.0 · HHS 405(d)

ฉบับร่าง · ตุลาคม 2569

25 บท · 35+ แผนภาพ · Lab ลงมือทำ

ภาค 1	ภาค 2	ภาค 3	ภาค 4	ภาค 5	ภาค 6	ภาค 7
รู้จักภัยและกรอบคิด	กฎหมาย มาตรฐาน กำกับดูแล	ลงมือป้องกัน	ตรวจจับและตอบสนอง	คนและองค์กร	สุขภาพดิจิทัลยุคใหม่	รู้เขารู้เรา และเทคโนโลยีใหม่

ข้อมูลการพิมพ์และลิขสิทธิ์

ความมั่นคงปลอดภัยไซเบอร์สำหรับเทคโนโลยีสุขภาพดิจิทัล
Cybersecurity in Digital Health Technology

คู่มือฉบับปฏิบัติการสำหรับโรงพยาบาลและหน่วยบริการสาธารณสุขไทย

รายการ	ข้อมูล
ผู้เรียบเรียง	[ชื่อผู้เรียบเรียง]
จัดพิมพ์โดย	[ชื่อหน่วยงาน/สำนักพิมพ์]
พิมพ์ครั้งที่	ฉบับเผยแพร่ 1.0 ตุลาคม 2569
ISBN (ฉบับพิมพ์)	[รอขอเลข ISBN จากหอสมุดแห่งชาติ]
ISBN (ฉบับอิเล็กทรอนิกส์)	[รอขอเลข ISBN]
ความยาว	25 บท 7 ภาค ภาคผนวก 6 เรื่อง และดัชนีคำค้น

สัญญาอนุญาต

หนังสือนี้เผยแพร่ภายใต้สัญญาอนุญาต **Creative Commons แสดงที่มา-ไม่ใช้เพื่อการค้า-อนุญาตแบบเดียวกัน 4.0 สากล (CC BY-NC-SA 4.0)** ผู้อ่านคัดลอก แจกจ่าย และดัดแปลงเพื่อการศึกษาและการพัฒนาหน่วยงานได้ โดยต้องอ้างอิงที่มา ไม่นำไปใช้เพื่อการค้า และเผยแพร่งานดัดแปลงภายใต้สัญญาอนุญาตเดียวกัน รายละเอียดดูที่ `creativecommons.org/licenses/by-nc-sa/4.0/deed.th`

แบบฟอร์มใน Toolkit ที่มากับหนังสือ หน่วยงานนำไปแก้ไขใช้ภายในได้โดยไม่ต้องขออนุญาต

การอ้างอิงหนังสือเล่มนี้

[ชื่อผู้เรียบเรียง]. (2569). *ความมั่นคงปลอดภัยไซเบอร์สำหรับเทคโนโลยีสุขภาพดิจิทัล (Cybersecurity in Digital Health Technology)* (ฉบับเผยแพร่ 1.0). [ชื่อหน่วยงาน/สำนักพิมพ์].

ข้อจำกัดความรับผิด

- เนื้อหาถูกต้องตามข้อมูลที่ค้นได้ ณ วันที่ 31 ตุลาคม 2569 กฎหมาย ประกาศ เกณฑ์ CTAM+ และช่องทางติดต่อหน่วยงานอาจเปลี่ยนแปลง ให้ตรวจสอบกับแหล่งทางการก่อนใช้งานทุกครั้ง
- คำสั่ง สคริปต์ และกฎตรวจจับในหนังสือเป็นตัวอย่างเพื่อการเรียนรู้ ต้องทดลองในเครื่องทดสอบ และได้รับอนุมัติตามขั้นตอนของหน่วยงานก่อนใช้กับระบบที่ให้บริการผู้ป่วย
- เนื้อหาเรื่องยุทธวิธีของผู้โจมตีอธิบายในระดับแนวคิดเพื่อการป้องกันเท่านั้น ห้ามนำไปใช้กับระบบที่ไม่ได้รับอนุญาต ซึ่งเป็นความผิดตาม พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์
- ข้อมูลตัวอย่างทั้งหมดเป็นข้อมูลสมมติ หมายเลข IP ใช้ช่วงสำหรับเอกสาร (RFC 5737) และชื่อโดเมนใช้ `.example` (RFC 2606) ไม่มีข้อมูลจริงของหน่วยงาน ผู้ป่วย หรือบุคคลใด

เครื่องหมายการค้า

ชื่อผลิตภัณฑ์และบริการที่กล่าวถึง เช่น Microsoft, Windows, Google Workspace, LINE, Wazuh, MITRE ATT&CK เป็นเครื่องหมายการค้าของเจ้าของแต่ละราย การกล่าวถึงในหนังสือมีเพื่อการอธิบายเท่านั้น ไม่ได้เป็นการรับรองหรือโฆษณา

ข้อเสนอแนะและการแจ้งแก้ไข

หากพบข้อผิดพลาดหรือมีข้อเสนอแนะ แจ้งได้ที่ [ช่องทางติดต่อผู้เรียบเรียง] ฉบับปรับปรุงจะระบุเลขฉบับและวันที่ไว้ในหน้านี้

คำนำ

โรงพยาบาลในวันนี้ไม่ได้ทำงานด้วยกระดาษอีกต่อไป ตั้งแต่จุดซักประวัติ ห้องตรวจ ห้องยา ห้องแล็บ ห้องเอกซเรย์ ไปจนถึงการส่งเบิกค่ารักษา ทุกขั้นตอนพึ่งพาระบบสารสนเทศโรงพยาบาล (HIS) ระบบ LIS ระบบ PACS และการเชื่อมต่อกับหน่วยงานภายนอก เช่น สปสช. และ HDC เมื่อระบบเหล่านี้หยุดทำงาน ผลกระทบไม่ได้หยุดแค่ “คอมพิวเตอร์ใช้ไม่ได้” แต่หมายถึงผู้ป่วยที่รอนานขึ้น แพทย์ที่มองไม่เห็นประวัติแพ้ยา และข้อมูลสุขภาพของประชาชนที่อาจหลุดไปอยู่ในมือคนร้าย

หนังสือเล่มนี้เขียนขึ้นสำหรับบุคลากรสาธารณสุขไทยทุกระดับ ตั้งแต่ผู้บริหารที่ต้องตัดสินใจเรื่องงบประมาณ ไปจนถึงนักวิชาการคอมพิวเตอร์ที่ต้องตั้งค่าไฟร์วอลล์เองตอนสองทุ่ม เนื้อหาอ้างอิงกฎหมายและเกณฑ์ที่ใช้จริงในกระทรวงสาธารณสุข ได้แก่ พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562, พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562, นโยบายและแนวปฏิบัติของกระทรวงสาธารณสุข พ.ศ. 2565, ตัวชี้วัด Cybersecurity v2.1 และเกณฑ์ CTAM/CTAM+ ของศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร สำนักงานปลัดกระทรวงสาธารณสุข (ศทส.สป.สธ.) พร้อมเทียบกับแนวทางสากลของภาคสุขภาพ ได้แก่ NIST CSF 2.0, NIST SP 800-61r3, HHS 405(d) HICP ของสหรัฐฯ, รายงานของ ENISA และข้อเสนอขององค์การอนามัยโลก เพื่อให้ประยุกต์ใช้กับงานสุขภาพดิจิทัลยุคใหม่ เช่น Telemedicine, API/FHIR, อุปกรณ์การแพทย์ที่เชื่อมเครือข่าย และ Cloud

จุดเด่นของหนังสือคือ **“อ่านแล้วทำตามได้”** ทุกบทในภาคปฏิบัติมีขั้นตอน คำสั่ง ตัวอย่างไฟล์ตั้งค่า และรายการหลักฐานที่ต้องเก็บเพื่อใช้ตอบการตรวจประเมิน เครื่องมือที่เลือกใช้เน้นโอเพนซอร์สที่หน่วยงานรัฐนำไปใช้ได้โดยไม่ต้องรองบประมาณ เช่น Wazuh, ClamAV, Nginx + ModSecurity, NCSA Blacklist Feed และ Cloudflare Tunnel

วิธีใช้หนังสือเล่มนี้

ผู้อ่าน	บทที่ควรอ่านก่อน	เป้าหมาย
ผู้อำนวยการ / CEO	1, 3, 4, 6, 17, 19, 20, 23 และภาคผนวก ช.1–ช.2	เข้าใจความเสี่ยง หน้าที่ตามกฎหมาย และการตัดสินใจลงทุน
CIO / CISO / หัวหน้างานสารสนเทศ	ทุกบท โดยเฉพาะ 5, 6, 7, 13, 17, 19, 20, 24, 25 และภาคผนวก ฉ, ช	วางแผน กำกับ และเตรียมรับการตรวจประเมิน
นักวิชาการคอมพิวเตอร์ / ผู้ดูแลระบบ	2, 6, 8–17, 21–25 และภาคผนวก	ลงมือตั้งค่าและเก็บหลักฐาน
DPO / งานเวชระเบียน / นิติกร	4, 12, 17, 21, 24	ปฏิบัติตาม PDPA และรับมือข้อมูลรั่วไหล
เจ้าหน้าที่ทั่วไป	1, 18, 25.9 (Deepfake) และภาคผนวก ช.4–ช.6	ใช้งานระบบอย่างปลอดภัยทุกวัน
วิศวกรรมการแพทย์ / งานรังสี / งานพัสดุ / งานช่างอาคาร	19, 22 (22.9 ระบบอาคารและ OT)	ซื้อและดูแลเครื่องมือแพทย์ให้ปลอดภัย

ทุกบทจบด้วยสรุปท้ายบทและคำถามทบทวน แนวคำตอบอยู่ในภาคผนวก ซ วิทยากรใช้คำถามชุดนี้ร่วมกับสไลด์อบรมและแบบทดสอบก่อนและหลังอบรมใน Toolkit ได้

ภาพด้านล่างคือแผนที่ของทั้งเล่ม ภาค 1–4 เรียงตามลำดับงาน ตั้งแต่เข้าใจภัย ทำตามกฎหมาย ลงมือป้องกัน ไปจนถึงตรวจจับและรับมือ ภาค 6–7 ต่อยอดเมื่อพื้นฐานครบ ส่วนภาค 5 เรื่องคนและองค์กรเป็นฐานรากของทุกภาค ถ้ากำลังเกิดเหตุและต้องการขั้นตอนทันที ให้เปิด **Playbook การ์ดหน้าเดียว ภาคผนวก ช**



▲ แผนที่หนังสือ 7 ภาคและฟังก์ชัน NIST CSF ที่แต่ละภาครองรับ

สัญลักษณ์ที่ใช้ในหนังสือ

- 💡 **เคล็ดลับ** — วิธีทำให้ง่ายหรือเร็วขึ้น
- ⚠️ **ข้อควรระวัง** — จุดที่มักผิดพลาดหรือเสี่ยงต่อระบบจริง
- 📋 **หลักฐาน CTAM+** — สิ่งที่ควรเก็บไว้เป็นหลักฐานตอบเกณฑ์
- 🧪 **Lab** — แบบฝึกหัดที่ทดลองทำในเครื่องทดสอบได้

ข้อตกลงเรื่องความถูกต้อง

กฎหมาย ประกาศ และเกณฑ์การประเมินมีการปรับปรุงทุกปี ผู้อ่านควรตรวจสอบฉบับล่าสุดจากแหล่งต้นทางเสมอ ได้แก่ ราชกิจจานุเบกษา, เว็บไซต์ สกมช. (ncsa.or.th), สคส. (pdpc.or.th), ศทส.สป.สธ. (ict.moph.go.th และ cyber.moph.go.th) ตัวอย่าง IP Address รหัสผ่าน และชื่อเครื่องในหนังสือเป็นค่าสมมติทั้งหมด ห้ามนำไปใช้ในระบบจริงโดยไม่เปลี่ยนค่า

คำสั่งทุกคำสั่งในหนังสือควรทดลองในเครื่องทดสอบก่อนใช้กับระบบที่ให้บริการผู้ป่วยจริง และควรทำ Snapshot หรือสำรองค่าตั้งค่าไว้ก่อนแก้ไขทุกครั้ง

เนื้อหาเรียบเรียงจากประสบการณ์การดำเนินงานของหน่วยงานสาธารณสุขระดับจังหวัด เอกสารของกระทรวงสาธารณสุข สกมช. สคส. สพร. และแนวทางสากล (NIST, HHS, ENISA, WHO) รายการแหล่งอ้างอิงทั้งหมดอยู่ในบรรณานุกรมท้ายเล่ม

สารบัญ

Cybersecurity in Digital Health Technology — ความมั่นคงปลอดภัยไซเบอร์สำหรับเทคโนโลยีสุขภาพดิจิทัล คู่มือฉบับปฏิบัติได้จริง สำหรับโรงพยาบาล สสจ. และหน่วยบริการสาธารณสุข

คำนำและวิธีใช้หนังสือเล่มนี้ — ใครควรอ่านบทไหน (ผู้บริหาร / CIO-CISO / นักวิชาการคอมพิวเตอร์ / เจ้าหน้าที่ทั่วไป)

ภาค 1 รู้จักภัยและกรอบคิด

1. **ทำไมระบบสุขภาพจึงตกเป็นเป้าหมาย** — มูลค่าข้อมูลสุขภาพ, กรณีศึกษาไทยและต่างประเทศ, ผลกระทบต่อการรักษาผู้ป่วย
2. **แนวคิดพื้นฐานที่ต้องรู้** — CIA Triad, Threat/Vulnerability/Risk, Defense in Depth, NIST CSF 2.0, Zero Trust

ภาค 2 กฎหมาย มาตรฐาน และการกำกับดูแล

3. **พ.ร.บ.ไซเบอร์ 2562 และ CII ด้านสาธารณสุข** — สกมช., หน่วยงานควบคุมกำกับ, ระดับภัยคุกคามตามประกาศ กมช., Health-CERT, คณะกรรมการไซเบอร์ด้านสาธารณสุข
4. **PDPA สำหรับสถานพยาบาล และธรรมาภิบาลข้อมูล** — ข้อมูลอ่อนไหว, ฐานกฎหมาย, ROPA, DPO, การแจ้งเหตุละเมิด 72 ชม., Privacy Policy/Notice ตามหนังสือ สป.
5. **นโยบายและมาตรฐานของกระทรวง** — นโยบายและแนวปฏิบัติ สธ. 2565, ตัวชี้วัด Cybersecurity v2.1, HAIT/HAIT+, ISO 27001 / ISO 27799
6. **CTAM+ ฉบับลงมือทำ** — เกณฑ์ 17 ข้อ (ปี 2569), ระดับเขียว/เหลือง/แดง, ขั้นตอนส่งผล, ตัวอย่างหลักฐานรายข้อ, checklist เตรียมรับการตรวจ

ภาค 3 ลงมือป้องกัน (Hands-on)

7. **บัญชีทรัพย์สินและการบริหารความเสี่ยงไซเบอร์** — Asset Inventory, ปิดระบบที่ไม่ใช้, แผนบริหารความเสี่ยงไซเบอร์ตามแนวทาง สธ., Risk Register
8. **การยืนยันตัวตนและการจัดการสิทธิ์** — Password Policy 12 ตัวอักษร, MFA/2FA, PAM, Access Rights Matrix, บัญชีใน HIS
9. **ความปลอดภัยเครือข่ายและไฟร์วอลล์** — แบ่ง VLAN/Zone (Server/Client/Medical IoT), Firewall 12 ข้อตาม CTAM, VPN, Time Sync, ตัวอย่างการตั้งค่า

10. **ความปลอดภัยเครื่องลูกข่ายและเซิร์ฟเวอร์** — Patch Management, Antivirus/EDR, ติดตั้ง ClamAV บน Linux, Hardening, ซอฟต์แวร์ถูกลิขสิทธิ์
11. **ความปลอดภัยเว็บแอปพลิเคชันและ WAF** — OWASP Top 10, ติดตั้ง Nginx + ModSecurity + OWASP CRS ทีละขั้น, Cloudflare Tunnel, การป้องกัน/แก้ไขเว็บถูกโจมตี
12. **ความปลอดภัยระบบ HIS และฐานข้อมูล** — HOSxP/MySQL/MariaDB hardening, สิทธิ์ฐานข้อมูล, การส่งออก 43 แฟ้ม, การเข้ารหัส
13. **การสำรองข้อมูล 3-2-1 และ BCP/DRP** — ตั้งค่า backup อัตโนมัติ, ทดสอบกู้คืน, RTO/RPO, Downtime Procedure, DR Site

ภาค 4 ตรวจจับและตอบสนอง

14. **Log Management และ SIEM ด้วย Wazuh** — เก็บ Log 90 วันตาม พ.ร.บ.คอมฯ, ติดตั้ง Wazuh, เพิ่ม Agent, กฎตรวจจับ 6 ด้านตาม CTAM
15. **Threat Intelligence ด้วย NCSA Blacklist** — ใช้ feed ของ สกมช., ติดตั้ง NCSA Blacklist SOC Dashboard, เชื่อมกับไฟร์วอลล์และ Wazuh
16. **Vulnerability Assessment และ Penetration Testing** — VA Scan, จัดลำดับ Critical/High, การขอรับบริการทดสอบเจาะระบบ (แบบ OP01)
17. **การรับมือเหตุการณ์และการแจ้งเหตุ** — NIST SP 800-61r3, Playbook Ransomware/Data Breach/Web Defacement, Flow แจ้งเหตุหน่วยงาน สธ. (Health-CIRT 24 ชม., สคส. 72 ชม.), CSOC/CO-CSIRT, เก็บหลักฐานดิจิทัล, ซ้อม Tabletop

ภาค 5 คนและองค์กร

18. **Security Awareness สำหรับบุคลากรสาธารณสุข** — Phishing, Social Engineering, Clear Desk/Clear Screen, การอบรม ≥80%
19. **ธรรมาภิบาลและแผนยกระดับระดับจังหวัด/เขต** — โครงสร้าง CEO/CIO/CISO/DPO, Supply Chain/Vendor, โมเดล สสจ. ดูแลหน่วยบริการ, Roadmap 1 ปี

ภาค 6 สุขภาพดิจิทัลยุคใหม่และแนวทางสากล

20. **มาตรฐานสากลและบทเรียนต่างประเทศสำหรับสุขภาพดิจิทัล** — ENISA, WHO, HHS 405(d) HICP, HPH CPGs, NIST SP 800-66r2, NIS2, หน่วยงานไทยที่ควรติดตาม, Telemedicine, แอปสุขภาพ, API/FHIR, IoMT/SBOM, AI, ตารางเทียบมาตรฐาน
21. **ความปลอดภัยอีเมล โดเมน และ Cloud Workspace** — SPF/DKIM/DMARC ทีละขั้น, Google Workspace/Microsoft 365, DNS/CAA/DNSSEC, ใบรับรอง HTTPS, เพจและ LINE OA
22. **อุปกรณ์การแพทย์ PACS การเชื่อมต่อ HL7 และระบบอาคาร** — ทะเบียน IoMT, แยกเครือข่าย, DICOM/AE Title, HL7 v2, ข้อกำหนดใน TOR (MDS2/SBOM), RACI, แผนสำรอง, ระบบอาคารและ OT (HVAC, ก๊าซทางการแพทย์, CCTV, ไฟฟ้าสำรอง)

ภาค 7 รู้เขารู้เรา: ผู้โจมตี การประสานข้อมูล และเทคโนโลยีใหม่

23. **ผู้โจมตีเจาะระบบโรงพยาบาลอย่างไร: รู้ทันยุทธวิธีเพื่อป้องกัน** — ประเภทผู้โจมตี, Cyber Kill Chain, MITRE ATT&CK v19–v20, ช่องทางเจาะระบบ 9 แบบ, กรณีจำลอง Ransomware 14 วัน, ตาราง เทคนิค → ป้องกัน → ตรวจจับ, กฎ Wazuh, Threat Hunting, Purple Team, Tabletop
24. **ระบบโฟลว์การประสานข้อมูลและแบ่งปันความรู้ด้านไซเบอร์** — เครือข่าย รพ.สต. → สสจ. → เขต → Health CERT → สกมช., RACI, โฟลว์มาตรฐาน 6 แบบ, แม่แบบคำเตือนและ SITREP, Pyramid of Pain, TLP 2.0, STIX/TAXII/MISP/TCTI, KM และ CoP, Lab เตือนช่องโหว่จาก CISA KEV
25. **เทคโนโลยีใหม่ที่ช่วยป้องกันการเจาะระบบ** — Technology Radar, Zero Trust (SP 800-207, SP 1800-35, CISA ZTMM 2.0), Passkey/FIDO2, EDR/XDR/NDR/MDR, SOAR, SASE/ZTNA, Deception และ OpenCanary, ASM/CTEM, AI ทั้งสองด้าน, PQC, ลำดับการลงทุนตามขนาดหน่วยบริการ

ภาคผนวก

- ก. Checklist หลักฐาน CTAM+ 17 ข้อ (พร้อมพิมพ์)
- ข. แม่แบบเอกสาร: นโยบาย, Risk Register, Access Matrix, แบบรายงานเหตุ, แบบบันทึกการทดสอบกู้คืน
- ค. คำสั่งที่ใช้บ่อย (Linux, Windows, MySQL, Wazuh, Nmap)
- ง. ช่องทางติดต่อและแหล่งข้อมูล
- จ. อภิธานศัพท์ 103 คำ และตัวย่อหน่วยงานภาษาไทย
- ฉ. แบบประเมินระดับวุฒิภาวะด้วยตนเอง (10 ด้าน ระดับ 0–4)
- ช. Playbook การ์ดหน้าเดียวพร้อม Flow 6 เหตุการณ์: Ransomware, ข้อมูลรั่วไหล, เว็บถูกเปลี่ยนหน้า, คลิกลิงก์ฟิชชิง, อุปกรณ์หาย, โทรศัพท์อ้างเป็น IT/Vendor
- ซ. แนวคำตอบคำถามทบทวนท้ายบททั้ง 25 บท

บรรณานุกรมและแหล่งอ้างอิง

กฎหมายและเอกสารของหน่วยงานไทย, แนวทางและรายงานต่างประเทศ, เครื่องมือและเอกสารทางเทคนิค, ยุทธวิธีผู้โจมตี การแบ่งปันข้อมูล และเทคโนโลยีป้องกันยุคใหม่

ดัชนีคำค้น

คำสำคัญภาษาอังกฤษและภาษาไทยประมาณ 100 คำ พร้อมเลขหน้า (ฉบับ PDF)



ภาค 1

รู้จักภัยและกรอบคิด

Threats & Mindset

1 ทำไมระบบสุขภาพจึงตกเป็นเป้าหมาย 🎯

2 แนวคิดพื้นฐานที่ต้องรู้ 🧠

🎯

ภาค 1 · รู้จักภัยและกรอบคิด บทที่ 1

ทำไมระบบสุขภาพจึงตกเป็นเป้าหมาย

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ อธิบายได้ว่าทำไมข้อมูลสุขภาพมีมูลค่าสูงในตลาดมืด
- ✔️ ยกตัวอย่างเหตุการณ์จริงในไทยและต่างประเทศ และบทเรียนที่ได้
- ✔️ เชื่อมโยงภัยไซเบอร์กับความปลอดภัยของผู้ป่วย (Patient Safety)

1.1 โรงพยาบาลคือ “เป้าหมายในอุดมคติ” ของผู้โจมตี

ผู้โจมตีเลือกเป้าหมายจากสามคำถาม คือ “ได้เงินไหม” “เจาะง่ายไหม” และ “เหยื่อยอมจ่ายเร็วไหม” ระบบสุขภาพตอบ “ใช่” ทั้งสามข้อ

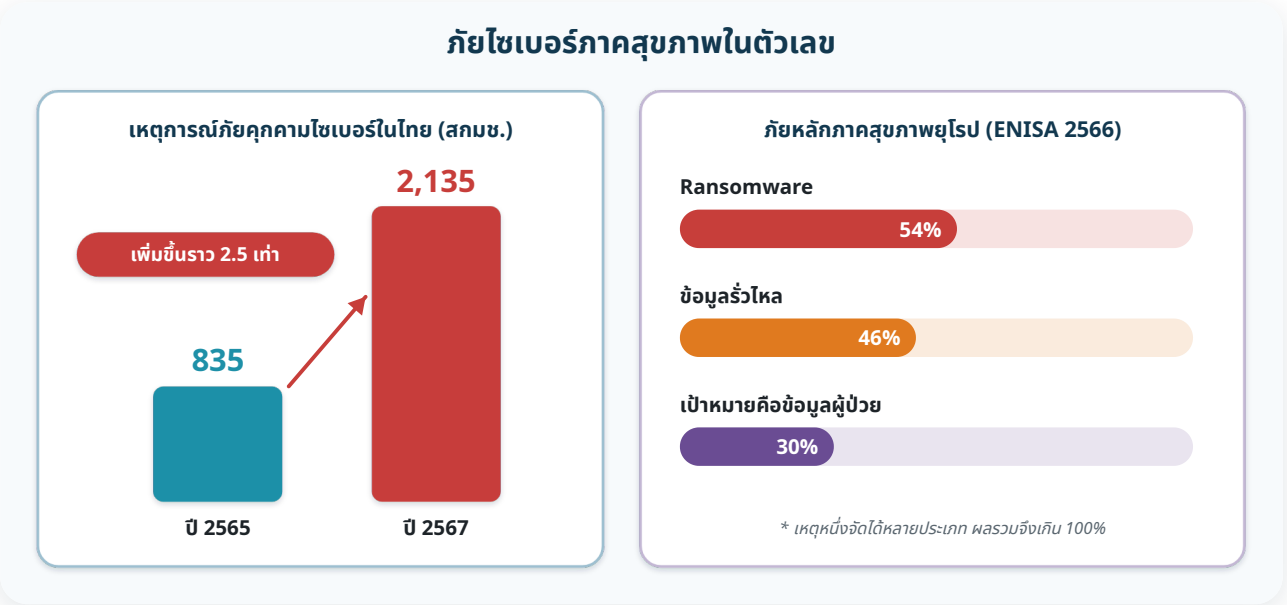
ปัจจัย	เหตุผลในบริบทโรงพยาบาล
ข้อมูลมีมูลค่าสูง	เวชระเบียนหนึ่งชุดมีทั้งชื่อ เลขบัตรประชาชน ที่อยู่ เบอร์โทร สิทธิการรักษา โรคประจำตัว ประวัติยา ซึ่งใช้ปลอมตัว หลอกลวง หรือแบล็กเมลได้นาน ต่างจากเลขบัตรเครดิตที่ยกเลิกได้ทันที
ต้องให้บริการตลอด 24 ชั่วโมง	ระบบหยุดหนึ่งชั่วโมงก็กระทบผู้ป่วยฉุกเฉิน ผู้บริหารจึงถูกกดดันให้ “จ่ายค่าไถ่ให้จบเร็ว” ซึ่งเป็นสิ่งที่แก๊งแรนซัมแวร์ต้องการ
ระบบเก่าและหลากหลาย	เครื่องมือแพทย์จำนวนมากใช้ Windows รุ่นเก่าที่แพตช์ไม่ได้ ระบบ HIS มีโมดูลเชื่อมต่อหลายสิบตัว และมีเครื่องคอมพิวเตอร์ที่เปิดใช้ร่วมกันหลายคน
คนเยอะ หมุนเวียนสูง	แพทย์ พยาบาล นักศึกษาฝึกงาน และผู้รับจ้างเข้าออกตลอด ทำให้ควบคุมบัญชีผู้ใช้และรหัสผ่านได้ยาก
งบประมาณและบุคลากรจำกัด	โรงพยาบาลชุมชนหลายแห่งมีนักวิชาการคอมพิวเตอร์เพียง 1–2 คนที่ดูแลทุกอย่างตั้งแต่เครื่องพิมพ์ถึงเซิร์ฟเวอร์

1.2 ภัยคุกคามหลักที่พบในหน่วยงานสาธารณสุข

1. **Ransomware (มัลแวร์เรียกค่าไถ่)** — เข้ารหัสไฟล์และฐานข้อมูล HIS แล้วเรียกเงิน ปัจจุบันมักเป็นแบบ “Double Extortion” คือขโมยข้อมูลออกไปก่อนแล้วขู่ว่าจะเผยแพร่ถ้าไม่จ่าย

2. **Data Breach (ข้อมูลรั่วไหล)** — เกิดจากทั้งการเจาะระบบ การตั้งค่าผิด (เช่น เปิดฐานข้อมูลสู่อินเทอร์เน็ตโดยไม่มีรหัสผ่าน) และคนในนำข้อมูลออกไป
3. **Web Defacement และการฝังเว็บพนัน** — เว็บไซต์โรงพยาบาลหรือ สสอ. ที่ใช้ CMS เก่า ถูกแก้หน้าเว็บหรือฝังลิงก์เว็บพนันออนไลน์ ซึ่งพบบ่อยมากในหน่วยงานรัฐไทย
4. **Phishing และ Business Email Compromise** — อีเมลปลอมหลอกให้กรอกรหัสผ่าน หรือหลอกให้โอนเงินจัดซื้อ
5. **Brute Force และ Credential Stuffing** — เดารหัสผ่าน RDP, SSH, VPN และหน้า Login ของระบบต่าง ๆ ที่เปิดสู่อินเทอร์เน็ต
6. **DDoS** — ทำให้เว็บไซต์หรือบริการออนไลน์ เช่น ระบบนัดหมาย ล่ม
7. **Supply Chain Attack** — เจาะผ่านบริษัทผู้ดูแลระบบ (Vendor) ที่มีสิทธิ์ Remote เข้ามาดูแล HIS
8. **Insider Threat** — เจ้าหน้าที่เปิดดูประวัติผู้ป่วยที่ไม่ใช่คนไข้ของตน เช่น ดาราหรือคนรู้จัก หรือถ่ายภาพหน้าจอไปเผยแพร่

ภาพรวมจากตัวเลข



▲ ภาพที่ 1.1 ภัยไซเบอร์ภาคสุขภาพในตัวเลข

แหล่งข้อมูล	ตัวเลขสำคัญ
สกมช. (ประเทศไทย)	เหตุการณ์ภัยคุกคามไซเบอร์ปี 2567 รวม **2,135 ครั้ง** เพิ่มจาก 835 ครั้งในปี 2565 และช่วงปี 2564–2567 มีข้อมูลรั่วไหลรวมกว่า 26,000 ล้านรายการ (ทุกภาคส่วน)
ข่าวภาคสาธารณสุขไทย (มี.ค. 2567)	มีผู้ประกาศขายข้อมูลที่อ้างว่ามาจากหน่วยงานในสังกัดกระทรวงสาธารณสุข 2.2 ล้านรายชื่อ กระทรวงชี้แจงร่วมกับ สกมช. ว่าตรวจสอบแล้วข้อมูลไม่ได้หลุดจากระบบ แสดงว่า **แม้ข่าวไม่จริง หน่วยงานก็ต้องพร้อมตรวจสอบและชี้แจงได้รวดเร็ว**
ENISA (สหภาพยุโรป, 2566)	Ransomware คิดเป็น **54%** ของภัยคุกคามภาคสุขภาพ, ข้อมูลรั่วไหล 46%, ข้อมูลผู้ป่วยเป็นเป้าหมายมากที่สุด
HHS (สหรัฐฯ, 2567–2568)	เหตุ Change Healthcare กระทบข้อมูลราว **190 ล้านคน** เป็นเหตุข้อมูลสุขภาพรั่วไหลใหญ่ที่สุดของสหรัฐฯ
WHO (พ.ย. 2567)	ผู้อำนวยการใหญ่ระบุต่อคณะมนตรีความมั่นคงแห่งสหประชาชาติว่าการโจมตีโรงพยาบาลด้วย Ransomware “เป็นเรื่องความเป็นความตาย”

> ตัวเลขเหล่านี้มาจากแหล่งที่ระบุในบรรณานุกรมท้ายเล่ม ตัวเลขของต่างประเทศใช้เพื่อเห็นแนวโน้ม ไม่ได้สะท้อนสถานการณ์ในไทยโดยตรง

1.3 กรณีศึกษา

กรณีที่ 1 แรนซัมแวร์โจมตีโรงพยาบาลในประเทศไทย

ในปี พ.ศ. 2563 โรงพยาบาลระดับจังหวัดแห่งหนึ่งในภาคกลางถูกแรนซัมแวร์เข้ารหัสระบบ ทำให้ต้องกลับไปใช้กระดาษและให้บริการได้ช้าลงหลายวัน เหตุการณ์นี้เป็นจุดเริ่มต้นที่ทำให้กระทรวงสาธารณสุขเร่งออกมาตรการด้านการสำรองข้อมูลและการแบ่งเครือข่ายอย่างจริงจัง

บทเรียน: ถ้ามี Backup ที่แยกออฟไลน์และทดสอบกู้คืนแล้ว ก็ไม่ต้องจ่ายค่าไถ่และกลับมาให้บริการได้เร็ว (ดูบทที่ 13)

กรณีที่ 2 ข้อมูลผู้ป่วยรั่วไหลจำนวนมาก

ในช่วงปี พ.ศ. 2564–2566 มีข่าวการประกาศขายข้อมูลผู้ป่วยและข้อมูลด้านสุขภาพของคนไทยหลายครั้ง บางกรณีอ้างว่ามีหลายล้านถึงหลายสิบล้านรายการ แหล่งที่มามีทั้งระบบที่เชื่อมต่อจากภายนอกและเซิร์ฟเวอร์ที่ตั้งค่าไม่ปลอดภัย

บทเรียน: ต้องรู้ว่าข้อมูลอยู่ที่ไหน ใครเข้าถึงได้ (Asset Inventory และ Access Control) และต้องมีระบบตรวจจับการดึงข้อมูลผิดปกติ (บทที่ 7, 8, 14)

กรณีที่ 3 WannaCry กับระบบสาธารณสุขอังกฤษ (พ.ศ. 2560)

หน่วยบริการจำนวนมากของ NHS ในสหราชอาณาจักรได้รับผลกระทบ ต้องยกเลิกนัดผ่าตัดและส่งต่อผู้ป่วยฉุกเฉิน ทั้งที่ไมโครซอฟท์ออกแพตช์แก้ช่องโหว่ไว้ก่อนแล้วหลายสัปดาห์

บทเรียน: การอัปเดตแพตช์ระบบปฏิบัติการ (OS Patching) เป็นมาตรการราคาถูกที่สุดแต่ได้ผลมากที่สุด (บทที่ 10)

กรณีที่ 4 การโจมตีผู้ให้บริการด้านการเงินสุขภาพในสหรัฐฯ (พ.ศ. 2567)

การโจมตีบริษัท Change Healthcare ซึ่งเป็นตัวกลางเรียกเก็บเงินค่ารักษาและใบสั่งยาเพียงแห่งเดียว ทำให้โรงพยาบาลและร้านยาทั่วประเทศเบิกจ่ายไม่ได้นานหลายสัปดาห์ บริษัทแม่ชี้แจงว่าผู้โจมตีใช้รหัสผ่านที่ถูกขโมยเข้าระบบ Remote Access ที่ **ไม่ได้เปิด MFA** อยู่ในระบบราว 9 วันก่อนปล่อย Ransomware และมีรายงานการจ่ายค่าไถ่ แต่ก็ไม่สามารถรับประกันได้ว่าข้อมูลจะไม่ถูกเผยแพร่ HHS รายงานผู้ได้รับผลกระทบราว 190 ล้านคน

บทเรียน: บัญชีที่เข้าถึงจากภายนอกต้องมี MFA เสมอ (บทที่ 8) และต้องประเมินความเสี่ยงจากผู้ให้บริการภายนอก (บทที่ 19)

1.4 ภัยไซเบอร์คือเรื่องความปลอดภัยของผู้ป่วย



▲ ภาพที่ 1.2 ห่วงโซ่ผลกระทบจากภัยไซเบอร์ถึงผู้ป่วย

กระบวนการคุณภาพโรงพยาบาล (HA) ให้ความสำคัญกับ Patient Safety มาโดยตลอด แต่ในยุคดิจิทัล ความเสี่ยงต่อผู้ป่วยเกิดจากระบบสารสนเทศได้โดยตรง เช่น

- ระบบ HIS ล่ม แพทย์ไม่เห็นประวัติแพ้ยา จึงสั่งยาที่ผู้ป่วยแพ้
- ผลแล็บถูกแก้ไขโดยไม่ได้รับอนุญาต (สูญเสีย Integrity) ทำให้วินิจฉัยผิด
- ปั๊มยาหรือเครื่องมือแพทย์ที่ต่อเครือข่ายติดมัลแวร์
- ระบบส่งต่อผู้ป่วย (Refer) ใช้งานไม่ได้ในช่วงวิกฤต

เพราะเหตุนี้มาตรฐาน **HAIT** (Hospital Accreditation for Information Technology) ของ สรพ. จึงนำเรื่องความมั่นคงปลอดภัยสารสนเทศเข้ามาเป็นส่วนหนึ่งของการรับรองคุณภาพ และกระทรวงสาธารณสุขกำหนดให้ “ร้อยละของหน่วยงานที่ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง” เป็นตัวชี้วัดระดับกระทรวง (ดูบทที่ 5–6)

1.5 ต้นทุนของการไม่ลงทุน

สิ่งที่สูญเสียเมื่อเกิดเหตุ	ตัวอย่าง
รายได้	เบิกจ่าย สปสช. ไม่ได้ ส่งข้อมูล 43 แฟ้มล่าช้า
ค่าใช้จ่ายกู้ระบบ	จ้างผู้เชี่ยวชาญ ซื้ออุปกรณ์ใหม่ ทำงานล่วงเวลา
โทษตามกฎหมาย	โทษปรับทางปกครองตาม PDPA สูงสุด 5 ล้านบาทต่อกรณีข้อมูลอ่อนไหว และความรับผิดทางแพ่ง ตัวอย่างจริง: ส.ค. 2567 สคส. สั่งปรับบริษัทเอกชนรายใหญ่รวม 7 ล้านบาท จากข้อหาไม่แต่งตั้ง DPO, มาตรการความปลอดภัยไม่เพียงพอ และไม่แจ้งเหตุภายใน 72 ชั่วโมง (ข้อมูลรั่วไปถึงแก๊งคอลเซ็นเตอร์)
ชื่อเสียงและความเชื่อมั่น	ประชาชนไม่กล้าให้ข้อมูลจริงกับแพทย์
ชีวิตและสุขภาพ	ผู้ป่วยได้รับการรักษาล่าช้าหรือผิดพลาด

เมื่อเทียบกันแล้ว การลงทุนในมาตรการพื้นฐาน เช่น Backup 3-2-1, MFA, แพตช์ และ SIEM แบบโอเพนซอร์ส มีต้นทุนต่ำกว่าค่าเสียหายจากเหตุการณ์เพียงครั้งเดียวมาก

⭐ สรุปท้ายบท

- ระบบสุขภาพเป็นเป้าหมายเพราะข้อมูลมีค่า ต้องเปิดบริการตลอดเวลา และมีระบบเก่าจำนวนมาก
- ภัยที่พบบ่อยในไทยคือ Ransomware, ข้อมูลรั่วไหล และเว็บไซต์ถูกฝังเว็บพนัน
- ภัยไซเบอร์คือความเสี่ยงต่อผู้ป่วยโดยตรง ไม่ใช่เพียงปัญหาของงานไอที

✏️ คำถามทบทวน

1. ให้ระบุระบบสารสนเทศ 5 ระบบในหน่วยงานของท่าน และบอกว่าถ้าระบบนั้นหยุดทำงาน 1 วัน จะกระทบผู้ป่วยอย่างไร
2. ทำไมแก๊งแรนซัมแวร์จึงนิยมขโมยข้อมูลออกไปก่อนเข้ารหัส
3. จากกรณี WannaCry มาตรการใดที่ป้องกันได้ และหน่วยงานของท่านทำแล้วหรือยัง

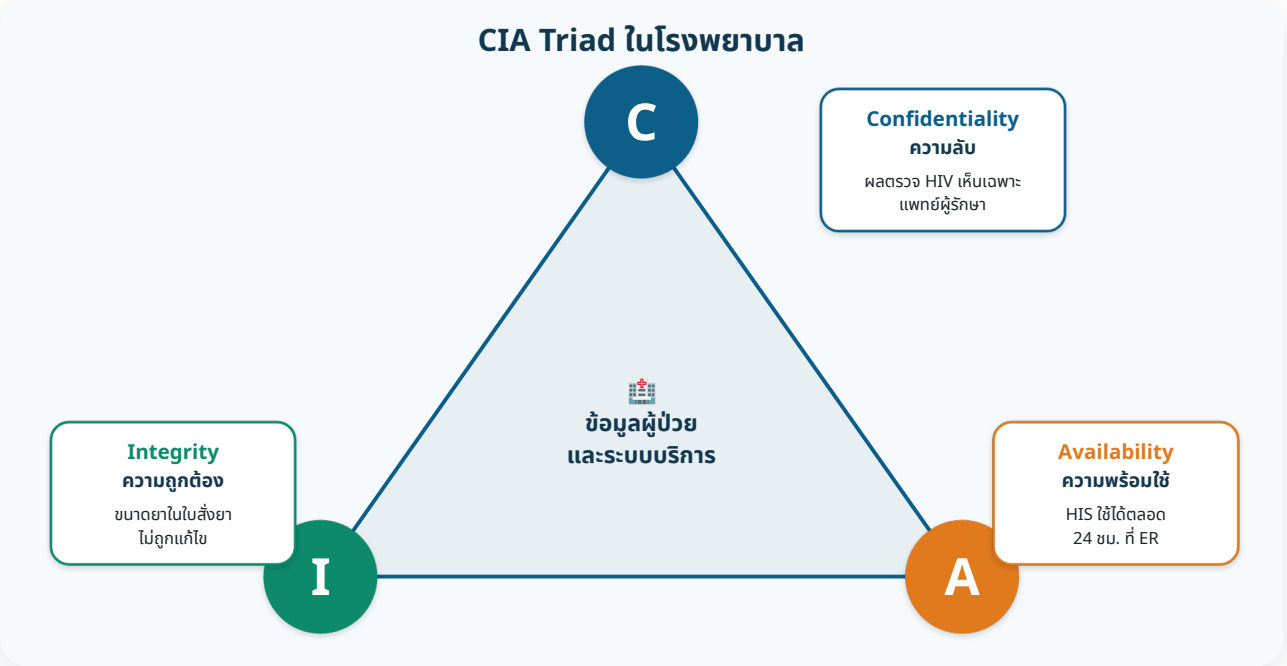
ภาค 1 · รู้จักภัยและกรอบคิด บทที่ 2

แนวคิดพื้นฐานที่ต้องรู้

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ ใช้ศัพท์พื้นฐานด้านความมั่นคงปลอดภัยได้ถูกต้อง
- ✔️ ประเมินความเสี่ยงอย่างง่ายด้วยสูตร โอกาส × ผลกระทบ
- ✔️ เข้าใจกรอบ NIST CSF 2.0 และแนวคิด Zero Trust ที่ใช้ออกแบบระบบ

2.1 CIA Triad: สามเสาหลักของความมั่นคงปลอดภัยสารสนเทศ



▲ ภาพที่ 2.1 CIA Triad พร้อมตัวอย่างในโรงพยาบาล

หลักการ	ความหมาย	ตัวอย่างในโรงพยาบาล	มาตรการ
Confidentiality (ความลับ)	ข้อมูลเปิดเผยเฉพาะผู้มีสิทธิ์	ผลตรวจ HIV เห็นได้เฉพาะแพทย์ผู้รักษา	กำหนดสิทธิ์ตามบทบาท, เข้ารหัส, Clear Screen
Integrity (ความถูกต้องครบถ้วน)	ข้อมูลไม่ถูกแก้ไขโดยไม่ได้รับอนุญาต	ขนาดยาในใบสั่งยาไม่ถูกเปลี่ยน	Audit Log, Checksum, ลายมือชื่อดิจิทัล
Availability (ความพร้อมใช้งาน)	ระบบใช้งานได้เมื่อต้องการ	HIS ใช้ได้ตลอด 24 ชั่วโมงที่ ER	Backup, UPS, ระบบสำรอง, DR Site

ในบริบทสาธารณสุข **Availability และ Integrity มักสำคัญเท่ากับหรือมากกว่า Confidentiality** เพราะกระทบต่อชีวิตผู้ป่วยโดยตรง

นอกจากนี้ยังมีหลักการเสริมที่ควรรู้

- **Authentication** ยืนยันว่าเป็นตัวจริง
- **Authorization** กำหนดว่าทำอะไรได้บ้าง
- **Accountability / Non-repudiation** ตรวจสอบย้อนหลังได้ว่าใครทำอะไร และปฏิเสธไม่ได้

2.2 Threat, Vulnerability, Risk ต่างกันอย่างไร

- **Asset (ทรัพย์สิน)** สิ่งที่มีคุณค่า เช่น ฐานข้อมูล HIS, เซิร์ฟเวอร์, ข้อมูลผู้ป่วย, ชื่อเสียงองค์กร
- **Threat (ภัยคุกคาม)** สิ่งที่อาจทำให้เกิดความเสียหาย เช่น แฮกเกอร์, แรนซัมแวร์, ไฟไหม้, เจ้าหน้าที่ทำผิดพลาด
- **Vulnerability (ช่องโหว่)** จุดอ่อนที่ภัยคุกคามใช้ประโยชน์ได้ เช่น ไม่ได้อัปเดตแพตช์, รหัสผ่าน `admin/admin`, เปิดพอร์ต 3389 สู่อินเทอร์เน็ต
- **Risk (ความเสี่ยง)** โอกาสที่ภัยคุกคามจะใช้ช่องโหว่แล้วเกิดผลกระทบต่อทรัพย์สิน

> **Risk = Likelihood (โอกาส) × Impact (ผลกระทบ)**

ตัวอย่างการประเมินอย่างง่าย (ระดับ 1–5)

ความเสี่ยง	โอกาส	ผลกระทบ	คะแนน	ระดับ
แรนซัมแวร์เข้ารหัสฐานข้อมูล HIS	4	5	20	สูงมาก
เว็บไซต์ถูกฝังเว็บพนัน	4	2	8	ปานกลาง
ไฟฟ้าดับนานกว่า UPS รองรับ	3	4	12	สูง
เจ้าหน้าที่ส่งไฟล์ผู้ป่วยผิดกลุ่ม LINE	3	3	9	ปานกลาง

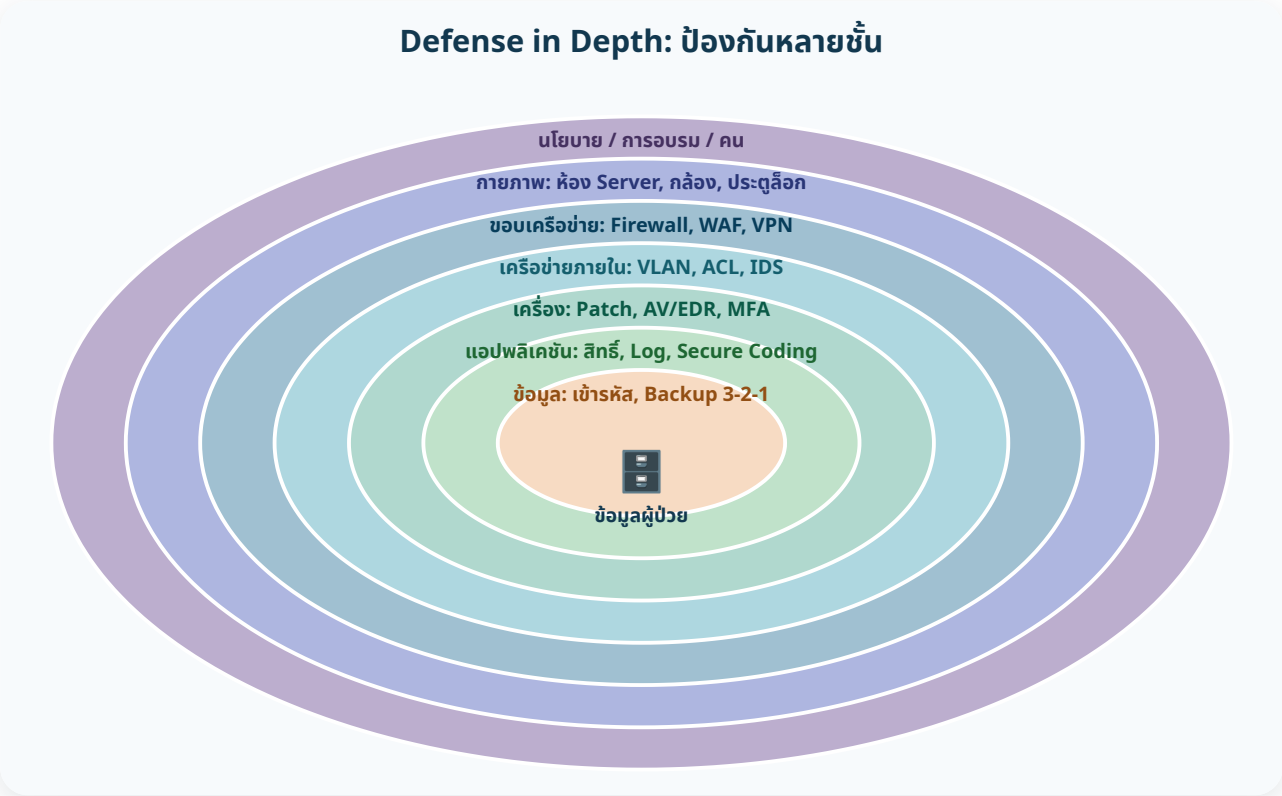
เกณฑ์แนะนำ: 1–4 ต่ำ, 5–9 ปานกลาง, 10–15 สูง, 16–25 สูงมาก รายละเอียดการทำทะเบียนความเสี่ยงอยู่ในบทที่ 7

- **วิธีจัดการความเสี่ยง 4 แบบ (ใช้กับผล VA และทะเบียนความเสี่ยง)**

1. **ลดความเสี่ยง (Mitigate)** ติดตั้งมาตรการ เช่น เปิด MFA
2. **หลีกเลี่ยง (Avoid)** เลิกทำกิจกรรมที่เสี่ยง เช่น ปิดบริการที่ไม่ใช้
3. **ถ่ายโอน (Transfer)** ให้ผู้อื่นรับความเสี่ยง เช่น ใช้ Cloud ที่มี SLA หรือทำประกัน
4. **ยอมรับ (Accept)** ยอมรับอย่างเป็นลายลักษณ์อักษรโดยผู้บริหาร เมื่อค่าใช้จ่ายในการแก้สูงกว่าผลกระทบ

2.3 Defense in Depth: ป้องกันหลายชั้น

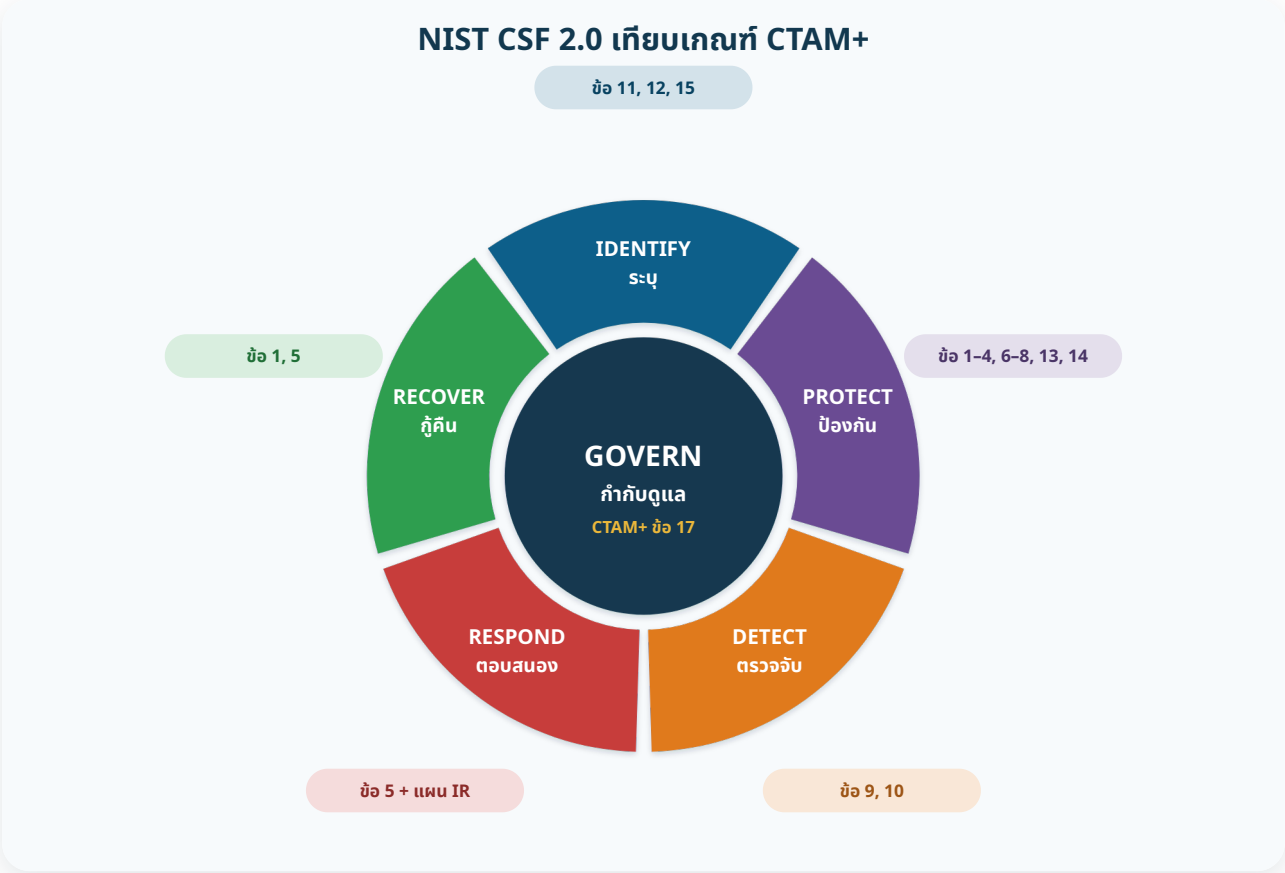
ไม่มีมาตรการใดป้องกันได้ 100% จึงต้องวางหลายชั้นซ้อนกัน เมื่อชั้นหนึ่งพลาด ชั้นถัดไปยังช่วยได้



▲ ภาพที่ 2.2 Defense in Depth ชั้นป้องกันจากนโยบายถึงข้อมูลผู้ป่วย

2.4 NIST Cybersecurity Framework 2.0

กรอบ NIST CSF เป็นกรอบที่ใช้แพร่หลายทั่วโลก และเป็นกรอบอ้างอิงสำคัญของประมวลแนวทางปฏิบัติและกรอบมาตรฐานด้านความมั่นคงปลอดภัยไซเบอร์ที่ สกมช. กำหนด ฉบับ 2.0 ที่ NIST ออกเมื่อกุมภาพันธ์ 2567 เพิ่มฟังก์ชัน **Govern** เป็นฟังก์ชันที่ 6 และขยายขอบเขตให้ใช้ได้กับองค์กรทุกขนาด ไม่เฉพาะโครงสร้างพื้นฐานสำคัญ แบ่งงานออกเป็น 6 ฟังก์ชัน



▲ ภาพที่ 2.3 NIST CSF 2.0 ทั้ง 6 ฟังก์ชันเทียบเกณฑ์ CTAM+

ฟังก์ชัน	คำถามหลัก	ตัวอย่างงานในโรงพยาบาล	เกณฑ์ CTAM+ ที่เกี่ยวข้อง
Govern กำกับดูแล	ใครรับผิดชอบ มีนโยบายอะไร	แต่งตั้ง CISO, ประกาศนโยบาย	ข้อ 17
Identify ระบุ	เรามีอะไร เสี่ยงตรงไหน	ทะเบียนทรัพย์สิน, ประเมินความเสี่ยง	ข้อ 11, 12, 15
Protect ป้องกัน	ป้องกันอย่างไร	MFA, Patch, Firewall, Backup	ข้อ 1–4, 6–8, 13, 14
Detect ตรวจจับ	รู้ได้อย่างไรว่าถูกโจมตี	Log, SIEM, Threat Feed	ข้อ 9, 10
Respond ตอบสนอง	เกิดเหตุแล้วทำอะไร	IR Plan, แจ้งเหตุภายใน 24 ชม.	ข้อ 5
Recover กู้คืน	กลับมาให้บริการอย่างไร	BCP/DRP, ทดสอบกู้คืน	ข้อ 1, 5

2.5 Zero Trust: “ไม่เชื่อใจใครโดยอัตโนมัติ”

แนวคิดเดิมเชื่อว่า “อยู่ในเครือข่ายโรงพยาบาลแล้วปลอดภัย” แต่ความจริงคือผู้โจมตีที่เข้ามาได้หนึ่งเครื่องจะเดินทางไปทั่วเครือข่าย (Lateral Movement) แนวคิด Zero Trust จึงยึดหลัก

1. **Verify explicitly** ตรวจสอบตัวตนและสภาพเครื่องทุกครั้งที่เข้าถึง ไม่ใช่ครั้งเดียวตอนเข้าเครือข่าย
2. **Least privilege** ให้สิทธิ์เท่าที่จำเป็น และเท่าที่จำเป็นในเวลานั้น (Just-in-Time)
3. **Assume breach** ออกแบบโดยถือว่าถูกเจาะแล้ว จึงต้องแบ่งเครือข่าย เข้ารหัส และเฝ้าระวังตลอด

การนำ Zero Trust มาใช้ในโรงพยาบาลไม่จำเป็นต้องซื้อระบบราคาแพง เริ่มได้จาก

- เปิด MFA ให้บัญชีผู้ดูแลระบบและ VPN ทุกบัญชี
- แบ่ง VLAN ให้เครื่องมือแพทย์ เครื่องผู้ใช้ และเซิร์ฟเวอร์แยกกัน แล้วให้ Firewall คุมระหว่างโซน
- ใช้ Cloudflare Tunnel หรือ Reverse Proxy แทนการเปิดพอร์ตตรงสู่อินเทอร์เน็ต
- ทบทวนสิทธิ์ทุกไตรมาส และปิดบัญชีของผู้ที่ย้ายหรือลาออกทันที

สถาปัตยกรรม Zero Trust แบบเต็ม ระดับความพร้อมตาม CISA และเส้นทาง 3 ระยะสำหรับโรงพยาบาล อยู่ในบทที่ 25

2.6 People, Process, Technology

ความมั่นคงปลอดภัยที่ยั่งยืนต้องมีครบสามด้าน

- **People** ผู้บริหารให้ความสำคัญ มีผู้รับผิดชอบชัดเจน และเจ้าหน้าที่ทุกคนได้รับการอบรม
- **Process** มีนโยบาย ขั้นตอน แบบฟอร์ม และการทบทวนสม่ำเสมอ
- **Technology** มีเครื่องมือที่เหมาะสมและตั้งค่าถูกต้อง

หน่วยงานจำนวนมากซื้อ Firewall ราคาแพงแต่ตั้งค่าแบบ Allow All หรือไม่มีใครอ่าน Log เลย ซึ่งเท่ากับไม่มีการป้องกัน

⭐ สรุปท้ายบท

- CIA Triad คือกรอบคิดพื้นฐาน และในโรงพยาบาลต้องให้ความสำคัญกับ Availability และ Integrity เป็นพิเศษ
- Risk = โอกาส × ผลกระทบ และจัดการได้ 4 วิธี คือ ลด หลีกเลี่ยง ถ่ายโอน ยอมรับ
- NIST CSF 2.0 มี 6 ฟังก์ชัน และเกณฑ์ CTAM+ ทั้ง 17 ข้อจัดเข้าฟังก์ชันเหล่านี้ได้ทั้งหมด
- Zero Trust เริ่มได้ทันทีจาก MFA, การแบ่งเครือข่าย และ Least Privilege

✏️ แบบฝึกหัด

1. เลือกระบบ 1 ระบบในหน่วยงาน แล้วระบุ Asset, Threat, Vulnerability และประเมินคะแนน Risk
2. จับคู่มาตรการต่อไปนี้กับฟังก์ชัน NIST CSF: Wazuh, Backup 3-2-1, คำสั่งแต่งตั้ง CISO, Asset Inventory, IR Playbook



ภาค 2

กฎหมาย มาตรฐาน และการกำกับดูแล

Law, Standards & Governance

3 พ.ร.บ.ไซเบอร์ 2562 และ CII ด้านสาธารณสุข

4 PDPA สำหรับสถานพยาบาล และธรรมาภิบาลข้อมูล

5 นโยบายและมาตรฐานของกระทรวงสาธารณสุข

6 CTAM+ ฉบับลงมือทำ



ภาค 2 · กฎหมาย มาตรฐาน และการกำกับดูแล บทที่ 3

พ.ร.บ.ไซเบอร์ 2562 และ CII ด้านสาธารณสุข

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้หน้าที่ของหน่วยงานตาม พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562
- ✔️ เข้าใจโครงสร้างการกำกับดูแลด้านสาธารณสุข ตั้งแต่ สกมช. จนถึงโรงพยาบาล
- ✔️ จำแนกระดับภัยคุกคามไซเบอร์ได้ตามประกาศ กมช. พ.ศ. 2564
- ✔️ รู้กฎหมายที่เกี่ยวข้องอื่น เช่น พ.ร.บ.คอมพิวเตอร์ (การเก็บ Log 90 วัน)

3.1 ภาพรวมกฎหมายที่เกี่ยวข้อง

กฎหมาย	สาระสำคัญต่องานสาธารณสุข	บทที่เกี่ยวข้อง
พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562	หน้าที่ของหน่วยงานรัฐและ CII ในการป้องกัน รับมือ และรายงานภัยคุกคาม	บทนี้, 17
พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 (PDPA)	การเก็บ ใช้ เปิดเผยข้อมูลสุขภาพ, แจ้งเหตุละเมิดภายใน 72 ชม.	4
พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. 2550 และแก้ไข 2560	ความผิดจากการเจาะระบบ, ผู้ให้บริการต้องเก็บข้อมูลจราจรคอมพิวเตอร์ไม่น้อยกว่า 90 วัน	14
พ.ร.บ.การบริหารงานและการให้บริการภาครัฐผ่านระบบดิจิทัล พ.ศ. 2562	การให้บริการดิจิทัลของรัฐ, มาตรฐานของ สพร. (DGA)	11, 19
พ.ร.บ.สุขภาพแห่งชาติ พ.ศ. 2550 มาตรา 7	ข้อมูลสุขภาพเป็นความลับส่วนบุคคล	4

3.2 สาระสำคัญของ พ.ร.บ.ไซเบอร์

องค์กรหลัก

- **กมช.** คณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ กำหนดนโยบายระดับชาติ

- **กกม.** คณะกรรมการกำกับดูแลด้านความมั่นคงปลอดภัยไซเบอร์ ดูแลการปฏิบัติตามกฎหมายและการรับมือภัยระดับร้ายแรง
- **สกมช.** สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ เป็นฝ่ายปฏิบัติ และมี ThaiCERT / ศปช. (ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ) เป็นหน่วยประสานเหตุ

โครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII)

กฎหมายกำหนด CII ไว้หลายด้าน ได้แก่ ความมั่นคงของรัฐ, บริการภาครัฐที่สำคัญ, การเงินการธนาคาร, เทคโนโลยีสารสนเทศและโทรคมนาคม, การขนส่งและโลจิสติกส์, พลังงานและสาธารณูปโภค, **สาธารณสุข** และด้านอื่นที่คณะกรรมการประกาศเพิ่ม

ภาคสาธารณสุขจึงเป็น CII โดยตรง หน่วยงานที่ถูกประกาศเป็น CII มีหน้าที่เพิ่มขึ้นจากหน่วยงานรัฐทั่วไป

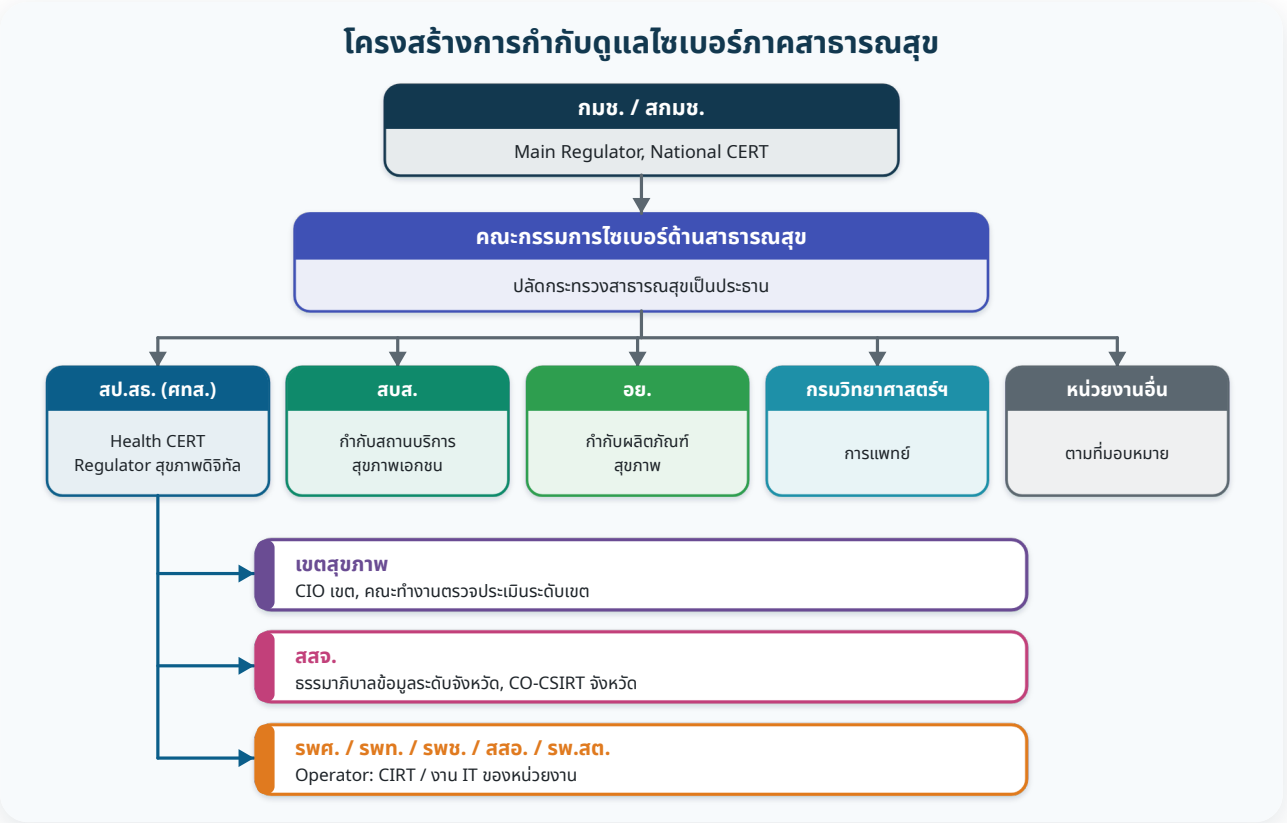
หน้าที่หลักของหน่วยงาน CII (สรุป)

1. ปฏิบัติตาม **ประมวลแนวทางปฏิบัติและกรอบมาตรฐาน** ด้านความมั่นคงปลอดภัยไซเบอร์ที่ สกมช. และหน่วยงานควบคุมกำกับดูแลกำหนด โดยข้อกำหนดขั้นต่ำอยู่ใน **ประกาศ กกม. เรื่อง ประมวลแนวทางปฏิบัติและกรอบมาตรฐานด้านการรักษาความมั่นคงปลอดภัยไซเบอร์สำหรับหน่วยงานของรัฐและหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ พ.ศ. 2564** ซึ่งหน่วยงานต้องนำไปจัดทำประมวลแนวทางปฏิบัติของตนเอง (กระทรวงสาธารณสุขถ่ายทอดผ่านนโยบาย สธ. 2565 และ CTAM+ ในบทที่ 5–6)
2. แจ้งรายชื่อ **เจ้าหน้าที่ระดับบริหารและระดับปฏิบัติการ** ที่รับผิดชอบ เพื่อใช้ประสานงาน
3. จัดให้มี **การประเมินความเสี่ยง** โดยผู้ตรวจประเมิน และ **การตรวจสอบ** ทั้งโดยผู้ตรวจสอบภายในและผู้ตรวจสอบอิสระ อย่างน้อยปีละ 1 ครั้ง แล้วส่งผลให้หน่วยงานควบคุมกำกับดูแลและ สกมช.
4. เข้าร่วมการ **ทดสอบความพร้อม** ในการรับมือภัยคุกคามที่ สกมช. จัด
5. **รายงานเหตุภัยคุกคามไซเบอร์** ต่อ สกมช. และหน่วยงานควบคุมกำกับดูแลโดยเร็ว และดำเนินการรับมือตามประมวลแนวทางปฏิบัติ
6. จัดทำ **แผนรับมือภัยคุกคามไซเบอร์** ที่มีโครงสร้างทีม CIRT ขั้นตอนการรายงาน และเกณฑ์การเรียกใช้งานทีม

📌 **สถานการณ์การปฏิบัติตามกฎหมาย**: สื่อมวลชนรายงานผลการประเมินของ สกมช. ปี 2568 ว่าคะแนนเฉลี่ยของหน่วยงานภาครัฐลดลงจาก 65% เหลือ 59% และหน่วยงานจำนวนมากยังไม่มีทะเบียนความเสี่ยง (Risk Register) ที่เป็นระบบ ภัยที่พบมากคือการใช้ช่องโหว่ภายในและการเข้าถึงระบบหรือข้อมูลโดยไม่ได้รับอนุญาต ข้อบกพร่องเหล่านี้แก้ได้ด้วยบทที่ 7, 8 และ 16

⚠️ ผู้อ่านควรตรวจสอบเลขมาตราและรายละเอียดจากตัวบทในราชกิจจานุเบกษาและประกาศล่าสุดของ สกมช. เนื่องจากมีกฎหมายลำดับรองออกเพิ่มเติมอย่างต่อเนื่อง

3.3 โครงสร้างการกำกับดูแลภาคสาธารณสุข



▲ ภาพที่ 3.1 โครงสร้างการกำกับดูแลไซเบอร์ภาคสาธารณสุข

คำอธิบาย

- **Health CERT (Healthcare Sectoral CERT)** คือศูนย์ประสานการรักษาความมั่นคงปลอดภัยไซเบอร์ด้านสาธารณสุข ดำเนินการโดย ศทส.สป.สธ. รับแจ้งเหตุ ประสานการแก้ไข และเผยแพร่ข่าวสาร
- **Regulator เฉพาะด้าน** เช่น สบส. กำกับโรงพยาบาลและคลินิกภาคเอกชน, อย. กำกับผู้ประกอบการผลิตภัณฑ์สุขภาพ
- **Operator** คือหน่วยบริการที่ให้บริการจริง ทุกแห่งควรมีทีม CIRT/IT ของตนเอง และประสาน SOC ระดับที่สูงกว่า

ช่องทางติดต่อ Health CERT (ตรวจสอบข้อมูลล่าสุดที่เว็บไซต์)

- เว็บไซต์รับแจ้งเหตุ: `https://health-cirt.moph.go.th`
- อีเมล: `health-cirt@moph.go.th`
- LINE Official: `@health-cirt`
- เว็บไซต์ข่าวสารและเกณฑ์: `https://cyber.moph.go.th`

3.4 ระดับภัยคุกคามไซเบอร์ตามประกาศ กมช. พ.ศ. 2564

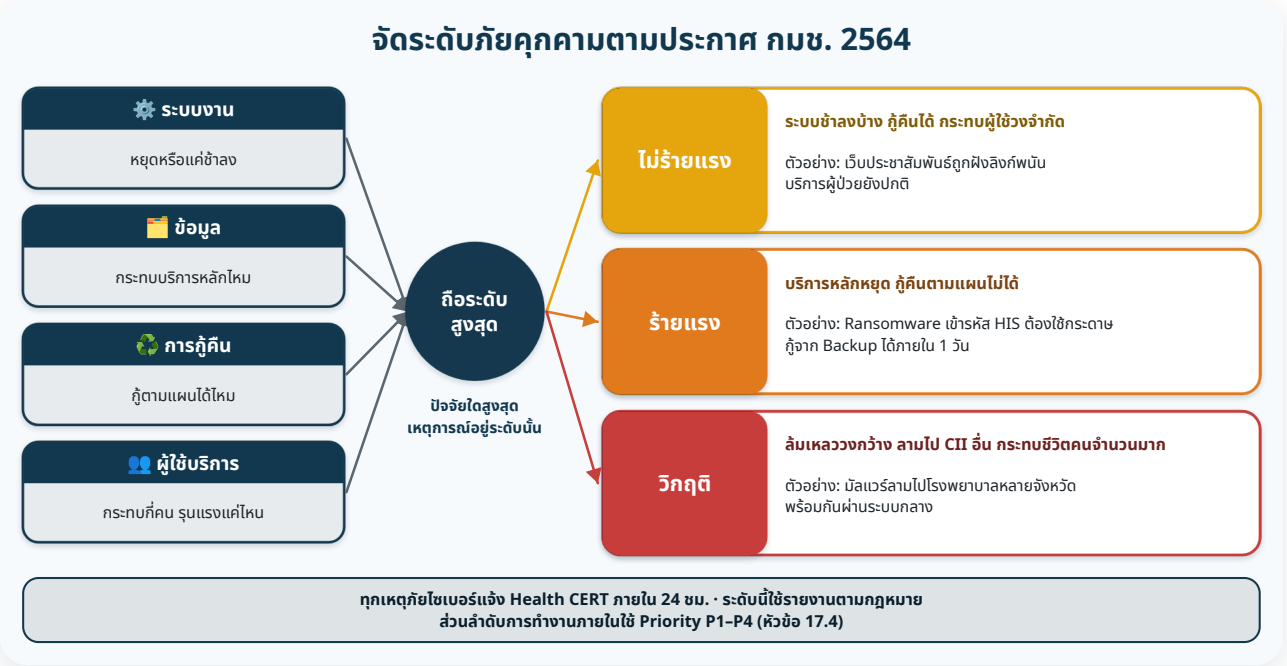
ประกาศคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ เรื่อง ลักษณะภัยคุกคามทางไซเบอร์ มาตรการป้องกัน รับมือ ประเมิน ปราบปราม และระงับภัยคุกคามทางไซเบอร์แต่ละระดับ พ.ศ. 2564 (ราชกิจจานุเบกษา 11 ธันวาคม 2564) แบ่งภัยเป็น 3 ระดับ และให้พิจารณาจาก **4 ปัจจัย** ดังนี้

1. ลักษณะผลกระทบที่เกิดขึ้นต่ออุปกรณ์หรือระบบงาน
2. ลักษณะผลกระทบต่อข้อมูลในระบบ
3. แนวโน้มในการกู้คืนระบบ
4. ลักษณะผลกระทบต่อลูกค้าหรือผู้ใช้บริการ

หลักสำคัญ: ให้ประเมินครบทั้ง 4 ปัจจัย แล้ว **ถือระดับสูงสุดที่ประเมินได้** เป็นระดับของเหตุการณ์ครั้งนั้น

ปัจจัย	ไม่ร้ายแรง	ร้ายแรง	วิกฤติ
ระบบงาน	ระบบด้อยประสิทธิภาพลงบ้าง แต่ไม่หยุดชะงัก	ระบบที่ให้บริการหลักเสียหายจนทำงานหรือให้บริการไม่ได้	ระบบล้มเหลวเป็นวงกว้าง รัฐควบคุมไม่ได้ หรือลุกลามไป CII อื่น
ข้อมูล	ข้อมูลถูกกระทบ ทำให้บริการด้อยลงบ้าง	ข้อมูลที่ใช้กับบริการหลักถูกกระทบจนบริการหลักหยุด	ข้อมูลที่เกี่ยวกับชีวิตคนจำนวนมาก หรือข้อมูลจำนวนมากระดับประเทศ
การกู้คืน	กู้คืนได้บางส่วนตามแผน	กู้คืนบริการหลักตามแผนไม่ได้	กู้คืนไม่ได้ ต้องใช้มาตรการเร่งด่วนระดับประเทศ
ผู้ใช้บริการ	กระทบผู้ใช้ในวงจำกัด	อาจกระทบผู้ใช้บริการทั้งหมด	กระทบผู้ใช้ทั้งหมด หรืออาจทำให้คนจำนวนมากเสียชีวิต

ภาพที่ 3.2 สรุปวิธีคิดให้จำง่าย ประเมินทีละปัจจัย แล้วใช้ปัจจัยที่ได้ระดับสูงสุดเป็นระดับของเหตุครั้งนั้น ระดับนี้ใช้รายงานตามกฎหมาย ส่วนการจัดลำดับงานภายในทีมใช้ Priority P1–P4 ในหัวข้อ 17.4



▲ ภาพที่ 3.2 จัดระดับภัยคุกคามจาก 4 ปัจจัย แล้วถือระดับสูงสุด

ตัวอย่างการจำแนกในโรงพยาบาล

เหตุการณ์	ระดับ	เหตุผล
เว็บไซต์ประชาสัมพันธ์ถูกฝังลิงก์เว็บพนัน ระบบบริการผู้ป่วยปกติ	ไม่ร้ายแรง	กระทบผู้ใช้วงจำกัด กู้คืนได้
แรนซัมแวร์เข้ารหัสฐานข้อมูล HIS ต้องใช้กระดาษ กู้จาก Backup ได้ภายใน 1 วัน	ร้ายแรง	บริการหลักหยุดชะงัก
แรนซัมแวร์ HIS และไม่มี Backup ที่ใช้ได้ ผู้ป่วยวิกฤตต้องส่งต่อ	ร้ายแรงถึงวิกฤติ	กู้คืนไม่ได้ และกระทบชีวิตผู้ป่วย
มัลแวร์แพร่ไปยังโรงพยาบาลหลายจังหวัดพร้อมกันผ่านระบบกลาง	วิกฤติ	ลุกลามเป็นวงกว้าง

3.5 พ.ร.บ.คอมพิวเตอร์ กับการเก็บ Log

พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ กำหนดให้ผู้ให้บริการ (ซึ่งรวมถึงหน่วยงานที่ให้บุคลากรใช้อินเทอร์เน็ต) **เก็บรักษาข้อมูลจราจรทางคอมพิวเตอร์ไม่น้อยกว่า 90 วัน** นับแต่วันที่ข้อมูลเข้าสู่ระบบ และอาจถูกสั่งให้เก็บนานขึ้นได้ไม่เกิน 2 ปีในกรณีจำเป็น ข้อกำหนดนี้คือที่มาของเกณฑ์ CTAM+ ข้อ 9 Log Management (ดูบทที่ 14)

ข้อมูลที่ควรเก็บอย่างน้อย

- ผู้ใช้ (User ID หรือ MAC/IP ที่ระบุตัวได้)
- เวลาเริ่มและสิ้นสุดการใช้งาน (ต้องตรงกับเวลามาตรฐาน จึงต้องทำ Time Sync)
- IP ต้นทาง ปลายทาง พอร์ต และ URL/Domain

3.6 คณะกรรมการและคำสั่งที่หน่วยงานควรมี

ระดับ	สิ่งที่ควรมี
กระทรวง	คณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์ด้านสาธารณสุข, Health CERT, DPO สป.สธ.
เขตสุขภาพ	CIO เขต, คณะทำงานควบคุมคุณภาพการตรวจประเมินความมั่นคงปลอดภัยไซเบอร์ระดับเขต
จังหวัด	คณะทำงานธรรมาภิบาลด้านข้อมูลและเทคโนโลยีสุขภาพระดับจังหวัด, ผู้ประสานงาน DPO, ทีม CO-CSIRT/ทีมสนับสนุนหน่วยบริการ
หน่วยบริการ	คำสั่งแต่งตั้ง CIO/CISO/DPO (หรือผู้ประสานงาน), ทีม CIRT, ผู้ดูแลห้อง Server, ผู้ดูแลระบบ HIS

📋 **หลักฐานที่ควรมี:** คำสั่งแต่งตั้งที่ระบุชื่อ ตำแหน่ง หน้าที่ และช่องทางติดต่อ 24 ชั่วโมง ใช้ประกอบ CTAM+ ข้อ 17 และตัวชี้วัด v2.1 ข้อ 8.2–8.4

⭐ สรุปท้ายบท

- ภาคสาธารณสุขเป็น CII ตามกฎหมาย หน่วยงานจึงต้องมีมาตรการ ประเมินความเสี่ยง และรายงานเหตุ
- ศทส.สป.สธ. ทำหน้าที่ Health CERT และเป็นผู้กำกับด้านสุขภาพดิจิทัล
- ระดับภัยมี 3 ระดับ ประเมินจาก 4 ปัจจัย และใช้ระดับสูงสุด
- ต้องเก็บ Log อย่างน้อย 90 วันตาม พ.ร.บ.คอมพิวเตอร์

✏️ คำถามทบทวน

1. หน่วยงานของท่านเป็น Operator หรือ Regulator และต้องรายงานเหตุไปที่ใด
2. เหตุการณ์ “ระบบ LIS ถูกเข้ารหัส แต่ HIS ยังใช้ได้ ผลแล็บต้องเขียนมือ 6 ชั่วโมง” ควรจัดเป็นระดับใด เพราะเหตุใด



ภาค 2 · กฎหมาย มาตรฐาน และการกำกับดูแล บทที่ 4

PDPA สำหรับสถานพยาบาล และธรรมาภิบาลข้อมูล

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้ว่าข้อมูลสุขภาพเป็น “ข้อมูลอ่อนไหว” และต้องมีฐานกฎหมายแบบใด
- ✔️ จัดทำเอกสารหลักตาม PDPA ได้ ได้แก่ Privacy Notice, ROPA, DPA/DSA
- ✔️ รู้ขั้นตอนเมื่อเกิดข้อมูลรั่วไหล (แจ้ง สคส. ภายใน 72 ชั่วโมง)
- ✔️ เชื่อม PDPA เข้ากับธรรมาภิบาลข้อมูล (Data Governance) ของกระทรวง

4.1 ศัพท์ที่ต้องรู้

คำ	ความหมาย	ตัวอย่างในโรงพยาบาล
เจ้าของข้อมูลส่วนบุคคล (Data Subject)	บุคคลที่ข้อมูลระบุตัวได้	ผู้ป่วย ญาติ เจ้าหน้าที่
ผู้ควบคุมข้อมูล (Data Controller)	ผู้มีอำนาจตัดสินใจเกี่ยวกับการเก็บ ใช้ เปิดเผย	โรงพยาบาล / สป.สธ.
ผู้ประมวลผลข้อมูล (Data Processor)	ผู้ดำเนินการตามคำสั่งผู้ควบคุม	บริษัทผู้ดูแล HIS, ผู้ให้บริการ Cloud
DPO	เจ้าหน้าที่คุ้มครองข้อมูลส่วนบุคคล	DPO สป.สธ. และผู้ประสานงาน DPO ระดับจังหวัด/หน่วยงาน
สคส.	สำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล	หน่วยงานรับแจ้งเหตุละเมิด

4.2 ข้อมูลสุขภาพคือข้อมูลอ่อนไหว (มาตรา 26)

PDPA มาตรา 26 กำหนดให้ข้อมูลสุขภาพ ความพิการ ข้อมูลพันธุกรรม ข้อมูลชีวภาพ (เช่น ลายนิ้วมือ ใบหน้า) ความเชื่อทางศาสนา พฤติกรรมทางเพศ ประวัติอาชญากรรม ฯลฯ เป็น **ข้อมูลอ่อนไหว (Sensitive Data)** ซึ่งการเก็บรวบรวมต้องได้รับ **ความยินยอมโดยชัดแจ้ง** เว้นแต่เข้าข้อยกเว้น

ข้อยกเว้นที่สถานพยาบาลใช้บ่อย

1. **ป้องกันหรือระงับอันตรายต่อชีวิต ร่างกาย หรือสุขภาพ** เมื่อเจ้าของข้อมูลไม่สามารถให้ความยินยอมได้ เช่น ผู้ป่วยหมดสติที่ห้องฉุกเฉิน
2. **เวชศาสตร์ป้องกัน อาชีวเวชศาสตร์ การวินิจฉัยโรคทางการแพทย์ การให้บริการด้านสุขภาพ** ภายใต้หน้าที่รักษาความลับของผู้ประกอบวิชาชีพ
3. **ประโยชน์สาธารณะด้านการสาธารณสุข** เช่น การป้องกันโรคติดต่ออันตราย การเฝ้าระวังโรค
4. การปฏิบัติตามกฎหมายเพื่อบรรลุวัตถุประสงค์ด้านการคุ้มครองแรงงาน ประกันสังคม หลักประกันสุขภาพแห่งชาติ

> 💡 การรักษาพยาบาลตามปกติ **ไม่จำเป็นต้องขอความยินยอม** แยกทุกครั้ง เพราะเข้าข้อยกเว้นข้อ 2 แต่ต้องแจ้งวัตถุประสงค์ให้ผู้ป่วยทราบผ่าน Privacy Notice ส่วนการนำข้อมูลไปใช้อย่างอื่น เช่น ถ่ายภาพผู้ป่วยลงสื่อประชาสัมพันธ์ หรือการวิจัยที่ไม่เข้าข้อยกเว้น ต้องขอความยินยอมโดยชัดแจ้ง

4.3 แนวทางของกระทรวงสาธารณสุข

คณะกรรมการคุ้มครองข้อมูลส่วนบุคคลกระทรวงสาธารณสุข (ครั้งที่ 2/2565) มีมติให้หน่วยงานดำเนินการในระยะเริ่มต้น ดังนี้

1. **นำนโยบาย แนวปฏิบัติ คู่มือ และแบบฟอร์มของกระทรวงไปใช้ได้เลย** ไม่ต้องจัดทำใหม่ (ดาวน์โหลดที่ `https://pdpa.moph.go.th`)
2. ประชาสัมพันธ์ **นโยบายการคุ้มครองข้อมูลส่วนบุคคล (Privacy Policy)** ของกระทรวงให้ผู้รับบริการทราบทุกช่องทาง
3. ประชาสัมพันธ์ **แนวปฏิบัติ** ให้บุคลากรถือปฏิบัติ
4. โรงพยาบาลเพิ่มชื่อหน่วยงานใน **หนังสือแจ้งการประมวลผลข้อมูลส่วนบุคคล (Privacy Notice)** สำหรับผู้รับบริการ แล้วติดประกาศให้เห็นชัด
5. จัดทำ **บันทึกรายการกิจกรรมการประมวลผล (ROPA) ตามมาตรา 39** โดยโรงพยาบาล **ใช้เวชระเบียนแทน ROPA ของผู้ป่วยได้** และ **ใช้ทะเบียนส่งต่อผู้ป่วย (Refer) แทนบัญชีการเปิดเผยข้อมูลได้**
6. ให้ความรู้บุคลากรทุกระดับ
7. ข้อมูลที่เก็บไว้ก่อน 1 มิถุนายน 2565 ให้ดำเนินการตามบทเฉพาะกาล (มาตรา 95)

นอกจากนี้ สป.สธ. แต่งตั้ง DPO และเจ้าหน้าที่ประสานงาน DPO (คำสั่ง สป. ที่ 1189/2565) และมอบอำนาจให้หัวหน้าหน่วยงาน เช่น นพ.สสจ. และ ผอ.รพศ./รพท. ลงนามในข้อตกลงการประมวลผลข้อมูล (DPA) ได้

4.4 เอกสารที่หน่วยงานต้องมี (Checklist)

เอกสาร	ใช้ทำอะไร	แหล่งแม่แบบ
Privacy Policy	นโยบายภาพรวมขององค์กร	pdpa.moph.go.th

เอกสาร	ใช้ทำอะไร	แหล่งแม่แบบ
Privacy Notice (ผู้รับบริการ / บุคลากร / CCTV / เว็บไซต์)	แจ้งเจ้าของข้อมูลว่าเก็บอะไร ใช้ทำอะไร เก็บนานเท่าใด	pdpa.moph.go.th
ROPA	ทะเบียนกิจกรรมการประมวลผล	เวชระเบียน + ROPA กิจกรรมอื่น
DPA (Data Processing Agreement)	สัญญากับผู้ประมวลผล เช่น บริษัท HIS	pdpa.moph.go.th
DSA (Data Sharing Agreement)	ข้อตกลงแลกเปลี่ยนข้อมูลกับหน่วยงานอื่น	pdpa.moph.go.th
แบบคำขอใช้สิทธิ์ของเจ้าของข้อมูล	ขอเข้าถึง แก้ไข ลบ คัดค้าน	pdpa.moph.go.th
แบบรายงานเหตุละเมิดข้อมูล	ใช้แจ้ง สคส.	สคส. / pdpa.moph.go.th
คำสั่งแต่งตั้ง DPO/ผู้ประสานงาน	ระบุผู้รับผิดชอบ	ตัวอย่างในภาคผนวก

📋 CTAM+ ข้อ 17 และตัวชี้วัด v2.1 ข้อ 13.3–13.4 ต้องการหลักฐานว่ามี Privacy Policy และ Privacy Notice ตามหนังสือ สป.สธ.

4.5 มาตรการรักษาความมั่นคงปลอดภัยตาม PDPA

ผู้ควบคุมข้อมูลต้องจัดให้มีมาตรการที่เหมาะสม 3 ด้าน

1. **Administrative Safeguard** นโยบาย การกำหนดสิทธิ์ การอบรม สัญญากับผู้ประมวลผล
2. **Technical Safeguard** การยืนยันตัวตน การเข้ารหัส Log การสำรองข้อมูล
3. **Physical Safeguard** ห้อง Server ที่ล็อก การทำลายเอกสาร การจัดวางจอให้คนนอกมองไม่เห็น

ตัวอย่างการปฏิบัติในงานประจำ

- ห้ามส่งภาพหน้าจอ HIS หรือผลตรวจผ่านกลุ่ม LINE ที่มีคนนอก ใช้ช่องทางที่หน่วยงานกำหนดแทน
- ไฟล์ Excel ที่มีเลขบัตรประชาชน ต้องตั้งรหัสผ่านก่อนส่ง และส่งรหัสผ่านแยกช่องทาง
- การส่งออกข้อมูลเพื่อวิเคราะห์ ให้ทำ **De-identification** เช่น แทนเลขบัตรด้วยค่า Hash และตัดชื่อออก
- ปิดหน้าจอ (Windows + L) ทุกครั้งที่ลุกจากโต๊ะ
- เอกสารที่มีข้อมูลผู้ป่วยต้องทำลายด้วยเครื่องย่อยเอกสาร ไม่ใช้เป็นกระดาษรีไซเคิล

ตัวอย่าง SQL ทำ Pseudonymization ก่อนส่งข้อมูลวิเคราะห์ (MySQL/MariaDB)

```sql
-- สร้างตารางสำหรับส่งต่อ โดยแปลงเลขบัตรเป็น Hash และตัดชื่อออก
CREATE TABLE export_visit AS
SELECT
  SHA2(CONCAT(p.cid, 'SALT-ลับเฉพาะหน่วยงาน'), 256) AS pid_hash,
  YEAR(p.birthday)  AS birth_year,
  p.sex,
  v.vstdate,
  v.pdx             AS diag_code
```

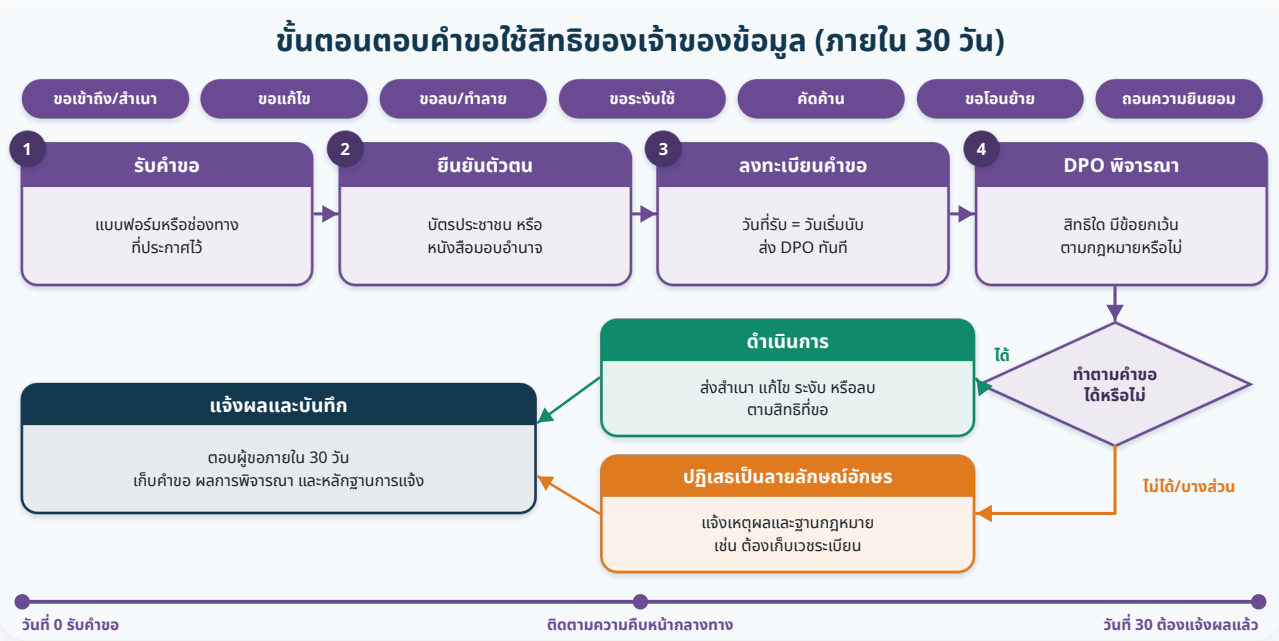
```
FROM ovst v
JOIN patient p ON p.hn = v.hn
WHERE v.vstdate BETWEEN '2025-10-01' AND '2026-09-30';
```

⚠️ ชื่อตารางและคอลัมน์ขึ้นกับระบบ HIS ที่ใช้ ให้ปรับตามโครงสร้างจริง และเก็บค่า SALT เป็นความลับ

4.6 สิทธิของเจ้าของข้อมูล

ผู้ป่วยมีสิทธิ ขอรับทราบ, ขอเข้าถึงและขอรับสำเนา, ขอให้แก้ไข, ขอให้ลบหรือทำลาย, ขอให้ระงับการใช้, คัดค้าน, ขอให้โอนย้ายข้อมูล และถอนความยินยอม หน่วยงานต้องตอบภายใน 30 วัน

ขั้นตอนในภาพที่ 4.1 ใช้ได้กับทุกสิทธิ จุดที่มักพลาดคือไม่ลงวันที่รับคำขอ ทำให้นับ 30 วันไม่ได้ และปฏิเสธด้วยวาจาโดยไม่มีหลักฐาน ให้ลงทะเบียนคำขอทุกครั้งและส่ง DPO ในวันเดียวกัน

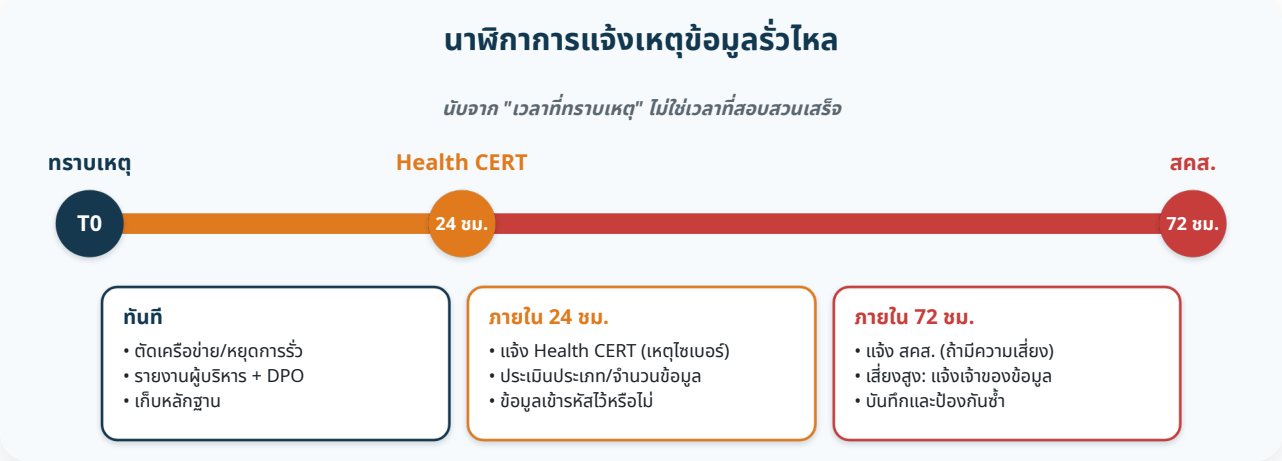


▲ ภาพที่ 4.1 ขั้นตอนตอบคำขอใช้สิทธิของเจ้าของข้อมูลภายใน 30 วัน

💡 การขอลบเวชระเบียนมักปฏิเสธได้ เพราะกฎหมายและมาตรฐานวิชาชีพกำหนดให้ต้องเก็บรักษาไว้ แต่ต้องแจ้งเหตุผลเป็นลายลักษณ์อักษร

4.7 เมื่อข้อมูลรั่วไหล: แจ้ง สคส. ภายใน 72 ชั่วโมง

PDPA มาตรา 37(4) กำหนดให้ผู้ควบคุมข้อมูลแจ้งเหตุละเมิดต่อ สคส. **โดยไม่ชักช้าภายใน 72 ชั่วโมงนับแต่ทราบเหตุ** เว้นแต่เหตุนั้นไม่มีความเสี่ยงที่จะกระทบสิทธิเสรีภาพของบุคคล และถ้ามีความเสี่ยงสูง ต้องแจ้งเจ้าของข้อมูลพร้อมแนวทางเยียวยาด้วย



▲ ภาพที่ 4.2 กรอบเวลาการแจ้งเหตุข้อมูลส่วนบุคคลรั่วไหล

หลักเกณฑ์และวิธีการแจ้งอยู่ใน **ประกาศคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล เรื่อง หลักเกณฑ์และวิธีการในการแจ้งเหตุการละเมิดข้อมูลส่วนบุคคล พ.ศ. 2565** ซึ่งกำหนดรายละเอียดข้อมูลที่ต้องแจ้งและการประเมินระดับความเสี่ยง และมีประกาศเพิ่มเติมเรื่องช่องทางแจ้งทางอิเล็กทรอนิกส์ ให้ตรวจแบบฟอร์มและช่องทางล่าสุดที่ `pdpc.or.th` ข้อมูลที่ควรเตรียมไว้แจ้ง

- ลักษณะของเหตุ วันเวลาที่เกิดและที่ทราบ
- ประเภทและจำนวน (โดยประมาณ) ของข้อมูลและเจ้าของข้อมูลที่ได้รับผลกระทบ
- ผลกระทบที่อาจเกิดขึ้นและระดับความเสี่ยง
- มาตรการที่ใช้หรือจะใช้เพื่อระงับเหตุและลดผลกระทบ
- ชื่อและช่องทางติดต่อของ DPO หรือผู้ประสานงาน

> 💡 ถ้ายังไม่มีข้อมูลครบภายใน 72 ชั่วโมง ให้แจ้งเท่าที่มีพร้อมเหตุผล แล้วแจ้งเพิ่มเติมภายหลัง ดีกว่าแจ้งช้า

รายละเอียด Flow การแจ้งเหตุของหน่วยงานสาธารณสุขและ Playbook อยู่ในบทที่ 17

4.8 โทษตามกฎหมาย (สรุป)

- **ทางแพ่ง** ชดใช้ค่าเสียหายจริง และศาลอาจสั่งค่าสินไหมเพื่อการลงโทษเพิ่มได้ไม่เกิน 2 เท่า
- **ทางอาญา** กรณีใช้หรือเปิดเผยข้อมูลอ่อนไหวโดยมิชอบ มีโทษจำคุกและปรับ และเจ้าหน้าที่ที่นำข้อมูลที่ได้จากหน้าที่ไปเปิดเผยก็มีโทษ
- **ทางปกครอง** โทษปรับสูงสุด 5 ล้านบาท สำหรับความผิดเกี่ยวกับข้อมูลอ่อนไหว สคส. เริ่มมีคำสั่งลงโทษปรับทางปกครองแล้ว กรณีแรกของภาคเอกชน (แถลงเมื่อ 21 ส.ค. 2567) ปรับบริษัทเอกชนรายใหญ่รวม **7 ล้านบาท** จาก 3 ข้อหา คือ ไม่แต่งตั้ง DPO ตามมาตรา 41(2), ไม่มีมาตรการรักษาความปลอดภัยที่เหมาะสมตามมาตรา 37(1) และไม่แจ้งเหตุละเมิดภายใน 72 ชั่วโมงตามมาตรา 37(4) ต่อมามีรายงานว่ามีคำสั่งลงโทษปรับทางปกครองรวมหลายเรื่อง มูลค่ารวมกว่า 21 ล้านบาท ทั้งสามข้อหาเป็นเรื่องที่โรงพยาบาลทำได้ทันที: แต่งตั้ง DPO, ทำตาม CTAM+ และซ้อมขั้นตอนแจ้งเหตุ

4.9 ธรรมาภิบาลข้อมูล (Data Governance) ของกระทรวง

ธรรมาภิบาลข้อมูลคือการกำหนดสิทธิ หน้าที่ และความรับผิดชอบของผู้เกี่ยวข้องกับข้อมูลตลอดวงจรชีวิต ตั้งแต่สร้าง เก็บ ใช้ เปิดเผย จนถึงทำลาย เพื่อให้ข้อมูลถูกต้อง ปลอดภัย และใช้ประโยชน์ได้ กระทรวงสาธารณสุขมีคณะทำงานธรรมาภิบาลด้านข้อมูลและเทคโนโลยีสุขภาพทั้งระดับกระทรวง เขต และจังหวัด

องค์ประกอบที่หน่วยงานควรมี

1. **บัญชีข้อมูล (Data Catalog)** รู้ว่ามีชุดข้อมูลอะไร อยู่ที่ไหน ใครเป็นเจ้าของ
2. **การจัดชั้นความลับ (Data Classification)** เช่น เปิดเผยได้ / ใช้ภายใน / ลับ / ลับมาก (ข้อมูลสุขภาพรายบุคคลอยู่ในชั้นลับขึ้นไป)
3. **บทบาท** Data Owner, Data Steward, Data Custodian (มักเป็นงาน IT)
4. **คุณภาพข้อมูล** เช่น ความครบถ้วนของ 43 แฟ้มที่ส่ง HDC
5. **การเปิดเผยข้อมูล** ผ่าน DSA และการขออนุมัติตามลำดับชั้น

⭐ สรุปท้ายบท

- ข้อมูลสุขภาพเป็นข้อมูลอ่อนไหว การรักษาตามปกติใช้ข้อยกเว้นมาตรา 26 ได้ แต่ต้องแจ้ง Privacy Notice
- ใช้แม่แบบของกระทรวงได้ทันที และใช้เวชระเบียนแทน ROPA ของผู้ป่วยได้
- ข้อมูลรั่ว: แจ้ง DPO ทันที แจ้ง สคส. ภายใน 72 ชม. และถ้าเกิดจากภัยไซเบอร์ แจ้ง Health CERT ภายใน 24 ชม.
- PDPA เป็นส่วนหนึ่งของธรรมาภิบาลข้อมูล ไม่ใช่งานของ DPO คนเดียว

✏️ แบบฝึกหัด

1. ตรวจว่าหน่วยงานของท่านติดประกาศ Privacy Notice ที่จุดลงทะเบียนผู้ป่วยแล้วหรือยัง
2. ระบุผู้ประมวลผลข้อมูลภายนอก 3 รายของหน่วยงาน และตรวจว่ามี DPA ครบหรือไม่



ภาค 2 · กฎหมาย มาตรฐาน และการกำกับดูแล บทที่ 5

นโยบายและมาตรฐานของกระทรวงสาธารณสุข

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้โครงสร้างประกาศนโยบายและแนวปฏิบัติด้านความมั่นคงปลอดภัยสารสนเทศ สธ. พ.ศ. 2565
- ✔️ เข้าใจตัวชี้วัด Cybersecurity v2.1 (เกณฑ์ขั้นต่ำ 7 ข้อ และเกณฑ์ขั้นสูง)
- ✔️ รู้ความสัมพันธ์ระหว่าง CTAM+, HAIT, ISO 27001 และ ISO 27799
- ✔️ รู้แนวทางจัดทำแผนบริหารความเสี่ยงไซเบอร์ของ สป.สธ. ปี 2566–2568

5.1 ประกาศ สธ. เรื่อง นโยบายและแนวปฏิบัติฯ พ.ศ. 2565

ประกาศฉบับนี้ออกตามพระราชกฤษฎีกากำหนดหลักเกณฑ์และวิธีการในการทำธุรกรรมทางอิเล็กทรอนิกส์ภาครัฐ พ.ศ. 2549 ใช้บังคับกับหน่วยงานในสังกัดกระทรวงทั้งหมด หลักสำคัญมีดังนี้

นโยบาย (ข้อ 5)

1. **ควบคุมการเข้าถึง** ทั้งสารสนเทศ ผู้ใช้งาน เครือข่าย ระบบปฏิบัติการ และแอปพลิเคชัน ต้องมีการลงทะเบียนผู้ใช้ ยืนยันตัวตน เก็บ Log แบ่งโซนเครือข่าย ตั้งเวลาตัดการเชื่อมต่อเมื่อไม่ใช้งาน และให้สิทธิ์ตามหน้าที่โดยหัวหน้าหน่วยงานอนุมัติเป็นลายลักษณ์อักษร
2. **ระบบสำรอง** เลือกระบบสำคัญเรียงตามความจำเป็น กำหนดผู้รับผิดชอบ และจัดทำ **แผนเตรียมความพร้อมกรณีฉุกเฉินอย่างน้อยปีละหนึ่งครั้ง**
3. **ตรวจสอบและประเมินความเสี่ยง** โดยผู้ตรวจสอบภายในหรือผู้ตรวจสอบอิสระภายนอก **อย่างน้อยปีละหนึ่งครั้ง**

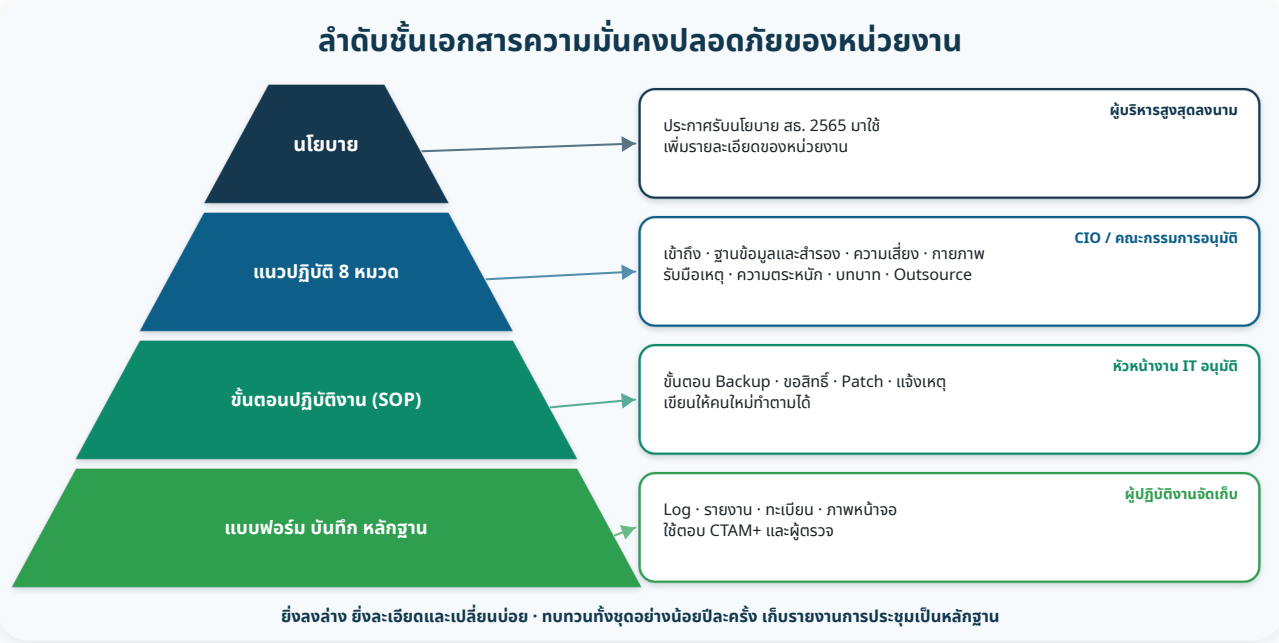
ความรับผิดชอบ (ข้อ 6) หากเกิดความเสียหายจากการละเลยหรือฝ่าฝืนนโยบาย **ผู้บริหารระดับสูงสุดของหน่วยงานเป็นผู้รับผิดชอบ** ต่อความเสี่ยงและความเสียหายที่เกิดขึ้น ข้อนี้คือเหตุผลที่ผู้อำนวยการต้องลงมาดูเรื่องไซเบอร์ด้วยตนเอง

โครงสร้างแนวปฏิบัติแนบท้าย

หมวด	เนื้อหา	บทในหนังสือ
1 การควบคุมการเข้าถึงและการใช้งาน (18 ส่วน)	Access Control, User Access, ความรับผิดชอบผู้ใช้, สินทรัพย์, เครือข่าย, OS, แอปพลิเคชัน, ลิขสิทธิ์และมัลแวร์, Teleworking, Wireless, Firewall, E-Mail, PC, Notebook, IDS/IPS, การติดตั้งระบบ, Log	7–11, 14
2 ความปลอดภัยฐานข้อมูลและสำรองข้อมูล	Database Security, Backup	12, 13
3 การตรวจสอบและประเมินความเสี่ยง	Risk Assessment	7, 16
4 ความปลอดภัยด้านกายภาพ	ห้อง Server, ไฟฟ้า, ดับเพลิง, การเข้าออก	13
5 การตอบสนองเหตุการณ์	Incident Response	17
6 การสร้างความตระหนัก	Awareness	18
7 หน้าที่และความรับผิดชอบ	บทบาทผู้บริหาร ผู้ดูแลระบบ ผู้ใช้	19
8 การใช้บริการจากหน่วยงานภายนอก	Outsource, Vendor	19

> 💡 หน่วยงานไม่ต้องเขียนนโยบายใหม่ทั้งหมด ให้ **ประกาศรับนโยบายของกระทรวงมาใช้** แล้วเพิ่มเฉพาะรายละเอียดที่เป็นของหน่วยงาน เช่น ชื่อผู้รับผิดชอบ ระบบสำคัญ และช่องทางติดต่อ ทบทวนปีละครั้งและเก็บรายงานการประชุมเป็นหลักฐาน

เอกสารที่ประกาศรับนโยบายแล้วต้องแตกลงเป็นชั้นตามภาพที่ 5.1 ชั้นบนเปลี่ยนน้อยและผู้บริหารลงนาม ชั้นล่างเปลี่ยนบ่อยและเป็นหลักฐานที่ผู้ตรวจประเมินขอดู ถ้ามีแต่นโยบายแต่ไม่มี SOP และบันทึก ก็พิสูจน์ไม่ได้ว่าทำจริง



▲ ภาพที่ 5.1 ลำดับชั้นเอกสารความมั่นคงปลอดภัย จากนโยบายถึงหลักฐาน

5.2 ตัวชี้วัด Cybersecurity v2.1

ตัวชี้วัดชุดนี้กำหนดเป้าหมายให้หน่วยงาน **ร้อยละ 90 ผ่านเกณฑ์ขั้นต่ำ** และ **ร้อยละ 25 ผ่านเกณฑ์ขั้นสูง** โดยการตรวจสอบทำได้ 2 รูปแบบ คือ ทีมประเมินภาคเอกชน (ต้องมีใบรับรองอย่างน้อย 1 คน) หรือทีมประเมินภาครัฐ (เช่น ทีมระดับเขต/จังหวัด ที่มีผู้มีใบรับรอง)

เกณฑ์ขั้นต่ำ 7 ข้อ

1. มี Backup แบบ 3-2-1
2. มี EDR บน Server/VM ที่สำคัญ
3. มี Firewall ที่ทำ Access Control
4. มีการทำ Privileged Access Management
5. มีแผน BCP และทดสอบอย่างน้อยปีละ 1 ครั้ง ในสถานการณ์ Ransomware
6. มีแผน DRP และทดสอบอย่างน้อยปีละ 1 ครั้ง ในสถานการณ์ Ransomware
7. มีการควบคุมการเข้าออก Data Center ที่เหมาะสม

เกณฑ์ขั้นสูง (อ้างอิงแนวทาง ISO 27001) — สรุปสาระสำคัญ

หมวด	ตัวอย่างข้อกำหนด
1 Data Center	แยกห้อง, ระบบควบคุมการเข้าออก (บัตร/ไบโอเมตริก), CCTV, ดับเพลิง, เครื่องปรับอากาศสำรอง, Generator, UPS อย่างน้อย 2 ชุดแบบ True Online, เฝ้าระวังอุณหภูมิ
2 Compute & Storage	Virtualization, Monitoring การใช้ทรัพยากร ไม่เกิน 90%, RAID, Managed Switch, EDR บน Server
3 Backup	3-2-1 (3 ชุด, 2 สื่อ, 1 Offline), **RPO ไม่เกิน 24 ชม., RTO ไม่เกิน 24 ชม.**
4 อินเทอร์เน็ต	อย่างน้อย 2 เส้นทาง จากผู้ให้บริการต่างกัน
5 เครือข่าย	NGFW (IPS/IDS/SSL Inspection), **Deny All แล้ว Whitelist**, Core Switch แบบ HA, **แบ่ง VLAN: Server Public, Server Private, Client, OT/Medical IoT**, Network Authentication, Routing ระหว่าง VLAN ผ่าน Firewall, Network Monitoring
6 เครื่องคอมพิวเตอร์	ทะเบียนเครื่อง, OS ไม่เก่ากว่า 1 Generation, Patch, Antivirus
7 ซอฟต์แวร์	ทะเบียนซอฟต์แวร์, ซอฟต์แวร์ใน Data Center ถูกลิขสิทธิ์
8 นโยบาย/องค์กร	นโยบาย, บทบาท, Flow แจ้งเหตุ, DPO, Return of Assets, Information Transfer, IAL/AAL, IR Plan, BCP/DRP, **เก็บ Log 90 วัน**, Privacy
9 บุคลากร	คัดกรองบุคลากร, **อบรมความตระหนักไม่น้อยกว่าร้อยละ 80** ของบุคลากร
10 กายภาพ	Clear Desk and Clear Screen, การทำลายสื่อ

หมวด	ตัวอย่างข้อกำหนด
11 เทคโนโลยี	Privileged Access, **SIEM (ใช้ Open Source ได้)**, Clock Sync, Web Filtering, **WAF ป้องกัน DDoS และ SQL Injection**
12 ความเสี่ยง	ทะเบียนและแผนจัดการความเสี่ยง
13 PDPA	Access Control, User Responsibilities, Privacy Policy, Privacy Notice

> ตัวชี้วัด v2.1 เป็นพื้นฐานของเกณฑ์ CTAM และ CTAM+ ในปีต่อมา ถ้าทำตามตัวชี้วัดนี้ครบ การผ่าน CTAM+ จะง่ายมาก

5.3 HAIT และ HAIT+

HAIT (Hospital Accreditation for Information Technology) เป็นการรับรองคุณภาพด้านไอทีของโรงพยาบาล ดูแลโดยสมาคมเวชสารสนเทศไทย (TMI) ร่วมกับ สรพ. มีระดับตั้งแต่ระดับ 1 ถึงระดับสูง ครอบคลุมทั้งการบริหาร การพัฒนาระบบ ความต่อเนื่อง และความมั่นคงปลอดภัย **HAIT+** เพิ่มการวิเคราะห์ผลกระทบทางธุรกิจ (BIA) หากเกิดภัยพิบัติไซเบอร์ และเกณฑ์ประเมินความเสี่ยงไซเบอร์สำหรับโรงพยาบาล

ประโยชน์ของการทำ HAIT

- เอกสารชุดเดียวกันใช้ตอบทั้ง HA, HAIT, CTAM+ และ PDPA
- ได้กรอบการพัฒนาต่อเนื่อง ไม่ใช่ทำเพื่อผ่านการตรวจครั้งเดียว

5.4 ISO/IEC 27001 และ ISO 27799

- **ISO/IEC 27001:2022** มาตรฐานระบบบริหารความมั่นคงปลอดภัยสารสนเทศ (ISMS) ใช้วงจร Plan-Do-Check-Act และมีมาตรการควบคุมใน Annex A จำนวน 93 ข้อ แบ่งเป็น 4 กลุ่ม คือ Organizational, People, Physical, Technological
- **ISO 27799** แนวทางการนำ ISO 27002 มาใช้ในงานสารสนเทศสุขภาพ เน้นความลับของข้อมูลสุขภาพและความพร้อมใช้ในการรักษา

เกณฑ์ CTAM ข้อ DR Site ระบุให้ระบบสำรองมีมาตรฐาน ISO 27001 และ ISO 27799 เป็นอย่างน้อย และ CO-CSIRT ใช้ ISO 27001 ร่วมกับ NIST CSF เป็นกรอบประเมินความเสี่ยงโรงพยาบาล

> 💡 โรงพยาบาลชุมชนไม่จำเป็นต้องขอใบรับรอง ISO 27001 แต่ควรใช้ Annex A เป็น Checklist ในการวางมาตรการ

5.5 แนวทางจัดทำแผนบริหารความเสี่ยง งบประมาณ บุคลากร และแนวปฏิบัติ ปี 2566–2568

สป.สธ. ออกแนวทางนี้เมื่อมิถุนายน 2566 เพื่อให้ผู้บริหารใช้วางแผน ประกอบด้วย 4 แผน

1. **แผนด้านงบประมาณ** (8 ข้อย่อย)
2. **แผนด้านการบริหารทรัพยากรบุคคล** (4 ข้อย่อย)
3. **แผนด้านการบริหารความเสี่ยงด้านดิจิทัล** (14 ข้อย่อย)
4. **แผนด้านแนวทางปฏิบัติสำหรับบุคลากรไอที/ดิจิทัล** (46 ข้อย่อย)

แบ่งหน่วยงานเป็น 2 กลุ่ม ได้แก่ **“กอง”** (หน่วยงานระดับกองใน สป., สำนักงานเขต, สสจ., รพศ./รพท.) และ **“รพช”** (รพช., สสอ., รพ.สต.) และแบ่งระยะเวลา

ปีงบประมาณ	ลักษณะงาน
2566	เร่งด่วน ทำได้ทันทีโดยไม่ต้องรองบประมาณ เช่น เปลี่ยนรหัสผ่าน Default, ปิดพอร์ตที่ไม่ใช้, ทำ Backup
2567	เร่งด่วน แต่ต้องรอจัดสรรงบประมาณ เช่น จัดหา Firewall, Storage สำรอง
2568	ไม่เร่งด่วนแต่สำคัญ เช่น DR Site, SIEM เต็มรูปแบบ

ภาคผนวกของแนวทางมีตัวอย่างเอกสารสื่อสารมาตรการถึงผู้ใช้ (การป้องกันภัยไซเบอร์, การใช้อีเมล, การปฏิบัติทั่วไป), Workflow แจ้งเหตุ และ **หน้าที่ของผู้ดูแลระบบ** ดังนี้

- **CIO & CDO** บริหารเทคโนโลยีและระบบสุขภาพดิจิทัล ดูแลให้ระบบสำคัญพร้อมใช้ (SLA 99.9%) จัดทำแผนงบประมาณ
- **CISO** จัดทำแผนบริหารความเสี่ยง ป้องกัน เฝ้าระวัง รับมือภัยตาม พ.ร.บ.ไซเบอร์ จัดให้มี CIRT, SOC และผู้ตรวจสอบภายใน
- **หัวหน้างานเทคโนโลยีสารสนเทศ** จัดทำหนังสือขออนุมัติสิทธิ์, ทะเบียนทรัพย์สิน, แผนผังระบบ/เครือข่าย/Data Center, ทะเบียนบัญชีผู้ใช้, มอบหมายผู้ควบคุม Data Center เป็นลายลักษณ์อักษร และทบทวนสิทธิ์อย่างน้อยปีละครั้ง

5.6 แผนที่เชื่อมโยงมาตรฐานทั้งหมด

เรื่อง	นโยบาย สธ. 2565	ตัวชี้วัด v2.1	CTAM+ 2569	ISO 27001:2022 Annex A
Backup	หมวด 2 ส่วน 2	ขั้นต่ำ 1, ขั้นสูง 3	ข้อ 1	8.13
Antivirus/EDR	หมวด 1 ส่วน 8	ขั้นต่ำ 2, ขั้นสูง 6.3	ข้อ 2	8.7
Firewall/Access	หมวด 1 ส่วน 5, 11	ขั้นต่ำ 3, ขั้นสูง 5	ข้อ 3, 14	8.20–8.22
PAM	หมวด 1 ส่วน 2	ขั้นต่ำ 4, ขั้นสูง 11.1	ข้อ 4	8.2

เรื่อง	นโยบาย สธ. 2565	ตัวชี้วัด v2.1	CTAM+ 2569	ISO 27001:2022 Annex A
BCP/DRP	ข้อ 5.2	ขั้นต่ำ 5–6	ข้อ 5	5.29–5.30
Patch	หมวด 1 ส่วน 17	ขั้นสูง 6.2	ข้อ 6, 13	8.8
MFA	หมวด 1 ส่วน 2	ขั้นสูง 8.8	ข้อ 7	8.5
WAF	—	ขั้นสูง 11.5	ข้อ 8	8.23, 8.26
Log	หมวด 1 ส่วน 18	ขั้นสูง 8.11	ข้อ 9	8.15
SIEM	หมวด 1 ส่วน 16	ขั้นสูง 11.2	ข้อ 10	8.16
VA/Pentest	หมวด 3	—	ข้อ 11, 16	8.8, 8.29
Asset Inventory	หมวด 1 ส่วน 4	ขั้นสูง 6.1, 7.1	ข้อ 12	5.9
ลิขสิทธิ์ซอฟต์แวร์	หมวด 1 ส่วน 8	ขั้นสูง 7.2	ข้อ 15	5.32
นโยบาย/อบรม	หมวด 6–7	ขั้นสูง 8.1, 9.2	ข้อ 17	5.1, 6.3

💡 การเทียบกับแนวทางสากลของภาคสุขภาพ เช่น HHS 405(d) HICP 10 แนวปฏิบัติ, HHS Cybersecurity Performance Goals และ NIST CSF 2.0 อยู่ในบทที่ 20 ข้อ 20.7

⭐ สรุปท้ายบท

- ประกาศ สธ. 2565 กำหนดให้ผู้บริหารสูงสุดรับผิดชอบความเสียหาย และให้ประเมินความเสี่ยงปีละครั้ง
- ตัวชี้วัด v2.1 มีเกณฑ์ขั้นต่ำ 7 ข้อ ซึ่งเป็นแกนของ CTAM+
- เอกสารชุดเดียวกันใช้ตอบได้หลายมาตรฐาน ถ้าจัดเก็บอย่างเป็นระบบ

✏️ คำถามทบทวน

1. ตามประกาศ สธ. พ.ศ. 2565 ใครรับผิดชอบเมื่อเกิดความเสียหายจากการละเลยนโยบาย และต้องตรวจประเมินความเสี่ยงบ่อยแค่ไหน
2. หน่วยงานต้องเขียนนโยบายความมั่นคงปลอดภัยใหม่ทั้งฉบับหรือไม่
3. ผู้ตรวจประเมินขอดูหลักฐานว่าหน่วยงาน “ทำตามแนวปฏิบัติเรื่อง Backup จริง” ควรเตรียมเอกสารชั้นใดบ้าง
4. เลือกเอกสาร 3 ฉบับที่หน่วยงานมีอยู่แล้ว และระบุว่าใช้ตอบมาตรฐานหรือเกณฑ์ใดได้บ้างตามตารางหัวข้อ 5.6



ภาค 2 · กฎหมาย มาตรฐาน และการกำกับดูแล บทที่ 6

CTAM+ ฉบับลงมือทำ

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้ที่มาและพัฒนาการของเกณฑ์ CTAM ตั้งแต่ V4 (2568) ถึง CTAM+ (2569)
- ✔️ อธิบายเกณฑ์ทั้ง 17 ข้อ และรู้ว่าต้องทำอะไร เก็บหลักฐานอะไร
- ✔️ ส่งผลประเมินผ่านระบบ CTAM+ ได้ตามขั้นตอน โรงพยาบาล → สสจ. → เขต → ศทส.
- ✔️ วางแผนเตรียมตัว 90 วันก่อนรับการตรวจ

6.1 CTAM คืออะไร

CTAM (Cybersecurity Technical Assessment Matrix) คือเกณฑ์การประเมินระดับการรักษาความมั่นคงปลอดภัยไซเบอร์ที่ ศทส.สป.สธ. ใช้วัดหน่วยงานในสังกัด เป็นเกณฑ์เชิงเทคนิคที่ตรวจสอบได้ด้วยหลักฐาน เช่น ภาพหน้าจอ รายงาน และเอกสาร ไม่ใช่การตอบแบบสอบถามอย่างเดียว

รุ่น	ปีงบประมาณ	จำนวนข้อ	หลักการให้ระดับ
CTAM V4 (22 พ.ย. 2567)	2568	14 ข้อ	แดง = ทำข้อ 1–4 ไม่ครบ / เหลือง = ทำข้อ 1–4 ครบ / เขียว = ทำข้อ 1–11 ครบ / ข้อ 12–14 เก็บข้อมูล ไม่มีผลต่อระดับ
CTAM+ (Version 25681125)	**2569**	**17 ข้อ**	**ผ่านระดับสูง = ทำครบทุกข้อ**

ตัวชี้วัดกระทรวงที่ผูกกับ CTAM+ (ปี 2569)

- **ชื่อตัวชี้วัด:** ร้อยละของหน่วยงานที่ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง (แผนที่ 9 การพัฒนาระบบบริการสุขภาพดิจิทัล โครงการที่ 21 ยกระดับความมั่นคงปลอดภัยไซเบอร์)
- **หน่วยงาน:** โรงพยาบาลศูนย์/ทั่วไป/ชุมชน ที่เปิดบริการแล้ว, สสจ., สำนักงานเขตสุขภาพที่ 1–12
- **สูตร:** (A/B) × 100 เมื่อ A = หน่วยงานที่ผ่าน CTAM+ ครบทุกข้อ, B = จำนวนหน่วยงานตามนิยาม
- **เป้าหมาย:** ปีงบประมาณ 2569 และ 2570 ร้อยละ 100 ของหน่วยงานผ่านระดับสูง โดยมีเป้าหมายรายรอบ เช่น โรงพยาบาลระดับ M1, S, A และ สสจ./สำนักงานเขต ผ่านไม่น้อยกว่าร้อยละ 80
- **มาตรการหลัก:** อบรมบุคลากร, Health CERT ประสานผ่านไลน์ `@health-cirt`, ตั้งคณะทำงานระดับจังหวัดที่ตรวจและรับรองได้เทียบเท่าเอกชน โดยมีคณะทำงานระดับเขตกำกับ และส่วนกลางสุ่มตรวจ, ส่งเสริมให้

จังหวัด/เขตดูแลกันเองด้วยซอฟต์แวร์โอเพนซอร์สและต่อรองจัดซื้อร่วมกัน

⚠️ เกณฑ์ปรับทุกปี ให้ตรวจสอบฉบับล่าสุดที่ `https://cyber.moph.go.th` และหน้าแสดงผลที่ `https://ict.moph.go.th/th/extension/1763`

6.2 ขั้นตอนการประเมินและส่งผล



▲ ภาพที่ 6.1 ขั้นตอนส่งและอนุมัติผลประเมิน CTAM+

- ผู้ประเมินเป็นได้ทั้งหน่วยงานประเมินตนเอง หรือผู้เชี่ยวชาญเป็นผู้ตรวจ (ถ้าเป็นเอกชนต้องมีใบรับรองมาตรฐาน)
- ช่องทางส่งผลเดิมคืออีเมล `cyberaudit@moph.go.th` ทุกวันพฤหัสบดี และ ศทส. ยืนยันผลทุกวันศุกร์ ปัจจุบันมี **ระบบ CTAM+ ออนไลน์** ที่เข้าสู่ระบบด้วย Username/Password หรือ **Digital ID ผ่าน ThaiD หรือ MyMOPH** ซึ่งจับคู่สิทธิ์ที่ สสจ. อนุมัติไว้ให้อัตโนมัติ
- ในเกณฑ์ V4 หน่วยงานที่ได้ระดับเขียวต้องส่ง **ยืนยันการรักษาระดับทุกไตรมาส** (ธันวาคม, มีนาคม, มิถุนายน, กันยายน) ภายในวันพฤหัสบดีสุดท้ายของเดือน แนวคิดนี้ยังใช้ได้ดีเป็นรอบทบทวนภายในของหน่วยงาน

การคิดคะแนนบน Dashboard CTAM+

ส่วน	สัดส่วน	วิธีคิด
เชิงปริมาณ (Quantitative)	70%	สัดส่วนข้อที่มีสถานะ “มี” เทียบกับ 17 ข้อ โดยแต่ละข้อเลือกสถานะ เลือกประเภทเครื่องมือ และอัปโหลดหลักฐาน
เชิงผลกระทบ (Impact)	30%	คะแนนเมื่อ **ไม่มีเหตุการณ์ภัยคุกคาม** และ **ไม่มีข้อมูลรั่วไหล** หากมีเหตุจะหักตามความรุนแรง

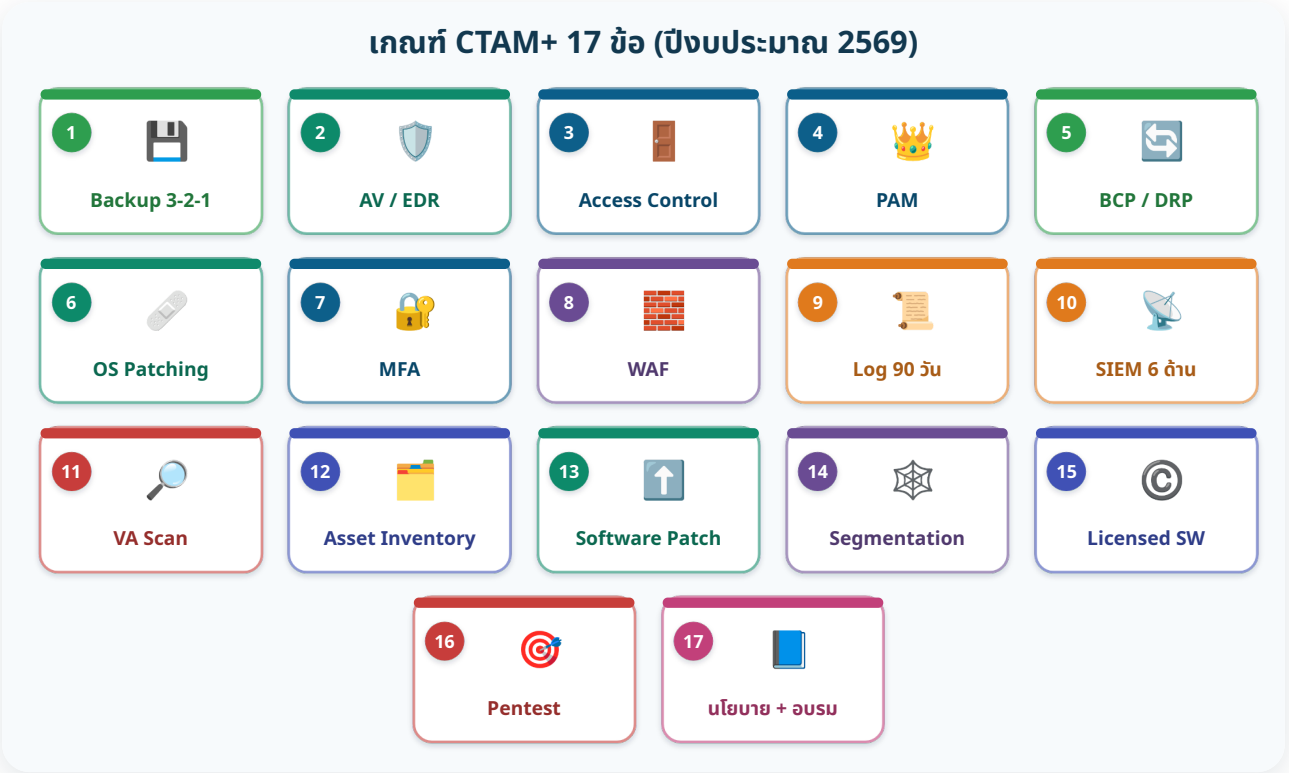
💡 หมายความว่า การผ่าน 17 ข้อยังไม่พอ หน่วยงานต้อง **ไม่เกิดเหตุ** ด้วย มาตรการทั้งหมดจึงต้องใช้งานจริง ไม่ใช่ทำเอกสารอย่างเดียว

ขั้นตอนใช้งานระบบ CTAM+ ตามบทบาท

บทบาทในระบบ	หน้าที่	ขั้นตอนหลัก
Hospital IT (ผู้เริ่มต้นเส้นทาง)	จัดทำแบบประเมินและแนบหลักฐาน	1) Login ด้วย Username/Password หรือ Digital ID (ThaiD / MyMOPH) 2) สร้างแบบประเมิน 3) ส่วนเชิงปริมาณ: เลือกสถานะ “มี/ไม่มี” ของแต่ละข้อ เลือกประเภทเครื่องมือ และอัปโหลดหลักฐาน **เป็นไฟล์ PDF** 4) ส่วนเชิงผลกระทบ: เลือกตัวเลือกเรื่องเหตุการณ์ภัยคุกคามและข้อมูลรั่วไหล (ต้องเลือกก่อนจึงอัปโหลดเอกสารได้) 5) ตรวจทานแล้วส่งให้ สสจ.
Provincial Admin / CISO จังหวัด (ด่านคัดกรอง)	ตรวจหลักฐานเบื้องต้น และอนุมัติผู้ใช้งานของหน่วยบริการในจังหวัด	ตรวจทีละข้อ → **Approve** หรือ **Return** พร้อมเหตุผลให้แก้ไข
Regional Admin (ด่านตรวจระดับเขต)	ตรวจภาพรวมของเขต	อนุมัติขั้นสุดท้าย หรือตีกลับ
Central Admin (ศทส.สป.) (จุดหมายปลายทาง)	รับรายงานและยืนยันผล	ผลขึ้น Dashboard ระดับประเทศ

💡 ศทส.สป.สธ. จัดอบรมการใช้งานระบบ CTAM+ แบบออนไลน์ (เช่น รอบวันที่ 28 เมษายน 2569) ครอบคลุม Scoring Logic, การใช้งานแต่ละระดับสิทธิ์ และช่องทาง Helpdesk ติดตามประกาศรอบอบรมกลุ่ม LINE ของระบบ และช่องทางติดต่อได้จากหนังสือแจ้งเวียนของกระทรวงและเว็บไซต์ ศทส.

6.3 เกณฑ์ CTAM+ 17 ข้อ พร้อมวิธีทำและหลักฐาน



▲ ภาพที่ 6.2 เกณฑ์ CTAM+ 17 ข้อ

ทุกข้อใช้ **ภาพหลักฐานหรือเอกสารที่บ่งชี้ในแต่ละรายการ** ได้ เอกสารที่มีคำว่า (options) คือแนะนำให้มีแต่ไม่บังคับ

ข้อ 1 Backup — การสำรองข้อมูล

เกณฑ์: สำรองข้อมูลอย่างน้อยวันละ 1 ครั้ง ย้อนหลังได้อย่างน้อย 7 วัน เก็บบน Logical หรือ Physical HDD และจัดเก็บแบบ **3-2-1**

1. สำเนาข้อมูล 3 ชุด
2. บนเทคโนโลยีต่างกัน 2 ชุด
3. แบบ Offline หรือ Offsite หรือ Cloud 1 ชุด

วิธีทำ: บทที่ 13 📋 **หลักฐาน:** (1) คู่มือปฏิบัติงาน (options) (2) รายงานผลการสำรองข้อมูล เช่น Log ของสคริปต์หรือหน้าจอโปรแกรม Backup ย้อนหลัง 7 วัน (3) รายการระบบที่สำรอง พร้อมตำแหน่งที่เก็บทั้ง 3 ชุด

ข้อ 2 Antivirus Software

เกณฑ์: ติดตั้ง Anti-Virus หรือ EDR หรือ XDR บนเครื่องของระบบที่สำคัญ และ (1) Review Alert Report (2) Update โปรแกรม (3) Schedule Update Signature **วิธีทำ:** บทที่ 10 📋 **หลักฐาน:** คู่มือติดตั้ง (options), ภาพหน้าจอ Console แสดงเครื่องที่ติดตั้งและสถานะอัปเดต, รายการเครื่องสำคัญที่ติดตั้ง, รายงาน Alert รายเดือน

ข้อ 3 Access Control (Public และ Private) — 12 เงื่อนไข

#	เงื่อนไข	ตัวอย่างหลักฐาน
1	เปิดพอร์ตจากภายนอกเท่าที่จำเป็น เช่น HTTPS 443	ภาพ Policy ขาเข้าบน Firewall, ผลสแกนพอร์ตจากภายนอก
2	IP Address Filter เช่น จำกัดตามประเทศ (Geo-IP)	ภาพ Geo Policy อนุญาตเฉพาะประเทศไทย
3	เปิด IDS/IPS	ภาพ Security Profile IPS ที่ผูกกับ Policy
4	VPN (IPsec/SSL) สำหรับเข้าถึงระบบภายใน	ภาพการตั้งค่า VPN
5	แบ่งโซนเครือข่าย และมี Firewall กั้นระหว่างโซนสำคัญ	Network Diagram, ภาพ Interface/Zone
6	สิทธิ์ผู้ใช้เท่าที่จำเป็น (Role/Group Based)	ตารางสิทธิ์
7	Password Policy ยาวอย่างน้อย 12 ตัวอักษร และเก็บแบบ Hash	ภาพ GPO/Password Policy
8	Time Sync	ภาพการตั้งค่า NTP บน Firewall/Server
9	เปลี่ยนบัญชี Default	ภาพรายชื่อบัญชีที่ไม่มี admin เดิม
10	ทบทวนบัญชีสิทธิ์สูง	บันทึกการทบทวนพร้อมวันที่และผู้ลงนาม
11	ทบทวน Log การเข้าถึง	รายงานสรุป Log รายเดือน
12	Feeds IOC (Option)	ภาพ External Threat Feed เช่น NCSA Blacklist

วิธีทำ: บทที่ 8, 9, 15

ข้อ 4 Privileged Access Management (PAM)

เกณฑ์: (1) Disable บัญชี Administrator/Root/Admin เดิม (2) Role-based access (3) มี Access Rights Matrix (4) Password อย่างน้อย 12 ตัว ผสมตัวพิมพ์ใหญ่ เล็ก ตัวเลข อักขระพิเศษ และเก็บแบบ Hash (5) Session Timeout (6) ทบทวนบัญชีสิทธิ์สูง (7) ทบทวนกิจกรรมผู้ใช้ **วิธีทำ:** บทที่ 8 📋 **หลักฐาน:** ตารางกำหนดสิทธิ์ระบบสำคัญเทียบกับระบบจริง, ภาพหน้าจอบัญชีที่ถูก Disable, ภาพการตั้ง Timeout

ข้อ 5 BCP และ DRP

เกณฑ์: ทดสอบ BCP และ DRP อย่างน้อยปีละ 1 ครั้ง และจัดทำรายงาน ครอบคลุม (1) Risk Management (2) Resource Management (3) Business Continuity Planning (4) Testing (5) Review & Update **วิธีทำ:** บทที่ 13 📋 **หลักฐาน:** เอกสาร BCP, เอกสาร DRP, รายงานผลการทดสอบ (วันเวลา ผู้เข้าร่วม สถานการณ์ เวลาที่ใช้กู้คืนจริงเทียบ RTO ปัญหาที่พบ และการปรับปรุง)

ข้อ 6 OS Patching

เกณฑ์: อัปเดต Security Patch ได้แก่ (1) Firewall Firmware (2) Operating System (3) Application (4) Software (5) Change Management **วิธีทำ:** บทที่ 10 📋 **หลักฐาน:** ภาพ Windows Update/WSUS, `apt` history, เวอร์ชัน Firmware Firewall, แบบบันทึกการเปลี่ยนแปลง (Change Request)

ข้อ 7 Multi-Factor Authentication (2FA)

เกณฑ์: ผู้ดูแลระบบต้องใช้ MFA อย่างน้อยกับ (1) VPN (2) อุปกรณ์เครือข่าย (3) อุปกรณ์ Security (4) Hypervisor (5) Operating System **วิธีทำ:** บทที่ 8 📋 **หลักฐาน:** ภาพหน้าจอการ Login ที่ขอรหัส OTP ของแต่ละระบบ, รายละเอียดระบบที่ใช้

ข้อ 8 Web Application Firewall (WAF)

เกณฑ์: ใช้ WAF ป้องกันการโจมตีตาม OWASP Top 10 และ (1) Review Attack Report (2) เพิ่ม Source IP Blocklist **วิธีทำ:** บทที่ 11 📋 **หลักฐาน:** คู่มือตั้งค่า (options), ภาพการติดตั้ง (เช่น Nginx + ModSecurity + OWASP CRS หรือ Cloudflare WAF), รายงานการโจมตีที่ถูกบล็อก

ข้อ 9 Log Management

เกณฑ์: เก็บ Log ตาม พ.ร.บ.คอมพิวเตอร์ อย่างน้อย 90 วัน ได้แก่ System, Access, Authentication, Authorization, Error และ Application Logs **วิธีทำ:** บทที่ 14 📋 **หลักฐาน:** คู่มือตั้งค่า (options), **รายงาน Log ย้อนหลังวันที่ 90** (เช่น ภาพการค้นหา Log ของวันที่ 90 วันก่อนหน้า)

ข้อ 10 SIEM

เกณฑ์: มี SIEM หรือระบบวิเคราะห์ภัยคุกคาม ที่ตรวจจับได้อย่างน้อย 6 ด้าน

1. การบุกรุก, Brute Force Login, Port Scan
2. Malware/Virus
3. การเชื่อมต่อ IP ใน Blacklist
4. Unauthorized Access
5. DDoS ทั้งภายนอกและภายใน
6. Data Breach / การเข้าถึงข้อมูลสำคัญโดยไม่ได้รับอนุญาต

วิธีทำ: บทที่ 14 (Wazuh) และ 15 (NCSA Blacklist) 📋 **หลักฐาน:** รายละเอียดระบบ SIEM และอุปกรณ์ที่ส่ง Log, คู่มือตั้งค่า, ภาพ Alert ที่ตรวจจับได้ทั้ง 6 ด้าน

ข้อ 11 Vulnerability Assessment (VA Scan)

เกณฑ์: สแกนช่องโหว่อย่างน้อยปีละ 1 ครั้ง แก้ไขโดยเริ่มจาก Critical และ High (1) Review รายงาน (2) จัดลำดับ Critical/High/Medium/Low และกำหนดเวลาแก้ (3) จัดการความเสี่ยงด้วย Accept/Avoid/Mitigate/Transfer **วิธีทำ:** บทที่ 16 📋 **หลักฐาน:** รายงาน VA ที่มีบทสรุปผู้บริหาร รายละเอียดช่องโหว่ และแนวทางแก้ไข, ทะเบียนติดตามการแก้ไข

ข้อ 12 Information Asset Inventory and System Termination

เกณฑ์: สำรวจและทำทะเบียนระบบงานสารสนเทศทั้งหมด และ **ปิดระบบที่ไม่ใช้แล้ว วิธีทำ:** บทที่ 7 📋 **หลักฐาน:** ทะเบียนระบบงาน, รายละเอียดสถานะการใช้งาน, หลักฐานการปิดระบบ (เช่น บันทึกขออนุมัติปิด และภาพหน้าจอเครื่องที่

ปิดแล้ว)

ข้อ 13 Software Update / Software Patching

เกณฑ์: อัปเดตซอฟต์แวร์หรือแพตช์ความปลอดภัยของระบบสำคัญ เช่น HIS 📋 **หลักฐาน:** คู่มือ (options), รายงานการอัปเดต เช่น เวอร์ชัน HIS ก่อนและหลัง วันที่อัปเดต

ข้อ 14 Network Segmentation

เกณฑ์: แบ่งเครือข่ายระบบสำคัญออกจากเครือข่ายอื่น เช่น Guest และ User Network และใช้ Firewall หรือ ACL ควบคุมระหว่าง Segment **วิธีทำ:** บทที่ 9 📋 **หลักฐาน:** Network Diagram ที่แสดงการแบ่ง, การตั้งค่า Firewall/ACL ระหว่าง Segment

ข้อ 15 Licensed Software (Software Asset Management)

เกณฑ์: ใช้ซอฟต์แวร์ถูกลิขสิทธิ์สำหรับระบบงานและเครื่องสำคัญ มีทะเบียนซอฟต์แวร์และตรวจสถานะ License 📋 **หลักฐาน:** Software Asset Inventory, หลักฐานการซื้อ/License, รายงานตรวจการใช้ซอฟต์แวร์

> 💡 ซอฟต์แวร์โอเพนซอร์สที่ใช้ตามสัญญาอนุญาต (เช่น LibreOffice, Ubuntu, Wazuh) ถือว่าถูกลิขสิทธิ์ ให้บันทึกชื่อ License ในทะเบียนด้วย

ข้อ 16 Penetration Testing

เกณฑ์: ทดสอบเจาะระบบ Web Application หรือระบบอื่นแบบ Gray box หรือ Black box อย่างน้อยปีละ 1 ครั้ง แก้ไขจน **ไม่มีช่องโหว่ระดับ Critical และ High** และไม่มีช่องโหว่ตาม OWASP Top 10 **วิธีทำ:** บทที่ 16 (รวมการขอรับบริการจาก สกมช.) 📋 **หลักฐาน:** รายงาน Pentest ที่มีบทสรุปผู้บริหาร รายละเอียดช่องโหว่ และแนวทางแก้ไข, รายงานการทดสอบซ้ำ (Retest)

ข้อ 17 Cybersecurity & PDPA Policy and Personnel Development

เกณฑ์: มีนโยบายไซเบอร์และ PDPA เป็นลายลักษณ์อักษรและประกาศใช้ และอบรมบุคลากรอย่างน้อยปีละ 1 ครั้ง **วิธีทำ:** บทที่ 4, 5, 18 📋 **หลักฐาน:** เอกสารนโยบายไซเบอร์, เอกสารนโยบาย PDPA, หลักฐานการอบรม (กำหนดการ รายชื่อผู้เข้าร่วม ภาพกิจกรรม)

6.4 การจัดเก็บหลักฐานให้ตรวจง่าย

โครงสร้างโฟลเดอร์ที่แนะนำ

```
CTAM+2569_<รหัสหน่วยบริการ>_<ชื่อหน่วยงาน>/
├── 00_สรุปผลประเมินตนเอง.pdf
├── 01_Backup/
```

```
│   ├── 01-1_คู่มือการสำรองข้อมูล.pdf
│   ├── 01-2_รายงานผลสำรอง_7วันล่าสุด.pdf
│   └── 01-3_รายการระบบที่สำรอง_3-2-1.xlsx
├── 02_Antivirus/
├── 03_AccessControl/
│   ├── 03-01_OpenPort.png
│   ├── 03-02_GeoIP.png
│   └── ... (ครบ 12 เงื่อนไข)
├── ...
└── 17_Policy_Training/
```

หลักการถ่ายภาพหน้าจอเป็นหลักฐาน

1. ให้เห็น **วันที่และเวลา** บนหน้าจอเสมอ (นาฬิกา Taskbar หรือคำสั่ง `date`)
2. ให้เห็น **ชื่ออุปกรณ์หรือ Hostname** เพื่อยืนยันว่าเป็นระบบของหน่วยงาน
3. **ปิดบังข้อมูลอ่อนไหว** ได้แก่ IP สาธารณะ รหัสผ่าน Token และข้อมูลผู้ป่วย ด้วยแถบทึบ (ไม่ใช่การเบลอที่ถอดกลับได้)
4. เขียนคำอธิบายใต้ภาพว่าภาพนี้ตอบเงื่อนไขข้อใด
5. รวมเป็นไฟล์ PDF ต่อข้อ ตั้งชื่อตามเลขข้อ

⚠️ ไฟล์หลักฐานมีรายละเอียดโครงสร้างเครือข่ายของหน่วยงาน ถือเป็นข้อมูลลับ ห้ามแชร์ในกลุ่มสาธารณะ และควรส่งผ่านช่องทางที่ระบบ CTAM+ กำหนดเท่านั้น

6.5 แผนเตรียมตัว 90 วัน

ช่วง	งาน	ผู้รับผิดชอบ
วันที่ 1–7	ผู้บริหารประกาศนโยบาย แต่งตั้งทีม และ Gap Analysis 17 ข้อ (ใช้ Checklist ภาคผนวก ก)	CEO, CIO, CISO
วันที่ 8–30	งานไม่ใช้งบ: เปลี่ยนรหัส Default, Disable admin, Password Policy 12 ตัว, MFA (Google Authenticator/FortiToken ฟรี), ปิดพอร์ตและระบบที่ไม่ใช้, ตั้ง Time Sync, เริ่ม Backup อัตโนมัติ	ทีม IT
วันที่ 31–60	ติดตั้ง Wazuh + ClamAV/Defender, เก็บ Log, ตั้ง WAF, แบ่ง VLAN, เปิด Threat Feed, ทำ VA Scan รอบแรก	ทีม IT + ทีมจังหวัด
วันที่ 61–75	แก้ไขช่องโหว่ Critical/High, ทดสอบ BCP/DRP สถานการณ์ Ransomware, อบรมบุคลากร	ทุกฝ่าย
วันที่ 76–90	Log ครบ 90 วัน, รวบรวมหลักฐาน, ประเมินตนเอง, ให้ทีม สสจ. ตรวจทานก่อนส่งจริง	CISO, สสจ.

💡 เริ่มเก็บ Log ให้เร็วที่สุด เพราะข้อ 9 ต้องการหลักฐาน **Log ย้อนหลัง 90 วัน** ซึ่งเร่งไม่ได้

6.6 ข้อผิดพลาดที่พบบ่อยเมื่อส่งผล

ข้อผิดพลาด	วิธีแก้
ส่งภาพ Backup วันเดียว	ส่งรายงานต่อเนื่อง 7 วัน และแสดงสำเนาชุดที่ 3 แบบ Offline
ภาพหน้าจอไม่มีวันที่	ถ่ายใหม่ให้เห็นวันเวลา
MFA ทำเฉพาะ VPN	ต้องครอบคลุมอุปกรณ์เครือข่าย อุปกรณ์ Security, Hypervisor และ OS ของผู้ดูแล
Log ไม่ถึง 90 วัน	ตั้งค่า Retention และรอจนครบ ห้ามแก้วันที่
SIEM แสดงเพียงหน้า Dashboard	แสดง Alert จริงทั้ง 6 ด้าน (ใช้ Lab ในบทที่ 14 สร้างเหตุทดสอบ)
รายงาน VA/Pentest ยังมี Critical/High ค้าง	แนบหลักฐานการแก้ไขและผล Retest หรือเอกสารยอมรับความเสี่ยงที่ผู้บริหารลงนาม (สำหรับ VA)
เปิดเผย IP จริงและรหัสผ่านในหลักฐาน	ปิดบังก่อนส่งทุกครั้ง

6.7 บทบาทของ สสจ. ในการขับเคลื่อน CTAM+ ระดับจังหวัด

สสจ. อยู่ในตำแหน่ง “ด่านคัดกรอง” และ “พี่เลี้ยง” ของหน่วยบริการ ตัวอย่างการดำเนินงานที่ได้ผล

1. ตั้งคณะทำงานไซเบอร์ระดับจังหวัด รวมนักวิชาการคอมพิวเตอร์จากทุกโรงพยาบาล
2. จัดทำ **ระบบกลางแบบโอเพนซอร์ส** ให้โรงพยาบาลใช้ร่วม เช่น Wazuh Manager ระดับจังหวัด และ NCSA Blacklist Dashboard (บทที่ 15) เพื่อลดภาระของโรงพยาบาลชุมชน
3. ทำ Template เอกสาร (นโยบาย, BCP/DRP, Access Matrix) ให้แต่ละแห่งแก้ไขต่อ
4. ตรวจเยี่ยมแบบ War Room ช่วยแก้ปัญหาหน้างานร่วมกัน
5. ติดตามผลรายสัปดาห์ด้วยตารางสรุปสถานะ 17 ข้อของทุกหน่วยงาน

⭐ สรุปท้ายบท

- CTAM+ ปี 2569 มี 17 ข้อ และต้องผ่านครบทุกข้อจึงได้ระดับสูง
- คะแนน Dashboard แบ่งเป็นเชิงปริมาณ 70% และเชิงผลกระทบ 30% (ไม่มีเหตุ ไม่มีข้อมูลรั่ว)
- เส้นทางส่งผล: โรงพยาบาล → สสจ. → เขต → ศทส.
- เริ่มจากงานที่ไม่ใช้งบ และเริ่มเก็บ Log ให้เร็วที่สุด

✏️ คำถามทบทวน

1. CTAM+ ปี 2569 มีกี่ข้อ และคะแนน Dashboard แบ่งสัดส่วนอย่างไร
2. ผลประเมิน CTAM+ ของโรงพยาบาลส่งผ่านใครบ้างก่อนถึงส่วนกลาง
3. หน่วยงานมีงบประมาณจำกัดมาก ควรเริ่มทำข้อใดของ CTAM+ ก่อน
4. ใช้ Checklist ภาคผนวก ก ตรวจหลักฐานของหน่วยงาน แล้วระบุ 3 ข้อที่ยังไม่มีหลักฐาน พร้อมผู้รับผิดชอบและกำหนดเสร็จ

ภาค 3

ลงมือป้องกัน

Hands-on Protection

7 บัญชีทรัพย์สินและการบริหารความเสี่ยงไซเบอร์

8 การยืนยันตัวตนและการจัดการสิทธิ์

9 ความปลอดภัยเครือข่ายและไฟร์วอลล์

10 ความปลอดภัยเครื่องลูกข่ายและเซิร์ฟเวอร์

11 ความปลอดภัยเว็บแอปพลิเคชันและ WAF

12 ความปลอดภัยระบบ HIS และฐานข้อมูล

13 การสำรองข้อมูล 3-2-1 และ BCP/DRP



ภาค 3 · ลงมือป้องกัน บทที่ 7

บัญชีทรัพย์สินและการบริหารความเสี่ยงไซเบอร์

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ จัดทำทะเบียนทรัพย์สินสารสนเทศ (Asset Inventory) ได้ทั้งแบบมือและแบบอัตโนมัติ
- ✔️ ค้นหาและปิดระบบที่ไม่ใช้งาน (CTAM+ ข้อ 12)
- ✔️ ทำ Gap Analysis และทะเบียนความเสี่ยง (Risk Register) ที่ผู้บริหารใช้ตัดสินใจได้

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 11, 12, 15 / ตัวชี้วัด v2.1 ข้อ 6.1, 7.1, 12.1

7.1 “ป้องกันสิ่งที่ไม่รู้ว่ามีไม่ได้”

เหตุการณ์จำนวนมากเริ่มจากระบบที่ “ลืมไปแล้ว” เช่น เว็บไซต์โครงการเก่าที่ยังเปิดอยู่ เซิร์ฟเวอร์ทดสอบที่ยังมีฐานข้อมูลผู้ป่วย หรือเครื่องที่บริษัทมาติดตั้งไว้แล้วไม่มีใครดูแล

กรณีศึกษา: ไฟล์ Excel เก่าบนเว็บไซต์

หน่วยงานสาธารณสุขระดับจังหวัดแห่งหนึ่งได้รับแจ้งจาก สกมช. ว่ามีข้อมูลส่วนบุคคลรั่วไหล เมื่อตรวจสอบพบว่าเป็นไฟล์ Excel ที่เจ้าหน้าที่อัปโหลดขึ้นเว็บไซต์ของหน่วยงานโดยตรงตั้งแต่หลายปีก่อน และค้นเจอได้ผ่าน Google ด้วยคำค้นทั่วไป เช่น คำว่า “บัตรประชาชน” ร่วมกับ `site:` ชื่อโดเมน แม้เคยลบไปบางส่วนแล้วแต่ยังหลงเหลือ

มาตรการที่หน่วยงานนำมาใช้หลังเหตุการณ์

1. ลบ ย้าย หรือเข้ารหัสไฟล์ที่มีข้อมูลอ่อนไหวก่อนอัปโหลดทุกครั้ง
2. กำชับและติดตามการเผยแพร่ข้อมูลส่วนบุคคลสู่สาธารณะ
3. ตรวจสอบเว็บไซต์ ฐานข้อมูล และ API ที่เชื่อมต่อ
4. ตั้งคณะทำงานไซเบอร์ที่มีนิติกรร่วม
5. สื่อสารให้เจ้าหน้าที่ไม่เผยแพร่ข้อมูลสำคัญ

🧪 **Lab ค้นหาข้อมูลรั่วของหน่วยงานตนเอง** (ทำกับโดเมนของหน่วยงานเท่านั้น)

```
site:hospital.example filetype:xls OR filetype:xlsx OR filetype:csv
site:hospital.example "เลขประจำตัวประชาชน"
site:hospital.example intitle:"index of"
site:hospital.example inurl:backup OR inurl:.sql
```

เมื่อพบให้ลบไฟล์ออกจากเซิร์ฟเวอร์ แล้วขอให้ Google ลบผลการค้นหาผ่าน Google Search Console (Removals)

7.2 ทะเบียนทรัพย์สินสารสนเทศ

ประเภททรัพย์สินที่ต้องบันทึก

ประเภท	ตัวอย่าง
ฮาร์ดแวร์	Server, Storage, Firewall, Switch, Access Point, PC, Notebook, Printer, UPS
เครื่องมือแพทย์ที่ต่อเครือข่าย	เครื่อง X-ray/CT, Lab Analyzer, Monitor ผู้ป่วย, เครื่องวัด BP อัตโนมัติ
ซอฟต์แวร์/ระบบงาน	HIS, LIS, PACS, ระบบบัญชี, ระบบสารบรรณ, เว็บไซต์, ระบบนัดหมาย
ข้อมูล	ฐานข้อมูล HIS, ไฟล์ 43 แฟ้ม, ไฟล์ Backup, เอกสารสแกน
บริการภายนอก	Cloud, Domain, SSL Certificate, อินเทอร์เน็ต, บริษัท MA
บัญชีสิทธิ์สูง	Domain Admin, root, DBA, บัญชี Firewall

แม่แบบทะเบียน (ตัวอย่างคอลัมน์)

รหัส	ชื่อ	ประเภท	Hostname/IP	OS/เวอร์ชัน	ที่ตั้ง	เจ้าของ (Owner)	ผู้ดูแล (Custodian)	ความสำคัญ (1–5)	ข้อมูลส่วนบุคคล	Backup	AV/EDR	สถานะ	วันที่ทบทวน
SRV-001	HIS Database	Server	db-his-01 / 10.10.10.11	Ubuntu 22.04 / MariaDB 10.6	ห้อง Server	ผอ.	งาน IT	5	มี (อ่อนไหว)	3-2-1	Wazuh+ ClamAV	ใช้งาน	ม.ค. 69
WEB-003	เว็บโครงการ ปี 2560	Web	old-web	CentOS 7	VM	งานประกัน	—	1	ไม่ทราบ	ไม่มี	ไม่มี	**รอปิด**	ม.ค. 69

💡 คอลัมน์ “ความสำคัญ” ใช้จัดลำดับการสำรองข้อมูล การทำ DRP และการแพตช์ ระบบที่ได้ 5 คือระบบที่หยุดแล้วกระทบผู้ป่วยทันที

7.3 สำรวจทรัพย์สินอัตโนมัติด้วย Nmap

⚠️ สแกนเฉพาะเครือข่ายของหน่วยงานตนเอง และแจ้งผู้บริหารหรือผู้เกี่ยวข้องก่อน เพราะเครื่องมือแพทย์รุ่นเก่าบางรุ่นอาจค้างเมื่อถูกสแกน ให้เริ่มจากการสแกนแบบเบาก่อน

```
# ติดตั้ง
sudo apt install -y nmap

# 1) หาเครื่องที่เปิดอยู่ในวง (Ping scan) ไม่สแกนพอร์ต
sudo nmap -sn 10.10.10.0/24 -oG hosts-up.txt

# 2) สแกนพอร์ตยอดนิยม 100 พอร์ต พร้อมตรวจเวอร์ชันบริการ
sudo nmap -sV --top-ports 100 -T3 10.10.10.0/24 -oX scan.xml

# 3) หาเครื่องที่เปิด RDP / SMB / ฐานข้อมูล ซึ่งเสี่ยงสูง
sudo nmap -p 3389,445,3306,1433,5432,27017 --open 10.10.0.0/16 -oN risky-ports.txt
```

แปลงผลเป็น CSV เพื่อนำเข้า Excel

```
grep "Up" hosts-up.txt | awk '{print $2","$3}' | tr -d '()' > assets.csv
```

ทางเลือกอื่นที่เป็นโอเพนซอร์ส

- **Wazuh** (บทที่ 14) เก็บรายการฮาร์ดแวร์ ซอฟต์แวร์ และพอร์ตที่เปิดของทุกเครื่องที่ลง Agent ให้อัตโนมัติ (Syscollector) ใช้ทำ Software Inventory ตอบ CTAM+ ข้อ 15 ได้
- **GLPI / Snipe-IT** ระบบทะเบียนครุภัณฑ์ไอทีแบบเว็บ
- **NetBox** จัดการทะเบียน IP และแผนผังเครือข่าย

7.4 ปิดระบบที่ไม่ใช้งาน (System Termination)

ขั้นตอนที่แนะนำ

1. จากทะเบียน คัดระบบที่ไม่มีเจ้าของ ไม่มีผู้ใช้ หรือไม่ได้ Login เกิน 90 วัน
2. แจ้งเจ้าของระบบ/หัวหน้างานยืนยันว่าเลิกใช้
3. **สำรองข้อมูลครั้งสุดท้าย** แล้วเก็บตามระยะเวลาที่กฎหมายหรือระเบียบกำหนด
4. ปิดการเข้าถึงจากภายนอก (ลบ NAT/Port Forward, ลบ DNS Record)
5. ปิดเครื่อง/ลบ VM และ **ลบข้อมูลอย่างปลอดภัย** หากจำหน่ายฮาร์ดดิสก์ (เช่น `shred` หรือทำลายทางกายภาพ)
6. ยกเลิกบัญชีผู้ใช้และ License ที่เกี่ยวข้อง
7. ปรับปรุงทะเบียนและเก็บบันทึกขออนุมัติปิดระบบเป็นหลักฐาน

📋 หลักฐาน CTAM+ ข้อ 12: ทะเบียนระบบ + บันทึกขออนุมัติปิด + ภาพหน้าจอยืนยันว่าเข้าถึงไม่ได้แล้ว

7.5 Gap Analysis

ศทส.สป.สธ. แนะนำให้ทุกหน่วยประเมินสถานการณ์ปัจจุบันเทียบแนวทาง HAIT+/ISO 27001 แล้วจัดระดับความพร้อม

ระดับ	ความหมาย
A	พร้อมสูง ปฏิบัติตามแนวทางมากกว่า 66%
B	พร้อมปานกลาง 33–66%
C	พร้อมต่ำ น้อยกว่า 33%

จากนั้นกำหนด **เป้าหมาย → Gap → Action Plan/Roadmap** ในทางปฏิบัติใช้ CTAM+ 17 ข้อเป็นแกนได้ทันที (Checklist ภาคผนวก ก)

ข้อ CTAM+	สถานะปัจจุบัน	เป้าหมาย	Gap	งานที่ต้องทำ	งบประมาณ	ผู้รับผิดชอบ	กำหนดเสร็จ
1 Backup	Backup ลง NAS เครื่องเดียว	3-2-1	ไม่มีชุด Offline	ซื้อ HDD ภายนอก 2 ลูก สลับเก็บนอกอาคาร	6,000	IT	30 วัน
7 MFA	ไม่มี	MFA ทุกระบบผู้ดูแล	ทั้งหมด	เปิด FortiToken Mobile / TOTP	0	IT	14 วัน

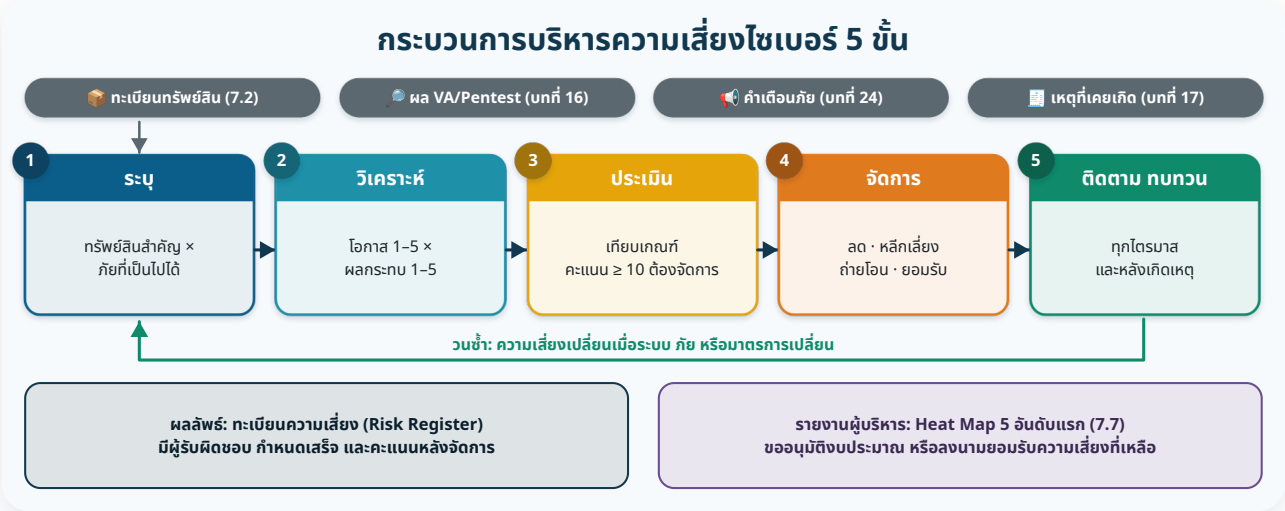
> ในการประเมินโดยบริษัทเอกชนหรือ Partner ควรเลือกผู้ที่มีใบรับรองด้านไซเบอร์ (เช่น Security+, CySA+, CISSP) ทำสัญญา DPA และ NDA และไม่ควรสำเนาเอกสารที่กระทบความมั่นคงของระบบให้ภายนอก

7.6 ทะเบียนความเสี่ยง (Risk Register)

ขั้นตอน

1. **ระบุความเสี่ยง** จากทรัพย์สินสำคัญ × ภัยคุกคามที่เป็นไปได้
2. **วิเคราะห์** โอกาส (1–5) × ผลกระทบ (1–5)
3. **ประเมิน** เทียบเกณฑ์ที่ยอมรับได้ (เช่น คะแนน ≥ 10 ต้องจัดการ)
4. **จัดการ** เลือก ลด/หลีกเลี่ยง/ถ่ายโอน/ยอมรับ และกำหนดผู้รับผิดชอบ
5. **ติดตามและทบทวน** อย่างน้อยทุกไตรมาส และหลังเกิดเหตุทุกครั้ง

ข้อมูลที่ใช้ระบุความเสี่ยงมาจากหลายบทในเล่ม ได้แก่ ทะเบียนทรัพย์สิน ผล VA คำเตือนภัย และเหตุที่เคยเกิด ผลลัพธ์ของทั้งวงจรคือทะเบียนความเสี่ยงที่มีผู้รับผิดชอบและกำหนดเสร็จ ตามภาพที่ 7.1



▲ ภาพที่ 7.1 กระบวนการบริหารความเสี่ยงไซเบอร์ 5 ขั้นและแหล่งข้อมูลนำเข้า

เกณฑ์ให้คะแนน (ตัวอย่าง)

คะแนน	โอกาส	ผลกระทบต่อบริการ	ผลกระทบต่อข้อมูล
1	ไม่น่าเกิดใน 5 ปี	ไม่กระทบบริการ	ไม่มีข้อมูลส่วนบุคคล
2	อาจเกิดใน 5 ปี	ล่าช้าเล็กน้อย < 1 ชม.	ข้อมูลภายใน ไม่ระบุตัว
3	อาจเกิดในปีนี้	หยุด 1–4 ชม.	ข้อมูลส่วนบุคคล < 100 ราย
4	เกิดปีละหลายครั้ง	หยุด 4–24 ชม.	ข้อมูลสุขภาพ 100–10,000 ราย
5	เกิดเป็นประจำ	หยุด > 24 ชม. หรือกระทบชีวิตผู้ป่วย	ข้อมูลสุขภาพ > 10,000 ราย

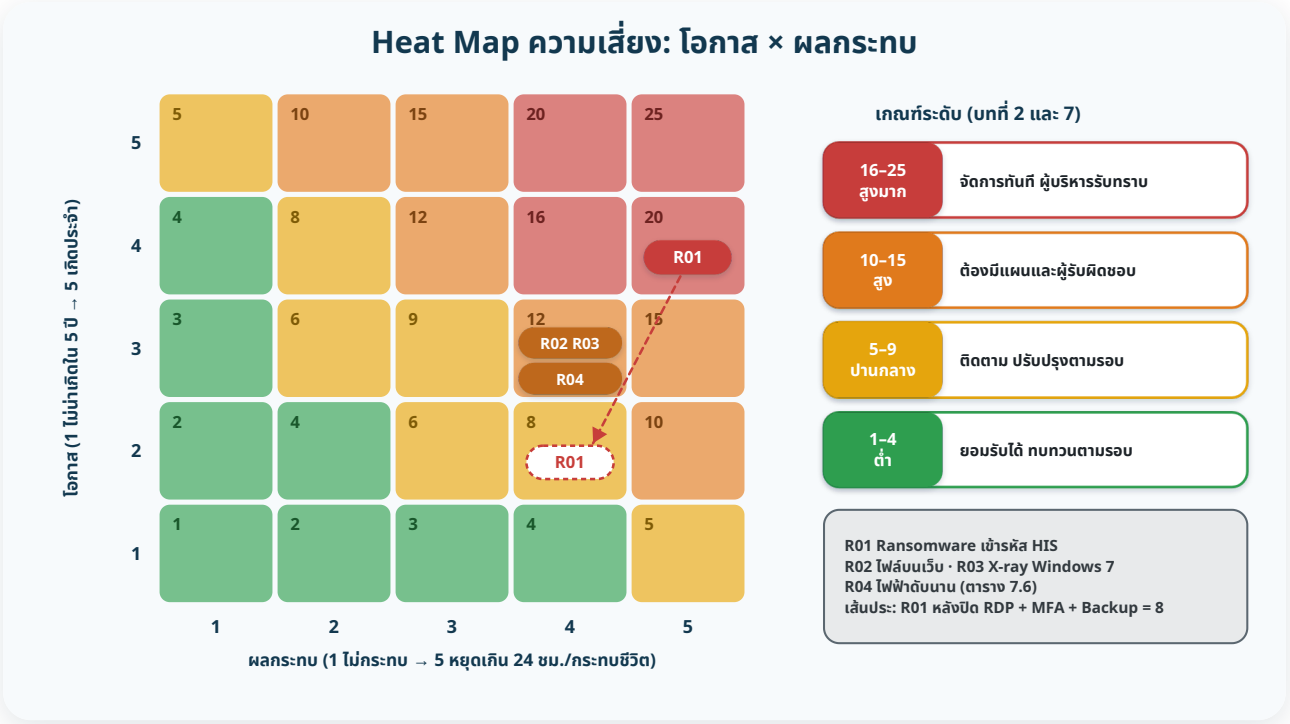
ตัวอย่างทะเบียน

รหัส	ความเสี่ยง	สาเหตุ	P	I	คะแนน	การจัดการ	มาตรการ	ผู้รับผิดชอบ	กำหนด	คะแนนหลังจัดการ
R01	Ransomware เข้ารหัส HIS	RDP เปิดสู่อินเทอร์เน็ต, ไม่มี Backup Offline	4	5	20	ลด	ปิด RDP, VPN+MFA, Backup 3-2-1, EDR	CISO	30 วัน	8
R02	ข้อมูลรั่วจากไฟล์บนเว็บ	ไม่มีขั้นตอนตรวจก่อนอัปโหลด	3	4	12	ลด	ขั้นตอนอนุมัติ, สแกน Google Dork รายเดือน	งานประชาสัมพันธ์ + IT	15 วัน	4
R03	เครื่อง X-ray ใช้ Windows 7	ผู้ผลิตไม่รองรับ OS ใหม่	3	4	12	ลด + ยอมรับส่วนที่เหลือ	แยก VLAN Medical, ห้ามออกอินเทอร์เน็ต, ผู้บริหารลงนามยอมรับ	IT + รังสี	30 วัน	6
R04	ไฟฟ้าดับนาน	UPS รองรับ 15 นาที	3	4	12	ถ่ายโอน/ลด	เชื่อม Generator, ทดสอบเดือนละครั้ง	งานซ่อมบำรุง	60 วัน	6

💡 ใช้ทะเบียนนี้เป็นเอกสารเดียวกันสำหรับ HA (ความเสี่ยงองค์กร), HAIT และหลักฐานประกอบ CTAM+ เช่น ช่องโหว่จากผล VA ตามข้อ 11 ที่ยังแก้ไม่ได้และต้องยอมรับความเสี่ยง

นำคะแนนในทะเบียนไปวางบน Heat Map ตามภาพที่ 7.2 จะเห็นทันทีว่าความเสี่ยงใดต้องจัดการก่อน และมาตรการช่วยลดคะแนนได้เท่าไร เช่น R01 ลดจาก 20 เหลือ 8 หลังปิด RDP ใช้ VPN+MFA และทำ Backup 3-2-1 ภาพนี้ใช้เป็น

หน้าแรกของรายงานผู้บริหารในหัวข้อ 7.7 ได้เลย



▲ ภาพที่ 7.2 Heat Map ความเสี่ยงจากตัวอย่างทะเบียน R01–R04

7.7 การรายงานผู้บริหาร

ผู้บริหารไม่ต้องการรายละเอียดเทคนิค ให้สรุปเป็นหน้าเดียว

1. ความเสี่ยงสูงสุด 5 อันดับ (Heat Map)
2. สิ่งที่ทำเสร็จในไตรมาส
3. สิ่งที่ต้องการให้ผู้บริหารตัดสินใจ (งบประมาณ, การยอมรับความเสี่ยง)
4. สถานะ CTAM+ 17 ข้อ (เขียว/เหลือง/แดง)

⭐ สรุปท้ายบท

- ทำทะเบียนทรัพย์สินให้ครบ รวมเครื่องมือแพทย์และบริการภายนอก
- ใช้ Nmap/Wazuh สำรวจอัตโนมัติ และปิดระบบที่ไม่ใช้อย่างเป็นขั้นตอน
- Risk Register คือเครื่องมือสื่อสารกับผู้บริหาร และใช้ร่วมกับ HA/HAIT/CTAM+ ได้

✏️ คำถามทบทวน

1. ความเสี่ยงที่มีโอกาส 4 และผลกระทบ 5 ได้คะแนนเท่าไร และต้องจัดการหรือไม่ตามเกณฑ์ตัวอย่าง
2. วิธีจัดการความเสี่ยง 4 แบบมีอะไรบ้าง ยกตัวอย่างในโรงพยาบาล
3. ผลสแกน Nmap พบเซิร์ฟเวอร์ที่ไม่มีใครรู้ว่าเป็นของงานใด ควรทำอย่างไร
4. เขียนความเสี่ยง 3 รายการของหน่วยงานลงทะเบียนความเสี่ยง ระบุคะแนนก่อนและหลังจัดการ



ภาค 3 · ลงมือป้องกัน บทที่ 8

การยืนยันตัวตนและการจัดการสิทธิ์

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ ตั้ง Password Policy ตามเกณฑ์ (อย่างน้อย 12 ตัวอักษร) บน Windows และ Linux
- ✔️ เปิดใช้ MFA สำหรับ VPN, อุปกรณ์เครือข่าย, Hypervisor และ OS
- ✔️ ทำ Access Rights Matrix และกระบวนการทบทวนสิทธิ์

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 3 (6, 7, 9, 10, 11), ข้อ 4, ข้อ 7

8.1 Identity, Authentication, Authorization

- **Identification** บอกว่าเป็นใคร (Username)
- **Authentication** พิสูจน์ว่าเป็นตัวจริง ด้วยปัจจัย 3 แบบ คือ สิ่งที่รู้ (รหัสผ่าน), สิ่งที่มี (โทรศัพท์/Token/บัตร), สิ่งที่เป็น (ลายนิ้วมือ/ใบหน้า)
- **Authorization** ให้สิทธิ์ทำอะไรได้บ้าง
- **MFA** ใช้ตั้งแต่ 2 ปัจจัยที่ต่างประเภทกัน

ตัวชี้วัด v2.1 อ้างถึงระดับความน่าเชื่อถือ **IAL** (Identity Assurance Level — การพิสูจน์ตัวตนตอนลงทะเบียน) และ **AAL** (Authenticator Assurance Level — ความแข็งแรงของการยืนยันตัวตนตอนใช้งาน) ระบบที่เข้าถึงข้อมูลผู้ป่วยจากภายนอกควรมีอย่างน้อย AAL2 คือใช้ MFA ในระบบของกระทรวงมีการใช้ **ProviderID / MOPH ID** และ **ThaiD** เป็นตัวยืนยันตัวตนกลาง ซึ่งช่วยลดการสร้างบัญชีซ้ำซ้อน

8.2 ปัญหาที่พบบ่อยในโรงพยาบาล

ปัญหา	ผลเสีย	ทางแก้
บัญชีกลาง เช่น `opd1`, `er` ใช้ร่วมกันทั้งแผนก	ตรวจย้อนหลังไม่ได้ว่าใครทำ	บัญชีรายบุคคล + Fast User Switching หรือ Login ด้วยบัตร
ไม่ปิดบัญชีคนลาออก/ย้าย	อดีตเจ้าหน้าที่ยังเข้าระบบได้	ผูกกับงานบุคคล แจ้ง IT ภายในวันที่พ้นสภาพ
รหัสผ่าน Default ของอุปกรณ์	ถูกเจาะง่ายที่สุด	เปลี่ยนทันทีหลังติดตั้ง
รหัสผ่านติดบนจอ	ใครก็ใช้ได้	อบรม, ใช้ Password Manager, Clear Desk
ผู้ดูแลใช้บัญชี Admin ทำงานประจำวัน	มัลแวร์ได้สิทธิ์สูงทันที	แยกบัญชีใช้งานปกติกับบัญชีผู้ดูแล
บริษัท MA ใช้ AnyDesk/TeamViewer เข้าได้ตลอด	ทางเข้าของผู้โจมตี	เปิดเฉพาะเมื่อขอ, ผ่าน VPN+MFA, บันทึกทุกครั้ง

8.3 Password Policy

นโยบายที่แนะนำ

- ความยาว **อย่างน้อย 12 ตัวอักษร** ผสมตัวพิมพ์ใหญ่ เล็ก ตัวเลข และอักขระพิเศษ (ตาม CTAM+)
- ห้ามใช้รหัสที่อยู่ในรายการรั่วไหลหรือเดาง่าย เช่น `P@ssw0rd123`, ชื่อโรงพยาบาล + ปี
- ล็อกบัญชีหลังใส่ผิด 5 ครั้ง เป็นเวลา 15 นาที
- เก็บรหัสผ่านแบบ Hash ในระบบ (เกณฑ์ระบุ MD5 หรือ SHA-256 แต่ในทางเทคนิค MD5 และ SHA-256 แบบไม่มี Salt ไม่ปลอดภัยสำหรับเก็บรหัสผ่านแล้ว ระบบที่พัฒนาใหม่ควรใช้ **bcrypt หรือ Argon2**)
- เทคนิค **Passphrase** ช่วยให้จำง่าย เช่น `ฝนตก3วันที่มุกดาหาร!` พิมพ์ด้วยแป้นภาษาอังกฤษ

Windows (Group Policy บน Domain Controller หรือ Local Security Policy)

`gpmc.msc` → Default Domain Policy → Computer Configuration → Policies → Windows Settings → Security Settings → Account Policies

นโยบาย	ค่าแนะนำ
Minimum password length	12 (Windows Server 2022/Windows 11 รองรับเกิน 14 เมื่อเปิด Relax minimum password length limits)
Password must meet complexity requirements	Enabled
Enforce password history	12
Account lockout threshold	5 invalid logon attempts
Account lockout duration	15 minutes

ตรวจสอบด้วยคำสั่ง

```
net accounts
# หรือบน Domain
Get-ADDefaultDomainPasswordPolicy
```

Linux (Ubuntu/Debian)

```
sudo apt install -y libpam-pwquality
sudo nano /etc/security/pwquality.conf
```

```
minlen = 12
dcredit = -1
ucredit = -1
lcredit = -1
ocredit = -1
retry = 3
enforce_for_root
```

ล็อกบัญชีเมื่อใส่ผิด (Ubuntu 22.04 ขึ้นไปใช้ `pam_faillock`)

```
sudo nano /etc/security/faillock.conf
# deny = 5
# unlock_time = 900
```

เปลี่ยนรหัส Default ของอุปกรณ์ (CTAM+ ข้อ 3.9)

รายการที่มักลืม: Firewall, Switch, Access Point, UPS Network Card, กล้อง CCTV/NVR, เครื่องพิมพ์, iLO/iDRAC ของ Server, หน้า Admin ของ NAS, MySQL `root` ไม่มีรหัส, Wazuh `admin` เริ่มต้น

8.4 Privileged Access Management (PAM)

หลักการ

1. **Disable หรือเปลี่ยนชื่อบัญชีเริ่มต้น** (Administrator, root, admin) แล้วใช้บัญชีผู้ดูแลรายบุคคล
2. **Least Privilege / Role-based Access** ให้สิทธิ์ตามบทบาท
3. **แยกบัญชี** เช่น `somchai` สำหรับงานทั่วไป และ `adm-somchai` สำหรับงานผู้ดูแล
4. **Session Timeout** หน้าจอล็อกเมื่อไม่ใช้งาน 10–15 นาที และ SSH ตัดเมื่อว่าง
5. **บันทึกและทบทวนกิจกรรม** ของบัญชีสิทธิ์สูงอย่างน้อยเดือนละครั้ง

Linux: ปิดการ Login ด้วย root และตั้ง Timeout

```
# สร้างผู้ดูแลรายบุคคล
sudo adduser adm-somchai
sudo usermod -aG sudo adm-somchai

# แก้ SSH
sudo nano /etc/ssh/sshd_config
```

```
PermitRootLogin no
PasswordAuthentication no      # ใช้ SSH Key (ทำหลังจากตั้ง Key แล้วเท่านั้น)
MaxAuthTries 3
ClientAliveInterval 300
ClientAliveCountMax 0
```

```
sudo systemctl restart ssh
# ล็อกรหัสผ่านของ root
sudo passwd -l root
# Timeout ของ Shell 15 นาที
echo 'TMOUT=900; readonly TMOUT; export TMOUT' | sudo tee /etc/profile.d/timeout.sh
```

Windows: Disable บัญชี Administrator ในเครื่อง

```
# สร้างบัญชีผู้ดูแลใหม่ก่อน แล้วจึงปิดบัญชีเดิม
net user adm-somchai * /add
net localgroup Administrators adm-somchai /add
net user Administrator /active:no
```

สำหรับเครื่องในโดเมน แนะนำ **Windows LAPS** (มีในตัว Windows ตั้งแต่อัปเดตเมษายน 2566) เพื่อสุ่มรหัสผ่าน Local Admin ของแต่ละเครื่องไม่ให้ซ้ำกัน

Access Rights Matrix (ตัวอย่าง)

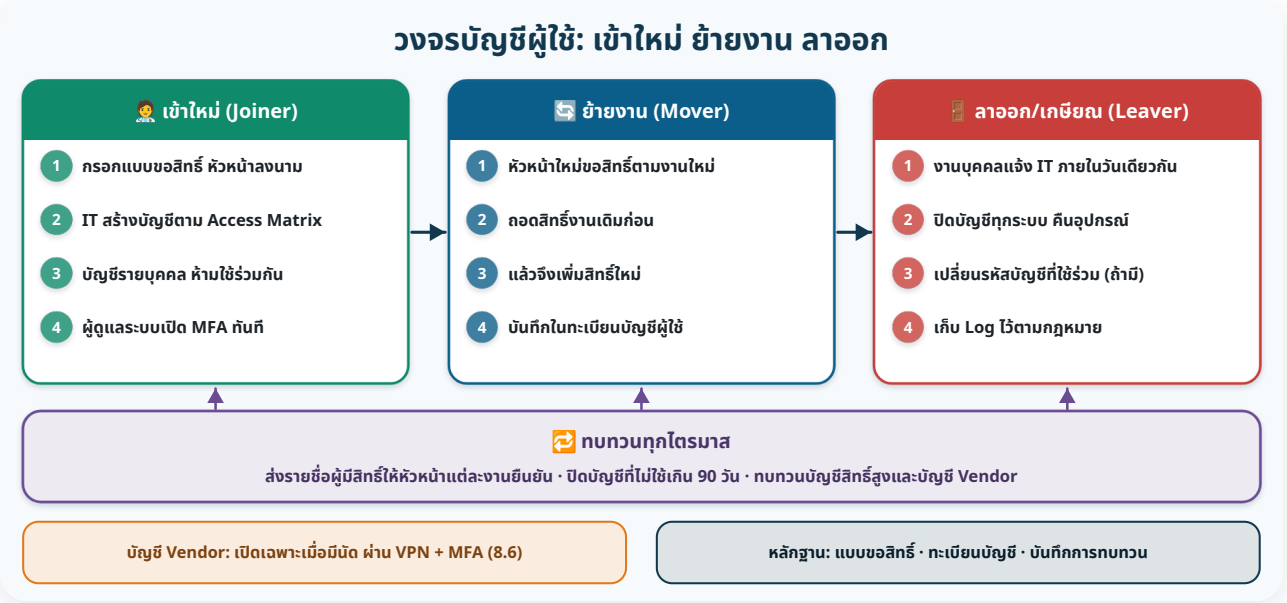
บทบาท	HIS	ฐานข้อมูล HIS	Server OS	Firewall	Wazuh	Backup	ผู้อนุมัติ
แพทย์	อ่าน/เขียน เวชระเบียน	—	—	—	—	—	หัวหน้ากลุ่มงาน
พยาบาล OPD	ซักประวัติ, คิว	—	—	—	—	—	หัวหน้าพยาบาล
เวชระเบียน	ลงทะเบียน, พิมพ์	—	—	—	—	—	หัวหน้างาน
นักวิชาการคอมพิวเตอร์	Admin HIS	DBA (อ่าน/เขียน)	sudo	อ่านอย่างเดียว	Admin	Admin	CIO
หัวหน้างาน IT	Admin HIS	DBA	sudo	Admin	Admin	Admin	CIO
บริษัท MA	—	อ่าน (เฉพาะเมื่อขอ)	—	—	—	—	CIO รายครั้ง

📋 หลักฐาน CTAM+ ข้อ 4: Matrix นี้ + ภาพหน้าจอสิทธิ์ในระบบจริงที่ตรงกัน + บันทึกการทบทวน

กระบวนการขอและทบทวนสิทธิ์

1. ผู้ใช้กรอก **แบบขอสิทธิ์** (ระบุระบบ สิทธิ์ เหตุผล) หัวหน้าหน่วยงานลงนาม
2. IT สร้างบัญชีตาม Matrix และบันทึกในทะเบียนบัญชีผู้ใช้
3. งานบุคคลแจ้ง IT เมื่อมีการย้าย/ลาออก ภายในวันทำการเดียวกัน
4. **ทบทวนทุกไตรมาส**: ส่งรายชื่อผู้มีสิทธิ์ให้หัวหน้าแต่ละงานยืนยัน และปิดบัญชีที่ไม่ใช้เกิน 90 วัน

ภาพที่ 8.1 แสดงทั้งวงจรของบัญชีผู้ใช้ จุดที่รั่วบ่อยที่สุดคือขั้นย้ายงานและลาออก เพราะต้องอาศัยงานบุคคลแจ้ง IT ภายในวันเดียวกัน ถ้าไม่มีขั้นตอนนี้ บัญชีของคนที่ออกไปแล้วจะยังใช้ได้อีกนาน



▲ ภาพที่ 8.1 วงจรบัญชีผู้ใช้ เข้าใหม่ ย้ายงาน ลาออก และทบทวนรายไตรมาส

คำสั่งช่วยหาบัญชีที่ไม่ได้ใช้นาน

```powershell
# Active Directory: ผู้ใช้ที่ไม่ Login เกิน 90 วัน
Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00 -UsersOnly |
  Select Name, LastLogonDate | Export-Csv inactive-users.csv -Encoding UTF8
```

```bash
# Linux: ดู Login ล่าสุดของทุกบัญชี
lastlog | awk 'NR==1 || /Never/ || $0 ~ /20[0-9][0-9]/'
```

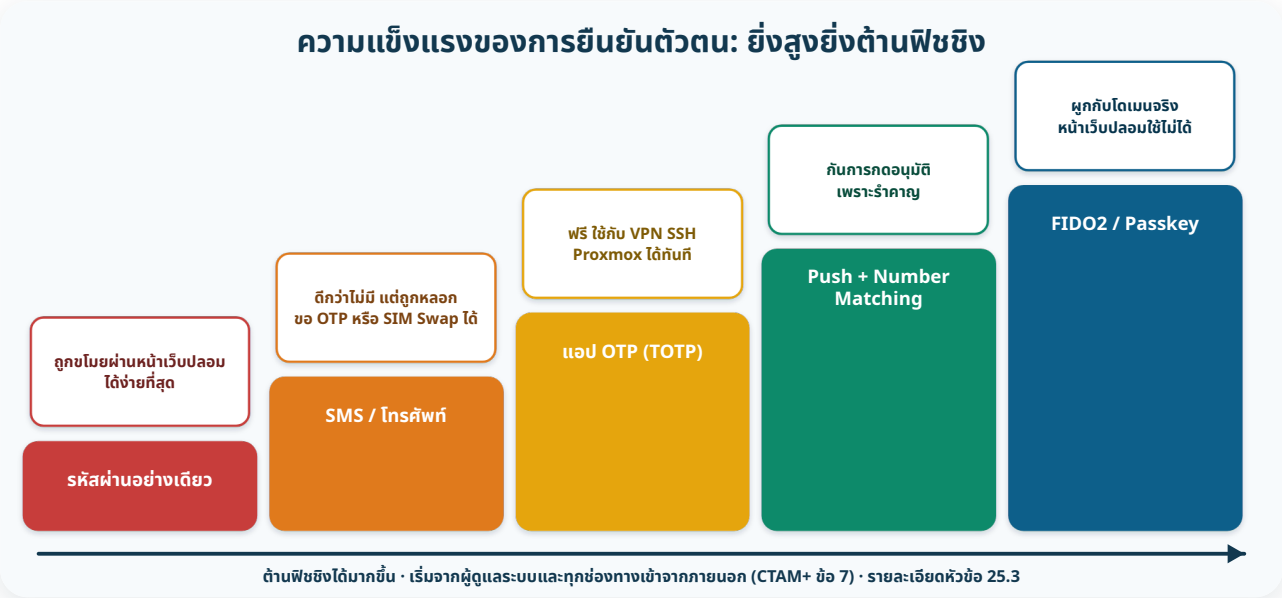
```sql
-- MySQL/MariaDB: รายชื่อบัญชีและ Host ที่อนุญาต
SELECT user, host FROM mysql.user ORDER BY user;
```

8.5 Multi-Factor Authentication (MFA)

CTAM+ ข้อ 7 กำหนดให้ผู้ดูแลระบบใช้ MFA อย่างน้อย 5 จุด

จุด	ตัวอย่างวิธีทำ (ไม่มีค่าใช้จ่ายเพิ่มหรือค่าใช้จ่ายต่ำ)
1. VPN	FortiGate: FortiToken Mobile (มีสิทธิ์ใช้ฟรีจำนวนหนึ่งกับอุปกรณ์), หรือ RADIUS + TOTP, WireGuard/OpenVPN + TOTP
2. อุปกรณ์เครือข่าย (Switch/Router)	ใช้ RADIUS/TACACS+ ที่เชื่อม MFA หรือจัดการผ่าน Jump Host ที่บังคับ MFA
3. อุปกรณ์ Security (Firewall, WAF)	FortiGate Admin + FortiToken, pfSense/OPNsense มี TOTP ในตัว
4. Hypervisor	VMware vCenter + Identity Provider, Proxmox VE มี TOTP/WebAuthn ในตัว
5. Operating System	Linux: `libpam-google-authenticator` สำหรับ SSH, Windows: Windows Hello for Business หรือผลิตภัณฑ์ MFA สำหรับ RDP

MFA แต่ละแบบต้านการโจมตีได้ไม่เท่ากัน SMS OTP ดีกว่ารหัสผ่านอย่างเดียว แต่ยังถูกหลอกให้กรอกในเว็บปลอมได้ ส่วน Passkey/FIDO2 ผูกกับโดเมนจริงจึงต้านฟิชชิงได้ (หัวข้อ 25.3) ใช้ภาพที่ 8.2 เลือกวิธีให้เหมาะกับแต่ละกลุ่ม โดยให้บัญชีผู้ดูแลระบบอยู่ขั้นสูงก่อน



▲ ภาพที่ 8.2 ระดับความแข็งแรงของการยืนยันตัวตน ยิ่งสูงยิ่งต้านฟิชชิง

Lab: เปิด MFA (TOTP) ให้ SSH บน Ubuntu

```
sudo apt install -y libpam-google-authenticator
# รันด้วยบัญชีผู้ดูแลแต่ละคน แล้วสแกน QR ด้วย Google Authenticator / Microsoft Authenticator
```

```
google-authenticator -t -d -f -r 3 -R 30 -w 3
```

แก้ `/etc/pam.d/sshd` เพิ่มบรรทัดบนสุด

```
auth required pam_google_authenticator.so
```

แก้ `/etc/ssh/sshd_config`

```
KbdInteractiveAuthentication yes
UsePAM yes
AuthenticationMethods publickey,keyboard-interactive
```

```
sudo systemctl restart ssh
```

⚠️ **เปิดหน้าต่าง SSH เดิมค้างไว้** ระหว่างทดสอบ ถ้าตั้งผิดจะได้แก้ไขได้ ไม่ถูกล็อกออกจากเครื่อง และเก็บ Emergency Scratch Codes ไว้ในที่ปลอดภัย

Lab: เปิด TOTP บน Proxmox VE

Datacenter → Permissions → Two Factor → Add → TOTP → สแกน QR → ยืนยันด้วยรหัส 6 หลัก

📋 หลักฐาน: ภาพหน้าจอ Login ที่ถามรหัส OTP ของแต่ละจุด พร้อมวันเวลา

8.6 Remote Access ของบริษัทผู้ดูแลระบบ

1. ห้ามติดตั้งโปรแกรม Remote แบบเปิดค้าง (Unattended) บนเซิร์ฟเวอร์ HIS
2. ให้บริษัทเข้าผ่าน **VPN + MFA** ด้วยบัญชีรายบุคคลของพนักงานบริษัท
3. เปิดบัญชีเฉพาะช่วงเวลาที่ขอ (Just-in-Time) และปิดเมื่อเสร็จ
4. บันทึกการเข้าใช้ (วันเวลา ผู้เข้า งานที่ทำ) และให้เจ้าหน้าที่ IT เฝ้าดู
5. มีสัญญา NDA และ DPA (บทที่ 4)

⭐ สรุปท้ายบท

- รหัสผ่านอย่างน้อย 12 ตัว ล็อกบัญชีเมื่อผิดซ้ำ เปลี่ยนรหัส Default ทุกอุปกรณ์
- Disable บัญชี admin/root เดิม ใช้บัญชีรายบุคคล และทำ Access Rights Matrix
- MFA ต้องครอบคลุม VPN, Network, Security, Hypervisor และ OS
- ทบทวนสิทธิ์ทุกไตรมาส และควบคุม Remote Access ของบริษัทภายนอก

✏️ คำถามทบทวน

1. นโยบายรหัสผ่านที่หนังสือแนะนำ กำหนดความยาวขั้นต่ำกี่ตัวอักษร และทำอะไรกับบัญชีที่ไม่ได้ใช้เกิน 90 วัน
2. CTAM+ ข้อ 7 กำหนดให้ผู้ดูแลระบบใช้ MFA อย่างน้อยกี่จุด อะไรบ้าง
3. พยาบาลย้ายจากหอผู้ป่วยไปงานการเงิน แต่ยังเข้าเมนูสั่งยาใน HIS ได้ ปัญหาเกิดจากขั้นใดในวงจรบัญชีผู้ใช้ และแก้อย่างไร
4. สำรวจว่าบัญชีผู้ดูแลระบบของหน่วยงานใช้ MFA แบบใดอยู่ และจะยกระดับขึ้นขั้นใดของภาพที่ 8.2

09

ภาค 3 · ลงมือป้องกัน บทที่ 9

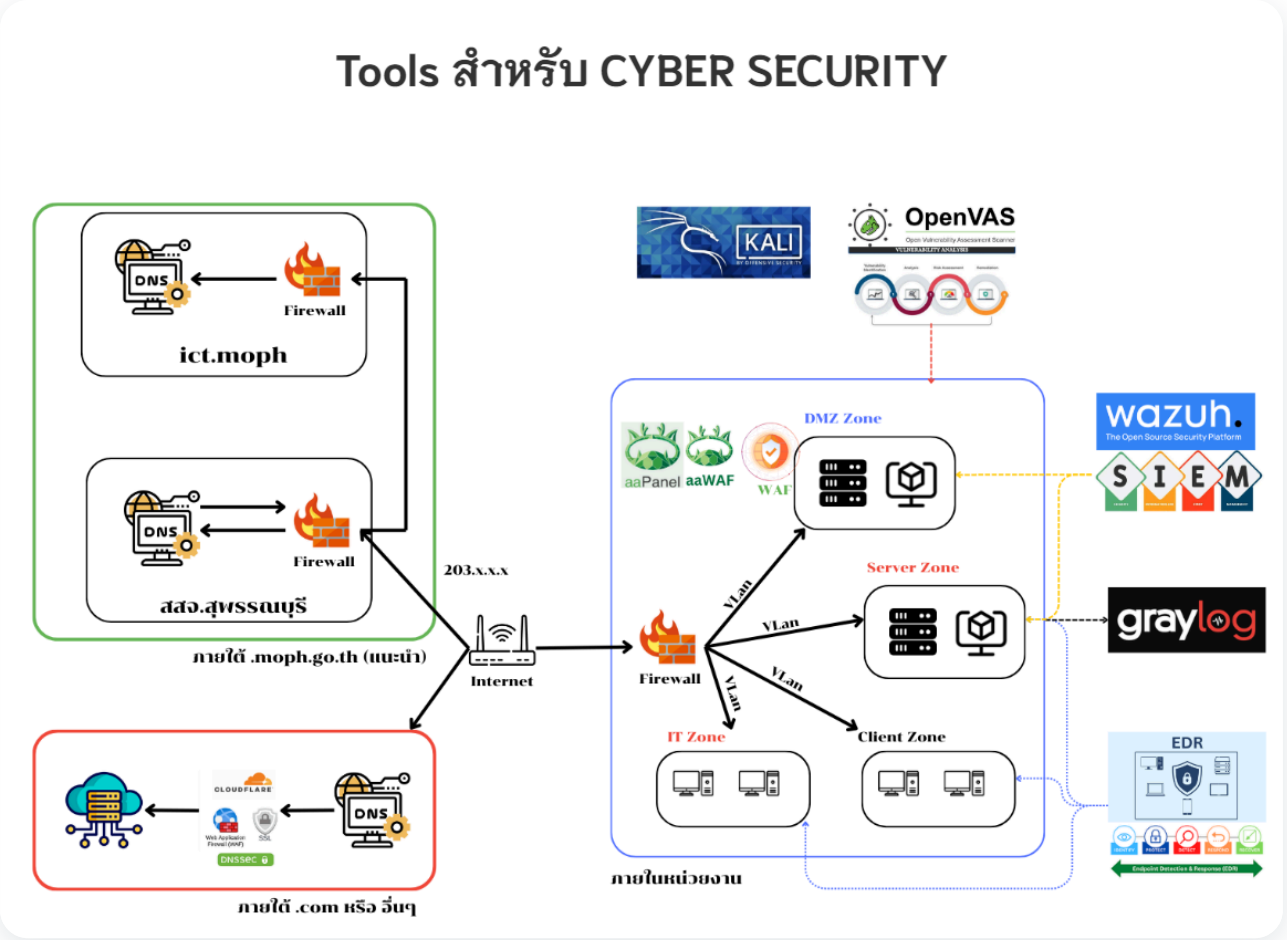
ความปลอดภัยเครือข่ายและไฟร์วอลล์

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ ออกแบบการแบ่งโซนเครือข่าย (VLAN) ของโรงพยาบาลตามเกณฑ์ได้
- ✔️ ตั้ง Firewall Policy แบบ Deny All + Whitelist และตอบ Access Control 12 ข้อของ CTAM+
- ✔️ ตั้งค่า Threat Feed, Geo-IP, VPN จำกัดประเทศ และการแจ้งเตือนบน FortiGate
- ✔️ ใช้ Cloudflare / Cloudflare Tunnel ลดการเปิดพอร์ตสู่อินเทอร์เน็ต

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 3, 14 / ตัวชี้วัด v2.1 ขั้นสูงหมวด 4–5

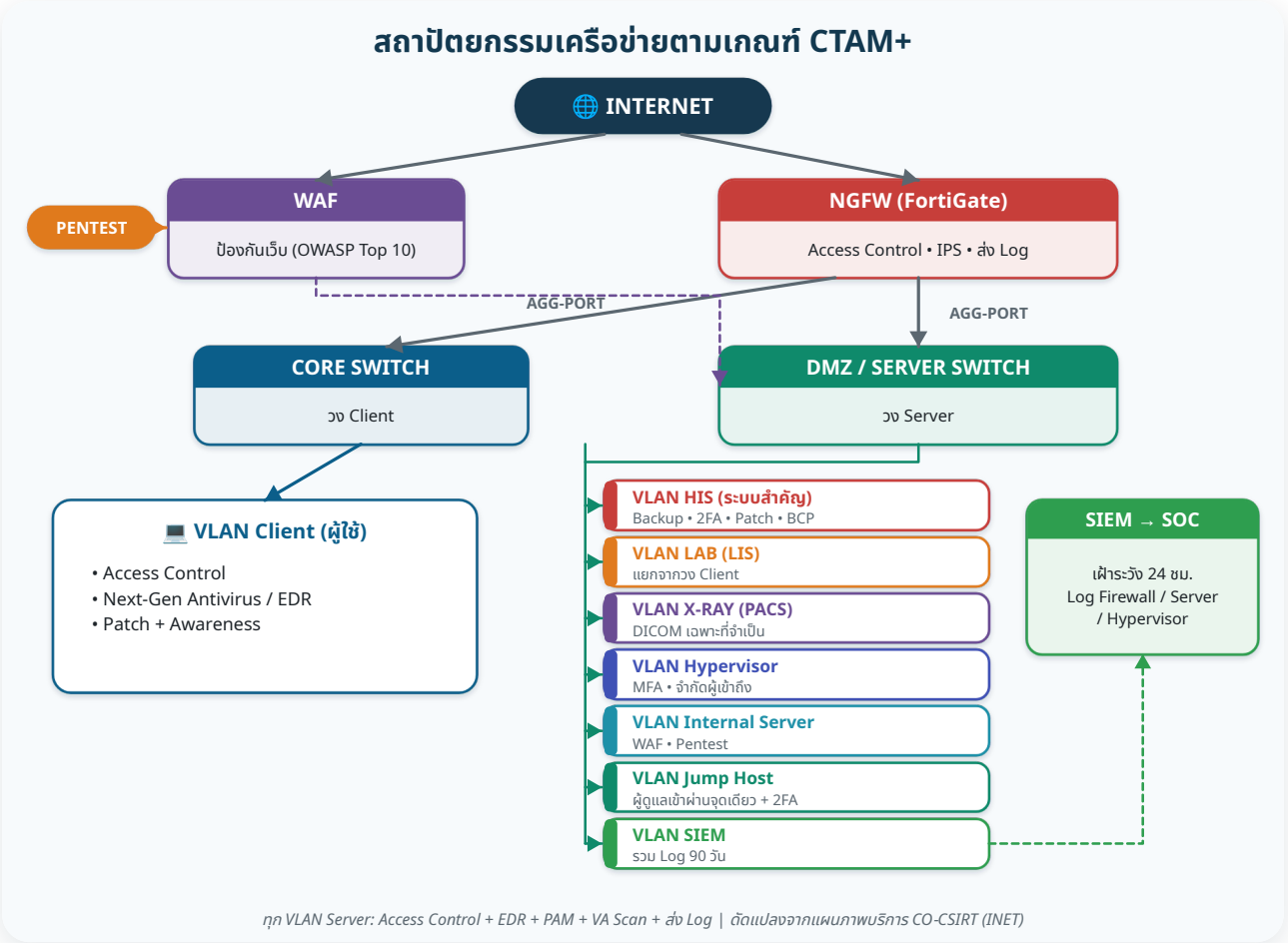
9.1 สถาปัตยกรรมอ้างอิง



▲ ภาพที่ 9.1 สถาปัตยกรรมเครื่องมือด้าน Cyber Security ในหน่วยงาน

คำอธิบายภาพที่ 9.1 ตัวอย่างการจัดวางเครื่องมือ: Firewall แบ่ง VLAN เป็น DMZ Zone, Server Zone, IT Zone และ Client Zone มี WAF ป้องกันเว็บใน DMZ, ส่ง Log เข้า SIEM (Wazuh/Graylog), สแกนช่องโหว่ด้วย OpenVAS/Kali, ใช้ EDR บนเครื่อง และแนะนำให้เว็บไซต์อยู่ภายใต้โดเมน .moph.go.th หรือใช้ Cloudflare (WAF, SSL, DNSSEC) กรณีใช้โดเมนอื่น

แผนผังตามแนวทาง CO-CSIRT (อ้างอิง ISO 27001 และ NIST CSF)



▲ ภาพที่ 9.2 สถาปัตยกรรมเครือข่ายตามเกณฑ์ CTAM+ (ดัดแปลงจากแผนภาพบริการ CO-CSIRT ของ INET)

ที่มาภาพที่ 9.2 ดัดแปลงจากตัวอย่าง Diagram ตามมาตรฐาน CO-CSIRT (บริษัท อินเทอร์เน็ตประเทศไทย จำกัด (มหาชน), เวอร์ชัน 8 ตุลาคม 2567)

ข้อสังเกตจากแผนผัง

- ระบบสำคัญแต่ละระบบ (HIS, LIS, PACS, Hypervisor) อยู่ **คนละ VLAN** และ Routing ระหว่าง VLAN ต้องผ่าน Firewall
- ทุกโซนเซิร์ฟเวอร์มีมาตรการพื้นฐานชุดเดียวกัน: Access Control, EDR, PAM, VA Scan และส่ง Log
- ระบบ HIS ที่เป็น Critical Application มีเพิ่ม: Backup, 2FA, OS Patching, BCP
- Log จาก Hypervisor, Firewall และ Server รวมศูนย์ที่ SIEM และเก็บ 90 วัน

9.2 การแบ่ง VLAN

ตัวชี้วัด v2.1 กำหนดอย่างน้อย 4 โซน และ CTAM+ ข้อ 14 กำหนดให้แยกระบบสำคัญออกจาก Guest/User

VLAN	ชื่อโซน	สมาชิก	ออกอินเทอร์เน็ต	เข้าถึงได้จาก
10	Server Private	DB HIS, LIS, PACS, AD, File Server	เฉพาะอัปเดตที่จำเป็น	Client (เฉพาะพอร์ตแอป), IT
20	Server Public / DMZ	Web, API, Reverse Proxy	ได้	อินเทอร์เน็ต (443 เท่านั้น)
30	IT / Management	เครื่องผู้ดูแล, Jump Host	ได้	—
40	Client	PC เจ้าหน้าที่	ผ่าน Web Filter	—
50	OT / Medical IoT	X-ray, CT, Lab Analyzer, Monitor	**ไม่ได้**	เฉพาะเซิร์ฟเวอร์ที่ต้องรับข้อมูล
60	Guest Wi-Fi	ผู้ป่วย ญาติ	ได้ (จำกัดแบนด์วิดท์)	**ห้ามเข้าโซนใดเลย**
70	CCTV / Building	กล้อง, NVR, ระบบลิฟต์	ไม่ได้	NVR เท่านั้น
99	Hypervisor / iLO	หน้าจัดการ VMware/Proxmox, iDRAC	ไม่ได้	IT VLAN เท่านั้น

ตัวอย่างตั้งค่า VLAN บน Switch (Cisco IOS-like)

```
vlan 10
 name SERVER-PRIVATE
vlan 40
 name CLIENT
vlan 50
 name MEDICAL-IOT
!
interface GigabitEthernet1/0/10
 description PC-OPD-01
 switchport mode access
 switchport access vlan 40
 spanning-tree portfast
!
interface GigabitEthernet1/0/48
 description UPLINK-TO-FIREWALL
 switchport mode trunk
 switchport trunk allowed vlan 10,20,30,40,50,60,70,99
```

💡 ให้ Firewall เป็น Gateway ของทุก VLAN (Router-on-a-stick หรือ Layer-3 บน Firewall) แทนการให้ Core Switch Route ระหว่าง VLAN เอง เพื่อให้ทุกการข้ามโซนถูกตรวจและบันทึก Log (ตัวชี้วัด v2.1 ข้อ 5.7)

9.3 หลักการเขียน Firewall Policy

1. **Default Deny** ปิดทุกอย่าง แล้วเปิดเฉพาะที่จำเป็น (Whitelist)

2. **ระบุให้แคบที่สุด** Source, Destination, Service ระบุชัด ไม่ใช้ `all` ถ้าไม่จำเป็น
3. **Policy บนสุดถูกอ่านก่อน** Firewall ส่วนใหญ่ (เช่น FortiGate) อ่านจากบนลงล่าง จึงวาง Policy Block Blacklist ไว้บนสุด
4. **เปิด Log ทุก Policy** และส่งไป SIEM
5. **ตั้งชื่อและคำอธิบาย** ให้รู้ว่าเปิดเพื่ออะไร ใครขอ เมื่อไร
6. **ทบทวนทุกไตรมาส** ลบ Policy ที่ไม่มี Traffic (Hit Count = 0)

ตัวอย่างตาราง Policy ของโรงพยาบาลชุมชน

#	ชื่อ	จาก	ไป	บริการ	การกระทำ
1	BLOCK-IN-BLACKLIST	WAN: IP-Blacklist + Threat Feeds	any	ALL	DENY
2	BLOCK-OUT-BLACKLIST	any internal	WAN: IP-Blacklist + Threat Feeds	ALL	DENY
3	WEB-PUBLIC	WAN (Thailand / Cloudflare IPs)	DMZ: web01	HTTPS	ACCEPT + IPS + WAF
4	VPN-ADMIN	SSL-VPN (MFA)	IT, Server Private	SSH, RDP, HTTPS	ACCEPT
5	CLIENT-TO-HIS	Client	Server Private: his-app	3306 (หรือพอร์ตแอป HIS)	ACCEPT
6	MEDICAL-TO-PACS	Medical IoT	Server Private: pacs	DICOM 104/11112	ACCEPT
7	CLIENT-INTERNET	Client	WAN	HTTP, HTTPS, DNS(ไป DNS ภายใน)	ACCEPT + Web Filter + AV + DNS Filter
8	GUEST-INTERNET	Guest	WAN	HTTP, HTTPS	ACCEPT (Traffic Shaping)
99	IMPLICIT-DENY	any	any	ALL	DENY + Log

⚠️ ห้ามเปิด RDP (3389), SMB (445), ฐานข้อมูล (3306/1433/5432) หรือหน้า Admin ของอุปกรณ์ออกสู่อินเทอร์เน็ตโดยตรงไม่ว่ากรณีใด ให้ใช้ VPN + MFA แทน

9.4 Access Control 12 ข้อของ CTAM+ บน FortiGate (ทีละขั้น)

เนื้อหาส่วนนี้เรียบเรียงจากคู่มือตั้งค่าความปลอดภัยของโรงพยาบาลสรรพสิทธิประสงค์ สำหรับโรงพยาบาลที่ใช้ Fortinet Firewall ชื่อเมนูอาจต่างกันเล็กน้อยตามเวอร์ชัน FortiOS

9.4.1 สร้างกลุ่ม IP-Blacklist และ Policy บล็อก

1. **Policy & Objects** → **Addresses** → **Create New** → **Address Group** ตั้งชื่อ `IP-Blacklist` เลือกสีแดง
2. เพิ่มสมาชิก: Create → Address → Type: Subnet → ใส่ IP ที่ได้รับแจ้ง
3. **Policy & Objects** → **Firewall Policy** → **Create New**
    - Incoming Interface: `virtual-wan-link` (หรือ WAN)
    - Outgoing Interface: โซนเซิร์ฟเวอร์
    - Source: `IP-Blacklist` / Destination: `all` / Schedule: `always` / Service: `ALL`
    - Action: **DENY** / Enable this policy
4. **ลาก Policy ขึ้นไปบนสุด** ของโซนนั้น
5. ทำ Policy เดียวกันใน **ขาออก** ด้วย (Internal → WAN, Destination = IP-Blacklist) เพื่อตัดการเชื่อมต่อของเครื่องที่ติดมัลแวร์ไปยัง C2

ครั้งต่อไปเมื่อได้รับแจ้งให้บล็อก IP เพียงเพิ่ม Address ในกลุ่ม `IP-Blacklist` ก็มีผลทันที

9.4.2 ใช้ Internet Service Database / IP Reputation

FortiGate มีฐาน IP Reputation ในตัว (กลุ่ม Malicious, Botnet, Phishing, Proxy, Tor ฯลฯ) สร้าง Policy DENY ทั้งขาเข้าและขาออกโดยเลือก Source/Destination เป็นกลุ่มเหล่านี้

9.4.3 Threat Feed อัตโนมัติ (External Connectors)

Security Fabric → **External Connectors** → **Create New** → **Threat Feeds** มี 3 ชนิด

ชนิด	ตัวอย่างแหล่ง	Refresh
IP Address	NCSA Blacklist (บทที่ 15), `https://lists.blocklist.de/lists/bots.txt`, `https://lists.blocklist.de/lists/ssh.txt`, `https://rules.emergingthreats.net/fwrules/emerging-Block-IPs.txt`, Feed ที่โรงพยาบาลแม่ข่าย/สสจ. จัดทำ	60 นาที
Domain Name	`https://hole.cert.pl/domains/domains.txt`, Feed ของเครือข่าย	60 นาที
Malware Hash	ไฟล์ MD5 ของมัลแวร์ที่กระทรวงแจ้งเตือน	60 นาที

จากนั้น

- **IP Feed:** ใส่ไว้ใน Policy BLOCK ทั้งขาเข้าและขาออก
- **Domain Feed:** System → Feature Visibility → เปิด *DNS Database* → Security Profiles → DNS Filter → เปิด *Redirect botnet C&C* และตั้ง Remote Categories ที่สร้างเป็น *Redirect to Block Portal* → ให้ FortiGate เป็น DNS Server ของ Client (Network → DNS Servers) แล้วผูก DNS Filter Profile
- **Hash Feed:** Security Profiles → AntiVirus → เปิด *Use External Malware Block List*

💡 การที่โรงพยาบาลแม่ข่ายหรือ สสจ. ทำ Feed กลางแล้วให้ทุกแห่งดึงไปใช้ ทำให้เมื่อกระทรวงประกาศเตือน ทุกแห่งได้รับการป้องกันพร้อมกันภายใน 1 ชั่วโมง

9.4.4 Geo-IP: จำกัดประเทศที่เข้าถึงบริการได้

1. Policy & Objects → Addresses → Create New → Type: **Geography** → Country: Thailand
2. ใช้ Address นี้เป็น Source ใน Policy ขาเข้า WAN → DMZ
3. ถ้าเว็บไซต์อยู่หลัง Cloudflare ให้สร้าง Address Group ของ **Cloudflare IP ranges** (`https://www.cloudflare.com/ips-v4/`) และอนุญาตเฉพาะ IP เหล่านี้เข้าเว็บ เพื่อบังคับให้ทุกคนต้องผ่าน WAF ของ Cloudflare

9.4.5 SSL-VPN จำกัดเฉพาะประเทศไทย

VPN → SSL-VPN Settings → **Limit access to specific hosts** → เลือก Address Geography Thailand → Apply และกำหนดให้ผู้ใช้ VPN เข้าได้เฉพาะพอร์ตที่จำเป็น

⚠️ ช่วงหลายปีที่ผ่านมามีช่องโหว่ร้ายแรงใน SSL-VPN ของหลายยี่ห้อที่ถูกใช้โจมตีจริง ต้องอัปเดต Firmware อย่างสม่ำเสมอ และติดตามประกาศของผู้ผลิต บางผู้ผลิตแนะนำให้ย้ายไปใช้ IPsec VPN แทน SSL-VPN

9.4.6 อัปเกรด Firmware อย่างปลอดภัย (CTAM+ ข้อ 6.1)

1. **สำรอง Config ก่อนเสมอ** (System → Configuration → Revisions พร้อมคำอธิบาย และดาวน์โหลดไฟล์ Config เก็บ)
2. ตรวจ **Upgrade Path** ที่เว็บไซต์ผู้ผลิต ห้ามข้ามเวอร์ชันที่กำหนด เช่น จาก 6.4.9 ต้องผ่าน 6.4.11 → 6.4.14 → 6.4.15
3. ดาวน์โหลด Firmware ให้ตรงรุ่น (เช่น `FGT_200E`)
4. System → Firmware → Browse → **Backup config and upgrade** ในช่วงเวลาที่กระทบผู้ใช้น้อยที่สุด
5. ทดสอบบริการสำคัญหลังอัปเกรด และบันทึกใน Change Log

9.4.7 แจ้งเตือนเมื่อมีการ Login/แก้ไข Policy/VPN เชื่อมต่อ

Security Fabric → **Automation** → Create New

Stitch	Trigger (FortiOS Event Log)	Action
แจ้ง Admin Login	Admin login successful	Webhook
แจ้งแก้ไข Config	Object attribute configured	Webhook (แนบ `%%user%%`, `%%ui%%`, `%%cfgattr%%`, `%%date%% %%time%%`)
แจ้ง VPN Up	SSL VPN tunnel up	Webhook

⚠️ คู่มือเดิมหลายฉบับใช้ **LINE Notify** ซึ่ง **ปิดให้บริการแล้วตั้งแต่ 31 มีนาคม 2568** ให้เปลี่ยน Webhook ไปที่ **LINE Messaging API** (ผ่าน LINE Official Account), **Telegram Bot API**, **Microsoft Teams/Slack Incoming Webhook** หรือส่งเข้า Wazuh/NCSA Dashboard แทน

ตัวอย่าง Webhook ไป Telegram

```
URL:     https://api.telegram.org/bot<TOKEN>/sendMessage
Method:  POST
Header:  Content-Type: application/json
Body:    {"chat_id":"<CHAT_ID>","text":"FW: %%log.logdesc%% by %%log.user%% from %%log.srcip%%"}
```

9.4.8 รายการตรวจ 12 ข้อ (ใช้เป็น Checklist)

- [ ] 1. เปิดพอร์ตขาเข้าเฉพาะที่จำเป็น (ส่วนใหญ่เหลือเพียง 443)
- [ ] 2. Geo-IP / Cloudflare-only สำหรับบริการสาธารณะ
- [ ] 3. เปิด IPS Profile ใน Policy ขาเข้าและขาออก
- [ ] 4. VPN (IPsec/SSL) + MFA สำหรับเข้าระบบภายใน
- [ ] 5. แบ่งโซนและมี Firewall กั้น (Network Diagram)
- [ ] 6. สิทธิ์ผู้ดูแล Firewall แยกตามบทบาท (Admin Profile)
- [ ] 7. Password Policy ของผู้ดูแล ≥ 12 ตัว
- [ ] 8. NTP Time Sync (System → Settings) ชี้ไป `time.navy.mi.th` หรือ `clock.nectec.or.th` หรือ NTP ภายใน
- [ ] 9. เปลี่ยน/ปิดบัญชี `admin` เริ่มต้น
- [ ] 10. ทบทวนบัญชีผู้ดูแลทุกไตรมาส
- [ ] 11. ทบทวน Log การเข้าถึงทุกเดือน
- [ ] 12. Threat Feed / IOC

9.5 Firewall โอเพนซอร์ส (กรณีไม่มีงบ)

pfSense หรือ **OPNsense** ติดตั้งบนเครื่อง PC ที่มีการ์ดแลน 2–4 พอร์ต ทำได้เกือบทุกข้อของ CTAM+

- VLAN และ Firewall Rules แบบ Default Deny
- IDS/IPS ด้วย **Suricata**
- Threat Feed ด้วยแพ็กเกจ **pfBlockerNG** (pfSense) หรือ Firewall Aliases แบบ URL Table (OPNsense)
- VPN: WireGuard / OpenVPN / IPsec พร้อม TOTP
- ส่ง Syslog ไป Wazuh

9.6 ลดพื้นที่เสี่ยงด้วย Cloudflare และ Cloudflare Tunnel

เว็บไซต์ผ่าน Cloudflare (Proxy Mode)

- เปลี่ยน Name Server ของโดเมนไปที่ Cloudflare แล้วเปิด Proxy (เมฆสีส้ม)
- ได้ WAF, ป้องกัน DDoS, SSL และ DNSSEC
- บน Firewall อนุญาตพอร์ต 443 เฉพาะ IP ของ Cloudflare (9.4.4)

Cloudflare Tunnel (`cloudflared`): ไม่ต้องเปิดพอร์ตขาเข้าเลย

`cloudflared` สร้างการเชื่อมต่อ **ขาออก** จากเซิร์ฟเวอร์ไปยัง Cloudflare ทำให้ไม่ต้องเปิด Port Forward บน Firewall และผู้โจมตีสแกนหา IP จริงไม่เจอ

```
# ติดตั้งบน Ubuntu (ดูวิธีล่าสุดที่ https://pkg.cloudflare.com)
sudo mkdir -p --mode=0755 /usr/share/keyrings
curl -fsSL https://pkg.cloudflare.com/cloudflare-main.gpg | sudo tee /usr/share/keyrings/cloudflare-main.gpg >/dev/null
echo "deb [signed-by=/usr/share/keyrings/cloudflare-main.gpg] https://pkg.cloudflare.com/cloudflared any main" | sudo tee /etc/apt/sources.list.d/cloudflared.list
sudo apt update && sudo apt install -y cloudflared

# วิธีที่ง่ายที่สุด: สร้าง Tunnel ใน Cloudflare Zero Trust Dashboard
# (Networks → Tunnels → Create) แล้วคัดลอกคำสั่งที่ได้ เช่น
sudo cloudflared service install <TUNNEL_TOKEN>
```

จากนั้นใน Dashboard เพิ่ม **Public Hostname** เช่น `appointment.example.go.th` → `http://localhost:8080`

> 💡 สำหรับหน้าผู้ดูแล (เช่น Wazuh Dashboard) ให้เพิ่ม **Cloudflare Access** บังคับ Login ด้วยอีเมลหน่วยงาน + OTP ก่อนเข้าถึง ซึ่งเป็นการทำ Zero Trust โดยไม่ต้องใช้ VPN ⚠️ ข้อมูลที่ผ่าน Cloudflare จะถูกถอดรหัสที่ Edge ของผู้ให้บริการ ควรพิจารณาตามนโยบาย PDPA และ Cloud ของหน่วยงานสำหรับระบบที่ส่งข้อมูลผู้ป่วยจำนวนมาก

9.7 Wi-Fi

- แยก SSID สำหรับเจ้าหน้าที่ (WPA2/WPA3-Enterprise + RADIUS ถ้าทำได้) และ Guest (VLAN แยก, Client Isolation)
- ห้ามแชร์รหัส Wi-Fi เจ้าหน้าที่ให้ผู้ป่วย
- ปิด WPS และเปลี่ยนรหัสผ่านหน้า Admin ของ Access Point

9.8 Network Monitoring

ติดตั้งระบบเฝ้าดูสถานะอุปกรณ์และแบนด์วิดท์ เช่น **Zabbix, LibreNMS, PRTG (รุ่นฟรี 100 sensors)** ตั้งแจ้งเตือนเมื่อ Link ล่มหรือ Traffic ผิดปกติ ซึ่งช่วยตรวจจับ DDoS และการดูดข้อมูลออก

⭐ สรุปท้ายบท

- แบ่ง VLAN อย่างน้อย Server, Client, Medical IoT, Guest และให้ Firewall คุมการข้ามโซน
- Firewall ต้อง Default Deny, Blacklist อยู่บนสุด, เปิด Log ทุก Policy
- Threat Feed + Geo-IP + VPN จำกัดประเทศ + MFA ลดการโจมตีได้มาก
- LINE Notify ปิดแล้ว ให้ย้ายการแจ้งเตือนไปช่องทางอื่น
- Cloudflare Tunnel ช่วยให้ไม่ต้องเปิดพอร์ตขาเข้า

✏️ คำถามทบทวน

1. หลัก Default Deny คืออะไร และทำไมต้องวาง Policy บล็อก Blacklist ไว้บนสุด
2. เครือข่ายโรงพยาบาลควรแบ่ง VLAN อย่างน้อยกี่โซน อะไรบ้าง
3. คู่มือเดิมให้ส่ง Alert จาก Firewall ผ่าน LINE Notify ตอนนี้ต้องทำอย่างไร
4. ทบทวน Policy ของ Firewall หลัก หากฎที่เปิด Any-Any หรือไม่ได้ใช้ และวางแผนปิด

ภาค 3 · ลงมือป้องกัน บทที่ 10

ความปลอดภัยเครื่องลูกข่ายและเซิร์ฟเวอร์

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ วางกระบวนการ Patch Management ที่มี Change Management รองรับ
- ✔️ ติดตั้งและดูแล Antivirus/EDR ทั้ง Windows และ Linux (ClamAV)
- ✔️ Hardening Windows และ Linux ขั้นพื้นฐาน
- ✔️ จัดการเครื่องรุ่นเก่าและเครื่องมือแพทย์ที่แพตช์ไม่ได้

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 2, 6, 13, 15 / ตัวชี้วัด v2.1 ขั้นต่ำข้อ 2 และขั้นสูงหมวด 6–7

10.1 Patch Management

ทำไมต้องรีบแพตช์

ผู้โจมตีมักใช้ช่องโหว่ภายในไม่กี่วันหลังผู้ผลิตประกาศ ส่วนหน่วยงานจำนวนมากแพตช์ช้ากว่านั้นหลายเดือน ช่องว่างนี้คือโอกาสของผู้โจมตี

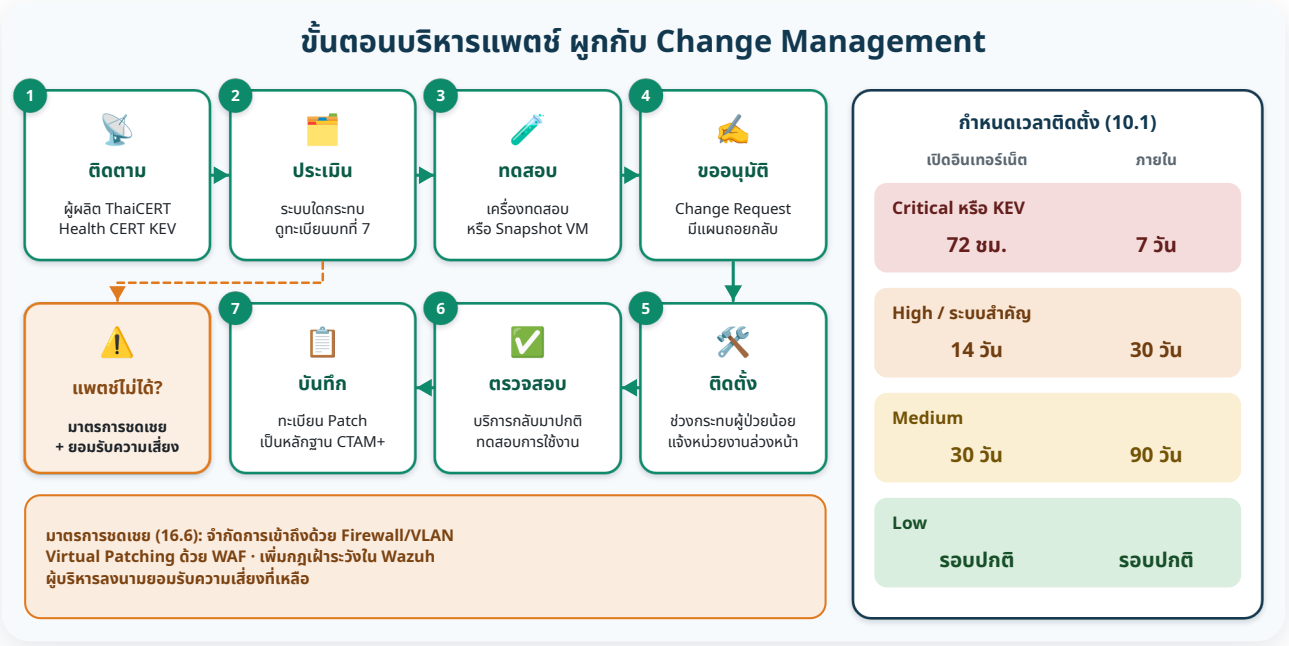
กรอบเวลาที่แนะนำ

ความรุนแรง (CVSS)	ระบบเปิดสู่อินเทอร์เน็ต	ระบบภายใน
Critical (9.0–10) หรืออยู่ใน CISA KEV / ประกาศเตือนของ สกมช.	ภายใน 72 ชั่วโมง	ภายใน 7 วัน
High (7.0–8.9) หรือกระทบระบบสำคัญ (HIS, PACS, Firewall)	ภายใน 14 วัน	ภายใน 30 วัน
Medium	ภายใน 30 วัน	ภายใน 90 วัน
Low	รอบปกติ	รอบปกติ

ขั้นตอน (ผูกกับ Change Management)

1. **ติดตาม** ประกาศจากผู้ผลิต, ThaiCERT, Health CERT, CISA KEV
2. **ประเมิน** ระบบใดได้รับผลกระทบ (ใช้ทะเบียนทรัพย์สินบทที่ 7)
3. **ทดสอบ** บนเครื่องทดสอบหรือ Snapshot VM ก่อน
4. **ขออนุมัติ** ผ่านแบบ Change Request (ระบบ เวลาดำเนินการ ผลกระทบ แผนถอยกลับ)
5. **ติดตั้ง** ในช่วงเวลาที่กระทบผู้ป่วยน้อย และแจ้งหน่วยงานล่วงหน้า
6. **ตรวจสอบ** บริการกลับมาปกติ
7. **บันทึก** ในทะเบียน Patch เป็นหลักฐาน

ถ้าแพตช์ไม่ทันกรอบเวลา เช่น Vendor ยังไม่รับรองเวอร์ชันใหม่ ให้ใช้มาตรการทดแทนตามทางแยกในภาพที่ 10.1 เช่น จำกัดการเข้าถึงด้วย Firewall/VLAN ทำ Virtual Patching ด้วย WAF และเพิ่มกฎเฝ้าระวังใน Wazuh แล้วให้ผู้บริหารลงนามยอมรับความเสี่ยงที่เหลือในทะเบียนความเสี่ยง (บทที่ 7)



▲ ภาพที่ 10.1 ขั้นตอนบริหารแพตช์และกรอบเวลาตามระดับความรุนแรง

ตัวอย่างแบบ Change Request

หัวข้อ	รายละเอียด
เลขที่	CR-2569-015
ระบบ	Firewall หลัก
การเปลี่ยนแปลง	อัปเกรด FortiOS 7.2.x → 7.2.y (แก้ช่องโหว่ระดับ Critical)
เหตุผล	ประกาศเตือนของผู้ผลิต และ Health CERT
ช่วงเวลา	วันเสาร์ 22:00–23:00
ผลกระทบ	อินเทอร์เน็ตและ VPN หยุด 10–15 นาที

หัวข้อ	รายละเอียด
แผนถอยกลับ	Downgrade + Restore Config Revision
ผู้ดำเนินการ / ผู้อนุมัติ	นักวิชาการคอมพิวเตอร์ / CIO
ผลการดำเนินการ	สำเร็จ ตรวจสอบ HIS, VPN, เว็บไซต์ ปกติ

Windows

- เครื่องจำนวนมาก: ใช้ **WSUS** (มีใน Windows Server) หรือ **Microsoft Intune** ถ้ามีไลเซนส์
- ตรวจสถานะ

```
Get-HotFix | Sort-Object InstalledOn -Descending | Select -First 10
# รายงานเครื่องที่ไม่ได้อัปเดตเกิน 30 วัน (บนเครื่องที่ตรวจ)
(Get-HotFix | Sort InstalledOn -Desc | Select -First 1).InstalledOn
```

Linux (Ubuntu/Debian)

```
sudo apt update && sudo apt list --upgradable
sudo apt upgrade -y
# เปิดอัปเดตความปลอดภัยอัตโนมัติ
sudo apt install -y unattended-upgrades
sudo dpkg-reconfigure -plow unattended-upgrades
# หลักฐาน: ประวัติการอัปเดต
grep " install \| upgrade " /var/log/dpkg.log | tail -20
cat /var/log/apt/history.log | tail -40
```

ระบบ HIS และซอฟต์แวร์ (CTAM+ ข้อ 13)

- ติดตามเวอร์ชันล่าสุดจากผู้พัฒนา HIS และอัปเดตตามรอบที่ผู้พัฒนาแนะนำ
- **สำรองฐานข้อมูลก่อนอัปเดตทุกครั้ง**
- บันทึกเวอร์ชันก่อน/หลัง และวันที่ เป็นหลักฐาน
- อย่าลืม Component รอบ ๆ ได้แก่ Web Server, PHP, Java, MySQL/MariaDB, OpenSSL, Browser และ Plugin

ระบบปฏิบัติการหมดอายุ (End of Life)

ระบบ	สถานะ
Windows 7 / Server 2008 R2	หมดการสนับสนุนแล้ว
Windows Server 2012 / 2012 R2	หมดการสนับสนุนแล้ว (ตุลาคม 2566)
Windows 10	หมดการสนับสนุนปกติ 14 ตุลาคม 2568 (มีโปรแกรม ESU แบบเสียค่าใช้จ่าย)
CentOS 7	หมดอายุ 30 มิถุนายน 2567 → ย้ายไป Rocky Linux / AlmaLinux / Ubuntu LTS
Ubuntu 20.04 LTS	หมดการสนับสนุนมาตรฐาน เมษายน 2568

ตัวชี้วัด v2.1 กำหนด OS ไม่เก่ากว่ารุ่นปัจจุบันเกิน 1 Generation ให้วางแผนงบประมาณเปลี่ยนเครื่อง/OS ล่วงหน้า

10.2 Antivirus / EDR / XDR

ประเภท	ทำอะไรได้	ตัวอย่าง
Antivirus	ตรวจจับจาก Signature	Microsoft Defender Antivirus, ClamAV
EDR	เฝ้าดูพฤติกรรม ตรวจจับ Ransomware แยกเครื่อง (Isolate) สืบสวนย้อนหลัง	Microsoft Defender for Endpoint, CrowdStrike, SentinelOne, Trend Micro, Sophos
XDR	รวม EDR + Network + Email + Cloud	ผลิตภัณฑ์ระดับองค์กร
HIDS โอเพนซอร์ส	ตรวจความสมบูรณ์ไฟล์ Rootcheck ตรวจ Log	Wazuh Agent (บทที่ 14)

CTAM+ ข้อ 2 ต้องการ: ติดตั้งบนเครื่องสำคัญ + Review Alert + Update โปรแกรม + ตั้งเวลาอัปเดต Signature

Microsoft Defender (มีในตัว Windows 10/11/Server 2016 ขึ้นไป)

```
# ตรวจสถานะ
Get-MpComputerStatus | Select AMRunningMode, AntivirusEnabled, RealTimeProtectionEnabled,
AntivirusSignatureLastUpdated
# อัปเดต Signature
Update-MpSignature
# เปิดการป้องกัน Ransomware (Controlled Folder Access)
Set-MpPreference -EnableControlledFolderAccess Enabled
# สแกนเต็ม
Start-MpScan -ScanType FullScan
```

💡 เปิด **Attack Surface Reduction (ASR) rules** ผ่าน Group Policy เช่น บล็อก Macro ของ Office ที่สร้าง Child Process และบล็อกไฟล์ปฏิบัติการจากอีเมล ช่วยลดการติดแรนซัมแวร์ได้มาก

ClamAV บน Linux (ฟรี)

```
# 1) ติดตั้ง
sudo apt-get update
sudo apt-get install -y clamav clamav-daemon

# 2) อัปเดตฐานข้อมูลไวรัสครั้งแรก
sudo systemctl stop clamav-freshclam
sudo freshclam
sudo systemctl start clamav-freshclam      # จากนี้อัปเดตอัตโนมัติ
sudo systemctl enable --now clamav-daemon

# 3) การสแกน
clamscan -r -i /var/www                    # แสดงเฉพาะไฟล์ที่ติดเชื้อ
clamscan -r /home | grep FOUND >> /var/log/clamav/found.txt
clamscan -r --move=/quarantine /var/www    # ย้ายไฟล์ติดเชื้อไปกักกัน
man clamscan
```

ตั้งเวลาสแกนทุกคืนด้วย cron และให้ Wazuh อ่านผล

```
sudo mkdir -p /quarantine && sudo chmod 700 /quarantine
sudo tee /etc/cron.d/clamscan-nightly >/dev/null <<'EOF'
30 1 * * * root /usr/bin/clamscan -r -i --move=/quarantine /var/www /home /tmp >>
/var/log/clamav/nightly.log 2>&1
EOF
```

💡 เว็บเซิร์ฟเวอร์ที่ใช้ PHP ควรสแกนโฟลเดอร์เว็บทุกคืน เพื่อหา **Web Shell** ที่ผู้โจมตีอัปโหลดมา (ดูบทที่ 11)

📋 หลักฐาน: ภาพ `systemctl status clamav-freshclam` ที่แสดงอัปเดตล่าสุด, รายการเครื่องที่ติดตั้ง, Log ผลสแกน, รายงาน Alert รายเดือน

10.3 Hardening ขั้นพื้นฐาน

Windows (เครื่องเจ้าหน้าที่และเซิร์ฟเวอร์)

- [ ] ผู้ใช้ทั่วไปไม่มีสิทธิ์ Local Administrator
- [ ] เปิด Windows Firewall ทุกโปรไฟล์ และปิด SMBv1

```
Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force
```

- [ ] ปิด RDP ถ้าไม่ใช้ ถ้าใช้ให้เปิด Network Level Authentication และอนุญาตเฉพาะ IT VLAN

- [ ] เปิด BitLocker บน Notebook (ป้องกันข้อมูลรั่วเมื่อเครื่องหาย)
- [ ] ปิด AutoRun/AutoPlay ของ USB และพิจารณาจำกัด USB Storage ด้วย GPO
- [ ] ตั้ง Screen Lock 10 นาที
- [ ] ตั้ง Audit Policy (Logon, Account Management, Policy Change) เพื่อส่ง Log ไป SIEM
- [ ] ถอนโปรแกรมที่ไม่ใช้และโปรแกรมละเมิดลิขสิทธิ์

Linux Server

- [ ] ติดตั้งเฉพาะแพ็กเกจที่จำเป็น และปิดบริการที่ไม่ใช้ (`systemctl list-unit-files --state=enabled`)
- [ ] SSH: ห้าม root, ใช้ Key + MFA, เปลี่ยนเฉพาะ IT VLAN เข้าได้ (บทที่ 8)
- [ ] เปิด Host Firewall

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from 10.10.30.0/24 to any port 22 proto tcp   # IT VLAN
sudo ufw allow 443/tcp
sudo ufw enable && sudo ufw status verbose
```

- [ ] ติดตั้ง **fail2ban** บล็อก Brute Force

```
sudo apt install -y fail2ban
sudo tee /etc/fail2ban/jail.local > /dev/null <<'EOF'
[sshd]
enabled  = true
maxretry = 5
findtime = 10m
bantime  = 1h
EOF
sudo systemctl restart fail2ban && sudo fail2ban-client status sshd
```

- [ ] ตั้ง Time Sync: `timedatectl set-ntp true` และตรวจด้วย `timedatectl`
- [ ] ตรวจด้วยเครื่องมือ **Lynis** (`sudo apt install lynis && sudo lynis audit system`) แล้วแก้ตามคำแนะนำ

มาตรฐานอ้างอิง

CIS Benchmarks มีแนวทาง Hardening ละเอียดสำหรับ Windows, Ubuntu, RHEL ฯลฯ ใช้ร่วมกับ Wazuh SCA (Security Configuration Assessment) ตรวจอัตโนมัติได้

10.4 เครื่องมือแพทย์และเครื่องรุ่นเก่าที่แพตช์ไม่ได้

เครื่องมือแพทย์จำนวนมากผูกกับ OS รุ่นเก่า และผู้ผลิตไม่อนุญาตให้ติดตั้ง Antivirus หรืออัปเดตเอง มาตรการชดเชย (Compensating Controls)

1. **แยก VLAN Medical IoT** และไม่ให้ออกอินเทอร์เน็ต (บทที่ 9)
2. Firewall อนุญาตเฉพาะการสื่อสารที่จำเป็น เช่น DICOM ไป PACS เท่านั้น
3. ปิดพอร์ต USB หรือควบคุมการเสียบสื่อ
4. ให้ผู้ผลิตยืนยันเป็นลายลักษณ์อักษรว่ารองรับแพตช์หรือไม่ และระยะเวลาสนับสนุน
5. บันทึกในทะเบียนความเสี่ยง และให้ผู้บริหารลงนามยอมรับความเสี่ยงส่วนที่เหลือ
6. ระบุข้อกำหนดด้าน Cybersecurity ใน **TOR จัดซื้อเครื่องมือแพทย์ใหม่** เช่น OS ที่ยังได้รับการสนับสนุน, รองรับการแพตช์อย่างน้อย 5 ปี, มี SBOM, เปลี่ยนรหัสผ่าน Default ได้

10.5 ซอฟต์แวร์ถูกลิขสิทธิ์ (CTAM+ ข้อ 15)

ซอฟต์แวร์ละเมิดลิขสิทธิ์และโปรแกรม Crack เป็นช่องทางหลักของมัลแวร์ และยังมีความเสี่ยงทางกฎหมาย

1. ทำ **Software Asset Inventory** (ใช้ Wazuh Syscollector หรือ GLPI ดึงรายการโปรแกรมจากทุกเครื่อง)
2. เทียบกับหลักฐานการซื้อ/สัญญา License
3. ถอนโปรแกรมที่ไม่มี License หรือเปลี่ยนเป็นโอเพนซอร์ส (LibreOffice, 7-Zip, GIMP, Thunderbird)
4. ตรวจทุกปี และบันทึกรายงาน

ตัวอย่างดึงรายการโปรแกรมบน Windows

```
Get-ItemProperty HKLM:\Software\Microsoft\Windows\CurrentVersion\Uninstall\*,
  HKLM:\Software\WOW6432Node\Microsoft\Windows\CurrentVersion\Uninstall\* |
  Where DisplayName | Select DisplayName, DisplayVersion, Publisher |
  Export-Csv "$env:COMPUTERNAME-software.csv" -NoTypeInformation -Encoding UTF8
```

⭐ สรุปท้ายบท

- แพตช์ตามกรอบเวลาตามความรุนแรง และบันทึกผ่าน Change Request
- ทุกเครื่องสำคัญต้องมี AV/EDR ที่อัปเดตและมีคนอ่าน Alert
- Hardening พื้นฐาน + fail2ban + Host Firewall ทำได้ฟรี
- เครื่องมือแพทย์ที่แพตช์ไม่ได้ ให้แยกเครือข่ายและบันทึกการยอมรับความเสี่ยง

✏️ คำถามทบทวน

1. ช่องโหว่ Critical ที่อยู่ใน CISA KEV บนระบบที่เปิดสู่อินเทอร์เน็ต ต้องแพตช์ภายในกี่วัน และถ้าเป็นระบบภายในล่ะ
2. ถ้าแพตช์ไม่ได้เพราะผู้ผลิตยังไม่รับรอง ต้องทำอะไรแทน
3. เครื่อง Ultrasound ใช้ Windows 7 และผู้ผลิตห้ามติดตั้งแอนติไวรัส ควรป้องกันอย่างไร
4. ตรวจ Hardening เครื่องเซิร์ฟเวอร์ 1 เครื่องตาม Checklist หัวข้อ 10.3 แล้วสรุปข้อที่ยังไม่ผ่าน



ภาค 3 · ลงมือป้องกัน บทที่ 11

ความปลอดภัยเว็บแอปพลิเคชันและ WAF

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้จัก OWASP Top 10 และช่องโหว่ที่พบบ่อยในเว็บหน่วยงานสาธารณสุข
- ✔️ ติดตั้ง WAF ด้วย Nginx + ModSecurity v3 + OWASP Core Rule Set ทีละขั้น
- ✔️ ป้องกันและแก้ไขเว็บไซต์ถูกโจมตี เช่น Web Defacement, ฝังเว็บพนัน, SQL Injection

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 8, 16 / ตัวชี้วัด v2.1 ข้อ 11.5

11.1 เว็บของหน่วยงานสาธารณสุขมีอะไรบ้าง

- เว็บไซต์ประชาสัมพันธ์ของโรงพยาบาล/สสจ./สสอ. (มักใช้ WordPress, Joomla หรือเขียนเองด้วย PHP)
- ระบบนัดหมาย จองคิว ตรวจสอบสิทธิ์
- ระบบภายในบนเว็บ เช่น ระบบรายงาน, Dashboard, ระบบลา, ระบบประเมิน
- API เชื่อมต่อกับหน่วยงานอื่น (สปสช., HDC, MOPH PHR, หมอพร้อม)
- หน้า Login ของ HIS เวอร์ชันเว็บ, PACS Viewer, Wazuh Dashboard

ทุกระบบที่เปิดสู่อินเทอร์เน็ตต้องอยู่หลัง WAF และต้องผ่าน VA/Pentest (บทที่ 16)

11.2 OWASP Top 10 (ฉบับ 2021)

อันดับ	ช่องโหว่	ตัวอย่างในหน่วยงาน	วิธีป้องกันหลัก
A01	Broken Access Control	เปลี่ยน `?hn=12345` ใน URL แล้วเห็นข้อมูลผู้ป่วยคนอื่น	ตรวจสิทธิ์ฝั่งเซิร์ฟเวอร์ทุกคำขอ
A02	Cryptographic Failures	ใช้ HTTP ธรรมดา, เก็บรหัสผ่านแบบ MD5	HTTPS ทุกหน้า, bcrypt/Argon2
A03	Injection (SQLi, XSS)	ช่องค้นหาที่ต่อ SQL ตรง ๆ	Prepared Statement, Escape Output

อันดับ	ช่องโหว่	ตัวอย่างในหน่วยงาน	วิธีป้องกันหลัก
A04	Insecure Design	ไม่มีการจำกัดจำนวนครั้ง Login	Threat Modeling, Rate Limit
A05	Security Misconfiguration	เปิด Directory Listing, แสดง Error ละเอียด	Hardening, ปิด Debug
A06	Vulnerable Components	WordPress/Plugin เก่า	อัปเดตสม่ำเสมอ
A07	Authentication Failures	ไม่มี MFA, Session ไม่หมดอายุ	MFA, Session Timeout
A08	Software & Data Integrity	ติดตั้ง Plugin จากแหล่งไม่น่าเชื่อถือ	ใช้แหล่งทางการ, ตรวจ Checksum
A09	Logging & Monitoring Failures	ไม่มี Log การ Login	ส่ง Log เข้า SIEM
A10	SSRF	ฟังก์ชันดึง URL ภายนอกที่ไม่กรอง	Allowlist ปลายทาง

> OWASP ปรับปรุงรายการเป็นระยะ ควรติดตามฉบับล่าสุดที่ `owasp.org/Top10`

11.3 แนวทางป้องกันและแก้ไขจากประกาศเตือนที่พบบ่อย

ป้องกันทั่วไปสำหรับเว็บ PHP

- ตั้งค่าใน `php.ini`

```
allow_url_fopen = Off
allow_url_include = Off
expose_php = Off
display_errors = Off
log_errors = On
disable_functions = exec,passthru,shell_exec,system,proc_open,popen
```

  (ตรวจสอบก่อนว่าแอปไม่ได้ใช้ฟังก์ชันที่ปิด)

- ตรวจสอบ Input/Output ทุกครั้ง แยกชนิดข้อมูลที่รับส่งให้ชัดเจน
- **อัปโหลดไฟล์:** อนุญาตเฉพาะนามสกุลที่กำหนด (Whitelist) ตรวจ MIME Type เปลี่ยนชื่อไฟล์ และเก็บนอก Web Root หรือห้ามรันสคริปต์ในโฟลเดอร์อัปโหลด
- ไม่ให้สิทธิ์เขียนไฟล์ซอร์สโค้ดแก่ผู้อื่น และตรวจวันที่แก้ไขไฟล์ (Date Modified) สม่ำเสมอ
- CMS (WordPress, Joomla, Drupal) และ Plugin ต้องอัปเดตทันทีเมื่อมีแพตช์ความปลอดภัย
- สแกนหา Web Shell ด้วย Antivirus (ClamAV บทที่ 10) หรือ Plugin ของ CMS
- สำรองเว็บไซต์ไว้ที่อื่นนอกเครื่องเซิร์ฟเวอร์

SQL Injection

```php
// ❌ อันตราย
$sql = "SELECT * FROM patient WHERE hn = '" . $_GET['hn'] . "'";

// ✅ ปลอดภัย: PDO Prepared Statement
$stmt = $pdo->prepare('SELECT hn, fname, lname FROM patient WHERE hn = :hn');
$stmt->bindParam(':hn', $_GET['hn'], PDO::PARAM_STR);
$stmt->execute();
```

- ทำ Allow-list Input (เช่น HN ต้องเป็นตัวเลขเท่านั้น)
- บัญชีฐานข้อมูลที่เว็บใช้ต้องมีสิทธิ์น้อยที่สุด (บทที่ 12)

ปิด Directory Listing

- **Apache:** ใน `.htaccess` หรือ `apache2.conf` เพิ่ม `Options -Indexes` แล้ว reload
- **Nginx:** ใน `server {}` ตั้ง `autoindex off;` แล้ว reload
- **IIS:** IIS Manager → เลือกเว็บ → Directory Browsing → Disable

Web Defacement และการฝังเว็บพนัน

อาการ: หน้าเว็บถูกเปลี่ยน, Google แสดงผลการค้นหาเป็นเว็บพนันภายใต้โดเมนของหน่วยงาน, มีไฟล์ `.php` แปลก ๆ หรือ Sitemap ใหม่

ขั้นตอนแก้ไข

1. ถ่ายภาพหลักฐานและสำรองสภาพปัจจุบัน (สำหรับสืบสวน) แล้ว **แจ้ง Health CERT** (บทที่ 17)
2. นำเว็บออฟไลน์หรือขึ้นหน้าปิดปรับปรุงชั่วคราว
3. หาไฟล์ที่ถูกแก้ไขล่าสุด

```bash
find /var/www -type f -mtime -14 -name "*.php" -ls
grep -rlE "eval\(base64_decode|gzinflate\(|str_rot13\(|assert\(\$_" /var/www
clamscan -r -i /var/www
```

4. ตรวจ Access Log หาจุดเข้า เช่น การอัปโหลดไฟล์ หรือ Login หน้าผู้ดูแล

```bash
grep -E "POST .*(upload|wp-login|xmlrpc|admin)" /var/log/nginx/access.log | tail -50
```

5. ติดตั้งใหม่จากซอร์สที่สะอาด หรือกู้จาก Backup ก่อนวันที่ถูกเจาะ
6. เปลี่ยนรหัสผ่านทั้งหมด (ผู้ดูแล CMS, ฐานข้อมูล, FTP/SSH) และอัปเดต CMS/Plugin
7. ปิดช่องโหว่ที่เป็นต้นเหตุ ติดตั้ง WAF
8. ขอให้ Google ลบผลการค้นหาที่ผิดผ่าน Google Search Console

9. บันทึกรายงานเหตุการณ์และบทเรียน

ใช้ HTTPS และ Security Headers

```
server {
    listen 443 ssl http2;
    server_name www.hospital.example;
    ssl_certificate     /etc/letsencrypt/live/www.hospital.example/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/www.hospital.example/privkey.pem;
    ssl_protocols TLSv1.2 TLSv1.3;
    server_tokens off;

    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;
    add_header Content-Security-Policy "default-src 'self'" always;   # ปรับตามเว็บจริง

    location ~* /(uploads|files)/.*\.php$ { deny all; }   # ห้ามรัน PHP ในโฟลเดอร์อัปโหลด
}
server { listen 80; server_name www.hospital.example; return 301 https://$host$request_uri; }
```

ใบรับรองฟรีด้วย Let's Encrypt: `sudo apt install certbot python3-certbot-nginx && sudo certbot --nginx` ตรวจคุณภาพ SSL ได้ที่ `ssllabs.com/ssltest`

11.4 Web Application Firewall (WAF)

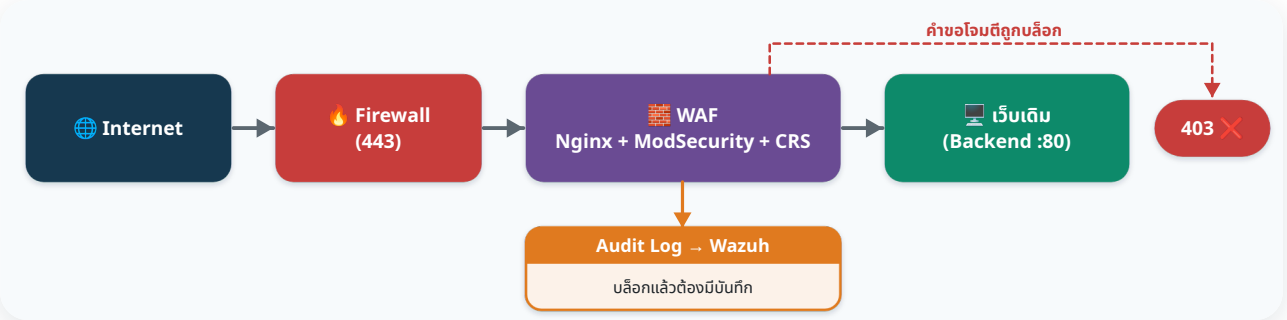
WAF ตรวจคำขอ HTTP/HTTPS ระดับแอปพลิเคชัน และบล็อกการโจมตี เช่น SQL Injection, XSS, Path Traversal, การสแกนหาช่องโหว่ และช่วยลด DDoS ระดับแอป ทำงาน 3 ส่วน คือ **Policy** (กฎ) → **Inspection** (ตรวจทุกคำขอ) → **Blocking** (บล็อก/ท้าทาย)

ทางเลือก WAF สำหรับหน่วยงาน

ทางเลือก	ค่าใช้จ่าย	เหมาะกับ
Cloudflare (Proxy) + WAF	มีแผนฟรี (กฎพื้นฐาน), แผนเสียเงินมี Managed Rules	เว็บสาธารณะทั่วไป
Nginx/Apache + ModSecurity + OWASP CRS	ฟรี	ทุกเว็บที่โฮสต์เอง
aaPanel + aaWAF / SafeLine	ฟรีหรือราคาต่ำ	ผู้ที่ต้องการหน้าจอจัดการง่าย
WAF ในตัว NGFW (เช่น FortiGate WAF Profile)	รวมในไลเซนส์บางรุ่น	ใช้ร่วมกับ Firewall ที่มีอยู่
WAF ของ GDCC (Cloud ภาครัฐ)	ตามบริการ	ระบบที่อยู่บน GDCC

11.5 Lab: ติดตั้ง Nginx + ModSecurity v3 + OWASP CRS (Reverse Proxy WAF) 🧪 LAB

แนวคิด: ตั้งเครื่อง WAF ไว้หน้าเว็บเดิม ผู้ใช้เข้าที่ WAF แล้ว WAF ส่งต่อไปยังเว็บจริง จึงป้องกันได้ทุกเว็บโดยไม่ต้องแก้เว็บต้นทาง



▲ ภาพที่ 11.1 วาง WAF แบบ Reverse Proxy หน้าเว็บเดิม

> ทดสอบกับ Ubuntu Server LTS ขึ้นไป โปรเจกต์ ModSecurity ย้ายไปอยู่ภายใต้ OWASP แล้ว (`github.com/owasp-modsecurity`) คำสั่งด้านล่างใช้ Repository ใหม่

ขั้นที่ 1 ติดตั้งเครื่องมือและ Nginx

```
sudo apt update && sudo apt upgrade -y
sudo apt install -y nginx git build-essential autoconf automake libtool pkg-config \
  libpcre2-dev libxml2-dev libyajl-dev libgeoip-dev liblmdb-dev libcurl4-openssl-dev \
  libssl-dev zlib1g-dev libmaxminddb-dev
nginx -v          # จดเวอร์ชันไว้ เช่น 1.24.0
```

ขั้นที่ 2 คอมไพล์ libmodsecurity (ModSecurity v3)

```
cd /opt
sudo git clone --depth 1 https://github.com/owasp-modsecurity/ModSecurity
cd ModSecurity
sudo git submodule init && sudo git submodule update
sudo ./build.sh
sudo ./configure
sudo make -j"$(nproc)"
sudo make install          # ติดตั้งที่ /usr/local/modsecurity
```

ขั้นที่ 3 คอมไพล์ Connector เป็น Dynamic Module ของ Nginx

```
cd /opt
sudo git clone --depth 1 https://github.com/owasp-modsecurity/ModSecurity-nginx
NGX=$(nginx -v 2>&1 | grep -o '[0-9.]*$')
```

```
sudo wget http://nginx.org/download/nginx-$NGX.tar.gz
sudo tar -xzf nginx-$NGX.tar.gz && cd nginx-$NGX
# ใช้ --with-compat เพื่อให้ Module เข้ากับ Nginx ที่ติดตั้งจากแพ็กเกจ
sudo ./configure --with-compat --add-dynamic-module=../ModSecurity-nginx
sudo make modules
sudo mkdir -p /etc/nginx/modules
sudo cp objs/ngx_http_modsecurity_module.so /etc/nginx/modules/
```

เพิ่มบรรทัดบนสุดของ `/etc/nginx/nginx.conf`

```
load_module /etc/nginx/modules/ngx_http_modsecurity_module.so;
```

ขั้นที่ 4 ตั้งค่า ModSecurity และ OWASP Core Rule Set

```
sudo mkdir -p /etc/nginx/modsec
sudo cp /opt/ModSecurity/unicode.mapping /etc/nginx/modsec/
sudo cp /opt/ModSecurity/modsecurity.conf-recommended /etc/nginx/modsec/modsecurity.conf

# OWASP CRS
cd /opt && sudo git clone --depth 1 https://github.com/coreruleset/coreruleset modsecurity-crs
sudo cp /opt/modsecurity-crs/crs-setup.conf.example /opt/modsecurity-crs/crs-setup.conf
sudo cp /opt/modsecurity-crs/rules/REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf.example \
        /opt/modsecurity-crs/rules/REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf
sudo mv /opt/modsecurity-crs /usr/local/
```

แก้ `/etc/nginx/modsec/modsecurity.conf`

```
SecRuleEngine DetectionOnly          # สัปดาห์แรกให้ตรวจจับอย่างเดียวก่อน แล้วค่อยเปลี่ยนเป็น On
SecAuditEngine RelevantOnly
SecAuditLogFormat JSON
SecAuditLogType Serial
SecAuditLog /var/log/modsec_audit.log
```

สร้าง `/etc/nginx/modsec/main.conf`

```
Include /etc/nginx/modsec/modsecurity.conf
Include /usr/local/modsecurity-crs/crs-setup.conf
Include /usr/local/modsecurity-crs/rules/*.conf
```

ขั้นที่ 5 ตั้ง Reverse Proxy และเปิด ModSecurity

`/etc/nginx/sites-available/waf-web`

```
server {
    listen 443 ssl http2;
    server_name www.hospital.example;
    # ssl_certificate ... (ดูหัวข้อ 11.3)
```

```
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;

    location / {
        proxy_pass http://10.10.20.11:80;        # เว็บเดิม
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto https;
    }
}
```

```
sudo ln -s /etc/nginx/sites-available/waf-web /etc/nginx/sites-enabled/
sudo nginx -t && sudo systemctl restart nginx
```

ขั้นที่ 6 ทดสอบ

```
# คำขอปกติ → ต้องได้ 200
curl -sk -o /dev/null -w "%{http_code}\n" https://www.hospital.example/
# จำลอง Path Traversal และ SQLi → เมื่อ SecRuleEngine On ต้องได้ 403
curl -sk -o /dev/null -w "%{http_code}\n" "https://www.hospital.example/?file=../../../../etc/passwd"
curl -sk -o /dev/null -w "%{http_code}\n" "https://www.hospital.example/?id=1'+OR+'1'='1"
# ดู Log
sudo tail -f /var/log/modsec_audit.log | jq '.transaction.messages[]?.message'
```

ขั้นที่ 7 ปรับแต่ง (Tuning) แล้วเปิดโหมดบล็อก

1. ใช้ `DetectionOnly` 1–2 สัปดาห์ เก็บ Log การแจ้งเตือนที่เกิดกับการใช้งานปกติ (False Positive)
2. เขียนข้อยกเว้นเฉพาะจุดใน `REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf` เช่น

```
# ยกเว้น 942100 เฉพาะ URI /appointment/save
SecRule REQUEST_URI "@beginsWith /appointment/save" \
    "id:2000,phase:1,pass,nolog,ctl:ruleRemoveTargetById=942100;ARGS:note"
```

3. ปรับระดับความเข้มงวด (Paranoia Level) ใน `crs-setup.conf` เริ่มที่ระดับ 1
4. เปลี่ยน `SecRuleEngine On` แล้ว `sudo nginx -t && sudo systemctl reload nginx`
5. ส่ง `/var/log/modsec_audit.log` เข้า Wazuh (บทที่ 14) เพื่อทำรายงานการโจมตีรายเดือน

ทางลัด: Apache + ModSecurity (ติดตั้งจากแพ็กเกจ)

```
sudo apt install -y apache2 libapache2-mod-security2 modsecurity-crs
sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
sudo sed -i 's/SecRuleEngine DetectionOnly/SecRuleEngine On/' /etc/modsecurity/modsecurity.conf
sudo systemctl restart apache2
```

รู้ไว้: WAF ถูกหลบเลี่ยงได้

ผู้โจมตีใช้เทคนิค เช่น สลับตัวพิมพ์เล็กใหญ่, เข้ารหัส URL ซ้ำสองชั้น, ใส่ Comment ใน SQL, ใช้ Unicode หรือ HTML Entity เพื่อหลบกฎ ดังนั้น **WAF เป็นเพียงชั้นหนึ่ง** ยังต้องแก้โค้ดให้ปลอดภัย อัปเดต CMS และทำ Pentest ประจำปี

📋 หลักฐาน CTAM+ ข้อ 8: ภาพการตั้งค่า WAF (เช่น `nginx -t` และไฟล์ main.conf), ภาพ Log/รายงานการโจมตีที่ถูกบล็อก, รายการ Source IP Blocklist ที่เพิ่ม

11.6 Cloudflare WAF สำหรับเว็บสาธารณะ

1. เพิ่มโดเมนใน Cloudflare และเปิด Proxy
2. Security → WAF: เปิด Managed Rules (ตามแผนที่ใช้) และสร้าง Custom Rules เช่น
   - บล็อกประเทศที่ไม่เกี่ยวข้องสำหรับหน้า `/wp-admin` หรือ `/admin`
   - Rate Limit หน้า Login
3. Security → Bots: เปิด Bot Fight Mode
4. SSL/TLS: Full (strict), Always Use HTTPS, เปิด DNSSEC
5. บน Firewall อนุญาตเฉพาะ IP ของ Cloudflare (บทที่ 9)

11.7 แนวปฏิบัติการพัฒนาเว็บของหน่วยงาน

- กำหนดข้อกำหนดด้านความปลอดภัยใน TOR การจ้างพัฒนา: ผ่าน OWASP Top 10, ผ่าน Pentest ก่อนส่งมอบ, ส่งมอบซอร์สโค้ด, มี MA แก้ช่องโหว่
- แยกเครื่อง Development / Test / Production และไม่ใช้ข้อมูลผู้ป่วยจริงในการทดสอบ
- ใช้ Git และตรวจไม่ให้รหัสผ่านหรือ API Key ถูก Commit ขึ้น Repository
- เว็บภาครัฐควรรองรับการเข้าถึงของทุกคน (Accessibility) ตามแนวทาง TWCAG 2022 ซึ่งอ้างอิง WCAG 2.1

⭐ สรุปท้ายบท

- เว็บที่เปิดสู่อินเทอร์เน็ตทุกเว็บต้องมี HTTPS, อัปเดต CMS และอยู่หลัง WAF
- ModSecurity + OWASP CRS เป็น WAF ฟรีที่ตอบ CTAM+ ข้อ 8 ได้ เริ่มจาก DetectionOnly แล้วค่อยบล็อก
- เมื่อเว็บถูกเจาะ ต้องเก็บหลักฐาน แจ้งเหตุ หาจุดเข้า และกู้จากแหล่งที่สะอาด

✏️ คำถามทบทวน

1. ทำไมต้องเปิด ModSecurity ในโหมด DetectionOnly ก่อนเปิดบล็อก
2. เว็บไซต์ที่เปิดสู่อินเทอร์เน็ตทุกเว็บต้องมีอะไรเป็นขั้นต่ำ
3. ผู้ใช้แจ้งว่า Google แสดงผลค้นหาเว็บโรงพยาบาลเป็นข้อความเว็บพนัน แต่หน้าเว็บที่เปิดดูปกติ เกิดอะไรขึ้นได้บ้าง
4. ตรวจเว็บไซต์ของหน่วยงานด้วยเครื่องมือตรวจ HTTPS และ Security Headers แล้วสรุปสิ่งที่ต้องแก้

ภาค 3 · ลงมือป้องกัน บทที่ 12

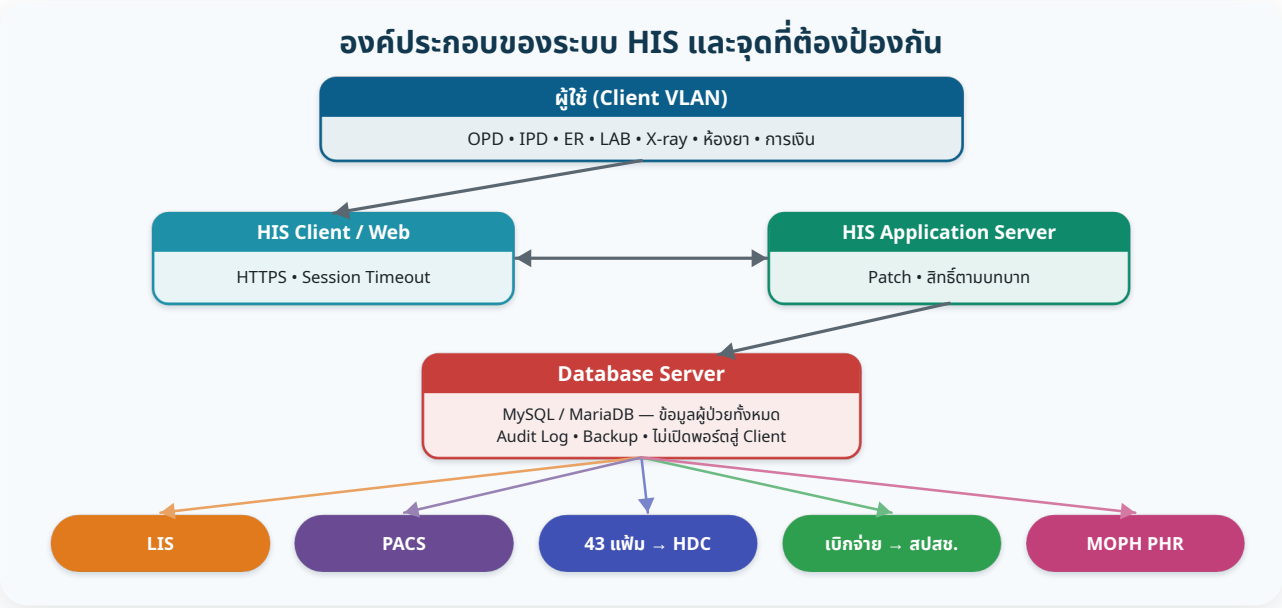
ความปลอดภัยระบบ HIS และฐานข้อมูล

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ Hardening ฐานข้อมูล MySQL/MariaDB ที่ใช้กับระบบ HIS ได้
- ✔️ กำหนดบัญชีฐานข้อมูลตามหลัก Least Privilege
- ✔️ เปิด Audit Log และตรวจจับการดึงข้อมูลผิดปกติ
- ✔️ ควบคุมการส่งออกข้อมูล (43 แฟ้ม, รายงาน, Excel) อย่างปลอดภัย

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 3, 4, 9, 13 / นโยบาย สธ. 2565 หมวด 2

12.1 ภาพรวมระบบสารสนเทศโรงพยาบาล



▲ ภาพที่ 12.1 องค์ประกอบของระบบ HIS และการเชื่อมต่อ

หน่วยบริการในสังกัดกระทรวงจำนวนมากใช้ระบบ HIS ที่ทำงานบน **MySQL/MariaDB** (เช่น HOSxP, HOSxP PCU, JHCIS) ฐานข้อมูลนี้คือทรัพย์สินที่สำคัญที่สุดของหน่วยงาน และเป็นเป้าหมายหลักของแรนซัมแวร์และการขโมยข้อมูล

12.2 จุดอ่อนที่พบบ่อย

จุดอ่อน	ผลที่ตามมา
ผู้ใช้ `root` ไม่มีรหัสผ่านหรือรหัสง่าย และอนุญาตจาก `%` (ทุก IP)	ใครอยู่ในเครือข่ายก็ดึงข้อมูลได้ทั้งหมด
โปรแกรม HIS บนเครื่องลูกข่ายใช้บัญชีฐานข้อมูลที่มีสิทธิ์สูงสุดร่วมกัน	มัลแวร์บนเครื่องผู้ใช้เครื่องเดียวเข้าถึงฐานข้อมูลได้ทั้งก้อน
พอร์ต 3306 เปิดให้ทุก VLAN หรือออกอินเทอร์เน็ต	ถูก Brute Force และแรนซัมแวร์ที่เข้ารหัสฐานข้อมูลโดยตรง
โปรแกรมรายงาน/เครื่องมือ Query ติดตั้งบนเครื่องผู้ใช้ทั่วไป	ดึงข้อมูลผู้ป่วยออกเป็น Excel ได้ไม่จำกัด
ไฟล์ Backup `.sql` วางไว้บนเครื่องเดียวกันหรือแชร์โฟลเดอร์	ถูกเข้ารหัสพร้อมกัน หรือรั่วไหลทั้งก้อน
ไม่มี Log ว่าใครค้นหาข้อมูลผู้ป่วยรายใด	ตรวจสอบการละเมิดไม่ได้

12.3 Hardening MySQL/MariaDB

> ⚠️ ประสานบริษัทผู้พัฒนา HIS ก่อนเปลี่ยนการตั้งค่า เพราะบางค่าอาจกระทบการทำงานของโปรแกรม ให้ทดสอบบนเครื่องสำรองก่อนเสมอ

1) รันสคริปต์ความปลอดภัยพื้นฐาน

```
sudo mysql_secure_installation      # MariaDB ใหม่ใช้ mariadb-secure-installation
```

ตอบ: ตั้งรหัส root, ลบ Anonymous Users, ห้าม root Login ระยะไกล, ลบฐานข้อมูล test

2) จำกัดการรับการเชื่อมต่อ

`/etc/mysql/mariadb.conf.d/50-server.cnf` (หรือ `my.cnf`)

```
[mysqld]
bind-address        = 10.10.10.11      # IP ของเครื่องฐานข้อมูลใน Server VLAN ไม่ใช้ 0.0.0.0 ถ้าไม่จำเป็น
local-infile        = 0                # ปิดการอ่านไฟล์ในเครื่องผ่าน LOAD DATA LOCAL
skip-symbolic-links
max_connect_errors  = 100
```

และที่ Firewall/Host Firewall อนุญาตพอร์ต 3306 เฉพาะ IP ของ Application Server หรือเครื่องที่จำเป็นเท่านั้น

```
sudo ufw allow from 10.10.40.0/24 to any port 3306 proto tcp   # เฉพาะกรณี HIS แบบ Client-Server ที่ต้องต่อตรง
sudo ufw allow from 10.10.30.0/24 to any port 3306 proto tcp   # IT VLAN
```

3) บัญชีฐานข้อมูลตามหน้าที่ (Least Privilege)

```
-- ตรวจบัญชีที่มีอยู่
SELECT user, host, plugin FROM mysql.user;

-- ลบหรือจำกัด root จากทุก Host
DROP USER IF EXISTS 'root'@'%';

-- บัญชี DBA รายบุคคล เข้าได้จาก IT VLAN เท่านั้น
CREATE USER 'dba_somchai'@'10.10.30.%' IDENTIFIED BY '<รหัสผ่านยาวอย่างน้อย 16 ตัว>';
GRANT ALL PRIVILEGES ON *.* TO 'dba_somchai'@'10.10.30.%' WITH GRANT OPTION;

-- บัญชีสำหรับระบบรายงาน อ่านอย่างเดียว เฉพาะตารางที่จำเป็น
CREATE USER 'report_ro'@'10.10.10.50' IDENTIFIED BY '<รหัสผ่าน>';
GRANT SELECT ON hosdb.ovst      TO 'report_ro'@'10.10.10.50';
GRANT SELECT ON hosdb.vn_stat   TO 'report_ro'@'10.10.10.50';

-- บัญชีสำรองข้อมูล
CREATE USER 'backup'@'localhost' IDENTIFIED BY '<รหัสผ่าน>';
GRANT SELECT, SHOW VIEW, LOCK TABLES, RELOAD, EVENT, TRIGGER, PROCESS ON *.* TO 'backup'@'localhost';

FLUSH PRIVILEGES;
```

> ชื่อฐานข้อมูลและตาราง (`hosdb` , `ovst` , `vn_stat`) เป็นตัวอย่าง ให้ปรับตาม HIS ที่ใช้จริง

4) เข้ารหัสการเชื่อมต่อ (TLS)

ถ้า Client ต่อฐานข้อมูลข้าม VLAN ควรเปิด TLS และบังคับให้บัญชีสำคัญใช้ TLS

```
ALTER USER 'dba_somchai'@'10.10.30.%' REQUIRE SSL;
SHOW VARIABLES LIKE 'have_ssl';
```

5) อัปเดตเวอร์ชัน

ใช้รุ่นที่ยังได้รับการสนับสนุน (เช่น MariaDB LTS ล่าสุด) และติดตามประกาศช่องโหว่ บันทึกเวอร์ชันเป็นหลักฐาน CTAM+ ข้อ 13

12.4 Audit Log: ใครเข้าถึงข้อมูลอะไร

ระดับฐานข้อมูล (MariaDB Audit Plugin)

```
INSTALL SONAME 'server_audit';
SET GLOBAL server_audit_events = 'CONNECT,QUERY_DDL,QUERY_DCL';
SET GLOBAL server_audit_logging = ON;
```

เพิ่มใน `my.cnf` เพื่อให้มีผลถาวร

```
[mysqld]
plugin_load_add            = server_audit
server_audit_logging       = ON
server_audit_events        = CONNECT,QUERY_DDL,QUERY_DCL
server_audit_file_path     = /var/log/mysql/audit.log
server_audit_file_rotate_size = 100000000
server_audit_file_rotations = 30
```

> 💡 การบันทึกทุก Query (`QUERY`) ทำให้ Log ใหญ่มากและอาจกระทบประสิทธิภาพ เริ่มจาก CONNECT + DDL + DCL ก่อน แล้วเพิ่มการบันทึก Query เฉพาะบัญชีที่มีความเสี่ยง (เช่น บัญชีรายงาน) ด้วย `server_audit_incl_users`

ระดับแอปพลิเคชัน

ระบบ HIS ส่วนใหญ่มีตาราง Log การเข้าใช้และการเปิดดูเวชระเบียน ให้ตรวจว่าเปิดใช้งานอยู่ และ **ทบทวนการเข้าดูข้อมูลผู้ป่วยกลุ่มพิเศษ** เช่น บุคคลสาธารณะ เจ้าหน้าที่ในโรงพยาบาล ผู้ป่วยคดี เป็นประจำ

ส่ง Log เข้า SIEM

ให้ Wazuh Agent อ่าน `/var/log/mysql/audit.log` และ Error Log แล้วตั้งกฎแจ้งเตือน (บทที่ 14)

- Login ฐานข้อมูลล้มเหลวหลายครั้ง
- Login ด้วยบัญชี DBA นอกเวลาราชการ
- คำสั่ง `DROP` , `TRUNCATE` , `GRANT` , `SELECT ... INTO OUTFILE`
- การเชื่อมต่อจาก IP ที่ไม่อยู่ในรายการอนุญาต

12.5 ตรวจจับการดึงข้อมูลผิดปกติ

ตัวอย่าง Query ตรวจการเชื่อมต่อขณะนั้น

```
SELECT user, host, db, command, time, LEFT(info, 120) AS query
FROM information_schema.processlist
WHERE user NOT IN ('system user','event_scheduler')
ORDER BY time DESC;
```

สัญญาณเตือน

- บัญชีเดียวดึงข้อมูลจำนวนมากผิดปกติ (เช่น SELECT ตาราง patient ทั้งตาราง)
- การเชื่อมต่อจากเครื่องผู้ใช้ทั่วไปที่ไม่ควรต่อฐานข้อมูลโดยตรง
- ไฟล์ขนาดใหญ่ถูกส่งออกไปยังอินเทอร์เน็ตจากเครื่องฐานข้อมูล (ดูจาก Firewall/Netflow)

12.6 การส่งออกข้อมูลอย่างปลอดภัย

สถานการณ์	แนวปฏิบัติ
ส่ง 43 แฟ้มไป HDC	ใช้โปรแกรม/ช่องทางทางการ เครื่องที่ใช้ส่งต้องอยู่ใน IT VLAN และไม่เก็บไฟล์ค้างไว้นาน
รายงานให้ผู้บริหาร	รายงานแบบสรุป (Aggregate) ไม่ต้องมีรายชื่อ
ส่งรายชื่อผู้ป่วยให้ รพ.สต./อสม. ติดตาม	ส่งเฉพาะคอลัมน์ที่จำเป็น ตั้งรหัสผ่านไฟล์ ส่งรหัสแยกช่องทาง และกำหนดให้ลบเมื่อใช้เสร็จ
ส่งข้อมูลให้นักวิจัย	ผ่านการอนุมัติจริยธรรมและ DSA, ทำ De-identification (บทที่ 4)
เจ้าหน้าที่ขอ Export Excel เอง	จำกัดสิทธิ์เมนูส่งออกเฉพาะผู้ที่ได้รับอนุมัติ และบันทึก Log

12.7 การเข้ารหัสข้อมูล

- **ข้อมูลระหว่างส่ง (In Transit):** HTTPS, TLS ของฐานข้อมูล, VPN
- **ข้อมูลที่จัดเก็บ (At Rest):** เข้ารหัสดิสก์ของ Notebook (BitLocker), เข้ารหัสไฟล์ Backup ก่อนส่งออกนอกสถานที่ (บทที่ 13), พิจารณา Encryption at Rest ของ MariaDB/InnoDB สำหรับเครื่องที่อยู่นอก Data Center
- **การจัดการกุญแจ:** เก็บกุญแจ/รหัสผ่านไว้ใน Password Manager ขององค์กร และมีผู้ถือสำรองอย่างน้อย 2 คน มิฉะนั้นจะกู้ข้อมูลไม่ได้

12.8 Checklist ความปลอดภัยฐานข้อมูล HIS

- ☐ `root` ไม่ Login จากเครือข่าย และมีรหัสผ่านแข็งแรง
- ☐ บัญชีรายบุคคลสำหรับ DBA และบัญชีเฉพาะกิจสำหรับรายงาน/สำรองข้อมูล
- ☐ พอร์ต 3306 ไม่เปิดสู่อินเทอร์เน็ต และจำกัดเฉพาะ VLAN ที่จำเป็น
- ☐ เปิด Audit Log และส่งเข้า SIEM
- ☐ Backup อัตโนมัติ 3-2-1 และทดสอบกู้คืน (บทที่ 13)
- ☐ เวอร์ชันฐานข้อมูลและ HIS ยังได้รับการสนับสนุน
- ☐ บริษัทผู้ดูแลเข้าถึงผ่าน VPN + MFA และมี DPA/NDA
- ☐ ทบทวนสิทธิ์ทุกไตรมาส

⭐ สรุปท้ายบท

- ฐานข้อมูล HIS คือหัวใจของโรงพยาบาล ต้องจำกัดทั้งเครือข่ายและบัญชีผู้ใช้
- Audit Log ทำให้ตรวจสอบการละเมิดได้ และเป็นหลักฐานตาม PDPA
- การส่งออกข้อมูลต้องมีขั้นตอน อนุมัติ และลดข้อมูลให้น้อยที่สุด

✏️ คำถามทบทวน

1. ทำไมไม่ควรให้เครื่องลูกข่ายทุกเครื่องเชื่อมต่อฐานข้อมูล HIS โดยตรงด้วยบัญชีเดียวกัน
2. Audit Log ของ HIS ใช้ทำอะไรในมุม PDPA
3. หน่วยงานภายนอกขอข้อมูลผู้ป่วยเบาหวานทั้งหมดเพื่อทำวิจัย ควรมีขั้นตอนอย่างไร
4. ตรวจรายชื่อบัญชีในฐานข้อมูล HIS ของหน่วยงาน มีบัญชีใดที่อนุญาตจากทุก Host หรือมีสิทธิ์เกินหน้าที่



ภาค 3 · ลงมือป้องกัน บทที่ 13

การสำรองข้อมูล 3-2-1 และ BCP/DRP

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ ออกแบบการสำรองข้อมูลแบบ 3-2-1-1-0 ที่รอดจากแรนซัมแวร์
- ✔️ เขียนสคริปต์สำรองฐานข้อมูล HIS อัตโนมัติ พร้อมเข้ารหัสและตรวจสอบ
- ✔️ กำหนด RTO/RPO และเขียนแผน BCP/DRP ที่ใช้ได้จริง
- ✔️ จัดการซ้อมแผนกรณี Ransomware และทำรายงานผลการทดสอบ

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 1, 5 / ตัวชี้วัด v2.1 ขั้นต่ำข้อ 1, 5, 6, 7 และขั้นสูงหมวด 1, 3

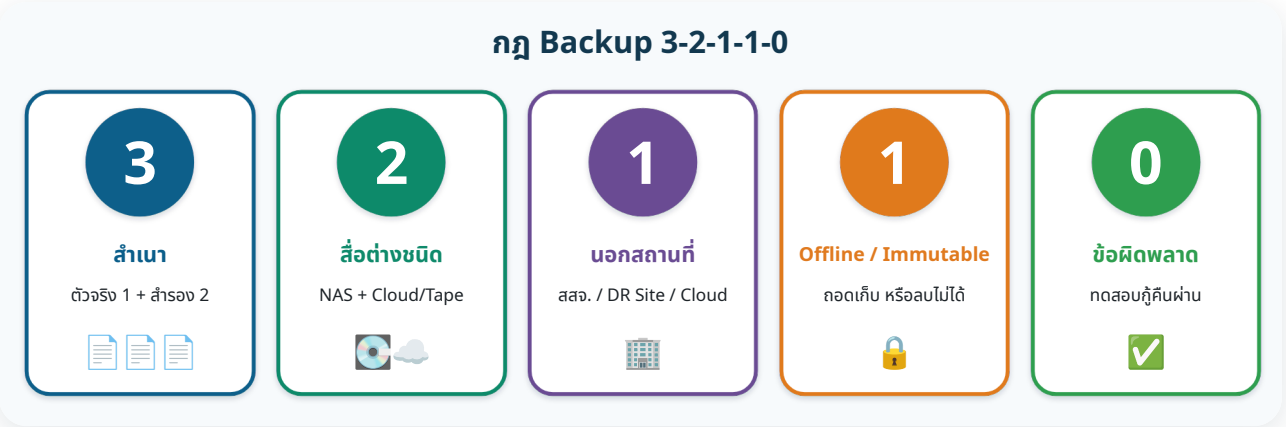
13.1 ทำไมต้องทำ Backup ก่อนเรื่องอื่น

ศทส.สป.สธ. ให้เหตุผลว่าควรเร่งทำระบบสำรองข้อมูลเป็นอันดับแรก เพราะ

1. เราไม่รู้ว่าจะถูกโจมตีเมื่อไร และอาจมีผู้โจมตีแฝงตัวอยู่ในระบบแล้ว
2. ช่องโหว่มีหลากหลาย ปิดได้ไม่หมด
3. ระบบป้องกันมีความซับซ้อนและเกี่ยวข้องกับหลายระบบ
4. **Backup ที่ใช้ได้จริงคือสิ่งเดียวที่ทำให้กลับมาให้บริการได้โดยไม่ต้องจ่ายค่าไถ่**

ข้อเสนอเชิงนโยบาย: ทุกหน่วยบริการทำตามนโยบาย 3-2-1-1 อย่างเร่งด่วน, ซักซ้อมและทดสอบสม่ำเสมอ, **RPO ขั้นต่ำ 24 ชั่วโมง และ RTO ขั้นต่ำ 24 ชั่วโมง**

13.2 กฎ 3-2-1-1-0



▲ ภาพที่ 13.1 กฎ Backup 3-2-1-1-0

ตัวเลข	ความหมาย	ตัวอย่างในโรงพยาบาลชุมชน
3 Copies	ข้อมูลอย่างน้อย 3 ชุด (ตัวจริง 1 + สำรอง 2)	ฐานข้อมูลจริงบนเซิร์ฟเวอร์ + NAS + HDD ภายนอก/Cloud
2 Media	เก็บบนเทคโนโลยีต่างกันอย่างน้อย 2 แบบ	HDD ใน NAS + Cloud หรือ HDD + Tape/RDX
1 Off-site	1 ชุดอยู่นอกสถานที่	สสจ., DR Site, Cloud ภาครัฐ (GDCC/MOPH Cloud)
1 Offline / Immutable	1 ชุดตัดขาดจากเครือข่าย หรือแก้ไข/ลบไม่ได้	HDD ถอดเก็บในตู้เซฟ, Object Storage แบบ Object Lock
0 Errors	ทดสอบกู้คืนแล้วไม่มีข้อผิดพลาด	ทดสอบ Restore ทุกเดือน

CTAM+ ข้อ 1 กำหนด: สำรองอย่างน้อยวันละ 1 ครั้ง, ย้อนหลังได้อย่างน้อย 7 วัน, และใช้รูปแบบ 3-2-1 ส่วนแนวทางของ ศทส. แนะนำให้ชุด Offline มี **7 ชุด** (หมุนเวียนรายวันย้อนหลัง 7 วัน)

แนวคิด Backup ยุคใหม่ “3I”

- **Isolation** แยกระบบ Backup ออกจากเครือข่ายและบัญชีของโดเมนหลัก (Backup Server ไม่ Join Domain, ใช้บัญชีแยก, MFA)
- **Immutable** สำเนาที่ลบ/แก้ไม่ได้ในช่วงเวลาที่กำหนด
- **Intelligent analytics** ตรวจจับความผิดปกติ เช่น ไฟล์ถูกเข้ารหัสจำนวนมาก หรือขนาด Backup เปลี่ยนผิดปกติ

⚠️ แรนซัมแวร์รุ่นใหม่จะค้นหาและลบ Backup ที่เข้าถึงได้ก่อนเข้ารหัสเสมอ NAS ที่ Map เป็นไดรฟ์บนเซิร์ฟเวอร์ หรือใช้รหัส admin เดียวกับโดเมน **ไม่นับว่าปลอดภัย**

13.3 RPO และ RTO

- **RPO (Recovery Point Objective)** ยอมให้ข้อมูลหายย้อนหลังได้มากที่สุดเท่าไร เช่น RPO 24 ชม. = สำรองอย่างน้อยวันละครั้ง
- **RTO (Recovery Time Objective)** ต้องกู้ระบบให้กลับมาภายในเวลาเท่าไร

ระบบ	ความสำคัญ	RPO เป้าหมาย	RTO เป้าหมาย	วิธีสำรอง
ฐานข้อมูล HIS	5	≤ 1 ชม. (เกณฑ์ขั้นต่ำ 24 ชม.)	≤ 4 ชม. (เกณฑ์ขั้นต่ำ 24 ชม.)	Replication + Dump รายชั่วโมง/รายวัน + Offline
PACS	4	24 ชม.	24 ชม.	สำรองรายวัน ภาพเก่าเก็บ Archive
LIS	4	24 ชม.	8 ชม.	Dump รายวัน
เว็บไซต์	2	7 วัน	72 ชม.	สำรองรายสัปดาห์
File Server	3	24 ชม.	48 ชม.	Snapshot + สำรองรายวัน

13.4 Lab: สคริปต์สำรองฐานข้อมูล HIS (MySQL/MariaDB) LAB

1) เตรียมไฟล์รหัสผ่าน (ไม่เขียนรหัสในสคริปต์)

```
sudo tee /root/.my-backup.cnf >/dev/null <<'EOF'
[client]
user=backup
password=<รหัสผ่านบัญชี backup>
EOF
sudo chmod 600 /root/.my-backup.cnf
```

2) สคริปต์ `/usr/local/sbin/his-backup.sh`

```
#!/usr/bin/env bash
# สำรองฐานข้อมูล HIS รายวัน: dump → บีบอัด → เข้ารหัส → ตรวจสอบ → ส่งออกนอกเครื่อง
set -euo pipefail

DB_NAME="hosdb"                              # ชื่อฐานข้อมูล HIS (ปรับตามจริง)
LOCAL_DIR="/backup/his"                      # ชุดที่ 2: ดิสก์แยกบนเครื่อง Backup/NAS
REMOTE="backup@10.10.30.20:/srv/his/"        # ชุดที่ 3: เครื่องนอกอาคาร/สสจ.
KEEP_DAYS=14
GPG_RECIPIENT="it-backup@hospital.example"   # กุญแจสาธารณะสำหรับเข้ารหัส
STAMP=$(date +%F_%H%M)
FILE="$LOCAL_DIR/${DB_NAME}_${STAMP}.sql.gz"
LOG="/var/log/his-backup.log"

mkdir -p "$LOCAL_DIR"
```

```
echo "$(date '+%F %T') START $DB_NAME" >> "$LOG"

# --single-transaction: สำรองตาราง InnoDB ได้โดยไม่ล็อกระบบ
mysqldump --defaults-extra-file=/root/.my-backup.cnf \
  --single-transaction --quick --routines --triggers --events \
  "$DB_NAME" | gzip -6 > "$FILE"

# ตรวจว่าไฟล์ gzip สมบูรณ์
gzip -t "$FILE"

# เข้ารหัสก่อนส่งออกนอกเครื่อง
gpg --batch --yes --trust-model always -r "$GPG_RECIPIENT" -o "$FILE.gpg" -e "$FILE"
sha256sum "$FILE.gpg" > "$FILE.gpg.sha256"

# ส่งชุดที่เข้ารหัสไปเก็บนอกเครื่อง
rsync -a "$FILE.gpg" "$FILE.gpg.sha256" "$REMOTE"

# ลบชุดเก่าเกินกำหนด
find "$LOCAL_DIR" -type f -mtime +"$KEEP_DAYS" -delete

SIZE=$(du -h "$FILE" | cut -f1)
echo "$(date '+%F %T') OK $FILE ($SIZE)" >> "$LOG"
```

```
sudo chmod 700 /usr/local/sbin/his-backup.sh
# รันทุกวัน 02:00 (และเพิ่มรอบระหว่างวันได้ตาม RPO)
echo "0 2 * * * root /usr/local/sbin/his-backup.sh || echo \"\$(date) FAIL\" >> /var/log/his-
backup.log" | sudo tee /etc/cron.d/his-backup
```

> 💡 ถ้าฐานข้อมูลใหญ่มาก (หลายร้อย GB) ให้ใช้ **mariabackup / Percona XtraBackup** ที่สำรองแบบ Physical ได้เร็วกว่า และทำ **Replication** ไปเครื่องสำรองเพื่อให้ RPO ต่ำ แต่ต้องจำไว้ว่า Replication ไม่ใช่ Backup เพราะถ้าข้อมูลถูกลบหรือถูกเข้ารหัส เครื่องสำรองก็ถูกด้วย

3) ฝั่งเครื่องรับ: ทำให้แก้ไขไม่ได้

- ให้เครื่องรับ (Backup Server) เป็นฝ่าย **ดึง (Pull)** ข้อมูลเอง แทนการให้เซิร์ฟเวอร์ HIS ส่งด้วยสิทธิ์เขียนทับ หรือใช้ `rsync` แบบบัญชีที่เขียนได้แต่ลบไม่ได้
- ใช้ Snapshot แบบอ่านอย่างเดียว (ZFS/Btrfs/Synology Snapshot Replication with immutable snapshots)
- Cloud Object Storage ที่รองรับ **Object Lock** (เช่น S3-compatible)

4) ชุด Offline

- HDD ภายนอกอย่างน้อย 2 ลูก สลับกันทุกวัน/ทุกสัปดาห์ ลูกที่ไม่ได้ใช้ **ถอดออกและเก็บในตู้เซฟนอกห้อง Server**
- บันทึกสมุดคุมการสลับดิสก์ (วันที่ ผู้ดำเนินการ ลายเซ็น) เป็นหลักฐาน

5) สำรองระบบทั้งเครื่อง (VM)

- Proxmox: **Proxmox Backup Server** (ฟรี) รองรับ Incremental, Encryption และการตรวจ Verify
- VMware/Hyper-V: Veeam Backup & Replication (มีรุ่น Community สำหรับ VM จำนวนน้อย)
- ตัวอย่างโรงพยาบาลขนาดใหญ่ใช้ระบบ Replication ระดับ VM ไปยังศูนย์สำรอง พร้อม Journal ย้อนเวลากู้คืนได้ และมีขั้นตอน Offline Backup ของ HIS แยกอีกชุด

13.5 ทดสอบกู้คืน (Restore Test)

Backup ที่ไม่เคยทดสอบกู้คืน เท่ากับไม่มี Backup

ขั้นตอนทดสอบรายเดือน

```
# บนเครื่องทดสอบที่แยกจากระบบจริง
gpg -d hosdb_2026-10-29_0200.sql.gz.gpg > /tmp/test.sql.gz
sha256sum -c hosdb_2026-10-29_0200.sql.gz.gpg.sha256
mysql -e "CREATE DATABASE hosdb_restore_test"
time (gunzip < /tmp/test.sql.gz | mysql hosdb_restore_test)
# ตรวจจำนวนแถวตารางหลักเทียบกับระบบจริง
mysql -e "SELECT COUNT(*) FROM hosdb_restore_test.patient; SELECT MAX(vstdate) FROM
hosdb_restore_test.ovst;"
```

บันทึกผล: วันที่, ชุด Backup ที่ใช้, เวลาที่ใช้กู้ (เทียบ RTO), ข้อมูลล่าสุดที่ได้ (เทียบ RPO), ปัญหา, ผู้ทดสอบ

13.6 BCP: แผนความต่อเนื่องทางธุรกิจ

BCP ตอบคำถามว่า "**เมื่อระบบใช้ไม่ได้ เราจะให้บริการผู้ป่วยต่ออย่างไร**" ส่วน DRP ตอบว่า "**จะกู้ระบบกลับมาอย่างไร**"

องค์ประกอบตาม CTAM+ ข้อ 5

1. **Risk Management** สถานการณ์ที่ทำให้หยุดชะงัก (Ransomware, ไฟดับ, น้ำท่วม, ไฟไหม้, เครือข่ายล่ม, ระบบ Cloud ภายนอกล่ม)
2. **Resource Management** คน อุปกรณ์ แบบฟอร์มกระดาษ เครื่องสำรอง งบประมาณฉุกเฉิน
3. **Business Continuity Planning** ขั้นตอนของแต่ละหน่วยบริการ
4. **Testing** ซ้อมอย่างน้อยปีละครั้ง (ตัวชี้วัด v2.1 กำหนดสถานการณ์ Ransomware)
5. **Review & Update** ทบทวนหลังการซ้อมและหลังเหตุจริง

ตัวอย่างการประกาศรหัสสถานการณ์

แนวทางจากแผน BCP ของโรงพยาบาลศูนย์แห่งหนึ่ง ใช้รหัสสั้นที่ทุกหน่วยเข้าใจตรงกัน

รหัส	ความหมาย	สิ่งที่หน่วยบริการทำ
BCP 1	ระบบหลักขัดข้องชั่วคราว คาดว่าแก้ได้ภายใน 15 นาที	หยุดบันทึกข้อมูลเข้าระบบ รอประกาศ ให้บริการต่อได้
BCP 2	ระบบหลักขัดข้อง แก้ไม่ได้ภายใน 15 นาที	เปลี่ยนไปใช้ **Downtime Procedure** (กระดาษ) ตามคู่มือของแต่ละหน่วย
BCP 0	ยกเลิก ระบบกลับมาใช้งานได้ปกติ	บันทึกข้อมูลย้อนหลังที่ทำบนกระดาษเข้าระบบ

Downtime Procedure ของหน่วยบริการ (ตัวอย่าง)

ห้องบัตร/เวชระเบียน

1. แจ้งผู้ป่วยว่าระบบ HIS ใช้ไม่ได้ชั่วคราว
2. ผู้ป่วยใหม่: กรอกแบบฟอร์มประวัติกระดาษ ออก HN ชั่วคราวจากสมุดเลขสำรอง
3. ผู้ป่วยเก่า: ค้นจาก HN บนบัตร หรือจาก **รายชื่อผู้ป่วยนัดที่พิมพ์ล่วงหน้า (Pre-printed list)**
4. บันทึกผู้ป่วยทุกรายในสมุดทะเบียนพร้อมเวลาส่งห้องตรวจ

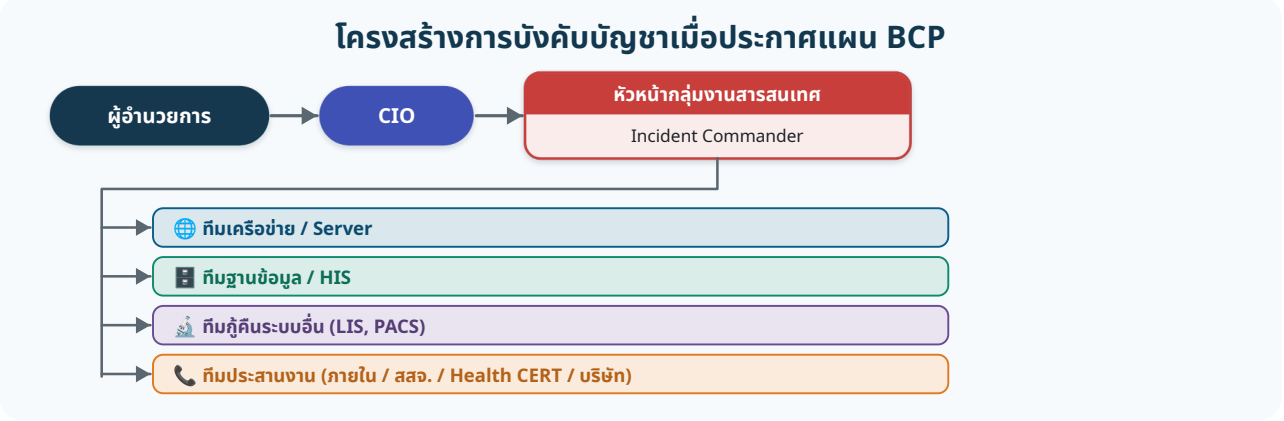
ห้องตรวจ/ห้องยา

- ใช้ใบสั่งยาชั่วคราว ระบุ ชื่อ-สกุล, HN, เลขบัตรประชาชน, **ประวัติแพ้ยา** (ถามผู้ป่วยทุกราย)
- ห้องยาตรวจสอบปฏิกิริยาระหว่างยาด้วยคู่มืออ้างอิงกระดาษหรือแหล่งออฟไลน์

การเตรียมล่วงหน้า (ทำทุกวัน)

- ส่งออก **รายชื่อผู้ป่วยนัดวันรุ่งขึ้น, ผู้ป่วยใน, ประวัติแพ้ยา** เป็น PDF เข้ารหัส เก็บในเครื่อง Standalone ที่ไม่ต่อเครือข่าย และพิมพ์สำรองที่ ER/Ward
- เตรียมแบบฟอร์มกระดาษให้พอใช้ 3 วัน

โครงสร้างการบังคับบัญชาเมื่อประกาศแผน



จุดรับแจ้งเหตุ: หน่วยงานที่พบเหตุ → Help Desk IT → วิเคราะห์และประเมินเวลาแก้ไข → เสนอ ผอ./CIO ประกาศรหัส → ประชาสัมพันธ์ (เสียงตามสาย, LINE กลุ่มหัวหน้างาน)

13.7 DRP: แผนกู้คืนระบบ

เนื้อหาที่ต้องมี

1. รายการระบบเรียงตามลำดับการกู้ (ใช้ความสำคัญและ RTO)
2. ผังระบบ, ข้อมูลเซิร์ฟเวอร์, ที่อยู่ Backup, ผู้ถือรหัสผ่าน/กุญแจถอดรหัส (เก็บซองปิดผนึก 2 ชุด)
3. ขั้นตอนกู้คืนทีละระบบ (Runbook) พร้อมภาพหน้าจอ เช่น กู้ VM, กู้ฐานข้อมูล, กู้ Offline Backup
4. ขั้นตอนตรวจสอบหลังกู้ (ข้อมูลล่าสุด, ทดสอบการใช้งานกับผู้ใช้ตัวแทน)
5. รายชื่อผู้ติดต่อ: ทีม IT, บริษัท HIS, ผู้ให้บริการเครือข่าย, สสจ., Health CERT

ลำดับการกู้คืนกรณีแรนซัมแวร์

1. **แยกเครือข่าย** ก่อน (ดูบทที่ 17) และอย่ากู้ลงเครื่องที่ยังติดเชื้อ
2. ตรวจว่า Backup ชุดใดสะอาด (ก่อนวันที่ผู้โจมตีเข้ามา ไม่ใช่แค่ก่อนวันที่เข้ารหัส)
3. สร้างเซิร์ฟเวอร์ใหม่/ติดตั้ง OS ใหม่ แพตช์ให้ครบ
4. กู้ฐานข้อมูล HIS → Application Server → เครื่องลูกข่ายจุดวิกฤต (ER, Ward, ห้องยา) → จุดอื่น
5. เปลี่ยนรหัสผ่านทุกบัญชีก่อนเปิดใช้
6. เฝ้าระวังด้วย SIEM อย่างใกล้ชิด

DR Site (CTAM V4 ข้อ 14)

เกณฑ์อ้างอิง: ห่างจาก DC ไม่น้อยกว่า 60 กม., มีระบบฐานข้อมูลสำคัญอย่างน้อย 1 ระบบ, RTO และ RPO ไม่เกิน 24 ชม., มีเอกสารผลการทดสอบ, และอ้างอิง ISO 27001/27799 ทางเลือกที่ประหยัด เช่น ใช้ Cloud ภาครัฐ หรือทำ DR ร่วมกันในระดับจังหวัด/เขต (โรงพยาบาลหนึ่งเป็น DR ให้อีกแห่ง)

13.8 ห้อง Server / Data Center (ตัวชี้วัดขั้นต่ำข้อ 7)

- [ ] ห้องแยก ล็อกได้ มีระบบควบคุมการเข้าออก (บัตร/ลายนิ้วมือ/กุญแจ + สมุดลงชื่อ)
- [ ] กล้อง CCTV บันทึกทางเข้า
- [ ] ระบบดับเพลิงที่เหมาะกับอุปกรณ์ไฟฟ้า (ไม่ใช่สปริงเกอร์น้ำ) และถังดับเพลิง CO2
- [ ] เครื่องปรับอากาศอย่างน้อย 2 ชุดสลับกัน และเซนเซอร์อุณหภูมิ/ความชื้นที่แจ้งเตือน
- [ ] UPS แบบ True Online และเชื่อมกับ Generator ทดสอบ Generator ทุกเดือน
- [ ] ไม่มีท่อน้ำผ่านเหนือ Rack และยกพื้นหรือป้องกันน้ำท่วม
- [ ] ไม่ใช้ห้อง Server เป็นห้องเก็บของ

13.9 รายงานผลการทดสอบ BCP/DRP (แม่แบบ)

หัวข้อ	รายละเอียด
วันที่/เวลา	15 มีนาคม 2569 08:30–12:00
สถานการณ์	แรนซัมแวร์เข้ารหัสเซิร์ฟเวอร์ HIS ช่วงกลางคืน
รูปแบบ	Tabletop + Technical Restore บนเครื่องทดสอบ + ซ้อม Downtime ที่ห้องบัตรและห้องยา
ผู้เข้าร่วม	ผอ., CIO, ทีม IT, หัวหน้าห้องบัตร, ER, ห้องยา, บริษัท HIS
ผลลัพธ์	ประกาศ BCP 2 ใน 12 นาที, กู้ฐานข้อมูลเสร็จใน 3 ชม. 40 นาที (RTO เป้าหมาย 4 ชม.), ข้อมูลล่าสุด 02:00 (RPO 7 ชม.)
ปัญหาที่พบ	แบบฟอร์มกระดาษที่ห้องยาไม่พอ, รหัสถอดรหัส Backup อยู่กับเจ้าหน้าที่คนเดียว
การปรับปรุง	เพิ่มแบบฟอร์ม, จัดทำซองรหัสผ่านสำรองเก็บที่ ผอ., เพิ่มรอบ Backup เป็นทุก 4 ชม.
ผู้รายงาน/ผู้รับรอง	หัวหน้ากลุ่มงานสารสนเทศ / CIO

📋 หลักฐาน CTAM+ ข้อ 1: รายงาน Backup 7 วัน + รายการระบบที่สำรอง + ภาพชุด Offline/Offsite 📋 หลักฐาน CTAM+ ข้อ 5: เอกสาร BCP + DRP + รายงานผลการทดสอบ (ตามแม่แบบข้างต้น) + ภาพกิจกรรม

⭐ สรุปท้ายบท

- Backup คืองานอันดับแรก ต้องเป็น 3-2-1 และอย่างน้อย 1 ชุด Offline/Immutable
- เข้ารหัส Backup ที่ออกนอกเครื่อง และทดสอบกู้คืนทุกเดือน
- BCP = ให้บริการต่ออย่างไร, DRP = กู้ระบบอย่างไร ต้องซ้อมสถานการณ์ Ransomware อย่างน้อยปีละครั้ง

✏️ คำถามทบทวน

1. อธิบายกฎ 3-2-1-1-0 ทีละตัวเลข
2. RPO กับ RTO ต่างกันอย่างไร
3. Ransomware เข้ารหัส NAS ที่เก็บ Backup ไปด้วย เพราะ NAS ต่ออยู่ในโดเมนเดียวกับเครื่องอื่น ควรออกแบบใหม่อย่างไร
4. ทดสอบกู้คืนฐานข้อมูล HIS ลงเครื่องทดสอบ 1 ครั้ง แล้วบันทึกเวลาที่ใช้เทียบกับ RTO ที่ตั้งไว้



ภาค 4

ตรวจจับและตอบสนอง

Detect & Respond

14 Log Management และ SIEM ด้วย Wazuh

15 Threat Intelligence ด้วย NCSA Blacklist

16 Vulnerability Assessment และ Penetration Testing

17 การรับมือเหตุการณ์และการแจ้งเหตุ



ภาค 4 · ตรวจจับและตอบสนอง บทที่ 14

Log Management และ SIEM ด้วย Wazuh

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ วางระบบเก็บ Log ให้ครบ 6 ประเภท และเก็บไม่น้อยกว่า 90 วัน
- ✔️ ติดตั้ง Wazuh (SIEM/XDR โอเพนซอร์ส) และลง Agent บน Windows/Linux
- ✔️ ตั้งกฎตรวจจับให้ครอบคลุม 6 ด้านตาม CTAM+ ข้อ 10
- ✔️ ใช้ Active Response บล็อกผู้โจมตีอัตโนมัติ

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 3 (8, 11), ข้อ 9, 10 / ตัวชี้วัด v2.1 ข้อ 8.11, 11.2, 11.3

14.1 Log ที่ต้องเก็บ

ประเภท (CTAM+ ข้อ 9)	แหล่ง	ตัวอย่างเหตุการณ์
System Logs	Windows System, Linux syslog/journald	บริการหยุด, รีบูต
Access Logs	Web Server, Proxy, Firewall	ใครเข้า URL ใด จาก IP ใด
Authentication Logs	Windows Security (4624/4625), `/var/log/auth.log`, VPN	Login สำเร็จ/ล้มเหลว
Authorization Logs	sudo, การเปลี่ยนสิทธิ์ AD (4728/4732), GRANT ในฐานข้อมูล	ผู้ใช้ถูกเพิ่มเข้ากลุ่ม Admin
Error Logs	Web/App/DB Error Log	SQL Error ที่อาจมาจาก SQL Injection
Application Logs	HIS, ModSecurity Audit, ClamAV, Backup Log	การเปิดดูเวชระเบียน, การโจมตีเว็บ

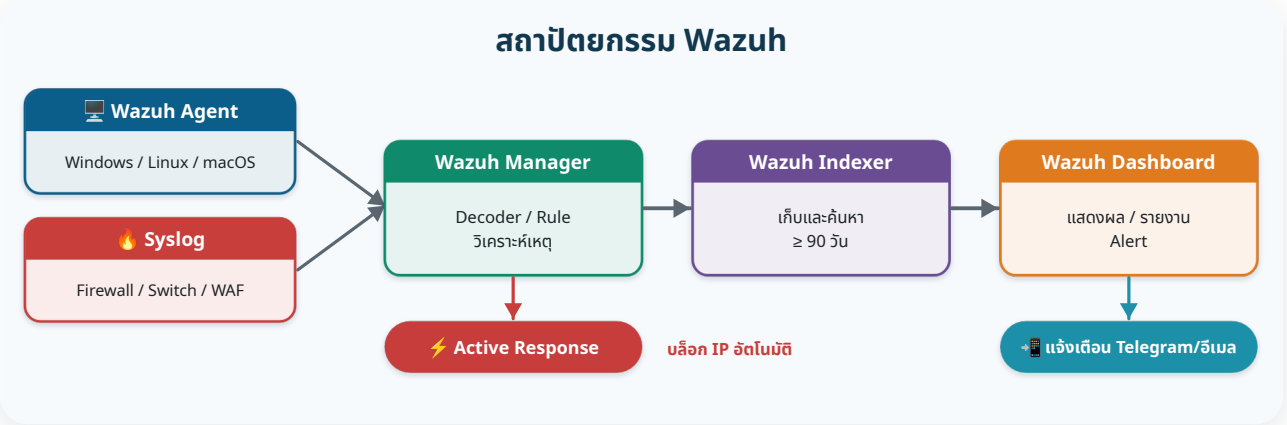
หลักการ

1. **เวลาต้องตรงกัน (Time Sync)** ทุกอุปกรณ์ใช้ NTP เดียวกัน มิฉะนั้นเชื่อมโยงเหตุการณ์ไม่ได้และใช้เป็นหลักฐานไม่ได้

2. **รวมศูนย์** ส่ง Log ออกจากเครื่องต้นทางทันที เพราะผู้โจมตีมักลบ Log ในเครื่อง
3. **เก็บไม่น้อยกว่า 90 วัน** ตาม พ.ร.บ.คอมพิวเตอร์ (แนะนำ 120–180 วันเพื่อเผื่อการสืบสวน)
4. **ป้องกันการแก้ไข** จำกัดผู้เข้าถึง Log Server และทำ Hash/สำรอง Log
5. **มีคนอ่าน** ตั้งการแจ้งเตือนและทบทวนเป็นประจำ

14.2 รู้จัก Wazuh

Wazuh เป็นแพลตฟอร์มความปลอดภัยโอเพนซอร์ส (SIEM + XDR) ใช้ได้ฟรี ประกอบด้วย



▲ ภาพที่ 14.1 สถาปัตยกรรม Wazuh

ความสามารถที่ตอบเกณฑ์ได้

- รวบรวมและวิเคราะห์ Log (ข้อ 9, 10)
- File Integrity Monitoring (FIM) ตรวจไฟล์สำคัญถูกแก้ไข
- ตรวจมัลแวร์/Rootkit และเชื่อม ClamAV, VirusTotal, YARA (ข้อ 2, 10)
- Vulnerability Detection จากรายการซอฟต์แวร์ของแต่ละเครื่อง (ข้อ 11)
- Security Configuration Assessment ตาม CIS Benchmark (ข้อ 6)
- Inventory ฮาร์ดแวร์และซอฟต์แวร์ (ข้อ 12, 15)
- Active Response

ขนาดเครื่องที่แนะนำ (All-in-one)

จำนวน Agent	CPU	RAM	Disk (เก็บ 90 วัน)
1–25	4 vCPU	8 GB	100–200 GB
25–50	8 vCPU	8–16 GB	200–500 GB
50–100	8 vCPU	16 GB	500 GB ขึ้นไป

> ขนาดดิสก์ขึ้นกับปริมาณ Log จริง ให้ติดตามการใช้พื้นที่ช่วงสัปดาห์แรกแล้วคำนวณใหม่

💡 **แนวทางระดับจังหวัด:** สสจ. ตั้ง Wazuh กลางหนึ่งชุด แล้วให้โรงพยาบาลชุมชนส่ง Agent เข้ามาผ่าน VPN/MOPH Network โดยแยก **Agent Group** ตามหน่วยงาน ช่วยลดภาระของโรงพยาบาลที่มีบุคลากรน้อย และทีมจังหวัดช่วยเฝ้าระวังได้

14.3 Lab: ติดตั้ง Wazuh แบบ All-in-one 🧪 LAB

```
# บน Ubuntu Server LTS ที่ติดตั้งใหม่ (ดูเวอร์ชันล่าสุดที่ documentation.wazuh.com แล้วแทน 4.x)
curl -sO https://packages.wazuh.com/4.x/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
```

เมื่อติดตั้งเสร็จ สคริปต์จะแสดงรหัสผ่านของผู้ใช้ `admin` ให้ **จดเก็บในที่ปลอดภัยและเปลี่ยนรหัสผ่านทันที**

```
# ดูรหัสผ่านทั้งหมดที่สร้าง
sudo tar -O -xvf wazuh-install-files.tar wazuh-install-files/wazuh-passwords.txt
```

เปิดเบราว์เซอร์ `https://<IP-Wazuh>` แล้ว Login

หลังติดตั้ง ให้ทำทันที

- [ ] เปลี่ยนรหัสผ่าน `admin` และสร้างบัญชีรายบุคคล
- [ ] จำกัดการเข้าถึง Dashboard (443) เฉพาะ IT VLAN หรือผ่าน VPN/Cloudflare Access
- [ ] ตั้ง NTP
- [ ] สำรอง `/var/ossec/etc` (ค่าตั้งค่าและกฎ)

⚠️ ห้ามเปิดหน้า Wazuh Dashboard หรือ API (55000) สู่อินเทอร์เน็ตโดยตรง และอย่าเก็บรหัสผ่านไว้ในไฟล์ข้อความบนเครื่องหรือในกลุ่มแชท

บังคับใช้รหัสผ่านในการลงทะเบียน Agent

ป้องกันไม่ให้ใครก็ได้นำเครื่องมาลงทะเบียนกับ Wazuh ของหน่วยงาน

```
# สร้างรหัสลงทะเบียน (ใช้ค่าสุ่ม ไม่ใช้ชื่อหน่วยงาน)
openssl rand -base64 24 | sudo tee /var/ossec/etc/authd.pass
sudo chmod 640 /var/ossec/etc/authd.pass && sudo chown root:wazuh /var/ossec/etc/authd.pass
```

แก้ `/var/ossec/etc/ossec.conf` ส่วน `<auth>` (หรือผ่าน Dashboard: Server management → Settings → Edit configuration)

```
<auth>
  <use_password>yes</use_password>
```

```
</auth>
```

```
sudo systemctl restart wazuh-manager
```

14.4 ติดตั้ง Agent

Windows (PowerShell แบบ Administrator)

```
# เปลี่ยน 4.x.x-1 เป็นเวอร์ชันเดียวกับ Manager หรือต่ำกว่า
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.x.x-1.msi -OutFile
$env:tmp\wazuh-agent.msi
msiexec.exe /i $env:tmp\wazuh-agent.msi /q `
  WAZUH_MANAGER='10.10.30.10' `
  WAZUH_REGISTRATION_PASSWORD='<รหัสลงทะเบียน>' `
  WAZUH_AGENT_GROUP='default,hospital-a' `
  WAZUH_AGENT_NAME='HOSA-OPD-PC01'
NET START WazuhSvc
```

> 💡 ตั้งชื่อ Agent ให้สื่อความหมาย เช่น `<รหัสหน่วยงาน>-<จุดบริการ>-<เลขเครื่อง>` จะช่วยค้นหาและทำรายงานได้ง่าย

Linux (Ubuntu/Debian)

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | sudo gpg --no-default-keyring --keyring gnupg-
ring:/usr/share/keyrings/wazuh.gpg --import && sudo chmod 644 /usr/share/keyrings/wazuh.gpg
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg] https://packages.wazuh.com/4.x/apt/ stable main" |
sudo tee /etc/apt/sources.list.d/wazuh.list
sudo apt update
sudo WAZUH_MANAGER='10.10.30.10' WAZUH_REGISTRATION_PASSWORD='<รหัสลงทะเบียน>' \
     WAZUH_AGENT_GROUP='default,servers' apt install -y wazuh-agent
sudo systemctl enable --now wazuh-agent
```

จัดการ Agent

```
sudo /var/ossec/bin/agent_control -l          # รายการ Agent และสถานะ
sudo /var/ossec/bin/manage_agents              # เมนูลบ/แก้ไข Agent
```

อุปกรณ์ที่ลง Agent ไม่ได้ (Firewall, Switch, WAF Appliance)

ส่ง Syslog เข้า Wazuh Manager โดยเพิ่มใน `ossec.conf`

```
<remote>
  <connection>syslog</connection>
  <port>514</port>
  <protocol>udp</protocol>
  <allowed-ips>10.10.0.1/32</allowed-ips>   <!-- IP ของ Firewall -->
</remote>
```

บน FortiGate: Log & Report → Log Settings → Remote Logging → Syslog → ใส่ IP ของ Wazuh

14.5 อ่าน Log เพิ่มเติมจาก Agent

แก้ที่ Group Configuration (Dashboard: Agents management → Groups → เลือกกลุ่ม → Edit `agent.conf`) เพื่อให้ทุกเครื่องในกลุ่มได้ค่าเดียวกัน

```
<agent_config os="Linux">
  <!-- Nginx -->
  <localfile><log_format>syslog</log_format><location>/var/log/nginx/access.log</location></localfile>
  <localfile><log_format>syslog</log_format><location>/var/log/nginx/error.log</location></localfile>
  <!-- ModSecurity (JSON) -->
  <localfile><log_format>json</log_format><location>/var/log/modsec_audit.log</location></localfile>
  <!-- ClamAV -->
  <localfile><log_format>syslog</log_format><location>/var/log/clamav/nightly.log</location>
</localfile>
  <!-- MariaDB audit -->
  <localfile><log_format>syslog</log_format><location>/var/log/mysql/audit.log</location></localfile>
  <!-- File Integrity Monitoring เว็บ และไฟล์ตั้งค่า -->
  <syscheck>
    <directories realtime="yes" report_changes="yes">/var/www</directories>
    <directories check_all="yes">/etc</directories>
  </syscheck>
</agent_config>

<agent_config os="Windows">
  <localfile><location>Microsoft-Windows-Windows Defender/Operational</location>
<log_format>eventchannel</log_format></localfile>
  <localfile><location>Microsoft-Windows-Sysmon/Operational</location>
<log_format>eventchannel</log_format></localfile>
</agent_config>
```

💡 ติดตั้ง **Sysmon** บน Windows เครื่องสำคัญ (ใช้ชุดค่าตั้งค่าที่เป็นที่นิยม เช่น SwiftOnSecurity หรือ Olaf Hartong) จะทำให้ Wazuh เห็นการรันโปรแกรมและการเชื่อมต่อเครือข่าย ช่วยตรวจจับแรนซัมแวร์ได้ดีขึ้นมาก

14.6 ตรวจจับ 6 ด้านตาม CTAM+ ข้อ 10

#	ด้าน	วิธีทำใน Wazuh	กฎ/ตัวอย่าง
1	การบุกรุก, Brute Force, Port Scan	กฎในตัวสำหรับ SSH/Windows/Web Login ล้มเหลวหลายครั้ง, รับ Log IPS/Port Scan จาก Firewall หรือ Suricata	Rule 5712 (SSH brute force), 60204 (Windows multiple logon failures), กฎ FortiGate IPS
2	Malware/Virus	Log ClamAV, Windows Defender, Rootcheck, VirusTotal Integration	กลุ่มกฎ `clamd`, `windows_defender`, `rootcheck`
3	Blacklist IP	CDB List จาก NCSA Blacklist + กฎกำหนดเอง	Rule 100100 (ด้านล่าง)
4	Unauthorized Access	FIM ไฟล์สำคัญ, Windows 4720/4728/4732, sudo ล้มเหลว, Login ฐานข้อมูลจาก IP ที่ไม่อนุญาต	กลุ่ม `syscheck`, `win_group_changed`
5	DDoS	Frequency Rule จาก Web/Firewall Log, IPS Anomaly ของ Firewall	Rule 100200 (ด้านล่าง)
6	Data Breach	Audit Log ฐานข้อมูล (SELECT INTO OUTFILE, Query ปริมาณมาก), FIM โฟลเดอร์ Export, Traffic ขาออกผิดปกติจาก Firewall	Rule 100300 (ด้านล่าง)

กฎกำหนดเอง `/var/ossec/etc/rules/local_rules.xml`

3) Blacklist IP จาก NCSA ดาวน์โหลดรายการเป็น CDB List (บทที่ 15 มีระบบที่ Export รูปแบบนี้ให้อัตโนมัติ)

```
# รูปแบบไฟล์: หนึ่ง IP ต่อหนึ่งบรรทัด ตามด้วย ":"  เช่น 203.0.113.5:
sudo curl -s http://ncsa-dashboard.local:3939/export/wazuh -o /var/ossec/etc/lists/ncsa-blacklist
sudo chown wazuh:wazuh /var/ossec/etc/lists/ncsa-blacklist
```

เพิ่มใน `ossec.conf` ส่วน `<ruleset>`

```
<list>etc/lists/ncsa-blacklist</list>
```

กฎ

```
<group name="local,threat_intel,">
  <rule id="100100" level="12">
    <if_group>web|sshd|authentication_failed|authentication_success|firewall</if_group>
    <list field="srcip" lookup="address_match_key">etc/lists/ncsa-blacklist</list>
    <description>เชื่อมต่อจาก IP ใน NCSA Blacklist: $(srcip)</description>
    <mitre><id>T1071</id></mitre>
```

```
  </rule>
</group>
```

5) DDoS ระดับเว็บ (คำขอจาก IP เดียวจำนวนมาก)

```
<group name="local,web,ddos,">
  <rule id="100200" level="10" frequency="300" timeframe="60">
    <if_matched_group>web</if_matched_group>
    <same_source_ip />
    <description>คำขอเว็บจาก $(srcip) มากกว่า 300 ครั้งใน 60 วินาที (สงสัย DoS/Scraping)</description>
  </rule>
</group>
```

6) Data Breach — การส่งออกข้อมูลจากฐานข้อมูลเป็นไฟล์

```
<group name="local,database,data_breach,">
  <rule id="100300" level="12">
    <match>INTO OUTFILE|INTO DUMPFILE</match>
    <description>มีการส่งออกข้อมูลจากฐานข้อมูลเป็นไฟล์ (สงสัยข้อมูลรั่วไหล)</description>
  </rule>
</group>
```

ทดสอบกฎก่อนใช้งานจริง

```
sudo /var/ossec/bin/wazuh-logtest     # วางบรรทัด Log ตัวอย่างเพื่อดูว่าตรงกฎใด
sudo systemctl restart wazuh-manager
```

🧪 Lab: สร้างเหตุการณ์ทดสอบเพื่อเก็บหลักฐาน (ทำในเครื่องทดสอบ)

ด้าน	วิธีจำลอง
Brute Force	SSH เข้าเครื่องทดสอบด้วยรหัสผิด 8 ครั้ง
Port Scan	`nmap -sS <เครื่องทดสอบ>` ผ่าน Firewall ที่เปิด IPS
Malware	ดาวน์โหลดไฟล์ทดสอบ **EICAR** (ไฟล์มาตรฐานที่ไม่อันตราย) แล้วให้ ClamAV/Defender สแกน
Blacklist IP	เพิ่ม IP ทดสอบเข้า CDB List แล้ว `curl` จาก IP นั้นไปยังเว็บที่ส่ง Log
Unauthorized Access	แก้ไขไฟล์ใน `/var/www` หรือเพิ่มผู้ใช้เข้ากลุ่ม Administrators
Data Breach	รัน `SELECT ... INTO OUTFILE` บนฐานข้อมูลทดสอบ

ถ่ายภาพ Alert ที่เกิดขึ้นบน Dashboard พร้อมเวลา เป็นหลักฐาน CTAM+ ข้อ 10

14.7 Active Response: บล็อกอัตโนมัติ

ตัวอย่างบล็อก IP ที่ทำ Brute Force SSH เป็นเวลา 1 ชั่วโมง (เพิ่มใน `ossec.conf` ของ Manager)

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5712,100100</rules_id>
  <timeout>3600</timeout>
</active-response>
```

⚠️ ระวังบล็อกผิดตัว (เช่น IP ของ NAT ภายในที่ผู้ใช้หลายคนใช้ร่วมกัน) ให้เพิ่ม IP ภายในและ IP ของผู้ดูแลไว้ใน `<white_list>` ของ `<global>` ก่อนเปิดใช้

14.8 เก็บ Log 90 วัน (และพิสูจน์ได้)

Index ของ Alert

ใน Dashboard → Indexer management → Index Management → State management policies → Create policy

```
{
  "policy": {
    "description": "Wazuh alerts: เก็บ 120 วันแล้วลบ",
    "default_state": "hot",
    "states": [
      { "name": "hot", "actions": [],
        "transitions": [ { "state_name": "delete", "conditions": { "min_index_age": "120d" } } ] },
      { "name": "delete", "actions": [ { "delete": {} } ], "transitions": [] }
    ],
    "ism_template": [ { "index_patterns": ["wazuh-alerts-*"], "priority": 100 } ]
  }
}
```

Log ดิบทั้งหมด (Archives)

เปิดเก็บทุกเหตุการณ์ (ไม่ใช่เฉพาะที่เป็น Alert) ใน `ossec.conf`

```
<global>
  <logall>yes</logall>
</global>
```

ไฟล์จะอยู่ที่ `/var/ossec/logs/archives/YYYY/Mon/` และถูกบีบอัดรายวัน ให้สำรองออกนอกเครื่องและลบที่เก่ากว่ากำหนด

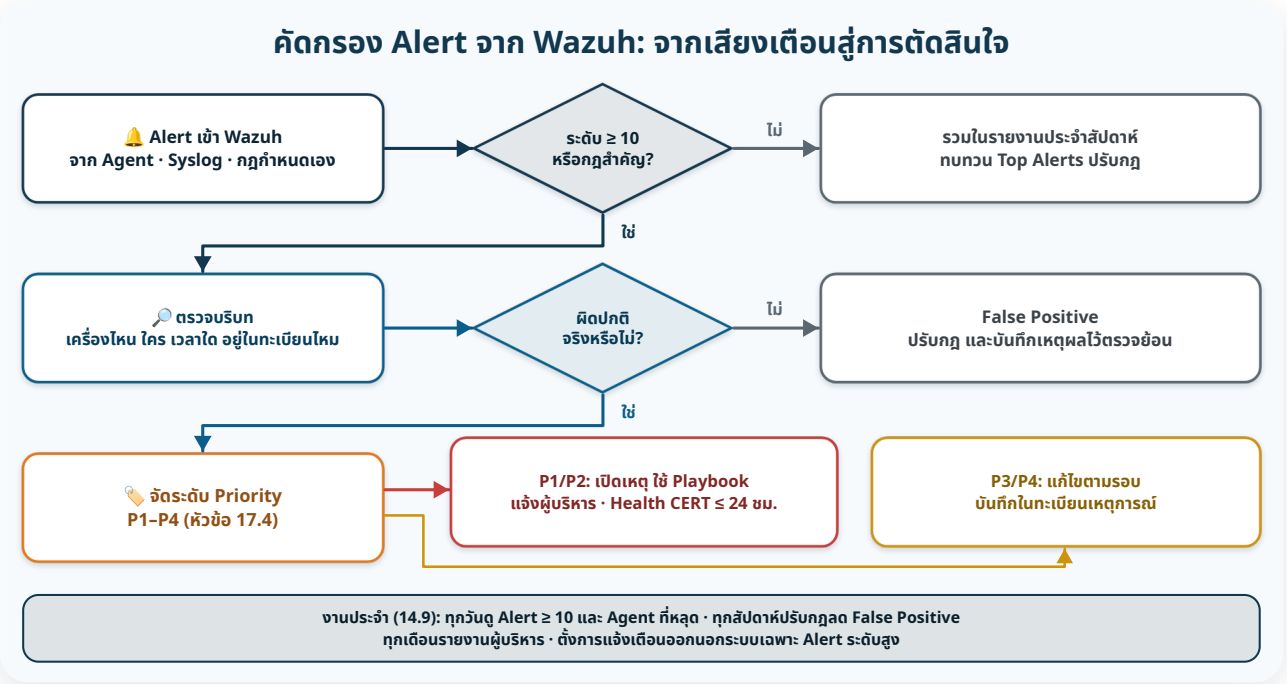
```
# ลบ archives ที่เก่ากว่า 180 วัน (หลังจากสำรองออกแล้ว)
echo '0 3 * * * root find /var/ossec/logs/archives -type f -mtime +180 -delete' | sudo tee
/etc/cron.d/wazuh-archive-retention
```

📋 หลักฐาน CTAM+ ข้อ 9: ภาพการค้นหาใน Discover ของ Dashboard ที่ตั้งช่วงเวลาเป็นวันที่ 90 ย้อนหลัง และแสดงผล Log ได้ หรือรายการไฟล์ archives ที่มีวันที่ครบ 90 วัน

14.9 งานประจำของผู้ดูแล SIEM

ความถี่	งาน
ทุกวัน	ดู Alert ระดับ ≥ 10, ตรวจ Agent ที่ Disconnected
ทุกสัปดาห์	ทบทวน Top Alerts, ปรับกฎลด False Positive, ตรวจ Vulnerability ระดับ Critical
ทุกเดือน	ทำรายงานสรุปให้ผู้บริหาร (จำนวน Alert แยกประเภท, เหตุการณ์ที่จัดการ, ช่องโหว่ค้าง), ทบทวน Log การเข้าถึง (CTAM+ ข้อ 3.11)
ทุกไตรมาส	อัปเดต Wazuh, ทบทวน Agent Group และกฎ, ทดสอบ Lab 6 ด้านซ้ำ

เมื่อดู Alert ประจำวัน ให้คัดกรองตามภาพที่ 14.2 เพื่อแยก False Positive ออกให้เร็ว แล้วส่งเหตุจริงเข้ากระบวนการรับมือในบทที่ 17 ทุกครั้งที่ปรับกฎ ให้บันทึกเหตุผลไว้เป็นหลักฐาน



▲ ภาพที่ 14.2 คัดกรอง Alert จาก Wazuh จากเสียงเตือนสู่การตัดสินใจ

การแจ้งเตือนออกนอกระบบ

Wazuh รองรับ Integration ไป Slack, PagerDuty, Email และ Custom Webhook (เช่น ไป LINE Messaging API หรือ Telegram ผ่านสคริปต์ใน `/var/ossec/integrations/`) ตั้งให้แจ้งเฉพาะ Alert ระดับสูง เพื่อไม่ให้ทีมชินชากับการแจ้งเตือน

14.10 ทางเลือกอื่น

- **Graylog** สำหรับรวม Log และค้นหา ใช้คู่กับ Wazuh ได้
- **Security Onion** รวม Suricata, Zeek และ Elastic สำหรับเฝ้าระวังเครือข่าย
- **บริการ CSOC/MSSP** เช่น โครงการ CO-CSIRT ที่มีทีมเฝ้าระวัง 24×7 (บทที่ 17)

⭐ สรุปท้ายบท

- เก็บ Log 6 ประเภท รวมศูนย์ เวลาตรงกัน และเก็บอย่างน้อย 90 วัน
- Wazuh ติดตั้งได้ฟรี ตอบ CTAM+ ได้หลายข้อพร้อมกัน (2, 6, 9, 10, 11, 12, 15)
- ต้องตั้งกฎให้ครอบคลุม 6 ด้าน และทดสอบด้วย Lab เพื่อมีหลักฐาน Alert จริง
- SIEM มีค่าเมื่อมีคนดูและตอบสนองเท่านั้น

✏️ คำถามทบทวน

1. Log ที่ CTAM+ ข้อ 9 ต้องการมี 6 ประเภทอะไรบ้าง และต้องเก็บอย่างน้อยกี่วัน
2. ทำไมทุกอุปกรณ์ต้องตั้งเวลาจาก NTP เดียวกัน
3. Wazuh แจ้ง Alert ระดับ 12 ว่ามี Login ผิดซ้ำจำนวนมากที่ VPN จาก IP ต่างประเทศ ควรทำอะไรต่อ
4. ทำ Lab ทดสอบกฎ Wazuh 1 ด้าน (เช่น Login ผิดซ้ำ) แล้วเก็บภาพหน้าจอ Alert เป็นหลักฐาน



ภาค 4 · ตรวจจับและตอบสนอง บทที่ 15

Threat Intelligence ด้วย NCSA Blacklist

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ เข้าใจ Threat Intelligence และ IOC (Indicator of Compromise)
- ✔️ ใช้ NCSA Blacklist Feed ของ สกมช. ป้องกันเครือข่าย
- ✔️ ติดตั้ง NCSA Blacklist SOC Dashboard (โอเพนซอร์ส) และเชื่อมกับ FortiGate/pfSense/Wazuh

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 3.12 (Feeds IOC), ข้อ 10.3 (Blacklist IP)

15.1 Threat Intelligence คืออะไร

Threat Intelligence คือข้อมูลเกี่ยวกับภัยคุกคามที่ผ่านการวิเคราะห์แล้ว นำไปใช้ป้องกันหรือตรวจจับได้ หน่วยย่อยที่ใช้งานบ่อยที่สุดคือ **IOC (Indicator of Compromise)** เช่น

- IP Address ของเครื่องที่โจมตีหรือเครื่องสั่งการมัลแวร์ (C2)
- Domain ของเว็บฟิชชิงหรือแจกจ่ายมัลแวร์
- File Hash (MD5/SHA1/SHA256) ของมัลแวร์

แหล่งข้อมูลที่หน่วยงานสาธารณสุขควรใช้

แหล่ง	ลักษณะ
NCSA Blacklist Feed (สกมช.)	รายการ IP/Domain/Hash ที่ สกมช. รวบรวม เผยแพร่แบบ CC0 ใช้ได้ฟรี
ThaiCERT ข่าวและประกาศเตือน	สถานการณ์ภัยในประเทศ
Health CERT (ศทส.สป.สธ.)	ประกาศเตือนเฉพาะภาคสาธารณสุข
Feed สาธารณะต่างประเทศ	blocklist.de, Emerging Threats, abuse.ch (URLhaus, MalwareBazaar), CERT.PL
บริการตรวจสอบ	VirusTotal, AbuseIPDB, Shodan, GreyNoise, URLScan

15.2 NCSA Blacklist SOC Dashboard

NCSA Blacklist SOC Dashboard เป็นซอฟต์แวร์โอเพนซอร์ส (MIT License) ที่ **กลุ่มงานสุขภาพดิจิทัล สำนักงานสาธารณสุขจังหวัดมุกดาหาร** พัฒนาต่อยอดจาก NCSA Blacklist Feed เพื่อใช้ในหน่วยงานสาธารณสุขไทย (ไม่ใช่ผลิตภัณฑ์ทางการของ สกมช.) ที่ `github.com/thering999/ncsa-blacklist`

ความสามารถหลัก

- **ตรวจสอบ IP/Domain/Hash** จาก Feed แบบทันที พร้อม Risk Score, GeoIP, ASN และลิงก์ OSINT
- **Bulk Check / CIDR Scan / Log Scan** วางรายการหรือ Log แล้วหาค่าที่อยู่ใน Blacklist
- **Watch List / Allow List** ติดตามค่าที่สนใจ และยกเว้น False Positive (ค่าที่อยู่ใน Allow List จะไม่ถูกส่งออกไปยัง Firewall)
- **Export หลายรูปแบบ** สำหรับอุปกรณ์ต่าง ๆ: Plain-text EDL, iptables/ipset, dnsmasq, **Wazuh CDB**, CSV, JSON, **STIX 2.1** และ **TAXII 2.1 Server**
- **Auto-Block Pipeline** ส่ง IP ใหม่ไปยัง Address Group บน FortiGate อัตโนมัติหลังซิงก์ (จำกัดจำนวนต่อรอบเพื่อความปลอดภัย)
- **Wazuh Proxy** ดู Alert จาก Wazuh ในหน้าเดียวกัน
- **SOC Dashboard** แสดงคะแนนความพร้อมตาม CTAM+ 17 เกณฑ์, MOPH Cybersecurity KPI, NIST CSF, MTTD/MTTR
- **Incident Response** Playbook 5 สถานการณ์ (Ransomware, Web Attack, PDPA Data Breach, DDoS, Malware/APT), Incident Log พร้อม **PDPA Mode แจ้งเตือนเมื่อใกล้ครบ 72 ชั่วโมง**
- **Asset & Compliance** Asset Inventory, SSL Monitor, Vulnerability Tracker (เชื่อม NVD), Training Tracker, PDPA Data Flow Register
- ความปลอดภัยของตัวระบบเอง: TOTP 2FA, API Key แบบ Hash, ป้องกัน Brute Force, Audit Log

15.3 Lab: ติดตั้งด้วย Docker LAB

```bash
# 1) ติดตั้ง Docker
curl -fsSL https://get.docker.com | sh
sudo usermod -aG docker $USER && newgrp docker
docker --version && docker compose version

# 2) ดาวน์โหลดโปรแกรม
git clone https://github.com/thering999/ncsa-blacklist.git
cd ncsa-blacklist

# 3) ตั้งค่า
cp .env.example .env
nano .env
```

ค่าขั้นต่ำใน `.env`

```
PORT=3939
DATA_DIR=/data
ADMIN_TOKEN=<สุ่มค่ายาว เช่นจาก openssl rand -hex 32>
```

```
# 4) เริ่มระบบ
docker compose up -d

# 5) ดึงข้อมูล Feed ครั้งแรก (ครั้งต่อไประบบซิงก์อัตโนมัติทุก 6 ชั่วโมง)
docker compose exec ncsa-blacklist node src/fetch.js
#   (ถ้าชื่อ Service ต่างไป ให้ดูด้วย docker compose ps)

# 6) เปิดใช้งาน
#    http://<IP-เครื่อง>:3939  → ทำ Setup Wizard เลือกประเภทหน่วยงาน (sw./สสจ.)
```

⚠️ ระบบนี้ควรเปิดให้เข้าถึงเฉพาะภายใน (LAN/IT VLAN) หรือผ่าน Reverse Proxy ที่มี HTTPS และเปิด 2FA ให้ผู้ใช้ทุกคน รายละเอียดการติดตั้งแบบ Production (Nginx/Caddy + HTTPS) อยู่ใน README ของโครงการ

15.4 เชื่อมกับอุปกรณ์ป้องกัน

FortiGate (Threat Feed)

Security Fabric → External Connectors → Threat Feeds → **IP Address**

- URL: `http://<ncsa-dashboard>:3939/export/txt/ip`
- Refresh Rate: 60 นาที จากนั้นนำ Feed ไปใส่ใน Policy BLOCK ขาเข้าและขาออก (บทที่ 9) และทำแบบเดียวกันกับ `/export/txt/domain` ใน DNS Filter

💡 อุปกรณ์ที่รับรายการได้จำกัด ใช้ `?days=30` เพื่อดึงเฉพาะรายการที่เพิ่มใหม่ใน 30 วัน (Delta Feed)

pfSense (pfBlockerNG) / OPNsense (URL Table Alias)

ใส่ URL `/export/txt/ip` เป็น IPv4 Source แล้วสร้างกฎ Block

Linux Server (iptables/ipset)

```
curl -s http://<ncsa-dashboard>:3939/export/iptables -o /usr/local/sbin/ncsa-block.sh
less /usr/local/sbin/ncsa-block.sh      # อ่านสคริปต์ก่อนรันทุกครั้ง
sudo bash /usr/local/sbin/ncsa-block.sh
```

DNS ภายใน (dnsmasq/Pi-hole)

ใช้ `/export/dnsmasq` เพื่อให้ Domain อันตรายถูกตอบเป็น `0.0.0.0`

Wazuh (CDB List)

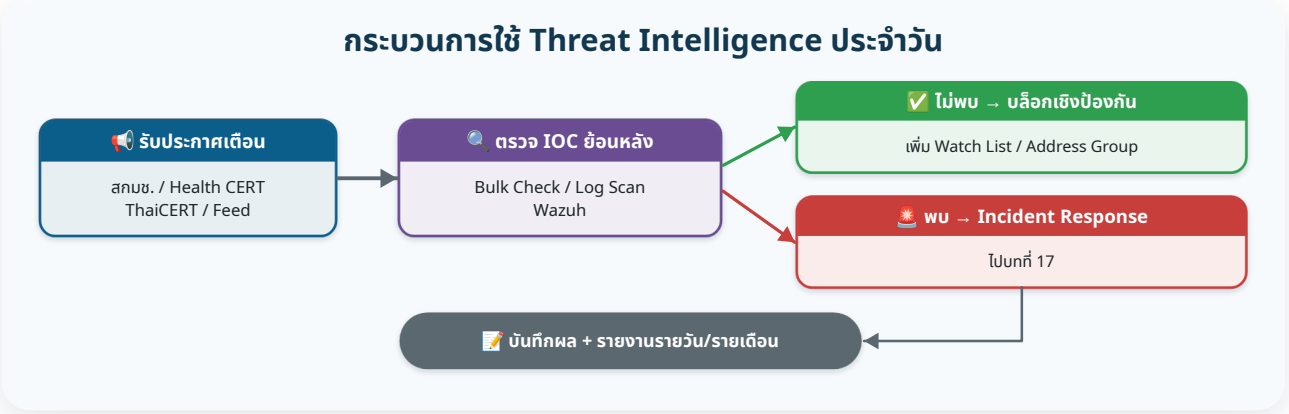
```
# ตั้งเวลาอัปเดตรายการทุก 6 ชั่วโมง บนเครื่อง Wazuh Manager
sudo tee /etc/cron.d/ncsa-wazuh >/dev/null <<'EOF'
15 */6 * * * root curl -sf http://ncsa-dashboard.local:3939/export/wazuh -o /var/ossec/etc/lists/ncsa-blacklist.new && mv /var/ossec/etc/lists/ncsa-blacklist.new /var/ossec/etc/lists/ncsa-blacklist && chown wazuh:wazuh /var/ossec/etc/lists/ncsa-blacklist && systemctl restart wazuh-manager
EOF
```

แล้วใช้กฎ 100100 ในบทที่ 14 แจ้งเตือนเมื่อมีการเชื่อมต่อจาก IP ใน Blacklist

MISP / OpenCTI

ใช้ TAXII 2.1 (`/taxii2/`) หรือ STIX Export (`/export/stix`) เพื่อแลกเปลี่ยน IOC กับเครือข่าย

15.5 กระบวนการใช้ Threat Intelligence ประจำวัน



▲ ภาพที่ 15.1 กระบวนการใช้ Threat Intelligence ประจำวัน

เมื่อหน่วยงานพบ IoC จากเหตุของตนเอง ให้ส่งต่อให้เครือข่ายตามโฟลว์ W3 ในบทที่ 24 (ติดป้าย TLP และลบข้อมูลอ่อนไหวก่อน) เพื่อให้โรงพยาบาลอื่นบล็อกได้ทันเวลา

15.6 ข้อควรระวัง

- **False Positive**: IP ของบริการที่ใช้ร่วมกัน (CDN, Cloud) อาจอยู่ใน Feed ให้ตรวจสอบก่อนบล็อกถาวร และใช้ Allow List สำหรับ IP ของหน่วยงานตนเองและคู่ค้าสำคัญ
- **ขนาดรายการ**: อุปกรณ์บางรุ่นรับรายการได้จำกัด ให้ใช้ Delta Feed หรือเลือกเฉพาะประเภท
- **ความสดของข้อมูล**: ตรวจว่าการซิงก์ยังทำงาน (หน้า `/status` บอกอายุของ Feed)

- **อย่าส่ง Log ที่มีข้อมูลผู้ป่วย** ไปตรวจในบริการภายนอก

📋 หลักฐาน: ภาพ Threat Feed บน Firewall ที่ดึงสำเร็จ (จำนวนรายการ + เวลาอัปเดตล่าสุด), ภาพ Alert ของ Wazuh กฎ Blacklist IP

⭐ สรุปท้ายบท

- NCSA Blacklist Feed เป็นแหล่ง IOC ฟรีที่หน่วยงานไทยควรใช้
- NCSA Blacklist SOC Dashboard ช่วยแปลง Feed ไปใช้กับ Firewall, DNS, Wazuh ได้ในที่เดียว และมีเครื่องมือ SOC/IR/CTAM+ ประกอบ
- ใช้ Threat Intelligence ทั้งเชิงป้องกัน (บล็อก) และเชิงตรวจจับ (ค้น Log ย้อนหลัง)

✏️ คำถามทบทวน

1. Threat Intelligence ใช้ได้ 2 แบบอะไรบ้าง
2. ทำไมไม่ควรนำ IOC จากทุกแหล่งไปบล็อกทันทีโดยไม่ตรวจ
3. ค้น Log ย้อนหลังแล้วพบว่าเครื่องงานการเงินเคยเชื่อมต่อ IP ใน NCSA Blacklist เมื่อ 3 วันก่อน ควรทำอย่างไร
4. ตั้งค่าดึง NCSA Blacklist Feed เข้า Firewall หรือ Wazuh ของหน่วยงาน และกำหนดรอบอัปเดต



ภาค 4 · ตรวจจับและตอบสนอง บทที่ 16

Vulnerability Assessment และ Penetration Testing

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ แยกความต่างระหว่าง VA กับ Pentest และรู้ว่าควรทำเมื่อใด
- ✔️ สแกนช่องโหว่ระบบของตนเองด้วยเครื่องมือโอเพนซอร์ส (Nmap, Greenbone/OpenVAS, Nuclei, OWASP ZAP)
- ✔️ จัดลำดับความสำคัญการแก้ไข และติดตามจนปิดช่องโหว่ได้จริง
- ✔️ ขอรับบริการทดสอบเจาะระบบจาก ศปช./สกมช. ด้วยแบบ OP01

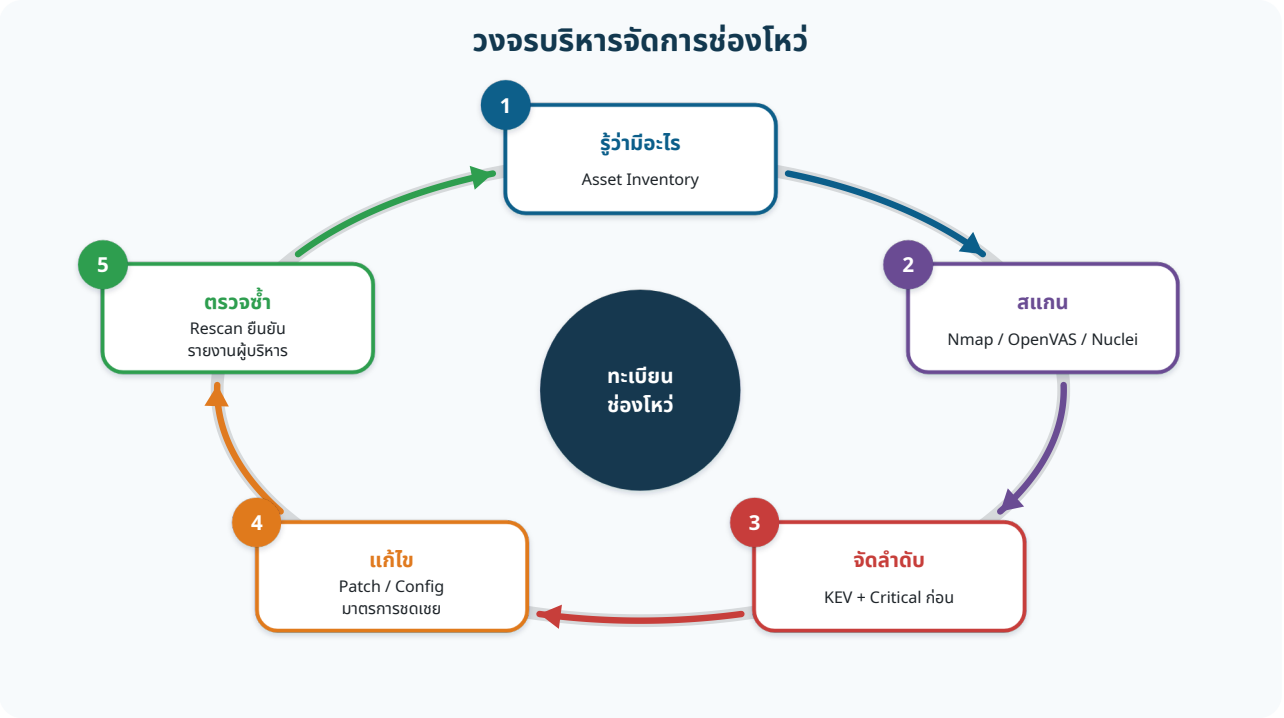
📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 11 (VA), ข้อ 16 (Pentest), ข้อ 6 และ 13 (Patching)

16.1 VA กับ Pentest ต่างกันอย่างไร

	Vulnerability Assessment (VA)	Penetration Testing (Pentest)
คำถามที่ตอบ	“มีช่องโหว่อะไรบ้าง”	“ช่องโหว่นั้นถูกใช้เจาะได้จริงหรือไม่ และไปได้ไกลแค่ไหน”
วิธีการ	เครื่องมือสแกนอัตโนมัติ เทียบกับฐานข้อมูลช่องโหว่ (CVE)	ผู้เชี่ยวชาญทดสอบด้วยมือ ใช้เครื่องมือร่วมจำลองการโจมตี
ความถี่แนะนำ	ทุกไตรมาส และหลังเปลี่ยนแปลงระบบสำคัญ	ปีละ 1 ครั้งสำหรับระบบสำคัญ (HIS, เว็บที่เปิดสู่ภายนอก)
ผู้ทำ	ทีม IT ของหน่วยงานทำเองได้	ผู้ทดสอบภายนอกที่มีหนังสืออนุญาต (เช่น ศปช./สกมช., บริษัทที่ว่าจ้าง)
ความเสี่ยงต่อระบบ	ต่ำ (แต่ยังอาจทำให้อุปกรณ์เก่าค้าง)	ปานกลาง ต้องวางแผนและกำหนดขอบเขต

⚠️ **ห้ามสแกนหรือทดสอบระบบที่ไม่ใช่ของตนเอง** หรือไม่ได้รับอนุญาตเป็นลายลักษณ์อักษร การกระทำดังกล่าวอาจเป็นความผิดตาม พ.ร.บ.คอมพิวเตอร์ แม้ทำด้วยเจตนาดี ระบบที่ Vendor หรือ Cloud ดูแล ให้ขออนุญาตเจ้าของระบบก่อน

16.2 วงจรการบริหารจัดการช่องโหว่



ขั้นที่ ① ต้องมาจากทะเบียนทรัพย์สินในบทที่ 7 ระบบที่ไม่อยู่ในทะเบียนจะไม่ถูกสแกน และมักเป็นระบบที่ถูกเจาะ

16.3 Lab 1: สำรวจด้วย Nmap 🧪 LAB

```
sudo apt install -y nmap

# ค้นหาเครื่องที่เปิดอยู่ในวง Server (ไม่สแกนพอร์ต)
sudo nmap -sn 10.10.20.0/24 -oN hosts-server.txt

# สแกนพอร์ตที่ใช้บ่อย + ตรวจเวอร์ชันบริการ
sudo nmap -sS -sV --top-ports 1000 -T3 10.10.20.0/24 -oA scan-server-$(date +%F)

# ตรวจสคริปต์ช่องโหว่พื้นฐาน (ใช้กับเครื่องที่ยืนยันแล้วว่าเป็นของเรา)
sudo nmap -sV --script vuln 10.10.20.15 -oN vuln-his.txt

# ตรวจ TLS ของเว็บ
nmap --script ssl-enum-ciphers -p 443 www.hospital.example
```

สิ่งที่ต้องดูในผล

- พอร์ตฐานข้อมูล (3306, 5432, 1433) เปิดให้วง Client หรืออินเทอร์เน็ตเข้าถึงได้หรือไม่
- RDP (3389), SMB (445), Telnet (23), FTP (21) เปิดโดยไม่จำเป็นหรือไม่
- เวอร์ชันซอฟต์แวร์ที่หมดอายุ (เช่น PHP, OpenSSH, Apache, IIS รุ่นเก่า)

💡 ใช้ `-T3` หรือช้ากว่า และหลีกเลี่ยงการสแกนอุปกรณ์การแพทย์ (Monitor, เครื่องวิเคราะห์ Lab, PACS Modality) ในเวลาให้บริการ อุปกรณ์เหล่านี้หลายรุ่นค้างเมื่อถูกสแกน ให้ประสาน Vendor และทำนอกเวลาเสมอ

16.4 Lab 2: สแกนช่องโหว่ด้วย Greenbone (OpenVAS) 🧪 LAB

Greenbone Community Edition เป็นเครื่องมือ VA โอเพนซอร์สที่นิยมที่สุด ติดตั้งแบบ Docker ได้ตามคู่มือทางการที่ `greenbone.github.io/docs` (ขั้นตอนเปลี่ยนตามรุ่น ให้ยึดคู่มือล่าสุด) ภาพรวมการใช้งาน

1. ติดตั้งบนเครื่องแยก (RAM ≥ 8 GB) ที่อยู่ในวงที่เข้าถึงเครื่องเป้าหมายได้
2. รอให้ระบบซิงก์ Feed (NVT/SCAP/CERT) ครั้งแรกจนเสร็จ ซึ่งอาจใช้หลายชั่วโมง
3. สร้าง **Target** ตามกลุ่ม (เช่น Server Zone, DMZ) แล้วสร้าง **Task** ใช้ Scan Config “Full and fast”
4. สำหรับ Linux/Windows ที่ต้องการผลลึก ให้ใส่ **Credential** แบบอ่านอย่างเดียวที่สร้างไว้เฉพาะงานสแกน (Authenticated Scan) แล้วปิดบัญชีเมื่อไม่ใช้
5. ตั้งเวลาสแกนรายเดือนนอกเวลาราชการ และ Export รายงานเป็น PDF/CSV เก็บเป็นหลักฐาน CTAM+ ข้อ 11

16.5 Lab 3: เว็บแอปพลิเคชันด้วย Nuclei และ OWASP ZAP 🧪 LAB

```
# Nuclei: ตรวจตาม Template ที่ชุมชนดูแล (CVE, การตั้งค่าผิด, ไฟล์หลุด)
# ติดตั้งจาก Release ทางการที่ github.com/projectdiscovery/nuclei
nuclei -update-templates
nuclei -u https://www.hospital.example -severity critical,high,medium -o nuclei-web.txt

# OWASP ZAP baseline (Passive scan ไม่โจมตี เหมาะกับเว็บที่ใช้งานจริง)
docker run --rm -v $(pwd):/zap/wrk/:rw -t ghcr.io/zaproxy/zaproxy:stable \
  zap-baseline.py -t https://www.hospital.example -r zap-report.html
```

⚠️ ZAP แบบ Active Scan (`zap-full-scan.py`) จะส่งข้อมูลโจมตีจริง อาจสร้างข้อมูลขยะในฐานข้อมูล หรือทำให้เว็บช้า ให้ทำบนเครื่อง Staging เท่านั้น

ตรวจด้วยตนเองเพิ่ม (ตรงกับปัญหาที่พบบ่อยในบทที่ 11)

- เปิด `/.git/` , `/backup.zip` , `/phpinfo.php` , `/phpmyadmin/` ได้หรือไม่
- หน้า Login มีการจำกัดการเดารหัสผ่านหรือไม่
- ค้นด้วย Google `site:hospital.example filetype:xls OR filetype:pdf` เพื่อดูเอกสารที่ไม่ควรเผยแพร่

16.6 จัดลำดับความสำคัญการแก้ไข

ใช้คะแนน **CVSS** เป็นจุดเริ่มต้น แล้วปรับตามบริบทของหน่วยงาน

ระดับ	CVSS	กำหนดแก้ไข (แนะนำ)	ปรับขึ้นเมื่อ
Critical	9.0–10.0	ภายใน 7 วัน (เปิดสู่อินเทอร์เน็ต: 72 ชม.)	อยู่ในรายการ **CISA KEV** (ถูกใช้โจมตีจริงแล้ว)
High	7.0–8.9	ภายใน 30 วัน (เปิดสู่อินเทอร์เน็ตหรือระบบสำคัญ: 14 วัน)	ระบบเก็บข้อมูลผู้ป่วย หรือเข้าถึงได้จากภายนอก
Medium	4.0–6.9	ภายใน 90 วัน	มีหลายช่องโหว่ต่อกันเป็นเส้นทางโจมตี
Low	0.1–3.9	ตามรอบบำรุงรักษา	—

> 💡 **CISA Known Exploited Vulnerabilities (KEV)** ที่ `cisa.gov/known-exploited-vulnerabilities-catalog` คือรายการช่องโหว่ที่มีหลักฐานว่าถูกใช้โจมตีแล้ว หากผลสแกนพบ CVE ที่อยู่ใน KEV ให้ถือเป็นเรื่องด่วนที่สุดไม่ว่าคะแนน CVSS จะเท่าใด ตัวอย่างที่เกี่ยวข้องกับภาคสุขภาพบ่อยคือ อุปกรณ์ VPN/Remote Access (FortiOS, Citrix, Ivanti) ซึ่งเป็นประตูหน้าของหน่วยงาน

ถ้าแก้ไขไม่ได้ทันที (เช่น ระบบ Vendor หรืออุปกรณ์การแพทย์) ให้ใช้ **มาตรการชดเชย** และบันทึกการยอมรับความเสี่ยงโดยผู้บริหาร

- จำกัดการเข้าถึงด้วย Firewall/VLAN ให้เฉพาะเครื่องที่จำเป็น
- ใส่ WAF Rule เฉพาะ (Virtual Patching)
- เพิ่มกฎเฝ้าระวังใน Wazuh

16.7 ทะเบียนช่องโหว่ (Vulnerability Register)

ID	วันที่พบ	ระบบ/IP	ช่องโหว่ (CVE)	ระดับ	KEV	ผู้รับผิดชอบ	กำหนดเสร็จ	วิธีแก้	สถานะ	วันที่ Rescan ยืนยัน
V-2569-001	3 พ.ย.	Web-01	CVE-xxxx-xxxx (PHP)	Critical	ใช่	งาน IT	6 พ.ย.	อัปเกรด PHP 8.3	ปิดแล้ว	7 พ.ย.
V-2569-002	3 พ.ย.	เครื่องวิเคราะห์ Lab	SMBv1 เปิด	High	—	Vendor/งาน IT	3 ธ.ค.	ย้ายเข้า VLAN Medical + ACL	ยอมรับความเสี่ยง (มีมาตรการชดเชย)	—

> 💡 NCSA Blacklist SOC Dashboard (บทที่ 15) มีเมนู Vulnerability Tracker ที่ดึงข้อมูล CVE จาก NVD และติดตามสถานะได้ ใช้แทนตารางนี้ได้

16.8 ขอรับบริการทดสอบเจาะระบบจาก ศปช./สกมช. (แบบ OP01)

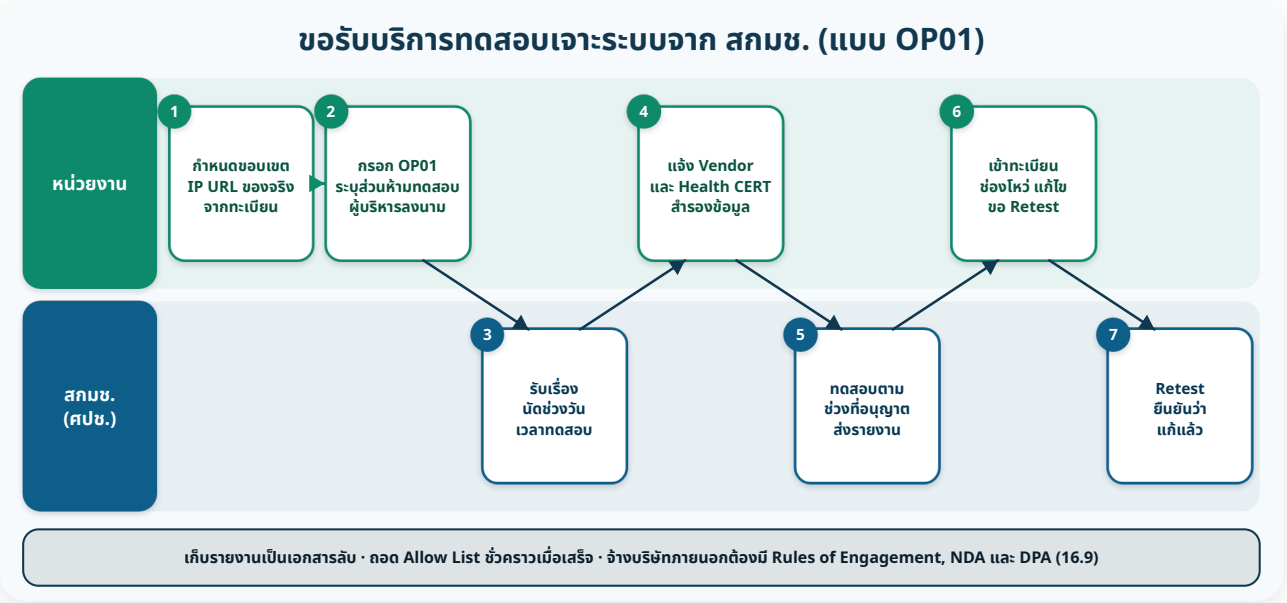
หน่วยงานของรัฐสามารถขอให้ **ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)** ภายใต้ สกมช. ทดสอบหาจุดอ่อนของเครื่องแม่ข่ายและเว็บไซต์ได้ โดยกรอก **แบบขอรับการทดสอบความมั่นคงปลอดภัยของระบบเครื่องแม่ข่ายและเว็บไซต์ (OP01)** ซึ่งเป็นหนังสือยินยอมให้ทดสอบ เนื้อหาหลักของแบบ

หัวข้อในแบบ	สิ่งที่ต้องเตรียม
1. บริเวณที่ให้ทดสอบ	IP Address, Port, URL ที่ **เป็นของหน่วยงานจริง** (ตรวจจากทะเบียนทรัพย์สิน)
2. ส่วนที่ไม่ให้ทดสอบ	ระบบที่อาจกระทบการรักษา เช่น HIS Production ช่วงกลางวัน, อุปกรณ์การแพทย์, ระบบของ Vendor ที่ไม่ได้รับอนุญาต
3. ข้อมูลเพิ่มเติม	เทคโนโลยีที่ใช้, WAF/Firewall ที่อาจบล็อก, ข้อจำกัดอื่น
4. วันและเวลาที่อนุญาต	ช่วงวันเวลาที่ชัดเจน (กำหนดช่วงทำการ เช่น ภายใน 5 วันทำการ)
ผู้ประสานงาน	ชื่อ ตำแหน่ง โทรศัพท์ อีเมล ของผู้ติดต่อด้านเทคนิค (ติดต่อได้ตลอดช่วงทดสอบ)
การลงนาม	หัวหน้าหน่วยงานหรือผู้มีอำนาจ

ขั้นตอนแนะนำ

1. ขอแบบฟอร์มฉบับล่าสุดจาก สกมช. (`ncsa.or.th`) หรือผ่าน ศทส.สป.สธ.
2. แจ้ง Vendor/ผู้ดูแลเว็บ และ Health CERT ล่วงหน้าว่าจะมีการทดสอบ เพื่อไม่ให้สับสนกับการโจมตีจริง
3. ใส่ IP ของผู้ทดสอบใน Allow List ชั่วคราวหากต้องการผลที่ไม่ถูก WAF บัง (ตกลงกับผู้ทดสอบก่อน) และถอดออกเมื่อเสร็จ
4. **สำรองข้อมูลก่อนวันทดสอบ** (บทที่ 13)
5. รับรายงาน แล้วนำแต่ละข้อเข้าทะเบียนช่องโหว่ (16.7) แก้ไข และขอทดสอบซ้ำ (Retest)
6. เก็บรายงานเป็นเอกสารลับ ไม่ส่งต่อทางช่องทางที่ไม่เข้ารหัส

ภาพที่ 16.2 สรุปการประสานงานระหว่างหน่วยงานกับ สกมช. ตั้งแต่ส่งแบบ OP01 จนถึงทดสอบซ้ำหลังแก้ไข



▲ ภาพที่ 16.2 ขั้นตอนขอรับบริการทดสอบเจาะระบบจาก สกมช. (แบบ OP01)

16.9 เมื่อว่าจ้างบริษัทภายนอกทำ Pentest

- ทำ **Rules of Engagement** ระบุขอบเขต วิธีการที่ห้ามใช้ (เช่น DoS, Social Engineering ต่อผู้ป่วย) ช่วงเวลา และช่องทางติดต่อฉุกเฉิน
- ทำ **NDA** และข้อตกลงการประมวลผลข้อมูลส่วนบุคคล (DPA) เพราะผู้ทดสอบอาจเห็นข้อมูลผู้ป่วย
- กำหนดให้รายงานมีหลักฐาน (PoC) วิธีแก้ และ Retest อย่างน้อย 1 ครั้งในราคา
- ตรวจคุณสมบัติผู้ทดสอบ (ประสบการณ์ภาคสุขภาพ, ใบรับรองวิชาชีพ)

📋 **หลักฐาน CTAM+**: รายงาน VA ล่าสุด (ไม่เกิน 1 ปี/ตามเกณฑ์), ทะเบียนช่องโหว่พร้อมสถานะ, รายงาน Pentest และผล Retest, หนังสือขอรับบริการ/สัญญาจ้าง

⭐ สรุปท้ายบท

- VA ทำเองได้บ่อย ๆ, Pentest ทำปีละครั้งโดยผู้ทดสอบที่ได้รับอนุญาต
- สแกนเฉพาะระบบในทะเบียนทรัพย์สินของตน และระวังอุปกรณ์การแพทย์
- ช่องโหว่ที่อยู่ใน CISA KEV และระบบที่เปิดสู่อินเทอร์เน็ตต้องแก้ก่อน
- งานยังไม่จบจนกว่าจะ Rescan ยืนยันว่าปิดแล้ว

✏️ คำถามทบทวน

1. VA กับ Pentest ต่างกันอย่างไร และควรทำบ่อยแค่ไหน
2. ช่องโหว่แบบใดต้องแก้ก่อน
3. ระหว่างการทดสอบตาม OP01 ระบบ HIS ช้าลงมาก ควรทำอย่างไร และควรป้องกันอย่างไรตั้งแต่ก่อนทดสอบ
4. สแกน VA ระบบ 1 ระบบที่อยู่ในทะเบียนทรัพย์สิน แล้วนำผลเข้าทะเบียนช่องโหว่พร้อมกำหนดแก้ไข



ภาค 4 · ตรวจจับและตอบสนอง บทที่ 17

การรับมือเหตุการณ์และการแจ้งเหตุ

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้ขั้นตอนรับมือเหตุการณ์ (Incident Response) ตามแนวทางสากลล่าสุด NIST SP 800-61r3
- ✔️ ใช้ Playbook สำหรับ Ransomware, ข้อมูลรั่วไหล และเว็บถูกเปลี่ยนหน้า (Defacement) ได้ทันที
- ✔️ แจ้งเหตุตามเส้นทางของกระทรวงสาธารณสุข (Health CERT ภายใน 24 ชม.) และ สคส. (72 ชม.) ได้ถูกต้อง

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 5 (BCP/DRP), ข้อ 10 (SIEM), ข้อ 17 (นโยบาย), PDPA มาตรา 37(4), พ.ร.บ.ไซเบอร์ หมวด 3

17.1 เหตุการณ์ (Event) กับเหตุภัย (Incident)

- **Event** คือสิ่งที่เกิดขึ้นในระบบ เช่น มีคน Login ผิด 3 ครั้ง, Antivirus กักไฟล์ 1 ไฟล์
- **Incident** คือเหตุที่กระทบหรือมีแนวโน้มกระทบความลับ ความถูกต้อง หรือความพร้อมใช้ของระบบหรือข้อมูล เช่น มีบัญชีถูกยึด, ไฟล์ถูกเข้ารหัส, ข้อมูลผู้ป่วยถูกเผยแพร่

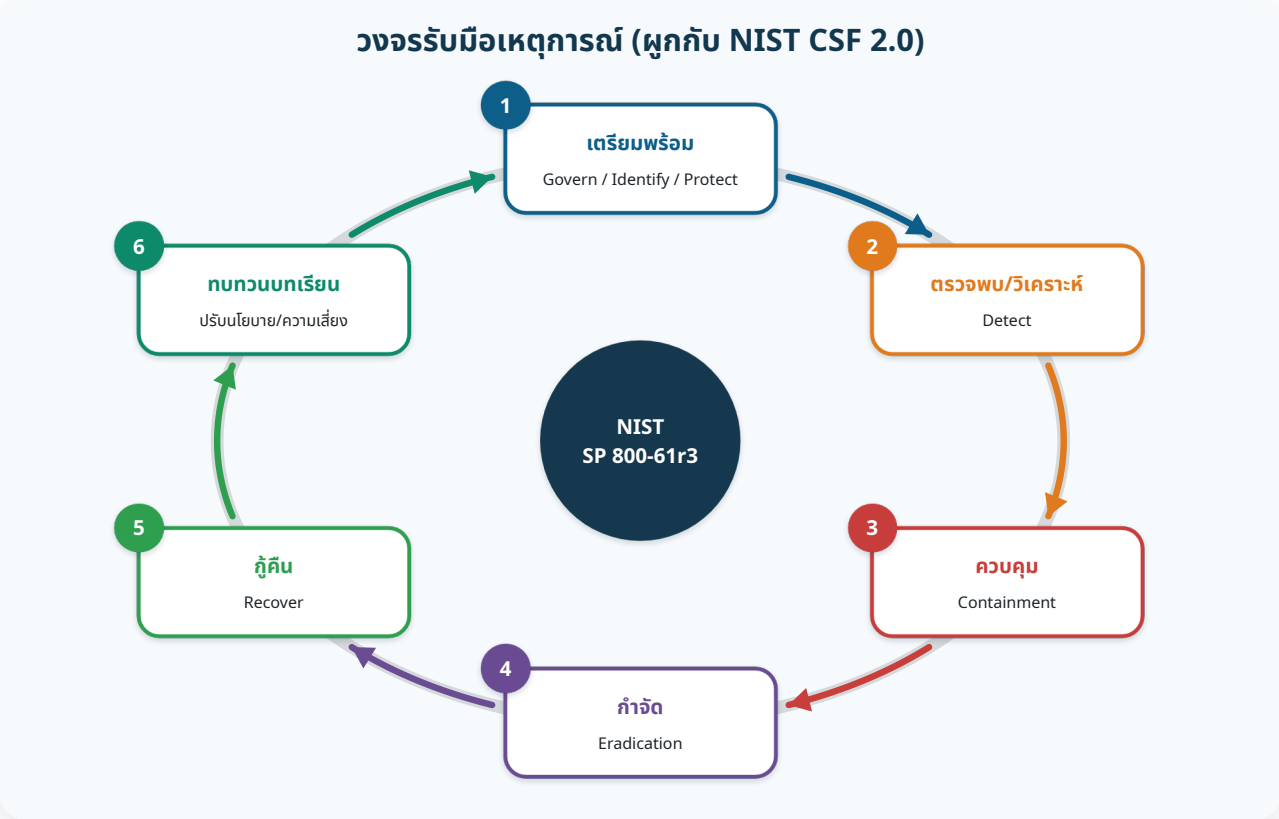
ทุก Incident เริ่มจาก Event แต่ไม่ใช่ทุก Event เป็น Incident หน้าที่ของ SIEM (บทที่ 14) คือคัดกรอง Event ให้เหลือเฉพาะเรื่องที่ต้องตอบสนอง

17.2 กรอบ NIST SP 800-61 Revision 3 (เมษายน 2568)

NIST ปรับปรุงคู่มือรับมือเหตุการณ์ครั้งใหญ่ในเดือนเมษายน 2025 (พ.ศ. 2568) โดยเลิกใช้วงจร 4 ขั้นแบบเดิม (Preparation → Detection & Analysis → Containment/Eradication/Recovery → Post-Incident) และผูกการรับมือเหตุเข้ากับ **6 ฟังก์ชันของ NIST CSF 2.0** แนวคิดสำคัญคือ IR ไม่ได้เริ่มเมื่อเกิดเหตุ แต่เป็นส่วนหนึ่งของการบริหารความเสี่ยงตลอดเวลา

ฟังก์ชัน CSF 2.0	บทบาทต่อการรับมือเหตุ	ตัวอย่างในโรงพยาบาล	บทในหนังสือ
Govern	กำหนดนโยบาย บทบาท อำนาจตัดสินใจ	คำสั่งแต่งตั้งทีม CSIRT, อำนาจตัดเน็ต/ปิดระบบ	5, 19
Identify	รู้ทรัพย์สิน ความเสี่ยง และบทเรียนจากเหตุครั้งก่อน	ทะเบียนทรัพย์สิน, Risk Register	7
Protect	ลดโอกาสเกิดเหตุ	MFA, Patch, Backup	8–13
Detect	พบเหตุเร็ว	Wazuh, Threat Feed	14–15
Respond	จัดการ วิเคราะห์ รายงาน ควบคุมเหตุ	Playbook ในบทนี้	17
Recover	กู้คืนบริการและสื่อสาร	DRP, Downtime Procedure	13

ในทางปฏิบัติ ทีมหน้างานยังใช้ขั้นตอนย่อยที่คุ้นเคยได้ ดังนี้



▲ ภาพที่ 17.1 วงจรรับมือเหตุการณ์

17.3 เตรียมพร้อมก่อนเกิดเหตุ (ทำวันนี้)

- ☐ คำสั่งแต่งตั้ง **ทีมรับมือเหตุ (CSIRT ของหน่วยงาน)**: หัวหน้าทีม (CISO), ผู้ดูแลระบบ/เครือข่าย, DPO, ผู้แทนฝ่ายการพยาบาล, ประชาสัมพันธ์, ผู้บริหารผู้มีอำนาจตัดสินใจ
- ☐ **รายชื่อและเบอร์ติดต่อฉุกเฉิน** ฉบับพิมพ์ (เมื่อระบบล่ม อีเมลและไฟล์ในเครื่องอาจใช้ไม่ได้) รวม Vendor HIS, ผู้ให้บริการอินเทอร์เน็ต, ผู้ดูแล Firewall, Health CERT
- ☐ กำหนด **อำนาจตัดสินใจ** ล่วงหน้า เช่น ผู้ดูแลระบบตัดเครื่องออกจากเครือข่ายได้ทันทีโดยไม่ต้องรออนุมัติ

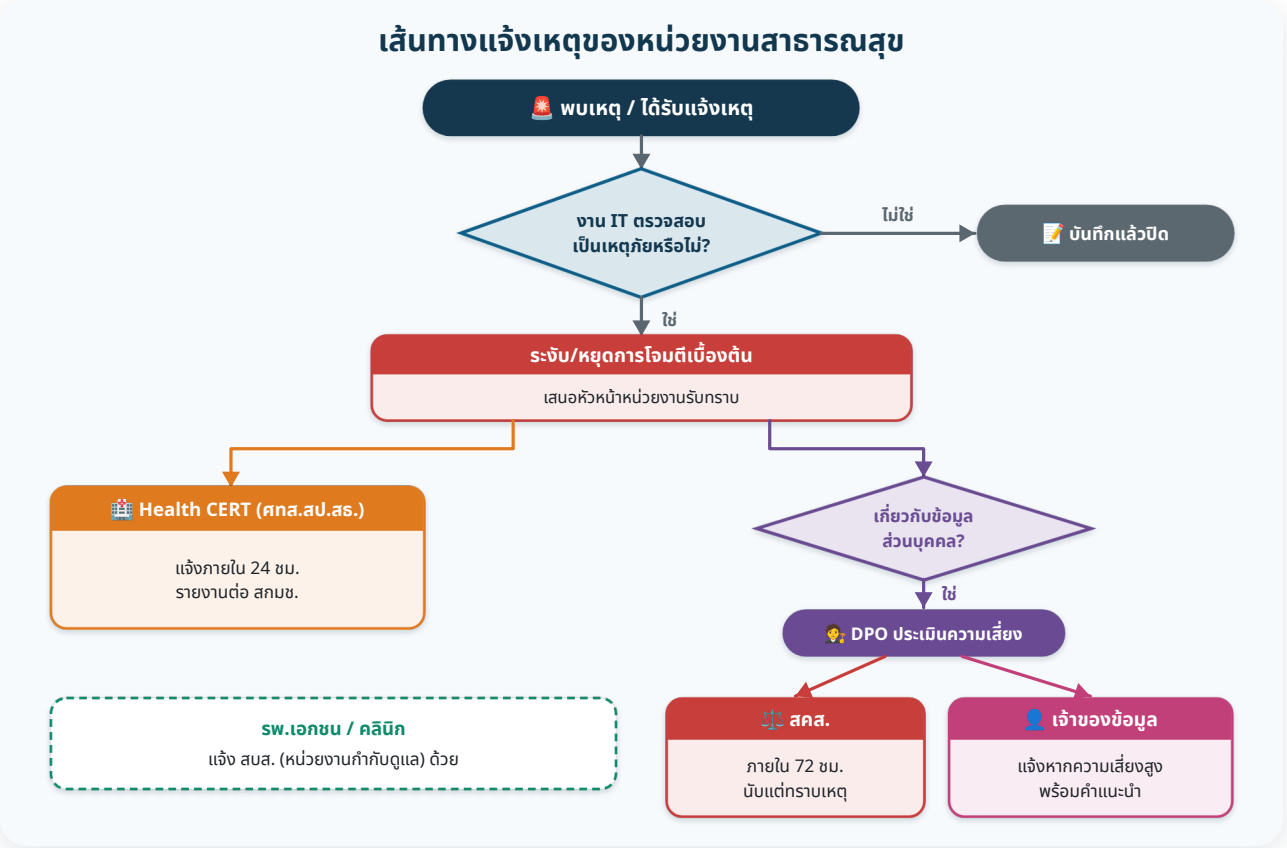
- ☐ Backup แบบ Offline/Immutable ที่ทดสอบกู้คืนแล้ว (บทที่ 13)
- ☐ เอกสาร Downtime Procedure และแบบฟอร์มกระดาษพร้อมใช้ทุกจุดบริการ
- ☐ Log เก็บอย่างน้อย 90 วัน และนาฬิกาทุกเครื่องตรงกัน (NTP) เพื่อให้สืบย้อนได้
- ☐ ซ้อมแผนอย่างน้อยปีละ 1 ครั้ง (Tabletop Exercise ตาม 17.11)

17.4 จัดระดับความรุนแรง

ใช้สองมุมประกอบกัน คือ **ระดับภัยคุกคามตามประกาศ กมช.** (บทที่ 3: ไม่ร้ายแรง / ร้ายแรง / วิกฤติ) สำหรับการรายงานตามกฎหมาย และ **ระดับความสำคัญในการตอบสนอง** สำหรับการทำงานภายใน ซึ่งศูนย์ CSOC/CO-CSIRT ที่ให้บริการโรงพยาบาลใช้ในลักษณะนี้

Priority	ความหมาย	ตัวอย่าง	การตอบสนอง
P1 Critical	ระบบหลักหยุดทำงาน กระทบการรักษา	Ransomware เข้ารหัส HIS, ข้อมูลผู้ป่วยถูกเผยแพร่	ทันที เปิด War Room แจ้งผู้บริหารและ Health CERT
P2 High	บางส่วนของระบบหยุด หรือข้อมูลบางส่วนถูกเข้าถึงโดยไม่ได้รับอนุญาต	บัญชีแพทย์ถูกยึด, เว็บถูก Deface	ภายในไม่กี่ชั่วโมง
P3 Medium	กระทบเล็กน้อย ไม่ส่งผลต่องานหลัก	มัลแวร์ในเครื่องลูกข่ายเครื่องเดียวที่ถูกกักแล้ว	ภายในวันทำการ
P4 Low	ไม่ก่อภัยแต่ควรบันทึก	การสแกนพอร์ตจากภายนอกที่ถูกบล็อก	บันทึก ทบทวนตามรอบ

17.5 เส้นทางการแจ้งเหตุของหน่วยงานสาธารณสุข



▲ ภาพที่ 17.2 เส้นทางแจ้งเหตุของหน่วยงานสาธารณสุข

ช่องทางทางการของ Health CERT (ตรวจสอบช่องทางล่าสุดที่ `cyber.moph.go.th` ก่อนใช้)

- เว็บไซต์รับแจ้งเหตุ: `health-cirt.moph.go.th`
- อีเมล: `health-cirt@moph.go.th`
- LINE Official: `@health-cirt`

ประเด็นที่มักพลาด

1. นับเวลา 72 ชั่วโมงของ PDPA **นับจากเวลาที่ทราบเหตุ** ไม่ใช่เวลาที่สอบสวนเสร็จ แจ้งข้อมูลเบื้องต้นก่อนแล้วส่งเพิ่มเติมภายหลังได้
2. การแจ้ง สคส. ต้องทำตาม **ประกาศคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล เรื่อง หลักเกณฑ์และวิธีการในการแจ้งเหตุการละเมิดข้อมูลส่วนบุคคล พ.ศ. 2565** และใช้ช่องทางอิเล็กทรอนิกส์ที่ สคส. กำหนด (ตรวจที่ `pdpc.or.th`)
3. กรณีปรับทางปกครองรายแรกของภาคเอกชนเมื่อเดือนสิงหาคม 2567 (7 ล้านบาท) มีข้อหา **ไม่แจ้งเหตุภายใน 72 ชั่วโมง** รวมอยู่ด้วย ร่วมกับการไม่มี DPO และมาตรการความปลอดภัยไม่เพียงพอ แสดงว่าการแจ้งเหตุช้าเป็นความผิดในตัวเอง

ข้อมูลที่ต้องมีในรายงานเหตุ (แบบรายงานเบื้องต้น)

หัวข้อ	ตัวอย่าง
หน่วยงาน / ผู้รายงาน / ช่องทางติดต่อ	รพ.ตัวอย่าง, งาน IT
วันเวลาที่เกิดเหตุ / ที่ทราบเหตุ	3 พ.ย. 69 02:10 / 3 พ.ย. 69 07:30
ประเภทเหตุ	Ransomware / Data Breach / Defacement / DDoS / บัญชีถูกยึด
ระบบที่ได้รับผลกระทบ	HIS Database, File Server
ผลกระทบต่อบริการ	OPD ใช้ Downtime Procedure ตั้งแต่ 08:00
ข้อมูลส่วนบุคคลที่เกี่ยวข้อง	ประเภทข้อมูล, จำนวนรายโดยประมาณ
สิ่งที่ทำไปแล้ว	ตัดเครือข่าย, ปิดบัญชี, เก็บหลักฐาน
ระดับภัยคุกคาม (ประกาศ กมช.)	ร้ายแรง
ความช่วยเหลือที่ต้องการ	วิเคราะห์มัลแวร์, กู้ข้อมูล

💡 Playbook ในหัวข้อ 17.6–17.8 มีฉบับการ์ดหน้าเดียวพร้อม Flow ในภาคผนวก ช พร้อมการ์ดเพิ่มอีก 3 เหตุที่พบบ่อย ได้แก่ คลิกลิงก์ฟิชชิง อุปกรณ์หาย และโทรศัพท์อ้างเป็น IT หรือ Vendor พิมพ์ติดห้อง IT และห้องผู้บริหารไว้ใช้ตอนเกิดเหตุ

17.6 Playbook 1: Ransomware

สัญญาณ: ไฟล์เปลี่ยนนามสกุล, มีไฟล์ `README` / `HOW_TO_DECRYPT`, HIS เชื่อมต่อฐานข้อมูลไม่ได้, Wazuh แจ้ง FIM เปลี่ยนแปลงจำนวนมาก, CPU/Disk สูงผิดปกติ

ลำดับ	ทำ	ห้ามทำ
1. ควบคุม (นาทีแรก)	**ดึงสายแลน/ปิด Wi-Fi** ของเครื่องที่ติด, ตัด VLAN/พอร์ตสวิตช์, ปิดการเชื่อมต่อ VPN ทั้งหมดชั่วคราว	อย่าปิดเครื่อง (Shutdown) ทันทีถ้ายังไม่ได้ปรึกษาผู้เชี่ยวชาญ เพราะหลักฐานในหน่วยความจำจะหาย
2. ปกป้อง Backup	ตัดการเชื่อมต่อเครื่อง Backup/NAS จากเครือข่าย ตรวจว่า Backup Offline ยังสมบูรณ์	อย่าเสียบ USB Backup เข้าเครื่องที่ติด
3. ประกาศ	หัวหน้าทีมประกาศ **BCP Code** (บทที่ 13) ให้หน่วยบริการเปลี่ยนเป็น Downtime Procedure	—
4. แจ้ง	ผู้บริหาร, Health CERT ภายใน 24 ชม., DPO ประเมินการรั่วไหล (กลุ่มนี้มักขโมยข้อมูลก่อนเข้ารหัส: Double Extortion)	อย่าติดต่อหรือต่อรองกับผู้โจมตีเอง

ลำดับ	ทำ	ห้ามทำ
5. ระบุขอบเขต	หาเครื่องแรก (Patient Zero) และวิธีเข้า (VPN ไม่มี MFA, RDP เปิด, Phishing) จาก Log Firewall/Wazuh	—
6. กำจัด	เปลี่ยนรหัสผ่านทุกบัญชีผู้ดูแล (รวม Domain Admin, Service Account, บัญชี Vendor), ปิดช่องทางที่ใช้เข้า	อย่าใช้รหัสผ่านเดิม หรือกู้คืนก่อนปิดช่องทางเข้า
7. กู้คืน	ติดตั้งระบบใหม่ (Clean Install) แล้วกู้ข้อมูลจาก Backup ที่ตรวจแล้วว่าสะอาด ตามลำดับความสำคัญ: AD/DNS → ฐานข้อมูล HIS → แอป HIS → LIS/PACS → ระบบอื่น	อย่าใช้เครื่องที่ติดซ้ำเพียงเพราะลบไฟล์มัลแวร์แล้ว
8. เฝ้าระวัง	เฝ้า Log เข้มข้นอย่างน้อย 30 วัน	—

📌 **กรณีศึกษา Change Healthcare (สหรัฐฯ, 2567)**: ผู้โจมตีใช้รหัสผ่านที่ถูกขโมยเข้าระบบ Remote Access (Citrix) ที่ **ไม่ได้เปิด MFA** อยู่ในระบบราว 9 วันก่อนปล่อย Ransomware ผลคือระบบเบิกจ่ายและใบสั่งยาของสถานพยาบาลทั่วประเทศหยุดชะงักนานหลายสัปดาห์ และกระทรวงสาธารณสุขสหรัฐฯ (HHS) รายงานผู้ได้รับผลกระทบด้านข้อมูลราว 190 ล้านคน บทเรียนตรงกับ CTAM+ ข้อ 7 คือ **ทุกช่องทางเข้าจากภายนอกต้องมี MFA** และควรตรวจ Log การ Login ผิดปกติ

17.7 Playbook 2: ข้อมูลส่วนบุคคลรั่วไหล (Data Breach)

สัญญาณ: พบข้อมูลผู้ป่วยในกลุ่ม Social/Dark Web, ได้รับแจ้งจากผู้ป่วยหรือสื่อ, Log แสดงการ Export ข้อมูลจำนวนมาก, เอกสารเปิดสาธารณะใน Google Drive/เว็บไซต์

1. **ยืนยันและหยุดการรั่ว**: ปิดลิงก์แชร์, ลบไฟล์จากเว็บ, ปิดบัญชีที่เกี่ยวข้อง, ขอให้แพลตฟอร์มลบโพสต์ (เก็บหลักฐานก่อน: ภาพหน้าจอพร้อม URL และเวลา)
2. **เริ่มนับเวลา 72 ชั่วโมง** และแจ้ง DPO ทันที
3. **ประเมินความเสี่ยง**: ประเภทข้อมูล (ข้อมูลสุขภาพเป็นข้อมูลอ่อนไหวตามมาตรา 26), จำนวนราย, ข้อมูลเข้ารหัสหรือไม่, ใครได้รับ
4. **แจ้ง สคส.** ภายใน 72 ชม. (ถ้ามีความเสี่ยง) และ **แจ้งเจ้าของข้อมูล** หากมีความเสี่ยงสูง พร้อมคำแนะนำ (เช่น ระวังโทรศัพท์หลอกลวงที่อ้างข้อมูลการรักษา)
5. **แจ้ง Health CERT** ภายใน 24 ชม. ถ้าเกิดจากเหตุภัยไซเบอร์
6. **หาสาเหตุ**: ใครเข้าถึงข้อมูล (Audit Log ของ HIS/ฐานข้อมูล บทที่ 12), Google Dork (บทที่ 7), ช่องโหว่เว็บ
7. **ปรับปรุง**: ทบทวนสิทธิ์, เพิ่มการปกปิดข้อมูล, อบรมผู้เกี่ยวข้อง

17.8 Playbook 3: เว็บไซต์ถูกเปลี่ยนหน้า (Web Defacement)

1. **เปลี่ยนเป็นหน้าปิดปรับปรุง** หรือหยุดเว็บไซต์ (เช่น ชี้ DNS/Cloudflare ไปหน้า Maintenance)

2. **เก็บหลักฐาน**: Snapshot เครื่องหรือคัดลอกไดเรกทอรีเว็บและ Log (access.log, error.log, ModSecurity audit log) ก่อนแก้ไข
3. **หาไฟล์แปลกปลอม** ที่มักถูกฝาก (Web Shell)

```
# ไฟล์ที่ถูกแก้ไขใน 7 วันล่าสุด
find /var/www -type f -mtime -7 -ls
# ไฟล์ PHP ในโฟลเดอร์อัปโหลด (ไม่ควรมี)
find /var/www -path '*upload*' -name '*.php'
# ฟังก์ชันอันตรายที่ Web Shell ใช้บ่อย
grep -RIl --include='*.php' -E 'eval\(|base64_decode\(|shell_exec\(|assert\(' /var/www
```

4. **กู้คืน** จาก Backup หรือ Source Code ที่สะอาด แล้ว **อัปเดต CMS/Plugin/PHP** และเปลี่ยนรหัสผ่านผู้ดูแลเว็บและฐานข้อมูลทั้งหมด
5. เปิด WAF (บทที่ 11) แล้วจึงเปิดเว็บกลับ
6. แจ้ง Health CERT และหากมีหน้าเว็บอ้างอิงที่ผู้ป่วยใช้ ให้ประชาสัมพันธ์ช่องทางทางการ

17.9 เก็บหลักฐานดิจิทัลเบื้องต้น

หลักฐานที่เก็บถูกวิธีช่วยให้หาสาเหตุได้ ใช้ประกอบการแจ้งความ และใช้ยืนยันกับ สคส. ว่าข้อมูลรั่วหรือไม่ หลักสำคัญคือ **เก็บก่อนแก้ เก็บของที่หายเร็วก่อน และบันทึกทุกขั้น**

ลำดับความไวของหลักฐาน (เก็บจากบนลงล่าง)

1. หน่วยความจำ (RAM) และการเชื่อมต่อเครือข่ายที่กำลังเปิดอยู่
2. รายการโปรเซสและผู้ใช้ที่ Login อยู่
3. ไฟล์ชั่วคราวและ Log ในเครื่อง
4. ดิสก์ทั้งลูก
5. Log ภายนอก (Firewall, Wazuh, Proxy) และ Backup

คำสั่งเก็บข้อมูลเบื้องต้น (บันทึกผลไปยัง USB ที่เตรียมไว้ ไม่เขียนลงดิสก์ของเครื่องที่ติด)

```
# Linux
OUT=/media/ir-usb/$(hostname)-$(date +%F_%H%M); mkdir -p $OUT
date -u > $OUT/time.txt
ss -antup > $OUT/connections.txt
ps auxf > $OUT/processes.txt
who -a > $OUT/users.txt; last -n 50 >> $OUT/users.txt
crontab -l > $OUT/crontab-user.txt 2>&1; ls -la /etc/cron* > $OUT/cron.txt
tar czf $OUT/varlog.tgz /var/log
sha256sum $OUT/* > $OUT/SHA256SUMS
```

```powershell
# Windows (PowerShell สิทธิ์ผู้ดูแล)
$o="E:\IR\$env:COMPUTERNAME-$(Get-Date -f yyyyMMdd_HHmm)"; mkdir $o
Get-Date -AsUTC | Out-File $o\time.txt
Get-NetTCPConnection | Export-Csv $o\connections.csv
Get-Process | Select Id,ProcessName,Path,StartTime | Export-Csv $o\processes.csv
Get-ScheduledTask | Export-Csv $o\tasks.csv
Get-CimInstance Win32_StartupCommand | Export-Csv $o\startup.csv
wevtutil epl Security $o\Security.evtx; wevtutil epl System $o\System.evtx
Get-FileHash $o\* -Algorithm SHA256 | Export-Csv $o\hashes.csv
```

- เครื่อง Virtual Machine: ทำ **Snapshot รวมหน่วยความจำ** บน Hypervisor ก่อนปิดเครื่อง เป็นวิธีที่ง่ายและได้หลักฐานครบที่สุด
- การทำสำเนาดิสก์หรือหน่วยความจำแบบเต็มเพื่อดำเนินคดี ให้ผู้เชี่ยวชาญดำเนินการ (ขอความช่วยเหลือผ่าน Health CERT/สกมช.)

บันทึกการส่งต่อหลักฐาน (Chain of Custody)

ลำดับ	หลักฐาน	ค่า SHA-256	เก็บเมื่อ	ผู้เก็บ	ส่งให้	วันเวลาส่ง	ลายมือชื่อ
1	varlog.tgz จาก Web-01	(ค่า hash)	3 พ.ย. 69 08:15	งาน IT	CISO	3 พ.ย. 69 09:00	

⚠️ อย่าเปิดไฟล์มัลแวร์ด้วยโปรแกรมทั่วไป และอย่าอัปโหลดไฟล์ที่อาจมีข้อมูลผู้ป่วยไปยังบริการวิเคราะห์ออนไลน์ ให้ส่งเฉพาะค่า Hash ไปตรวจสอบ

17.10 สื่อสารระหว่างเกิดเหตุ

- กำหนด **ผู้ให้ข่าวคนเดียว** (ผู้อำนวยการหรือผู้ได้รับมอบหมาย) เจ้าหน้าที่คนอื่นไม่โพสต์ในโซเชียล
- แจ้งบุคลากรผ่านช่องทางสำรองที่ไม่พึ่งระบบที่ล่ม (กลุ่มไลน์ผู้บริหาร, วิทยุสื่อสาร, ประกาศหน้างาน)
- แจ้งผู้ป่วยด้วยข้อความที่ชัดเจน เช่น “ระบบคอมพิวเตอร์ขัดข้อง การให้บริการยังดำเนินต่อแต่อาจล่าช้า”
- ใช้ **War Room** (ห้องบัญชาการ) สำหรับเหตุ P1 รวมทีมเทคนิค ผู้บริหาร DPO และฝ่ายการพยาบาลไว้ในที่เดียว ประชุมสรุปทุก 2–4 ชั่วโมง

แม่แบบรายงานสถานการณ์ (SITREP) การสื่อสารนอกช่องทางปกติ และตารางว่าต้องแจ้งใครเมื่อใดตามระดับเหตุ อยู่ในหัวข้อ 24.5

17.11 ซ้อมแผนแบบ Tabletop (2 ชั่วโมง)

สถานการณ์ตัวอย่าง: “07:30 วันจันทร์ เจ้าหน้าที่เวชระเบียนพบว่าเปิด HIS ไม่ได้ และพบไฟล์ชื่อ RESTORE_FILES.txt บน File Server”

เวลาในสถานการณ์	ข้อมูลที่ผู้ดำเนินการเติมให้	คำถามให้ทีมตอบ
07:30	HIS ใช้ไม่ได้ทั้งโรงพยาบาล	ใครต้องรู้คนแรก? ประกาศ BCP Code ใด?
08:30	พบว่า Backup NAS ก็ถูกเข้ารหัส	Backup Offline อยู่ที่ไหน? ใครถือกุญแจ?
10:00	ผู้โจมตีโพสต์ตัวอย่างข้อมูลผู้ป่วย 100 ราย	DPO ทำอะไร? เวลา 72 ชม. เริ่มนับเมื่อใด?
13:00	สื่อมวลชนโทรมาสอบถาม	ใครให้ข่าว? พูดว่าอะไร?
วันถัดไป	Vendor HIS ต้องเข้ามาช่วยกู้ระบบจากระยะไกล	อนุญาตอย่างไรให้ปลอดภัย?

บันทึกจุดที่ทีมตอบไม่ได้หรือตอบไม่ตรงกัน แล้วแปลงเป็นงานแก้ไขพร้อมผู้รับผิดชอบ

17.12 ทบทวนหลังเหตุ (Lessons Learned)

ประชุมภายใน 2 สัปดาห์หลังปิดเหตุ ใช้หลัก **ไม่กล่าวโทษบุคคล (Blameless)** ตอบคำถาม

1. เกิดอะไรขึ้น ลำดับเวลาเป็นอย่างไร (Timeline)
2. ตรวจพบช้าหรือเร็ว เพราะอะไร (MTTD) และใช้เวลากู้คืนเท่าไร (MTTR)
3. อะไรทำได้ดี อะไรต้องปรับ
4. ต้องเพิ่มกฎตรวจจับใน Wazuh, ปรับ Playbook, หรือเพิ่มงบประมาณใด

📋 **หลักฐาน**: คำสั่งแต่งตั้งทีม, Playbook, รายงานเหตุพร้อมหลักฐานการแจ้ง Health CERT/สคส., รายงานการซ้อมแผน, บันทึกบทเรียน

⭐ สรุปท้ายบท

- เตรียมพร้อมก่อนเกิดเหตุสำคัญที่สุด: ทีม อำนาจตัดสินใจ รายชื่อติดต่อฉบับกระดาษ Backup Offline
- เกิดเหตุให้ **ตัดเครือข่ายก่อน** ปกป้อง Backup แล้วจึงแจ้ง
- Health CERT ภายใน 24 ชม., สคส. ภายใน 72 ชม. นับแต่ทราบเหตุ (ถ้าเกี่ยวกับข้อมูลส่วนบุคคล)
- ซ้อมแผนปีละครั้ง และทบทวนบทเรียนทุกเหตุการณ์

✏️ คำถามทบทวน

1. เมื่อเกิดเหตุภัยไซเบอร์ ต้องแจ้ง Health CERT และ สคส. ภายในกี่ชั่วโมง นับจากเมื่อใด
2. ทำไม Playbook Ransomware จึงห้ามปิดเครื่องที่ติดทันที
3. บัญชีอีเมลของแพทย์ถูกยึดและใช้ส่งฟิชชิงไปหาเพื่อนร่วมงาน 50 คน ควรจัด Priority ใด และใช้การ์ดใด
4. จัด Tabletop 2 ชั่วโมงด้วยการ์ด Playbook 1 ใบ แล้วบันทึกสิ่งที่ทีมทำไม่ได้ตามการ์ด



ภาค 5

คนและองค์กร

People & Organization

18 Security Awareness สำหรับบุคลากรสาธารณสุข 

19 ธรรมาภิบาลและแผนยกระดับระดับจังหวัด/เขต 



ภาค 5 · คนและองค์กร บทที่ 18

Security Awareness สำหรับบุคลากรสาธารณสุข

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้จักกลลวงที่พบบ่อยในโรงพยาบาล (Phishing, Social Engineering, QR หลอก, โทรศัพท์แอบอ้าง)
- ✔️ ใช้กฎสั้น ๆ ที่บุคลากรทุกคนจำได้และทำตามได้
- ✔️ จัดโปรแกรมอบรมและทดสอบฟิชชิงที่วัดผลได้ (เป้าหมายผ่านอบรม ≥ 80%)

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 17 (นโยบายและการอบรม), ตัวชี้วัด Cybersecurity สธ., HHS 405(d) Threat #1 Email Phishing

18.1 ทำไมต้องเริ่มที่คน

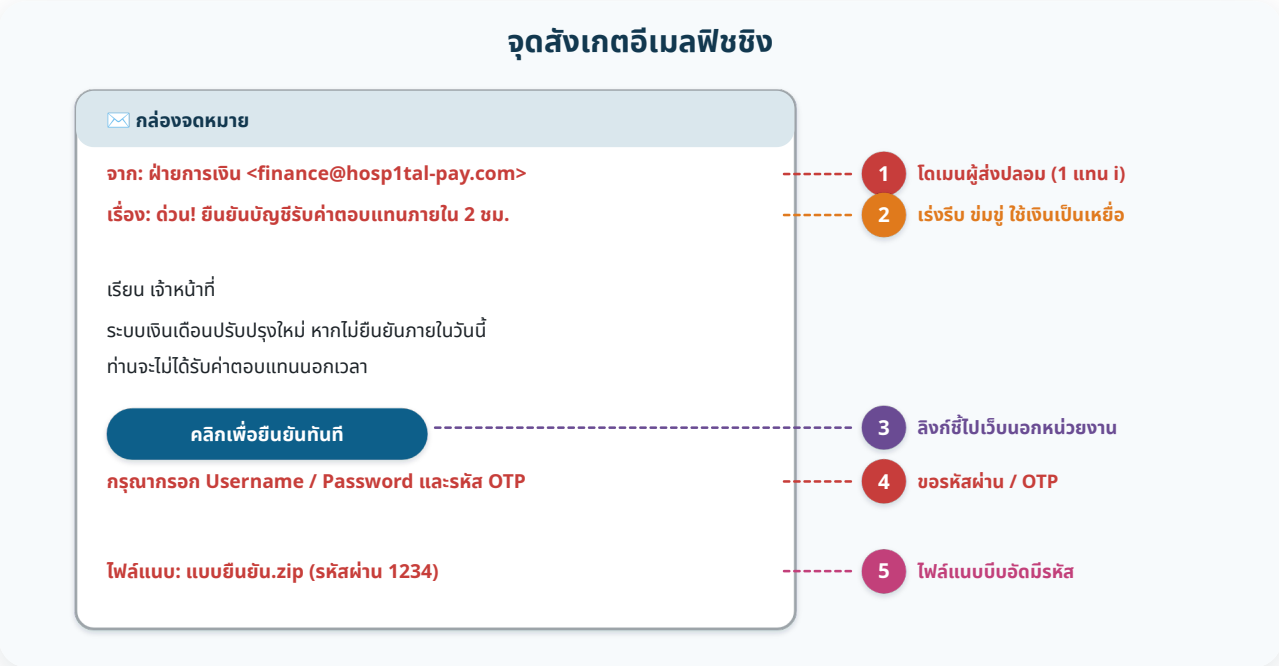
ภัยส่วนใหญ่ในโรงพยาบาลเริ่มจากการกระทำของผู้ใช้ เช่น กดลิงก์ในอีเมล ใช้รหัสผ่านซ้ำ หรือแชร์ไฟล์ผิดคน คู่มือแนวทางการจัดทำแผนบริหารความเสี่ยงไซเบอร์ของกระทรวงระบุว่าปัญหาจาก **ข้อผิดพลาดของบุคลากร (Human Errors)** แก้ได้ด้วยการฝึกวินัยการใช้งาน **ซึ่งไม่ต้องลงทุนสูง** และควรซักซ้อมอย่างน้อยปีละครั้ง **เหมือนการซ้อมแผนอัคคีภัย**

ในต่างประเทศ โครงการ HHS 405(d) ของสหรัฐฯ จัด **Email Phishing** เป็นภัยอันดับ 1 จาก 5 ภัยหลักของภาคสุขภาพ (ตามด้วย Ransomware, การสูญหายหรือถูกขโมยอุปกรณ์/ข้อมูล, ภัยจากคนใน และการโจมตีอุปกรณ์การแพทย์ที่เชื่อมเครือข่าย)

18.2 กลลวงที่พบบ่อยในหน่วยบริการ

กลลวง	ตัวอย่างในบริบทโรงพยาบาล	จุดสังเกต
อีเมลฟิชชิง	“แจ้งปรับเงินเดือน/ค่าตอบแทนนอกเวลา คลิกเพื่อยืนยัน”, “กล่องจดหมายเต็ม กรุณา Login”	ผู้ส่งไม่ใช่โดเมนหน่วยงาน, เร่งรีบ, ลิงก์ไม่ตรงชื่อ
SMS/LINE หลอก (Smishing)	“สปสช. แจ้งยอดเบิกจ่ายผิดพลาด”, “พัสดุตกค้าง”	ลิงก์ย่อ, ขอ OTP

กลลวง	ตัวอย่างในบริบทโรงพยาบาล	จุดสังเกต
โทรแอบอ้าง (Vishing)	อ้างเป็นเจ้าหน้าที่ IT ส่วนกลางหรือ Vendor HIS ขอรหัสผ่าน/ขอติดตั้งโปรแกรม Remote	IT จริงไม่ขอรหัสผ่านทางโทรศัพท์
แอบอ้างผู้บริหาร	“ผอ. ขอให้โอนเงินด่วน/ส่งรายชื่อผู้ป่วยให้” ทางไลน์ส่วนตัว	ช่องทางผิดปกติ, ขอให้ข้ามขั้นตอน
QR Code หลอก (Quishing)	สติกเกอร์ QR แปะทับที่จุดชำระเงินหรือประกาศ Wi-Fi	ตรวจ URL ก่อนกรอกข้อมูล
USB แปลกปลอม	USB วางทิ้งไว้ในห้องประชุม	ห้ามเสียบเครื่องหน่วยงาน
คนนอกเดินตาม (Tailgating)	เดินตามเข้าห้อง Server/ห้องเวชระเบียน	ขอดูบัตร, ไม่เปิดประตูให้
ขอข้อมูลผู้ป่วยทางโทรศัพท์	อ้างเป็นญาติ/ตำรวจ/บริษัทประกัน	ยืนยันตัวตนและขั้นตอนตามระเบียบ



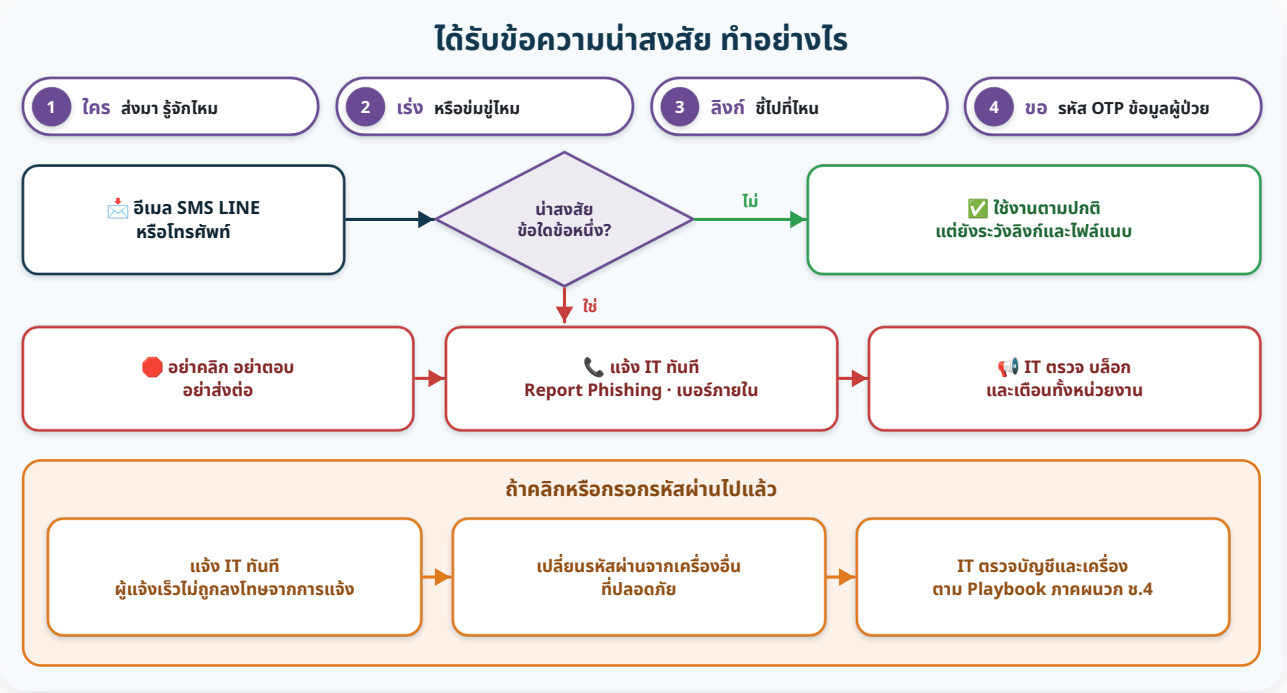
▲ ภาพที่ 18.1 จุดสังเกตอีเมลฟิชชิง 5 จุด

5 วินาทีก่อนคลิก: คำถาม 4 ข้อ

1. **ใคร** ส่งมา ฉันรู้จักและคาดว่าจะได้รับข้อความนี้หรือไม่
2. **เร่ง** ให้ทำทันทีหรือข่มขู่หรือไม่
3. **ลิงก์** ชี้ไปที่ไหน (เอาเมาส์วางเพื่อดูโดยไม่คลิก)
4. **ขอ** รหัสผ่าน OTP ข้อมูลผู้ป่วย หรือให้ติดตั้งโปรแกรมหรือไม่

ถ้าข้อใดข้อหนึ่งน่าสงสัย **อย่าคลิก** และแจ้งงาน IT

ภาพที่ 18.2 ใช้สอนหน้างานได้ทันที จุดสำคัญคือแจ้งได้เสมอแม้เผลอคลิกไปแล้ว ยิ่งแจ้งเร็วยิ่งแก้ง่าย ขั้นตอนของงาน IT หลังได้รับแจ้งอยู่ใน Playbook ภาคผนวก ช.4



▲ ภาพที่ 18.2 ได้รับข้อความน่าสงสัย ทำอย่างไร

18.3 กฎทอง 10 ข้อสำหรับบุคลากรทุกคน (พิมพ์ติดบอร์ดได้)

1. **รหัสผ่านยาว** อย่างน้อย 12 ตัวอักษร (ใช้วลี เช่น `ดอกไม้บาน3ต้นหน้าตึก0PD` ในรูปภาษาอังกฤษ) ไม่ใช้ซ้ำกับบัญชีส่วนตัว
2. **ไม่บอกรหัสผ่าน** ใคร รวมถึงหัวหน้าและงาน IT และไม่จดติดหน้าจอ
3. **เปิด MFA** ทุกระบบที่รองรับ และไม่กดยืนยันคำขอ MFA ที่ตนเองไม่ได้ขอ
4. **ล็อกหน้าจอทุกครั้ง** ที่ลุกจากเครื่อง (Windows + L) และ Logout HIS เมื่อเปลี่ยนเวร
5. **ไม่ใช้บัญชีคนอื่น** เข้า HIS แม้จะเร่งรีบ เพราะ Log จะบันทึกว่าเจ้าของบัญชีเป็นผู้กระทำ
6. **ไม่ส่งข้อมูลผู้ป่วย** ทางไลน์ส่วนตัวหรืออีเมลส่วนตัว ใช้ช่องทางที่หน่วยงานกำหนด และส่งเท่าที่จำเป็น
7. **ไม่ถ่ายภาพ** หน้าจอ HIS ผู้ป่วย หรือเอกสารเวชระเบียนลงโทรศัพท์ส่วนตัว
8. **Clear Desk**: เก็บเอกสารที่มีข้อมูลผู้ป่วยเมื่อเลิกงาน ใช้เครื่องทำลายเอกสาร ไม่ทิ้งถังขยะทั่วไป
9. **ไม่ติดตั้งโปรแกรมเอง** และไม่เสียบ USB ที่ไม่รู้ที่มา
10. **พบสิ่งผิดปกติ แจ้งทันที** การแจ้งเร็วไม่ใช่ความผิด แม้จะเป็นผู้คลิกเอง

18.4 ตัวอย่างเอกสารสื่อสารมาตรการ

ตามแนวทางของกระทรวง ผู้บริหารควรออกเอกสารสื่อสารมาตรการให้ผู้ใช้งานรับทราบและลงนามรับทราบ ประเด็นที่ควรครอบคลุม ได้แก่ ความสำคัญของการรักษาความลับตาม PDPA, การเข้าถึงข้อมูลตามสิทธิ์และชั้นความลับ, การจัดเก็บข้อมูล, การสำรองข้อมูล, การอัปเดตซอฟต์แวร์, การอบรม และ **ช่องทางรายงานการละเมิดความปลอดภัย**

ตัวอย่างฉบับย่อ

เรื่อง การใช้งานระบบจดหมายอิเล็กทรอนิกส์ (E-Mail) ในโรงพยาบาล

1. **รักษาความลับ** เปลี่ยนรหัสผ่านทันทีเมื่อเข้าใช้ครั้งแรก ไม่อนุญาตให้ผู้อื่นใช้บัญชี และ Logout ทุกครั้ง ข้อมูลลับให้ส่งด้วยวิธีเข้ารหัสที่หน่วยงานกำหนด และตรวจชื่อผู้รับก่อนส่ง
2. **ใช้อย่างปลอดภัย** ตรวจไฟล์แนบก่อนเปิด ระวังไฟล์ .exe .com .js .zip ที่มีรหัสผ่าน และ **ให้ถือว่าลิงก์ทุกลิงก์ไม่ปลอดภัยจนกว่าจะตรวจแล้ว**
3. **ไม่ส่ง** Spam จดหมายลูกโซ่ หรือข้อความที่ละเมิดกฎหมายหรือสิทธิผู้อื่น
4. **แจ้งปัญหา** หากสงสัย ให้แจ้งทีมความปลอดภัยของโรงพยาบาลทันที

(ลงชื่อผู้บริหาร / วันที่)

18.5 กลุ่มเป้าหมายและเนื้อหาที่ต่างกัน

กลุ่ม	เนื้อหาเน้น	รูปแบบ	ความถี่
ผู้บริหาร (CEO/คณะกรรมการบริหาร)	ความเสี่ยงต่อการให้บริการ ภาระทางกฎหมาย งบประมาณ บทบาทเมื่อเกิดเหตุ	บรรยาย 1 ชม. + Tabletop	ปีละครั้ง
แพทย์ พยาบาล บุคลากรหน้างาน	ฟิชชิง รหัสผ่าน Clear Screen PDPA การส่งข้อมูลผู้ป่วย	คลิปสั้น 5–10 นาที, โปสเตอร์, ประชุมเวร	รายไตรมาส
เวชระเบียน การเงิน พัสดุ	การยืนยันตัวตนผู้ขอข้อมูล การโอนเงินที่ถูกแอบอ้าง	Workshop กรณีศึกษา	ปีละ 2 ครั้ง
งาน IT / ผู้ดูแลระบบ	Hardening, IR, Log, การใช้บัญชีสิทธิ์สูง	Lab ลงมือทำ (บท 8–17)	ต่อเนื่อง
บุคลากรใหม่ นักศึกษาฝึกงาน Vendor	กฎทอง 10 ข้อ และลงนามรับทราบนโยบาย	ปฐมนิเทศ	ก่อนได้รับบัญชี

💡 **แหล่งสื่อฟรีที่ใช้ได้**: คู่มือ Cyber Security สำหรับประชาชน และสื่อของ สกมช. (`ncsa.or.th`), สื่อ PDPA ของ สคส. (`pdpc.or.th`), บทเรียนออนไลน์ของสถาบันพัฒนาบุคลากรดิจิทัลภาครัฐ (TDGA) ภายใต้ สพร., ชุด “5 Threats” ของ HHS 405(d) (`405d.hhs.gov` , ภาษาอังกฤษ)

18.6 ทดสอบฟิชชิงจำลอง (Phishing Simulation)

ใช้เครื่องมือโอเพนซอร์ส **GoPhish** หรือบริการที่หน่วยงานจัดหา โดย

1. **ขออนุมัติผู้บริหารเป็นลายลักษณ์อักษร** และแจ้ง DPO ก่อน (เป็นการประมวลผลข้อมูลบุคลากร)
2. ใช้ฉากที่สมจริงแต่ **ไม่สร้างความเสียหายหรืออับอาย** หลีกเลี่ยงเรื่องโบนัส/สวัสดิการที่ทำให้รู้สึกถูกหลอกเรื่องเงินจริง

3. วัดผลเป็นภาพรวมรายหน่วยงาน **ไม่ประจานรายบุคคล** ผู้ที่คลิกให้ได้รับบทเรียนสั้นทันที
4. ตัวชี้วัดที่ควรติดตาม

ตัวชี้วัด	ความหมาย	เป้าหมายตัวอย่าง
Click Rate	% ผู้ที่คลิกลิงก์	ลดลงทุกรอบ (เช่น < 10%)
Submit Rate	% ผู้ที่กรอกรหัสผ่าน	< 3%
Report Rate	% ผู้ที่แจ้ง IT ว่าเป็นอีเมลน่าสงสัย	**สูงขึ้นทุกรอบ** (ตัวชี้วัดที่ดีที่สุด)
อบรมผ่าน	% บุคลากรที่ผ่านการอบรมประจำปี	≥ 80%

18.7 Clear Desk / Clear Screen และพื้นที่บริการ

- ตั้งค่า **ล็อกหน้าจออัตโนมัติ** ผ่าน GPO (เช่น 10 นาที) และ HIS Session Timeout
- หันจอที่จุดคัดกรอง ห้องจ่ายยา เคาน์เตอร์การเงิน ไม่ให้ผู้ป่วยรายอื่นเห็น ใช้ฟิล์มกันมอง
- ไม่ประกาศชื่อเต็มพร้อมการวินิจฉัย ใช้หมายเลขคิว
- เครื่องพิมพ์ร่วม: เก็บเอกสารทันที หรือใช้ Secure Print
- ห้อง Server และตู้เวชระเบียนต้องล็อก และมีบันทึกการเข้าออก

18.8 วัฒนธรรมการแจ้งเหตุ

สิ่งที่ทำให้โครงการ Awareness สำเร็จไม่ใช่จำนวนชั่วโมงอบรม แต่เป็น **ความกล้าแจ้ง** ผู้บริหารควรประกาศชัดว่า

- ผู้ที่แจ้งเหตุทันที แม้เป็นผู้กระทำพลาดเอง จะไม่ถูกลงโทษจากการแจ้ง
- มีช่องทางแจ้งที่ง่าย เช่น เบอร์ภายใน กลุ่มไลน์งาน IT ปุ่ม “Report Phishing” ใน Outlook/Gmail
- ชมเชยผู้แจ้งในที่ประชุม (เช่น “ผู้พิทักษ์ข้อมูลประจำเดือน”)

📋 **หลักฐาน CTAM+ ข้อ 17**: แผนและหลักสูตรอบรม, รายชื่อผู้เข้าอบรมพร้อมร้อยละเทียบบุคลากรทั้งหมด, ภาพกิจกรรม, เอกสารสื่อสารมาตรการที่ลงนาม, รายงานผลทดสอบฟิชชิง (ถ้ามี)

⭐ สรุปท้ายบท

- คนเป็นทั้งจุดอ่อนและแนวป้องกันที่คุ้มค่าที่สุด
- สอนกฎสั้นที่จำได้ (คำถาม 4 ข้อ, กฎทอง 10 ข้อ) แทนบรรยายยาว
- วัดผลด้วย Report Rate และร้อยละผู้ผ่านอบรม ≥ 80%
- สร้างวัฒนธรรมแจ้งเหตุโดยไม่กล่าวโทษ

✏️ คำถามทบทวน

1. คำถาม 4 ข้อก่อนคลิกมีอะไรบ้าง
2. ทำไม Report Rate จึงเป็นตัวชี้วัดที่ดีกว่าอัตราการคลิกเพียงอย่างเดียว
3. เจ้าหน้าที่เผลอกรอกรหัสผ่านในเว็บปลอมแต่กลัวถูกลงโทษจึงไม่แจ้ง หัวหน้างานควรสื่อสารอย่างไร
4. ออกแบบการอบรม 15 นาทีสำหรับเจ้าหน้าที่จุดลงทะเบียน โดยใช้ภาพที่ 18.2 และกฎทอง 10 ข้อ

ภาค 5 · คนและองค์กร บทที่ 19

ธรรมาภิบาลและแผนยกระดับระดับจังหวัด/เขต

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

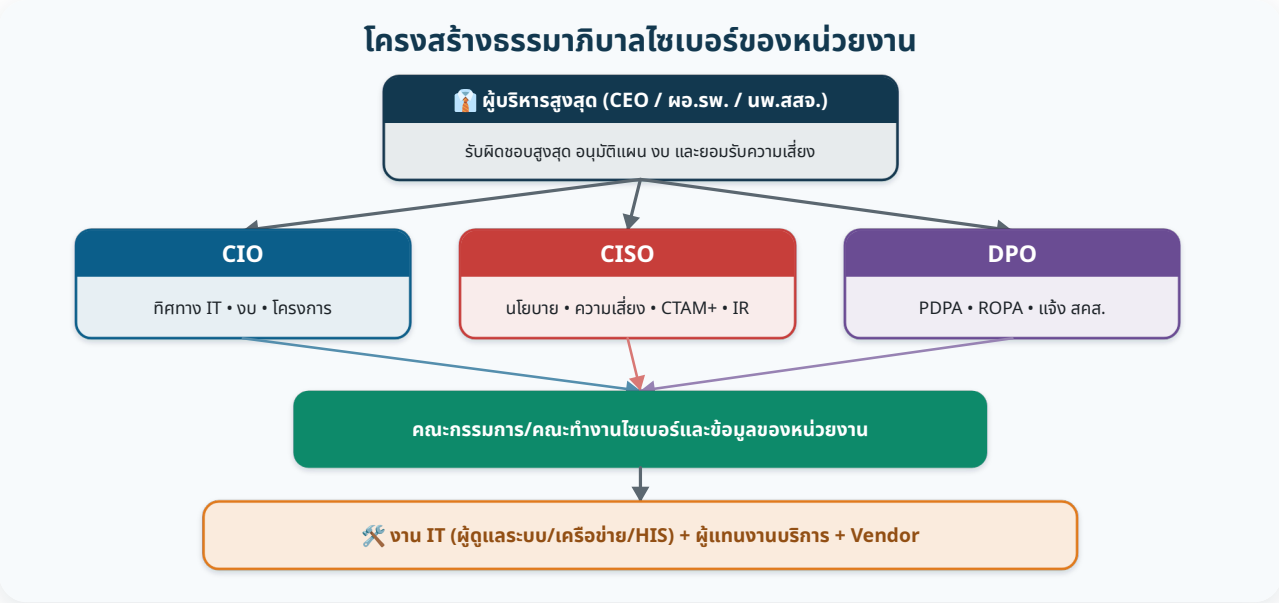
- ✔️ กำหนดโครงสร้างและบทบาท CEO / CIO / CISO / DPO ได้ชัดเจน
- ✔️ บริหารความเสี่ยงจากคู่ค้าและผู้ให้บริการ (Vendor/Supply Chain) รวมถึง Cloud
- ✔️ ใช้โมเดล สสจ. เป็นศูนย์กลางดูแลหน่วยบริการในจังหวัด
- ✔️ มี Roadmap 12 เดือนที่นำไปใช้ได้ทันที

📋 เกณฑ์ที่เกี่ยวข้อง: นโยบาย สธ. 2565 ข้อ 6 (ผู้บริหารสูงสุดรับผิดชอบ), CTAM+ ข้อ 3, 12, 15, 17, NIST CSF 2.0 ฟังก์ชัน Govern

19.1 ทำไมต้องเริ่มที่ธรรมาภิบาล

NIST CSF 2.0 เพิ่มฟังก์ชัน **Govern** เป็นฟังก์ชันที่ 6 และวางไว้ตรงกลางของอีก 5 ฟังก์ชัน เพราะบทเรียนจากเหตุใหญ่ทั่วโลกคือ ปัญหาส่วนมากไม่ได้เกิดจากเทคโนโลยีไม่พอ แต่เกิดจาก **ไม่มีใครเป็นเจ้าของความเสี่ยง** ไม่มีงบประมาณ และไม่มีการติดตาม ผู้อำนวยการใหญ่องค์การอนามัยโลก (WHO) กล่าวต่อคณะมนตรีความมั่นคงแห่งสหประชาชาติเมื่อพฤศจิกายน 2567 ว่า **ผู้มีอำนาจด้านสุขภาพ ผู้ให้ทุน และเจ้าของระบบยังคงต้องรับผิดชอบต่อความปลอดภัยของระบบสารสนเทศที่ใช้ในงานสุขภาพ** ซึ่งตรงกับนโยบายของกระทรวงสาธารณสุขที่ให้ผู้บริหารสูงสุดของหน่วยงานเป็นผู้รับผิดชอบ

19.2 โครงสร้างและบทบาท



▲ ภาพที่ 19.1 โครงสร้างธรรมาภิบาลไซเบอร์ของหน่วยงาน

บทบาท	สิ่งที่ต้องทำเป็นประจำ	ตัวชี้วัดที่ควรรายงาน
CEO	ลงนามนโยบาย, อนุมัติงบ, รับรายงานรายไตรมาส, ร่วมซ้อมแผน	ระดับ CTAM+ ของหน่วยงาน, เหตุการณ์สำคัญ
CIO	วางแผน IT ให้สอดคล้องความปลอดภัย, จัดซื้อที่มีข้อกำหนดความปลอดภัย	% ระบบที่อยู่ในทะเบียนและมีเจ้าของ
CISO	ประเมินความเสี่ยง, ติดตาม CTAM+, นำทีม IR, รายงานผู้บริหาร	% เกณฑ์ CTAM+ ที่ผ่าน, ช่องโหว่ Critical ค้าง, MTTD/MTTR
DPO	ROPA/เวชระเบียน, คำขอใช้สิทธิ, ประเมินเหตุละเมิด, ให้คำปรึกษา	จำนวนคำขอ/เหตุละเมิด, ระยะเวลาแจ้ง
งาน IT	ดำเนินการตามบท 7–16, เก็บหลักฐาน	Patch ตาม SLA, Backup ทดสอบผ่าน
หัวหน้างานบริการ	ควบคุมสิทธิ์และพฤติกรรมของทีม, Downtime Procedure	% ผ่านอบรม

💡 หน่วยงานขนาดเล็ก (รพ.สต./รพช.) อาจให้คนเดียวมีหลายบทบาทได้ แต่ **CISO ไม่ควรเป็นคนเดียวกับผู้ดูแลระบบที่ถูกตรวจ** หากเลี่ยงไม่ได้ ให้ สสจ. หรือหน่วยงานแม่ข่ายทำหน้าที่สอบทาน

19.3 การรายงานผู้บริหาร (1 หน้าต่อไตรมาส)

หัวข้อ	สถานะ	แนวโน้ม	ต้องการการตัดสินใจ
ระดับ CTAM+	14/17 เกณฑ์	▲ จาก 11	อนุมัติงบ WAF/MFA
ช่องโหว่ Critical ค้างเกินกำหนด	2	▼	ยอมรับความเสี่ยงอุปกรณ์ Lab รุ่นเก่า?
Backup ทดสอบกู้คืนสำเร็จ	3/3 ระบบหลัก	—	—
เหตุการณ์ P1/P2	0 / 1 (บัญชีถูกยึด แก้แล้ว)	—	—
บุคลากรผ่านอบรม	76%	▲	ให้หัวหน้างานติดตาม

19.4 ความเสี่ยงจากคู่ค้าและห่วงโซ่อุปทาน

โรงพยาบาลไทยพึ่ง Vendor สูงมาก (HIS, LIS, PACS, เครื่องมือแพทย์, Cloud, ผู้พัฒนาเว็บ) เหตุ Change Healthcare ในสหรัฐฯ ปี 2567 แสดงว่าเมื่อผู้ให้บริการรายเดียวถูกโจมตี สถานพยาบาลจำนวนมากหยุดชะงักพร้อมกัน เป้าหมายด้านความปลอดภัยของภาคสุขภาพสหรัฐฯ (HHS Cybersecurity Performance Goals) จึงบรรจุ **การจัดการความเสี่ยงบุคคลที่สาม** ไว้ในกลุ่มเป้าหมายพื้นฐาน (Essential)

ข้อกำหนดที่ควรใส่ใน TOR / สัญญา

- ☐ ปฏิบัติตามนโยบายความปลอดภัยของหน่วยงาน, PDPA และ พ.ร.บ.ไซเบอร์
- ☐ **ข้อตกลงการประมวลผลข้อมูลส่วนบุคคล (DPA)** ระบุวัตถุประสงค์ การลบ/คืนข้อมูลเมื่อสิ้นสุดสัญญา และห้ามใช้ข้อมูลผู้ป่วยเพื่อวัตถุประสงค์อื่น
- ☐ **NDA** สำหรับพนักงานของ Vendor ที่เข้าถึงระบบ
- ☐ **แจ้งเหตุภายใน 24 ชั่วโมง** เมื่อ Vendor พบเหตุที่อาจกระทบหน่วยงาน (เพื่อให้หน่วยงานแจ้ง Health CERT/สคส. ทันเวลา)
- ☐ Remote Access ผ่านช่องทางที่หน่วยงานควบคุม มี MFA เปิดเฉพาะเมื่ออนุมัติ และบันทึก Log (บทที่ 8)
- ☐ ส่งมอบ **Patch และแจ้งช่องโหว่** ภายในเวลาที่กำหนด, ระบุวันสิ้นสุดการสนับสนุน (EOL)
- ☐ ไม่ใช้บัญชีหรือรหัสผ่านเริ่มต้นร่วมกันทุกโรงพยาบาล
- ☐ ส่งมอบ Source Code/ข้อมูลในรูปแบบมาตรฐาน หรือทำ Escrow เพื่อไม่ติดผู้ขายรายเดียว
- ☐ สำหรับเครื่องมือแพทย์: ขอ **SBOM (Software Bill of Materials)** และคำแนะนำการติดตั้งอย่างปลอดภัย (ดูบทที่ 22)
- ☐ สิทธิ์ของหน่วยงานในการตรวจสอบ/ทดสอบความปลอดภัย

ทะเบียน Vendor

Vendor	ระบบ	เข้าถึงข้อมูลผู้ป่วย	วิธีเข้าถึง	DPA/NDA	สัญญาหมดอายุ	ทบทวนล่าสุด
บริษัท ก	HIS	ใช่	VPN + MFA (เปิดตามคำขอ)	มี/มี	ก.ย. 70	ต.ค. 69

19.5 Cloud และบริการออนไลน์

ตัวเลือก	ข้อดี	สิ่งที่ต้องระวัง
GDCC (Government Data Center and Cloud service) ของภาครัฐ	อยู่ในประเทศ อยู่ภายใต้การกำกับของรัฐ	ความจุจำกัด, หน่วยงานยังต้องดูแลความปลอดภัยของ VM/แอปเอง
Cloud เอกชน (ในประเทศ/ต่างประเทศ)	ยืดหยุ่น มีเครื่องมือความปลอดภัยครบ	ที่ตั้งข้อมูล, การโอนข้อมูลไปต่างประเทศตาม PDPA มาตรา 28–29, ต้นทุนระยะยาว
SaaS (Google Workspace, Microsoft 365, ระบบนัดหมาย)	ไม่ต้องดูแลเครื่อง	การตั้งค่าแชร์, MFA, ข้อมูลผู้ป่วยในเอกสารแชร์สาธารณะ

หลัก **ความรับผิดชอบร่วม (Shared Responsibility)**: ผู้ให้บริการดูแลโครงสร้างพื้นฐาน ส่วนหน่วยงานยังต้องดูแลบัญชีผู้ใช้ สิทธิ์ การตั้งค่า ข้อมูล และ Backup ของตนเองเสมอ

📌 สพร. (DGA) อยู่ระหว่างจัดทำมาตรฐานการบริหารจัดการคลาวด์ภาครัฐ และร่างหลักเกณฑ์การจัดระดับชั้นข้อมูลภาครัฐ ให้ติดตามฉบับประกาศใช้จริงที่ `standard.dga.or.th` ก่อนกำหนดนโยบาย Cloud ของหน่วยงาน

19.6 โมเดล สสจ. เป็นศูนย์กลางของจังหวัด

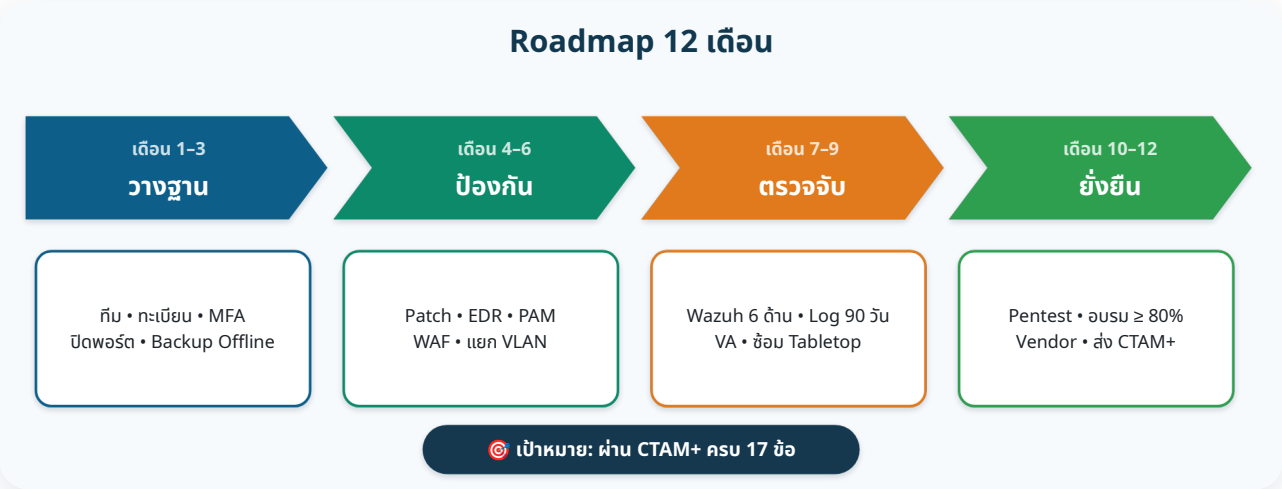
หน่วยบริการขนาดเล็กไม่สามารถมีผู้เชี่ยวชาญครบทุกด้าน โมเดลที่ใช้ได้ผลคือให้ **สสจ. หรือโรงพยาบาลแม่ข่ายเป็นศูนย์กลาง (Shared Service)** โดย

บริการกลาง	ตัวอย่างการจัดการ
ศูนย์เฝ้าระวัง (Mini-SOC)	Wazuh Manager ระดับจังหวัด รับ Log จาก รพ.ทุกแห่ง (แยกสิทธิ์ราย รพ.)
Threat Intelligence กลาง	NCSA Blacklist SOC Dashboard 1 ชุด ส่ง Feed ให้ Firewall ทุก รพ. (บทที่ 15)
VA Scan รายไตรมาส	ทีมจังหวัดสแกนตามรอบ ส่งรายงานให้แต่ละ รพ.
ที่ปรึกษา CTAM+	ตรวจหลักฐานก่อนส่ง (Provincial Admin) จัดคลินิกให้คำปรึกษา
อบรมและซ้อมแผน	หลักสูตรกลาง ซ้อม Tabletop ระดับจังหวัดปีละครั้ง
ประสานเหตุ	ช่องทางรวมแจ้งเหตุในจังหวัด ประสาน Health CERT และเขตสุขภาพ
จัดซื้อร่วม	ต่อรอง License/EDR/Firewall ร่วมกัน ได้ราคาและมาตรฐานเดียว

โฟลว์การประสานข้อมูล บทบาท RACI และระบบจัดการความรู้ของจังหวัดและเขต อยู่ในบทที่ 24

ในระดับเขตสุขภาพ ใช้บริการ CSOC/CO-CSIRT ที่กระทรวงจัดหา (ถ้ามี) ร่วมกับศูนย์จังหวัด เพื่อให้มีผู้เฝ้าระวังตลอด 24 ชั่วโมง

19.7 Roadmap 12 เดือน



▲ ภาพที่ 19.2 Roadmap 12 เดือน

ช่วง	เป้าหมาย	งานหลัก	บทอ้างอิง
เดือน 1–3: วางฐาน	รู้ว่ามีอะไร ปิดรูใหญ่	แต่งตั้ง CISO/DPO/ทีม IR, ทะเบียนทรัพย์สิน, MFA ที่ VPN/Remote Access, ปิดพอร์ตที่เปิดสู่ภายนอกโดยไม่จำเป็น, Backup Offline + ทดสอบกู้คืน, Threat Feed บน Firewall	7, 8, 9, 13, 15
เดือน 4–6: ป้องกัน	ผ่าน CTAM+ ข้อ 1–8	Patch ตาม SLA, EDR/AV ครบ, PAM, WAF หน้าเว็บ, แยก VLAN อุปกรณ์การแพทย์, Hardening HIS DB	10, 11, 12
เดือน 7–9: ตรวจจับ	เห็นเหตุภายในชั่วโมง	Wazuh + กฎ 6 ด้าน, Log 90 วัน, VA รอบแรก + ทะเบียนช่องโหว่, ซ้อม Tabletop ครั้งแรก	14, 16, 17
เดือน 10–12: ยั่งยืน	ผ่าน 17 เกณฑ์ และทำซ้ำได้	Pentest (OP01), อบรม ≥ 80% + Phishing Simulation, ทบทวน Vendor/สัญญา, รายงานผู้บริหาร, ส่ง CTAM+	6, 16, 18, 19

19.8 งบประมาณขั้นต่ำที่ควรขอ

รายการ	ทางเลือกต้นทุนต่ำ
Firewall NGFW + License	ใช้ Threat Feed ฟรี (NCSA Blacklist) เสริม
MFA	TOTP (Google Authenticator/FreeOTP) ฟรี

รายการ	ทางเลือกต้นทุนต่ำ
SIEM	Wazuh (โอเพนซอร์ส)
WAF	Nginx + ModSecurity + CRS หรือ Cloudflare แผนฟรี
Backup	Proxmox Backup Server + ฮาร์ดดิสก์สำรองแบบถอดได้
VA	Greenbone/Nuclei (โอเพนซอร์ส)
Pentest	ขอรับบริการจาก ศปช./สกมช.
อบรม	สื่อฟรีจาก สกมช./สคส./TDGA + GoPhish

ค่าใช้จ่ายที่หลีกเลี่ยงไม่ได้คือ **เวลาของคน** ผู้บริหารควรจัดสรรเวลาให้งาน IT ทำงานความปลอดภัยอย่างน้อย 20% ของเวลางาน

📋 **หลักฐาน**: คำสั่งแต่งตั้ง, ผังโครงสร้าง, รายงานผู้บริหาร, ทะเบียน Vendor + สัญญา DPA/NDA, Roadmap ที่ผู้บริหารอนุมัติ

⭐ สรุปท้ายบท

- ผู้บริหารสูงสุดเป็นเจ้าของความเสี่ยง CISO และ DPO เป็นผู้ขับเคลื่อน
- Vendor และ Cloud เป็นส่วนหนึ่งของพื้นที่โจมตี ต้องควบคุมด้วยสัญญาและการเข้าถึง
- สสจ./เขตเป็นศูนย์กลางบริการร่วม ช่วยหน่วยบริการขนาดเล็กได้คุ้มค่าที่สุด
- ทำตาม Roadmap 12 เดือน และรายงานผู้บริหาร 1 หน้าทุกไตรมาส

✏️ คำถามทบทวน

1. ใครเป็นเจ้าของความเสี่ยงไซเบอร์ของหน่วยงาน และใครเป็นผู้ขับเคลื่อนงาน
2. สัญญากับ Vendor ผู้ดูแล HIS ควรมีข้อกำหนดด้านความปลอดภัยอะไรบ้าง
3. รพ.สต. 20 แห่งในอำเภอไม่มีนักวิชาการคอมพิวเตอร์ สสจ. ควรช่วยอย่างไร
4. ร่างรายงานผู้บริหาร 1 หน้าของไตรมาสนี้ตามแม่แบบในบทนี้



ภาค 6

สุขภาพดิจิทัลยุคใหม่และแนวทางสากล

Digital Health & Global Practice

20 มาตรฐานสากลและบทเรียนต่างประเทศสำหรับสุขภาพดิจิทัล

21 ความปลอดภัยอีเมล โดเมน และ Cloud Workspace

22 ความปลอดภัยอุปกรณ์การแพทย์ PACS การเชื่อมต่อ HL7 และระบบอาคาร



ภาค 6 · สุขภาพดิจิทัลยุคใหม่และแนวทางสากล บทที่ 20

มาตรฐานสากลและบทเรียนต่างประเทศสำหรับสุขภาพดิจิทัล

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้จักแนวทางด้านความปลอดภัยไซเบอร์ของภาคสุขภาพที่สำคัญในต่างประเทศ (สหรัฐฯ, ยุโรป, WHO)
- ✔️ เทียบแนวทางสากลกับ CTAM+ และนโยบายกระทรวงสาธารณสุข เพื่อใช้เป็นข้อมูลประกอบการวางแผน
- ✔️ ประยุกต์ใช้กับงานสุขภาพดิจิทัลรุ่นใหม่ เช่น Telemedicine, แอปสุขภาพ, API/FHIR, อุปกรณ์การแพทย์ที่เชื่อมเครือข่าย และ AI

📋 บทนี้เป็นความรู้ประกอบ เกณฑ์ที่ใช้ประเมินจริงในประเทศไทยยังคือ CTAM+, ตัวชี้วัดของกระทรวง, พ.ร.บ.ไซเบอร์ และ PDPA

20.1 ภาพรวมสถานการณ์โลก

แหล่ง	ข้อค้นพบ	ความหมายต่อหน่วยงานไทย
ENISA (สหภาพยุโรป) รายงาน Threat Landscape ภาคสุขภาพฉบับแรก (ก.ค. 2566) วิเคราะห์ 215 เหตุการณ์ (ม.ค. 2564–มี.ค. 2566)	**Ransomware 54%** ของภัยคุกคาม, ข้อมูลรั่วไหล 46% (เหตุหนึ่งจัดได้หลายประเภท), ข้อมูลผู้ป่วยเป็นสินทรัพย์ที่ถูกโจมตีมากที่สุด (30%), องค์กรที่สำรวจ 73% ไม่มีโปรแกรมรับมือ Ransomware	Backup Offline + แผนรับมือ Ransomware (บท 13, 17) คือสิ่งที่ต้องมีก่อน
WHO ผู้อำนวยการใหญ่บรรยายต่อคณะมนตรีความมั่นคงแห่งสหประชาชาติ (8 พ.ย. 2567)	Ransomware ต่อโรงพยาบาล “เป็นเรื่องความเป็นความตาย”, การโจมตีภาคสุขภาพเพิ่มทั้งขนาดและความถี่, ผู้มีอำนาจด้านสุขภาพและเจ้าของระบบต้องรับผิดชอบต่อความปลอดภัยของระบบ	ความปลอดภัยไซเบอร์เป็นเรื่องความปลอดภัยของผู้ป่วย (Patient Safety) ไม่ใช่แค่งาน IT
HHS (สหรัฐฯ) กรณี Change Healthcare (ก.พ. 2567)	เข้าระบบด้วยรหัสผ่านที่ถูกขโมยผ่าน Remote Access ที่ไม่มี MFA, ข้อมูลรั่วราว 190 ล้านคน, ระบบเบิกจ่ายทั่วประเทศหยุดหลายสัปดาห์	MFA ทุกช่องทางเข้า (CTAM+ ข้อ 7) และความเสี่ยงจาก Vendor รายเดียว (บท 19)

20.2 สหรัฐอเมริกา: HHS 405(d) และ HICP

โครงการ **405(d)** ของกระทรวงสาธารณสุขสหรัฐฯ (HHS) ร่วมกับภาคเอกชนจัดทำเอกสาร **Health Industry Cybersecurity Practices (HICP)** ฉบับปรับปรุง 2566 (2023 Edition) เผยแพร่ฟรีที่ `405d.hhs.gov` ประกอบด้วย

- **เอกสารหลัก** อธิบาย **5 ภัยหลัก** ของภาคสุขภาพ: (1) อีเมลฟิชชิง (2) Ransomware (3) อุปกรณ์หรือข้อมูลสูญหาย/ถูกขโมย (4) ภัยจากคนใน (โดยตั้งใจหรือพลั้งเผลอ) (5) การโจมตีอุปกรณ์การแพทย์ที่เชื่อมเครือข่าย
- **Technical Volume 1** สำหรับองค์กรขนาดเล็ก และ **Technical Volume 2** สำหรับองค์กรขนาดกลาง–ใหญ่ โดยทั้งสองเล่มใช้ **10 แนวปฏิบัติ** ชุดเดียวกัน แต่ระดับความลึกต่างกัน

ข้อดีของ HICP สำหรับประเทศไทยคือแยกขนาดองค์กร ซึ่งเทียบได้กับ รพ.สต./รพช. (เล่ม 1) และ รพท./รพศ./สสจ. (เล่ม 2)

#	แนวปฏิบัติ HICP	เทียบ CTAM+	บทในหนังสือ
1	Email Protection Systems	2, 17	18, 21
2	Endpoint Protection Systems	2, 6, 13	10
3	Access Management	3, 4, 7	8
4	Data Protection and Loss Prevention	1	4, 12, 13
5	IT Asset Management	12, 15	7
6	Network Management	8, 14	9, 11
7	Vulnerability Management	6, 11, 13, 16	16
8	Security Operations Center and Incident Response	9, 10	14, 15, 17
9	Network Connected Medical Device Security	12, 14	10, 20.6, 22
10	Cybersecurity Oversight and Governance (ฉบับ 2566 เพิ่มหัวข้อย่อยการประเมินและบริหารความเสี่ยง)	5, 17	5, 7, 19

⚠️ ชื่อแนวปฏิบัติข้างต้นสรุปจากเอกสาร HICP โปรดตรวจกับต้นฉบับที่ `405d.hhs.gov` ก่อนอ้างอิงในเอกสารราชการ HICP เป็นแนวทางโดยสมัครใจ ไม่ใช่รายการควบคุมที่ทุกองค์กรต้องทำครบ

Cybersecurity Performance Goals (CPGs) ภาคสุขภาพ

ต้นปี 2567 HHS ออก **Healthcare and Public Health Sector-Specific CPGs** เป็นเป้าหมายโดยสมัครใจ แบ่งสองระดับ

- **Essential (พื้นฐาน)** เช่น แก้ไขช่องโหว่ที่รู้จัก, ป้องกันอีเมล, MFA, อบรม, เข้ารหัส, ความเสี่ยงจากบุคคลที่สาม

- **Enhanced (ขั้นสูง)** เช่น ทะเบียนทรัพย์สิน, แบ่งเครือข่าย, บริหารการตั้งค่า, รวบรวม Log จากศูนย์กลาง, ทดสอบความปลอดภัย, การแจ้งเหตุของบุคคลที่สาม

แนวคิด “พื้นฐานก่อน ขั้นสูงทีหลัง” สอดคล้องกับการแบ่ง **เกณฑ์ขั้นต่ำ** และ **เกณฑ์ขั้นสูง** ในตัวชี้วัด Cybersecurity v2.1 ของกระทรวง (บทที่ 5)

NIST SP 800-66 Revision 2 (กุมภาพันธ์ 2567)

“Implementing the HIPAA Security Rule: A Cybersecurity Resource Guide” เป็นคู่มือที่จับคู่ข้อกำหนดด้านความปลอดภัยของกฎหมายข้อมูลสุขภาพสหรัฐฯ (HIPAA) กับ **NIST CSF** และ **SP 800-53r5** มีประโยชน์กับผู้ที่ต้องการเทียบข้อกำหนดทางกฎหมายด้านข้อมูลสุขภาพเข้ากับมาตรการทางเทคนิค ซึ่งคล้ายกับการเทียบ PDPA มาตรา 37(1) (มาตรการความปลอดภัยที่เหมาะสม) กับ CTAM+ NIST ระบุชัดว่าเอกสารนี้เป็น **แหล่งความรู้ ไม่ใช่ Checklist** สำหรับการปฏิบัติตามกฎหมาย

NIST SP 800-61 Revision 3 (เมษายน 2568)

คู่มือรับมือเหตุการณ์ฉบับใหม่ที่ผูกกับ CSF 2.0 ทั้ง 6 ฟังก์ชัน รายละเอียดอยู่ในบทที่ 17

20.3 สหภาพยุโรป: ENISA และ NIS2

- **ENISA** (หน่วยงานความมั่นคงปลอดภัยไซเบอร์ของสหภาพยุโรป) เผยแพร่รายงานภัยคุกคามและแนวปฏิบัติด้านสุขภาพที่ `enisa.europa.eu/topics/cybersecurity-of-critical-sectors/health` เช่น แนวทางการจัดซื้อจัดจ้างที่ปลอดภัยสำหรับโรงพยาบาล
- กฎหมาย **NIS2** กำหนดให้ผู้ให้บริการด้านสุขภาพเป็นภาคส่วนสำคัญ มีหน้าที่บริหารความเสี่ยงและแจ้งเหตุภายในกรอบเวลาที่กำหนด (แจ้งเตือนเบื้องต้นภายใน 24 ชั่วโมง) แนวคิดคล้ายกับ CII ด้านสาธารณสุขตาม พ.ร.บ.ไซเบอร์ 2562 ของไทย (บทที่ 3)

20.4 องค์การอนามัยโลก (WHO)

WHO มองความปลอดภัยไซเบอร์เป็นองค์ประกอบของ **ยุทธศาสตร์สุขภาพดิจิทัลโลก (Global Strategy on Digital Health 2020–2025)** และระบุว่ากำลังจัดทำแนวทางการลงทุนด้านความปลอดภัยไซเบอร์และความเป็นส่วนตัวสำหรับ Digital Health Interventions หลักที่นำมาใช้ได้ทันที

1. ความปลอดภัยไซเบอร์ = ความปลอดภัยของผู้ป่วย ควรรายงานในคณะกรรมการความเสี่ยงของโรงพยาบาลร่วมกับความเสี่ยงทางคลินิก
2. ทุกโครงการสุขภาพดิจิทัลต้องมีงบประมาณด้านความปลอดภัยตั้งแต่เริ่ม (Security by Design) ไม่ใช่เพิ่มเมื่อเกิดเหตุ
3. ความร่วมมือข้ามหน่วยงานและข้ามประเทศ เช่น การแลกเปลี่ยน IOC (บทที่ 15)

20.5 หน่วยงานไทยที่ควรติดตาม

หน่วยงาน	สิ่งที่ได้	เว็บไซต์
ศทส.สป.สธ. / Health CERT	นโยบาย สธ., CTAM+, ประกาศเตือน, รับแจ้งเหตุ	`cyber.moph.go.th`, `health-cirt.moph.go.th`
สกมช. (NCSA) / ThaiCERT	พ.ร.บ.ไซเบอร์, ประมวลแนวทางปฏิบัติและกรอบมาตรฐานสำหรับหน่วยงานของรัฐและ CII (ประกาศ กกม. 2564), NCSA Blacklist Feed, Pentest (OP01)	`ncsa.or.th`, `thaicert.or.th`
สคส. (PDPC)	PDPA, ประกาศแจ้งเหตุละเมิด 2565, แนวปฏิบัติ, คำสั่งลงโทษทางปกครอง	`pdpc.or.th`
สพร. (DGA)	มาตรฐานรัฐบาลดิจิทัล, ธรรมาภิบาลข้อมูล, ร่างมาตรฐานคลาวด์และการจัดชั้นข้อมูล	`dga.or.th`, `standard.dga.or.th`
สพธอ. (ETDA)	มาตรฐานธุรกรรมอิเล็กทรอนิกส์, Digital ID, ลายมือชื่ออิเล็กทรอนิกส์	`etda.or.th`
สบส.	กำกับสถานพยาบาลเอกชน	`hss.moph.go.th`

💡 ประกาศ กกม. เรื่องประมวลแนวทางปฏิบัติและกรอบมาตรฐานฯ พ.ศ. 2564 เป็น **ข้อกำหนดขั้นต่ำ** ที่หน่วยงานของรัฐและ CII ต้องนำไปจัดทำประมวลแนวทางของตน ตรวจฉบับเต็มในราชกิจจานุเบกษาก่อนอ้างอิง

20.6 ประยุกต์ใช้กับงานสุขภาพดิจิทัล

20.6.1 Telemedicine และการให้คำปรึกษาออนไลน์

- ใช้แพลตฟอร์มที่หน่วยงานอนุมัติ ไม่ใช้วิดีโอคอลส่วนตัวกับผู้ป่วย
- ยืนยันตัวตนผู้ป่วยก่อนให้คำปรึกษา (เช่น ผ่าน Digital ID หรือข้อมูลที่ลงทะเบียนไว้)
- ไม่บันทึกวิดีโอเว้นแต่มีเหตุจำเป็นและแจ้งผู้ป่วย บันทึกที่เก็บต้องเข้ารหัสและกำหนดระยะเวลาเก็บ
- ใบสั่งยาและเอกสารอิเล็กทรอนิกส์ใช้ลายมือชื่ออิเล็กทรอนิกส์ตามมาตรฐาน ETDA

20.6.2 แอปพลิเคชันสุขภาพและ PHR

- ทดสอบตาม **OWASP MASVS** (มาตรฐานความปลอดภัยแอปมือถือ) ก่อนเผยแพร่
- ไม่เก็บข้อมูลสุขภาพในเครื่องโดยไม่เข้ารหัส ไม่ฝัง API Key ในแอป
- Privacy Notice ที่ผู้ป่วยอ่านเข้าใจได้ และขอความยินยอมแยกเรื่อง (บทที่ 4)

20.6.3 API, การแลกเปลี่ยนข้อมูล และ HL7 FHIR

การเชื่อมระบบผ่าน API (เช่น ส่งข้อมูลระหว่าง รพ., ส่งข้อมูลเบิกจ่าย, เชื่อม PHR) เพิ่มขึ้นมาก ภัยหลักตาม **OWASP API Security Top 10 (2023)** คือ การตรวจสิทธิ์ระดับรายการไม่ถูกต้อง (BOLA) เช่น เปลี่ยนเลข HN ใน URL แล้วเห็นข้อมูลผู้ป่วยรายอื่น

```
GET /api/patient/12345/lab    ← ผู้ใช้ A ดูของตนเองได้
GET /api/patient/12346/lab    ← ถ้าผู้ใช้ A ดูของคนอื่นได้ = ช่องโหว่ BOLA
```

มาตรการขั้นต่ำ

- ยืนยันตัวตนด้วย OAuth 2.0 / OpenID Connect (สำหรับ FHIR ใช้ SMART on FHIR) และใช้ Token อายุสั้น
- ตรวจสิทธิ์ทุกคำขอที่ฝั่งเซิร์ฟเวอร์ว่าผู้ขอมีสิทธิ์ในข้อมูลรายการนั้นจริง
- จำกัดอัตราการเรียก (Rate Limiting) และบันทึก Log ทุกการเข้าถึงข้อมูลผู้ป่วย
- ส่งเฉพาะฟิลด์ที่จำเป็น (Data Minimization) และใช้ HTTPS เสมอ
- ทำทะเบียน API ทั้งหมด เพราะ API ที่ถูกลืมคือช่องโหว่ที่พบบ่อย

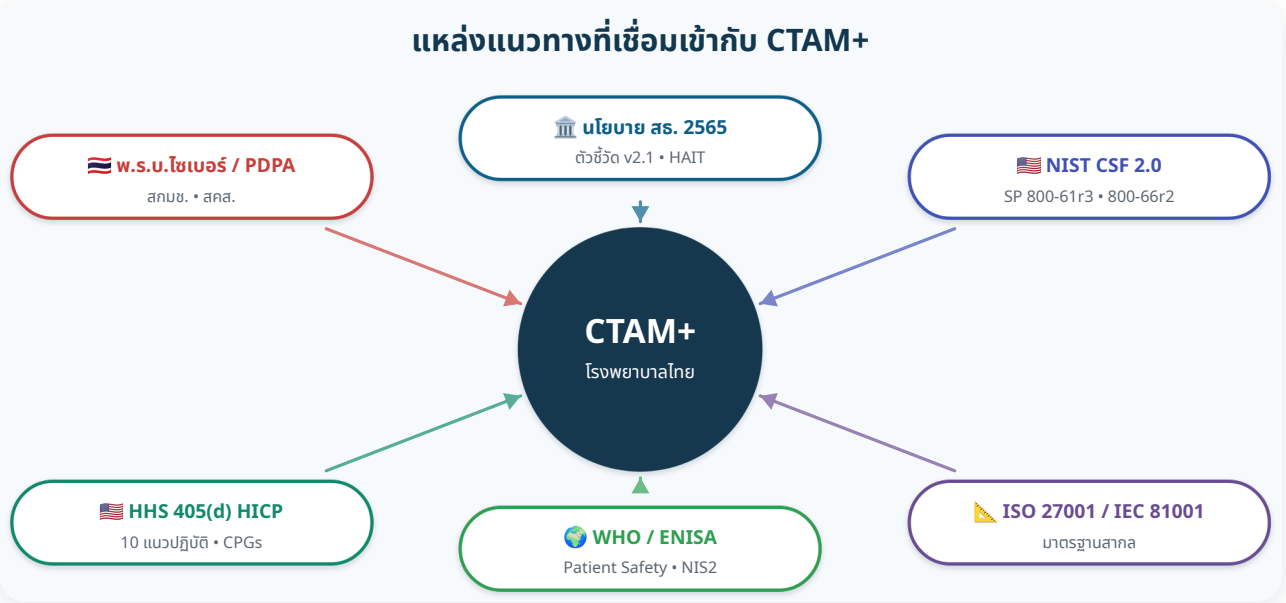
20.6.4 อุปกรณ์การแพทย์ที่เชื่อมเครือข่าย (IoMT)

- สหรัฐฯ เพิ่ม **มาตรา 524B** ในกฎหมายอาหารและยา (มีผลมีนาคม 2566) กำหนดให้ผู้ผลิต “Cyber Device” ต้องส่ง **SBOM**, แผนติดตามและแก้ไขช่องโหว่หลังวางตลาด และกระบวนการพัฒนาที่ปลอดภัย ก่อนขึ้นทะเบียนกับ FDA
- มาตรฐานสากลที่ใช้อ้างอิงในการจัดซื้อ: **IEC 81001-5-1** (วงจรการพัฒนาซอฟต์แวร์สุขภาพที่ปลอดภัย) และ **IEC 80001-1** (การบริหารความเสี่ยงเมื่อนำอุปกรณ์เข้าเครือข่ายโรงพยาบาล)
- สิ่งที่โรงพยาบาลไทยทำได้ทันที: ขอ SBOM และ MDS2 (แบบเปิดเผยข้อมูลความปลอดภัยของเครื่องมือแพทย์) ใน TOR, แยก VLAN อุปกรณ์การแพทย์ (บทที่ 9), ไม่ให้อุปกรณ์ออกอินเทอร์เน็ตโดยตรง, ทำทะเบียนพร้อมวัน EOL

20.6.5 ปัญญาประดิษฐ์ (AI) ในงานสุขภาพ

- **ห้ามนำข้อมูลผู้ป่วยที่ระบุตัวตนได้ ใส่ในบริการ AI สาธารณะ** ที่ไม่มีสัญญาคุ้มครองข้อมูลกับหน่วยงาน
- ใช้ข้อมูลแฝง (Pseudonymized) หรือข้อมูลนิรนาม และผ่านการพิจารณาของ DPO
- ผลจาก AI เป็นข้อมูลประกอบการตัดสินใจ แพทย์ยังเป็นผู้รับผิดชอบ
- ประเมินผู้ให้บริการ AI เหมือน Vendor อื่น (บทที่ 19): ที่ตั้งข้อมูล, การนำข้อมูลไปฝึกโมเดล, การลบข้อมูล

20.7 ตารางเทียบกรอบมาตรฐาน (สรุป)



▲ ภาพที่ 20.1 แนวทางในประเทศและสากลที่เชื่อมเข้ากับ CTAM+

ประเด็น	CTAM+ (ไทย)	NIST CSF 2.0	HHS HICP / CPG	ISO 27001:2022
ธรรมาภิบาล/นโยบาย	17	GV	Practice 10	5.1–5.4
ทะเบียนทรัพย์สิน	12, 15	ID.AM	Practice 5 / Enhanced	5.9
สิทธิ์และ MFA	3, 4, 7	PR.AA	Practice 3 / Essential	5.15–5.18, 8.5
ป้องกันเครื่อง	2, 6, 13	PR.PS	Practice 2	8.7, 8.8
เครือข่าย/WAF	8, 14	PR.IR	Practice 6 / Enhanced	8.20–8.23
Backup/BCP	1, 5	PR.DS, RC	Practice 4	8.13, 5.29–5.30
Log/SIEM	9, 10	DE.CM, DE.AE	Practice 8 / Enhanced	8.15, 8.16
ช่องโหว่/Pentest	11, 16	ID.RA	Practice 7 / Essential	8.8
อุปกรณ์การแพทย์	(12, 14)	ID.AM, PR.IR	Practice 9	8.20
รับมือเหตุ	(5, 10)	RS, RC	Practice 8	5.24–5.28

⚠️ ตารางนี้เป็นการเทียบโดยผู้เขียนเพื่อช่วยวางแผน ไม่ใช่การเทียบทางการของหน่วยงานใด

⭐ สรุปท้ายบท

- ทั่วโลกเห็นตรงกันว่า Ransomware และข้อมูลรั่วคือภัยหลักของภาคสุขภาพ และความปลอดภัยไซเบอร์เป็นเรื่องความปลอดภัยของผู้ป่วย
- HICP ของสหรัฐฯ แยกตามขนาดองค์กร ใช้เป็นแหล่งความรู้เสริม CTAM+ ได้ดี
- งานสุขภาพดิจิทัลรุ่นใหม่ (Telemedicine, API/FHIR, IoMT, AI) ต้องออกแบบความปลอดภัยตั้งแต่เริ่ม และควบคุมผ่านสัญญากับผู้ให้บริการ

✏️ คำถามทบทวน

1. HICP ของสหรัฐฯ ระบุภัยหลักของภาคสุขภาพ 5 ข้ออะไรบ้าง
2. Technical Volume 1 กับ 2 ของ HICP ต่างกันอย่างไร
3. โรงพยาบาลจะเปิดบริการ Telemedicine ผ่านแอปของบริษัทเอกชน ควรตรวจอะไรก่อนลงนาม
4. ใช้ตารางเทียบกรอบมาตรฐานหัวข้อ 20.7 เลือกงาน 3 อย่างที่ทำแล้วตอบได้ทั้ง CTAM+ และ NIST CSF



ภาค 6 · สุขภาพดิจิทัลยุคใหม่และแนวทางสากล บทที่ 21

ความปลอดภัยอีเมล โดเมน และ Cloud Workspace

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ ตั้งค่า SPF, DKIM และ DMARC ป้องกันผู้อื่นปลอมอีเมลในนามหน่วยงาน
- ✔️ ดูแลโดเมน DNS และใบรับรอง HTTPS ไม่ให้ถูกยึดหรือหมดอายุ
- ✔️ ตั้งค่าความปลอดภัยพื้นฐานของ Google Workspace / Microsoft 365 และบัญชีโซเชียลของหน่วยงาน

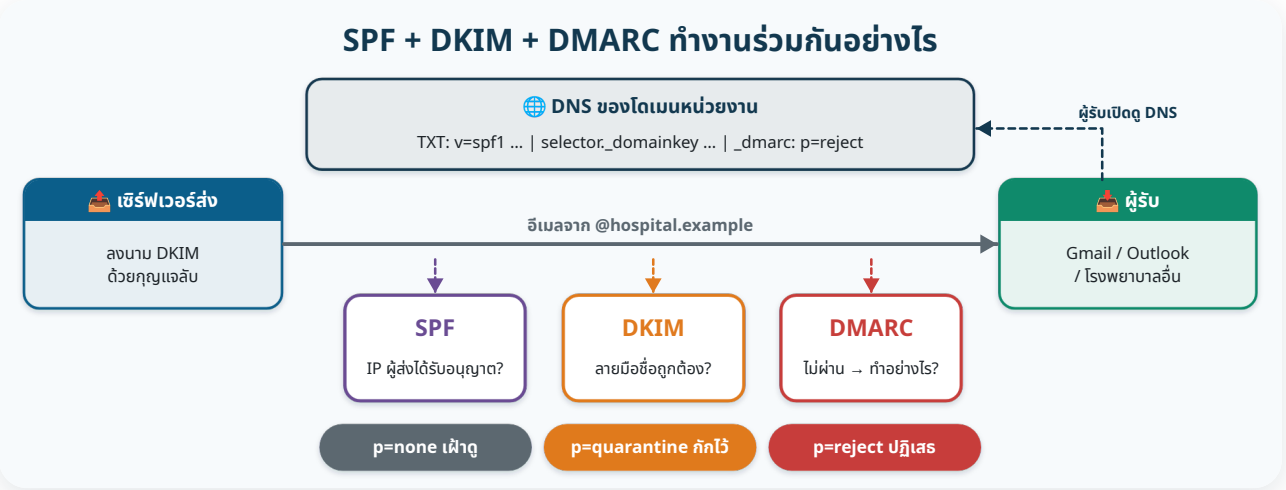
📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 3, 7, 12, 17, HHS 405(d) HICP Practice 1 (Email Protection), HPH CPG (Essential: Email Security)

21.1 ทำไมอีเมลและโดเมนสำคัญ

อีเมลเป็นช่องทางเริ่มต้นของการโจมตีส่วนใหญ่ (บทที่ 18) และโดเมนของโรงพยาบาลเป็น “ตัวตนทางดิจิทัล” ที่ผู้ป่วยเชื่อถือ ถ้าไม่มีการตั้งค่าป้องกัน ผู้โจมตีสามารถ

- ส่งอีเมลโดยใช้ชื่อผู้ส่ง `director@hospital.example` ปลอม ไปหลอกบุคลากรหรือคู่ค้าให้โอนเงิน
- ยึดโดเมนย่อยที่เลิกใช้แล้วแต่ DNS ยังชี้อยู่ (Subdomain Takeover) ไปทำหน้าเว็บหลอก
- ใช้ประโยชน์จากใบรับรอง HTTPS ที่หมดอายุ ทำให้ผู้ใช้ชินกับการกด “ยอมรับความเสี่ยง”

21.2 SPF, DKIM, DMARC เข้าใจใน 1 นาที



▲ ภาพที่ 21.1 SPF, DKIM และ DMARC ทำงานร่วมกัน

กลไก	ตอบคำถาม	อยู่ที่ไหน
SPF	เซิร์ฟเวอร์นี้ได้รับอนุญาตให้ส่งอีเมลในนามโดเมนนี้หรือไม่	DNS TXT ที่ชื่อโดเมน
DKIM	ข้อความถูกแก้ไขระหว่างทางหรือไม่ และลงลายมือชื่อโดยโดเมนนี้จริงหรือไม่	DNS TXT ที่ `<selector>._domainkey` + กุญแจในเซิร์ฟเวอร์ส่ง
DMARC	ถ้า SPF/DKIM ไม่ผ่าน ให้ผู้รับทำอย่างไร (ปล่อย/กักไว้/ปฏิเสธ) และส่งรายงานให้ใคร	DNS TXT ที่ `_dmarc.<โดเมน>`

💡 ผู้ให้บริการอีเมลรายใหญ่ (Google, Yahoo, Microsoft) เริ่มบังคับให้ผู้ส่งจำนวนมากต้องมี SPF, DKIM และ DMARC ตั้งแต่ปี 2567 อีเมลจากโดเมนที่ไม่ได้ตั้งค่ามีแนวโน้มเข้ากล่องขยะหรือถูกปฏิเสธ หน่วยงานรัฐของสหรัฐฯ ถูกกำหนดให้ใช้ DMARC ระดับ `p=reject` มาตั้งแต่คำสั่ง BOD 18-01 (2561)

21.3 Lab: ตรวจสถานะโดเมนของตนเอง 🧪 LAB

```
# ใช้ได้บน Linux/macOS (Windows ใช้ nslookup -type=TXT)
DOMAIN=hospital.example

dig +short TXT $DOMAIN | grep -i spf          # SPF
dig +short TXT _dmarc.$DOMAIN                # DMARC
dig +short TXT google._domainkey.$DOMAIN     # DKIM (selector ขึ้นกับผู้ให้บริการ)
dig +short TXT selector1._domainkey.$DOMAIN  # DKIM ของ Microsoft 365
dig +short MX $DOMAIN                        # เซิร์ฟเวอร์รับอีเมล
```

ผลที่มักพบในหน่วยงาน

- ไม่มี SPF หรือมี SPF หลายบรรทัด (ผิด ต้องมีบรรทัดเดียว)

- มี SPF ลงท้ายด้วย `+all` (อนุญาตทุกคน = ไม่มีประโยชน์)
- ไม่มี DMARC เลย

21.4 Lab: ตั้งค่าแบบค่อยเป็นค่อยไป (4 สัปดาห์–3 เดือน) 🧪 LAB

ขั้น 1 สำรวจว่าใครส่งอีเมลในนามโดเมนบ้าง

ทำรายการ: ระบบอีเมลหลัก (Google/Microsoft/เซิร์ฟเวอร์ของหน่วยงาน), ระบบแจ้งเตือนจาก HIS, ระบบนัดหมาย, ระบบสารบรรณ, เว็บไซต์ (ฟอร์มติดต่อ), ผู้ให้บริการส่งจดหมายข่าว

ขั้น 2 SPF

```
hospital.example.  TXT  "v=spf1 include:_spf.google.com ip4:203.0.113.10 -all"
```

- `include:` ใส่ของผู้ให้บริการที่ใช้จริง (Google: `_spf.google.com`, Microsoft 365: `spf.protection.outlook.com`)
- `ip4:` ใส่ IP สาธารณะของเซิร์ฟเวอร์ที่ส่งอีเมลเอง
- เริ่มด้วย `~all` (softfail) ระหว่างทดสอบ แล้วเปลี่ยนเป็น `-all` เมื่อมั่นใจ
- ระวังจำนวนการค้น DNS รวมไม่เกิน 10 ครั้ง (แต่ละ `include` นับ)

ขั้น 3 DKIM

เปิด DKIM ในคอนโซลของผู้ให้บริการ (Google Admin → Apps → Gmail → Authenticate email; Microsoft Defender → Email authentication → DKIM) ระบบจะให้ค่า TXT/CNAME นำไปใส่ใน DNS แล้วกด “เริ่มลงนาม” สำหรับเซิร์ฟเวอร์ Postfix ของหน่วยงานใช้ OpenDKIM

ขั้น 4 DMARC แบบเฝ้าดู

```
_dmarc.hospital.example.  TXT  "v=DMARC1; p=none; rua=mailto:dmarc-reports@hospital.example; fo=1"
```

รอ 2–4 สัปดาห์ อ่านรายงาน (เป็นไฟล์ XML รายวัน ใช้เครื่องมือฟรีอย่าง parsedmarc หรือบริการวิเคราะห์ DMARC) เพื่อหาแหล่งส่งที่ถูกต้องแต่ยังไม่ผ่าน แล้วแก้ SPF/DKIM

ขั้น 5 เพิ่มความเข้ม

```
"v=DMARC1; p=quarantine; pct=25; rua=mailto:dmarc-reports@hospital.example"
   ↓ (ไม่มีปัญหา 2 สัปดาห์)
"v=DMARC1; p=quarantine; pct=100; rua=..."
   ↓
"v=DMARC1; p=reject; rua=..."
```

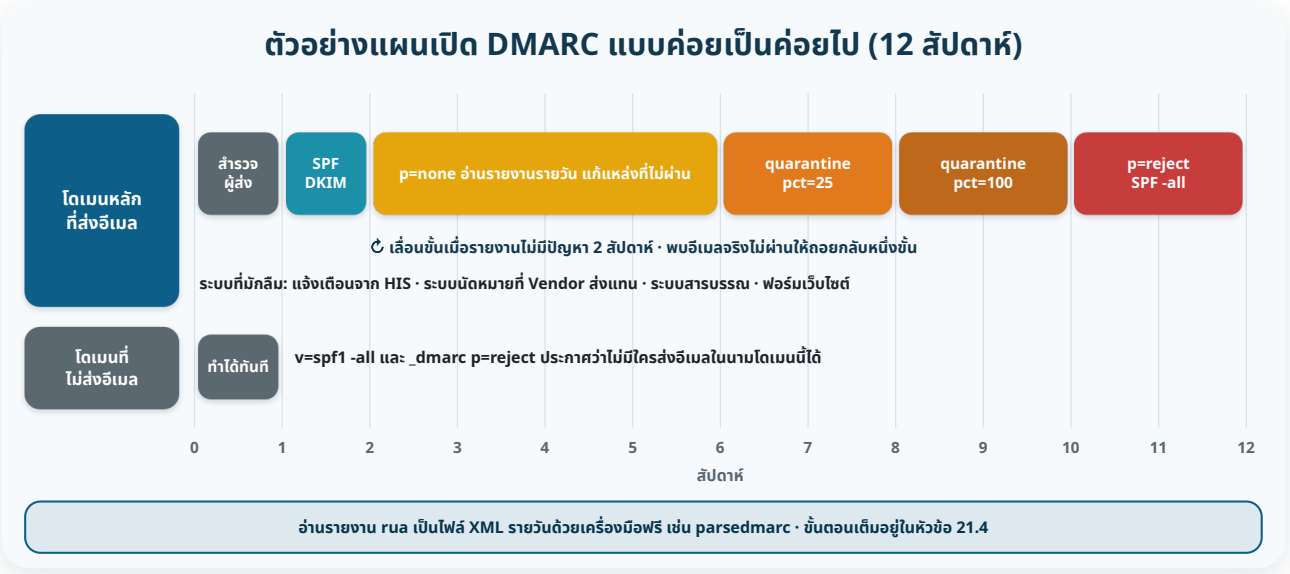
ขั้น 6 โดเมนที่ไม่ส่งอีเมล

โดเมนหรือโดเมนย่อยที่ไม่ใช้ส่งอีเมล ให้ประกาศชัดว่า “ไม่มีใครส่งได้”

```
old-project.hospital.example.          TXT "v=spf1 -all"
_dmarc.old-project.hospital.example.   TXT "v=DMARC1; p=reject"
```

> ⚠️ การไป `p=reject` เร็วเกินไปทำให้อีเมลจริงหาย เช่น ระบบนัดหมายที่ Vendor ส่งแทน หรือรายชื่อกลุ่มที่ส่งต่ออีเมล ให้ทำตามขั้นและอ่านรายงานก่อนเสมอ

ภาพที่ 21.2 สรุปทั้ง 6 ขั้นเป็นแผน 12 สัปดาห์ ปรับให้เร็วขึ้นหรือช้าลงตามผลรายงาน DMARC ถ้าพบอีเมลจริงไม่ผ่าน ให้ถอยกลับหนึ่งขั้นแล้วแก้ที่ต้นทาง



▲ ภาพที่ 21.2 ตัวอย่างแผนเปิด DMARC แบบค่อยเป็นค่อยไป 12 สัปดาห์

21.5 ป้องกันฝั่งผู้รับ

- เปิดการกรองสแปม/มัลแวร์ และ **Sandbox ไฟล์แนบ** (ถ้าระบบรองรับ)
- **ติดป้ายอีเมลจากภายนอก** เช่น เติม `[ภายนอก]` ที่หัวเรื่อง หรือแถบเตือน เพื่อให้ผู้ใช้สังเกตอีเมลปลอมที่อ้างเป็นผู้บริหาร
- บล็อกไฟล์แนบอันตราย: `.exe .js .vbs .scr .iso .img .hta .lnk` และไฟล์ Office ที่มี Macro จากภายนอก
- **ปิดการส่งต่ออัตโนมัติไปภายนอก** (Auto-forward) ซึ่งผู้โจมตีใช้ขโมยอีเมลหลังยึดบัญชี
- เพิ่มปุ่ม **Report Phishing** และกำหนดกล่องรับแจ้ง เช่น `phishing@<โดเมน>` ให้ทีม IT ตรวจ
- เชื่อม Log การ Login อีเมลเข้า SIEM (บทที่ 14) แจ้งเตือนการ Login จากต่างประเทศ

21.6 Google Workspace / Microsoft 365: ตั้งค่าขั้นต่ำ

หัวข้อ	Google Workspace	Microsoft 365
บังคับ MFA	Security → 2-Step Verification → Enforcement	Entra ID → Security defaults หรือ Conditional Access
ปิดการยืนยันตัวตนแบบเก่า (ไม่รองรับ MFA)	ปิด “Less secure apps” / ใช้ OAuth เท่านั้น	ปิด Legacy/Basic Authentication
ผู้ดูแลระบบ	Super Admin ไม่เกิน 2–3 คน ใช้ Security Key	Global Admin ไม่เกิน 2–4 คน ใช้บัญชีแยกจากบัญชีทำงาน
การแชร์ไฟล์	Drive → Sharing → ปิด “Anyone with the link” เป็นค่าเริ่มต้น, เตือนเมื่อแชร์ภายนอก	SharePoint/OneDrive → External sharing = เฉพาะผู้ที่ระบุ, ลิงก์หมดอายุ
ส่งต่ออีเมลอัตโนมัติ	ปิด Automatic forwarding	Outbound spam policy → Automatic forwarding = Off
แอปภายนอก	API Controls → อนุญาตเฉพาะแอปที่ตรวจแล้ว	ปิดการให้ผู้ใช้อนุญาตแอปเอง (User consent)
Log	Audit and investigation → ตั้ง Alert การ Login ผิดปกติ	Unified Audit Log เปิดใช้งาน
บัญชีผู้พ้นสภาพ	ระงับบัญชีภายในวันที่ออก โอนไฟล์ให้หัวหน้างาน	เช่นเดียวกัน + เพิกถอน Session

ค้นหาไฟล์ที่มีข้อมูลผู้ป่วยแต่แชร์สาธารณะ

- Google: Admin console → Reporting → Audit → Drive → กรอง Visibility = “Public on the web” หรือ “Anyone with link”
- Microsoft: Purview → Sharing reports / ใช้นโยบาย DLP ตรวจเลขบัตรประชาชน 13 หลัก
- ตรวจจากภายนอกด้วย Google Dork: `site:docs.google.com "ชื่อโรงพยาบาล"` และ `site:drive.google.com "ชื่อโรงพยาบาล"` (บทที่ 7)

> 💡 บัญชีอีเมลกลางของหน่วยงาน (เช่น `saraban@`) ที่หลายคนใช้ร่วมกัน ให้เปลี่ยนเป็น **กล่องจดหมายที่ใช้ร่วมกัน (Shared Mailbox/Group)** ที่แต่ละคนเข้าด้วยบัญชีตนเองพร้อม MFA แทนการแชร์รหัสผ่าน

21.7 โดเมนและ DNS

- [ ] รู้ว่าโดเมนจดทะเบียนกับใคร บัญชีผู้ดูแลโดเมนอยู่ในชื่อหน่วยงาน (ไม่ใช่อีเมลส่วนตัวของเจ้าหน้าที่หรือ Vendor) และเปิด MFA
- [ ] ตั้งเตือนวันหมดอายุโดเมนล่วงหน้า 90 วัน

- [ ] ทำทะเบียน DNS Record ทั้งหมด ลบ Record ที่ชี้ไปยัง IP หรือบริการ Cloud ที่เลิกใช้ (ป้องกัน Subdomain Takeover)
- [ ] เปิดใช้ **DNSSEC** ถ้าผู้ให้บริการรองรับ
- [ ] ตั้ง **CAA Record** ระบุผู้ออกใบรับรองที่อนุญาต

```
hospital.example.  CAA  0 issue "letsencrypt.org"
```

- [ ] ตรวจหาโดเมนเลียนแบบ (Typosquatting) เช่น `example-hosp1tal.com` ด้วยเครื่องมืออย่าง dnstwist

```
pip install dnstwist
dnstwist --registered hospital.example
```

21.8 ใบรับรอง HTTPS ไม่ให้หมดอายุ

```
# ติดตั้ง certbot (Nginx) และออกใบรับรองฟรีจาก Let's Encrypt
sudo apt install -y certbot python3-certbot-nginx
sudo certbot --nginx -d www.hospital.example -d hospital.example

# ทดสอบการต่ออายุอัตโนมัติ
sudo certbot renew --dry-run
systemctl list-timers | grep certbot

# ตรวจวันหมดอายุของเว็บใดก็ได้
echo | openssl s_client -connect www.hospital.example:443 -servername www.hospital.example 2>/dev/null
\
  | openssl x509 -noout -enddate
```

> 💡 NCSA Blacklist SOC Dashboard (บทที่ 15) มี SSL Monitor แจ้งเตือนใบรับรองใกล้หมดอายุของทุกเว็บในทะเบียน

21.9 บัญชีโซเชียลมีเดียและ LINE OA ของหน่วยงาน

เพจ Facebook และ LINE Official Account ของโรงพยาบาลมีผู้ติดตามจำนวนมาก ถ้าถูกยึดจะถูกใช้หลอกผู้ป่วย เช่น ขายวัคซีนปลอม หรือขอโอนเงินค่าตรวจ

- ผู้ดูแลอย่างน้อย 2 คน ทุกคนเปิด MFA และใช้บัญชีที่ผูกกับอีเมลหน่วยงาน
- ทบทวนรายชื่อผู้ดูแลทุก 6 เดือน ถอดผู้ย้าย/ลาออกทันที
- ห้ามบันทึกข้อมูลผู้ป่วยในแชตส่วนตัวของบัญชีทางการโดยไม่จำเป็น ตั้งข้อความตอบกลับอัตโนมัติให้ผู้ป่วยไม่ส่งข้อมูลอ่อนไหวทางแชต
- กำหนดช่องทางทางการเพียงไม่กี่ช่องทาง และประกาศให้ผู้ป่วยรู้ว่า **โรงพยาบาลไม่ขอให้โอนเงินผ่านแชต**

- เตรียมขั้นตอนกู้บัญชี (Recovery) และติดต่อแพลตฟอร์มล่วงหน้า

21.10 Checklist ประจำปี

รายการ	ผ่าน
SPF บรรทัดเดียว ลงท้าย `-all`	☐
DKIM เปิดสำหรับทุกระบบที่ส่งอีเมล	☐
DMARC ระดับ `quarantine` หรือ `reject` และมีผู้อ่านรายงาน	☐
บังคับ MFA ทุกบัญชีอีเมล/Workspace	☐
ปิด Legacy Authentication และ Auto-forward ภายนอก	☐
ไม่มีไฟล์ข้อมูลผู้ป่วยแชร์แบบ “ทุกคนที่มีลิงก์”	☐
โดเมนต่ออายุอัตโนมัติ บัญชีผู้ดูแลโดเมนมี MFA	☐
ไม่มี DNS Record ค้างที่ชี้ไปบริการที่เลิกใช้	☐
ใบรับรอง HTTPS ต่ออายุอัตโนมัติ และมีการแจ้งเตือน	☐
เพจ/LINE OA มีผู้ดูแล ≥ 2 คน เปิด MFA ทั้งหมด	☐

📋 **หลักฐาน**: ผลคำสั่ง `dig` แสดง SPF/DKIM/DMARC, ภาพหน้าจอการบังคับ MFA, ภาพนโยบายการแชร์, ทะเบียนโดเมนและ DNS

⭐ สรุปท้ายบท

- SPF + DKIM + DMARC ป้องกันการปลอมอีเมลในนามหน่วยงาน ตั้งค่าแบบค่อยเป็นค่อยไปจนถึง `p=reject`
- Cloud Workspace ปลอดภัยได้ถ้าบังคับ MFA ปิดการยืนยันตัวตนแบบเก่า และควบคุมการแชร์
- โดเมน DNS ใบรับรอง และบัญชีโซเชียลเป็นทรัพย์สินที่ต้องอยู่ในทะเบียนและมีเจ้าของ

✏️ คำถามทบทวน

1. SPF, DKIM และ DMARC ทำหน้าที่ต่างกันอย่างไร
2. ทำไมไม่ควรตั้ง DMARC เป็น p=reject ตั้งแต่วันแรก
3. โดเมนย่อยของโครงการเก่าไม่ได้ใช้ส่งอีเมลแล้ว ควรตั้งค่า DNS อย่างไร
4. ตรวจระเบียน SPF และ DMARC ของโดเมนหน่วยงาน แล้วระบุว่าอยู่ขั้นใดของแผน 12 สัปดาห์



ภาค 6 · สุขภาพดิจิทัลยุคใหม่และแนวทางสากล บทที่ 22

ความปลอดภัยอุปกรณ์การแพทย์ PACS การเชื่อมต่อ HL7 และระบบอาคาร

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ ทำทะเบียนและจัดกลุ่มความเสี่ยงของอุปกรณ์การแพทย์ที่เชื่อมเครือข่าย (IoMT)
- ✔️ ป้องกัน PACS/DICOM และอินเทอร์เฟซ HL7 ระหว่าง HIS–LIS–RIS ที่มักเปิดโดยไม่มีการยืนยันตัวตน
- ✔️ เขียนข้อกำหนดความปลอดภัยในการจัดซื้อเครื่องมือแพทย์ และทำงานร่วมกับวิศวกรรมการแพทย์และ Vendor
- ✔️ ดูแลระบบอาคารและเทคโนโลยีปฏิบัติการ (OT) เช่น ระบบปรับอากาศห้องผ่าตัด ก๊าซทางการแพทย์ CCTV และไฟฟ้าสำรอง

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 12 (ทะเบียน), 14 (Segmentation), 3 (Access Control), HHS 405(d) HICP Practice 9, IEC 80001-1, IEC 81001-5-1, NIST SP 800-82 Rev. 3, IEC 62443

22.1 ทำไมอุปกรณ์การแพทย์เป็นจุดอ่อน

ลักษณะ	ผลต่อความปลอดภัย
อายุการใช้งาน 10–15 ปี	ระบบปฏิบัติการภายในหมดอายุก่อนเครื่อง (เช่น Windows 7/XP Embedded)
แก้ไขซอฟต์แวร์ต้องผ่านผู้ผลิต	โรงพยาบาลติดตั้ง Patch หรือ Antivirus เองไม่ได้ เพราะอาจกระทบการรับรอง
ต้องทำงานตลอด 24 ชั่วโมง	Reboot หรือสแกนในเวลาบริการไม่ได้
ดูแลโดยหลายฝ่าย	วิศวกรรมการแพทย์ดูตัวเครื่อง, IT ดูเครือข่าย, Vendor ดูซอฟต์แวร์ ไม่มีใครเป็นเจ้าของความเสี่ยงไซเบอร์
โปรโตคอลเก่าไม่เข้ารหัส	DICOM และ HL7 v2 ส่งข้อมูลผู้ป่วยเป็นข้อความธรรมดา
บัญชี Service/รหัสผ่านเริ่มต้นที่ Vendor ใช้ทุกโรงพยาบาล	รู้รหัสหนึ่งที่ เข้าได้ทุกที่

📌 **ข้อมูลจากงานวิจัยต่างประเทศ**: การสำรวจเซิร์ฟเวอร์ภาพทางการแพทย์ (PACS/DICOM) ที่เปิดสู่อินเทอร์เน็ตพบต่อเนื่องหลายปี ตั้งแต่ 590 เซิร์ฟเวอร์ที่ดึงข้อมูลผู้ป่วยได้กว่า 24 ล้านรายการ (Greenbone, 2562), ภาพทางการแพทย์ราว 45 ล้านภาพเปิดให้เข้าถึงได้โดยไม่ต้องใช้รหัสผ่าน (CybelAngel, 2567) จนถึงการสำรวจปลายปี 2568 ที่พบเซิร์ฟเวอร์ DICOM เปิดสู่อินเทอร์เน็ตกว่า 3,600 เครื่อง ซึ่ง **มีไม่ถึง 1% ที่ใช้การเข้ารหัส TLS** และเกือบทั้งหมดไม่ตรวจสอบชื่อผู้เชื่อมต่อ (AE Title) ปัญหาเดียวกันเกิดได้ในโรงพยาบาลไทยที่เปิดพอร์ต PACS ให้แพทย์ดูภาพจากบ้าน

22.2 ทะเบียนอุปกรณ์การแพทย์ที่เชื่อมเครือข่าย

ทำร่วมกับงานวิศวกรรมการแพทย์ ต่อยอดจากทะเบียนทรัพย์สิน (บทที่ 7)

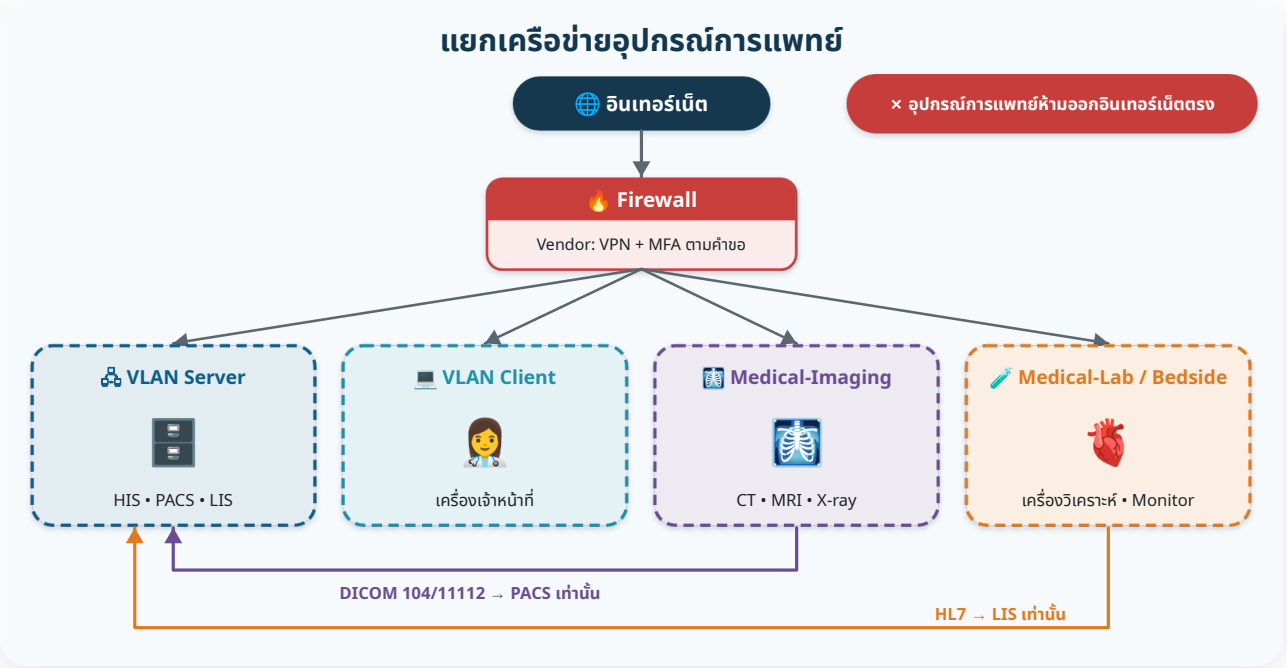
รหัส	ชนิด	ยี่ห้อ/รุ่น	หน่วยงาน	IP/MAC	VLAN	OS/Firmware	EOL	เชื่อมกับ	ข้อมูลผู้ป่วย	Remote ของ Vendor	กลุ่มความเสี่ยง
MD-001	CT Scanner	(รุ่น)	รังสี	10.10.60.11	60	Windows 10 IoT	2570	PACS, RIS	มี	VPN ตามคำขอ	สูง
MD-014	เครื่องวิเคราะห์เคมีคลินิก	(รุ่น)	Lab	10.10.61.5	61	Windows 7 Embedded	หมดแล้ว	LIS (HL7)	มี	TeamViewer (ต้องยกเลิก)	สูงมาก
MD-102	Infusion Pump	(รุ่น)	ICU	DHCP	62	Firmware 2.x	—	Server ยี่ห้อเดียวกัน	น้อย	ไม่มี	ปานกลาง

จัดกลุ่มความเสี่ยงแบบง่าย

- **สูงมาก**: ระบบปฏิบัติการหมดอายุ + มีข้อมูลผู้ป่วย + Vendor เข้าระยะไกลได้
- **สูง**: มีข้อมูลผู้ป่วยหรือมีผลต่อการรักษาโดยตรง (เครื่องช่วยหายใจ, ปั๊มยา, Monitor กลาง)
- **ปานกลาง**: เชื่อมเครือข่ายแต่ไม่มีข้อมูลระบุตัวตนและไม่ควบคุมการรักษา
- **ต่ำ**: ไม่เชื่อมเครือข่าย

💡 หาอุปกรณ์ที่ไม่อยู่ในทะเบียนจาก **ตาราง DHCP และตาราง MAC Address ของสวิตช์** แล้วเทียบ OUI (3 ไบต์แรกของ MAC) กับชื่อผู้ผลิต การสแกนแบบ Passive ปลอดภัยกว่า Nmap สำหรับอุปกรณ์การแพทย์ (บทที่ 16)

22.3 มาตรการป้องกันเป็นชั้น



▲ ภาพที่ 22.1 แยกเครือข่ายอุปกรณ์การแพทย์และจำกัดการเชื่อมต่อ

1. **แยก VLAN** ตามกลุ่มอุปกรณ์ (บทที่ 9) และเขียนกฎ Firewall/ACL แบบ “อนุญาตเฉพาะที่จำเป็น” เช่น Modality → PACS เท่านั้น
2. **ห้ามออกอินเทอร์เน็ต** ถ้า Vendor ต้องอัปเดต ให้เปิดชั่วคราวไปปลายทางที่ระบุ
3. **Remote Access ของ Vendor** ผ่าน VPN ของโรงพยาบาลที่มี MFA เปิดตามคำขอและปิดเมื่อเสร็จ บันทึกทุกครั้ง ยกเลิกโปรแกรม Remote ที่ติดตั้งค้าง (TeamViewer/AnyDesk) บนเครื่องที่เชื่อมอุปกรณ์
4. **ปิดบริการที่ไม่ใช้** บนเครื่องควบคุม เช่น SMBv1, RDP, Telnet (ขอให้ Vendor ดำเนินการและยืนยันเป็นลายลักษณ์อักษร)
5. **USB**: ปิดหรือควบคุม เครื่องที่ต้องใช้ USB เพื่อส่งภาพ ให้สแกนด้วยเครื่องสแกน USB เฉพาะก่อน
6. **เฝ้าระวัง**: ส่ง Log ของ Firewall ระหว่าง VLAN เข้า Wazuh (บทที่ 14) แจ้งเตือนเมื่ออุปกรณ์การแพทย์ติดต่อปลายทางใหม่หรือออกอินเทอร์เน็ต
7. **Backup การตั้งค่า** ของเครื่องควบคุมและ Worklist (ประสาน Vendor) เพื่อกู้คืนได้เร็ว

22.4 PACS และ DICOM

ความเสี่ยง	มาตรการ
พอร์ต DICOM (104, 11112) เปิดสู่อินเทอร์เน็ต	ปิดทันที ตรวจด้วย `nmap -p 104,11112 <IP สาธารณะ>` จากภายนอก และค้นชื่อหน่วยงานบน Shodan
ไม่ตรวจ AE Title / ใครก็ส่ง C-FIND/C-MOVE ได้	ตั้ง PACS ให้รับเฉพาะ AE Title + IP ที่ลงทะเบียน
เว็บดูภาพ (Web Viewer) เปิดสาธารณะ	วางหลัง VPN หรือ Reverse Proxy + MFA, ใช้ HTTPS, ปิดบัญชีผู้ใช้ทดลอง
แพทย์ดูภาพจากบ้าน	ใช้ VPN + MFA หรือระบบ Teleradiology ที่มีการยืนยันตัวตน ไม่เปิดพอร์ตตรง
ส่งภาพข้ามโรงพยาบาล (Refer)	ใช้ช่องทางที่เข้ารหัส ส่งเท่าที่จำเป็น ลบ/ปกปิดข้อมูลส่วนตัวเมื่อใช้เพื่อการสอนหรือวิจัย
ภาพใช้สอน/วิจัย	ทำ De-identification ข้อมูลใน DICOM Header (ชื่อ, HN, วันเกิด) และตรวจข้อความที่ฝังในภาพ

```
# ตรวจว่า PACS ตอบสนองต่อ C-ECHO จาก AE Title ที่ไม่ได้ลงทะเบียนหรือไม่ (ทำในวงภายใน กับระบบของตน)
sudo apt install -y dcmtk
echoscu -aet TESTSCU -aec ANYAE 10.10.20.30 104
#  ถ้าตอบ "Association Accepted" กับ AE ที่ไม่รู้จัก แปลว่ายังไม่ได้จำกัด AE Title
```

22.5 อินเทอร์เฟซ HL7 ระหว่าง HIS–LIS–RIS

HL7 v2 เป็นข้อความตัวอักษรที่มีข้อมูลผู้ป่วยครบ (ชื่อ, HN, ผลแลบ) ส่งผ่าน TCP โดย **ไม่เข้ารหัสและไม่ยืนยันตัวตน**

- จำกัดให้ Interface Engine/LIS รับการเชื่อมต่อเฉพาะ IP ของ HIS และเครื่องวิเคราะห์ที่ลงทะเบียน (Firewall/ACL)
- ถ้าต้องส่งข้ามเครือข่ายหรือข้ามหน่วยงาน ให้ส่งผ่าน VPN หรือห่อด้วย TLS (เช่น stunnel) หรือเปลี่ยนเป็น HL7 FHIR ผ่าน HTTPS + OAuth (บทที่ 20)
- เก็บ Log ข้อความที่รับส่ง (พร้อมควบคุมสิทธิ์การอ่าน Log เพราะมีข้อมูลผู้ป่วย)
- ทดสอบว่า Interface ปฏิเสธข้อความจากแหล่งที่ไม่รู้จัก

22.6 ข้อกำหนดความปลอดภัยใน TOR จัดซื้อเครื่องมือแพทย์

- [ ] ผู้ขายส่ง **MDS2** (Manufacturer Disclosure Statement for Medical Device Security) และ **SBOM** ของซอฟต์แวร์ในเครื่อง
- [ ] ระบุระบบปฏิบัติการ เวอร์ชัน และ **วันสิ้นสุดการสนับสนุน** ต้องไม่หมดอายุภายในระยะเวลารับประกัน

- [ ] ผู้ขายรับรองการติดตั้ง Security Patch ของระบบปฏิบัติการภายในเวลาที่กำหนดหลังผู้ผลิตออก และระบุว่า Antivirus/EDR ใดที่ติดตั้งได้
- [ ] รองรับการเปลี่ยนรหัสผ่านเริ่มต้น ไม่มีบัญชีฝังที่เปลี่ยนไม่ได้ (Hard-coded Credentials)
- [ ] รองรับการทำงานใน VLAN แยกโดยไม่ต้องออกอินเทอร์เน็ต ระบุพอร์ตและปลายทางที่ต้องใช้ทั้งหมด
- [ ] Remote Service ผ่านช่องทางของโรงพยาบาลเท่านั้น
- [ ] รองรับการเข้ารหัส (DICOM TLS, HTTPS) และส่ง Log ออกไปยัง Syslog/SIEM ได้
- [ ] แจ้งช่องโหว่และประกาศความปลอดภัย (Security Advisory) ของผลิตภัณฑ์ให้โรงพยาบาลทราบ
- [ ] ลบข้อมูลผู้ป่วยออกจากเครื่อง/ดิสก์อย่างปลอดภัยเมื่อส่งซ่อมหรือจำหน่าย พร้อมหนังสือยืนยัน
- [ ] ผู้ผลิตมีกระบวนการพัฒนาที่ปลอดภัย (อ้างอิง IEC 81001-5-1) และสำหรับเครื่องที่จำหน่ายในสหรัฐฯ ผ่านข้อกำหนดมาตรา 524B ของ FDA

22.7 บทบาทของแต่ละฝ่าย (RACI)

งาน	วิศวกรรมการแพทย์	งาน IT	หน่วยงานผู้ใช้	Vendor	CISO
ทะเบียนอุปกรณ์	**R**	C	I	C	A
แยกเครือข่าย/Firewall	C	**R**	I	C	A
Patch ระบบในเครื่อง	C	C	I	**R**	A
อนุมัติ Remote Access	I	**R**	I	C	A
ระบุข้อกำหนดใน TOR	**R**	**R**	C	I	A
แผนสำรองเมื่อเครื่องใช้ไม่ได้	C	C	**R**	C	A

R = ผู้ลงมือ, A = ผู้รับผิดชอบผลลัพธ์, C = ผู้ให้คำปรึกษา, I = ผู้รับทราบ

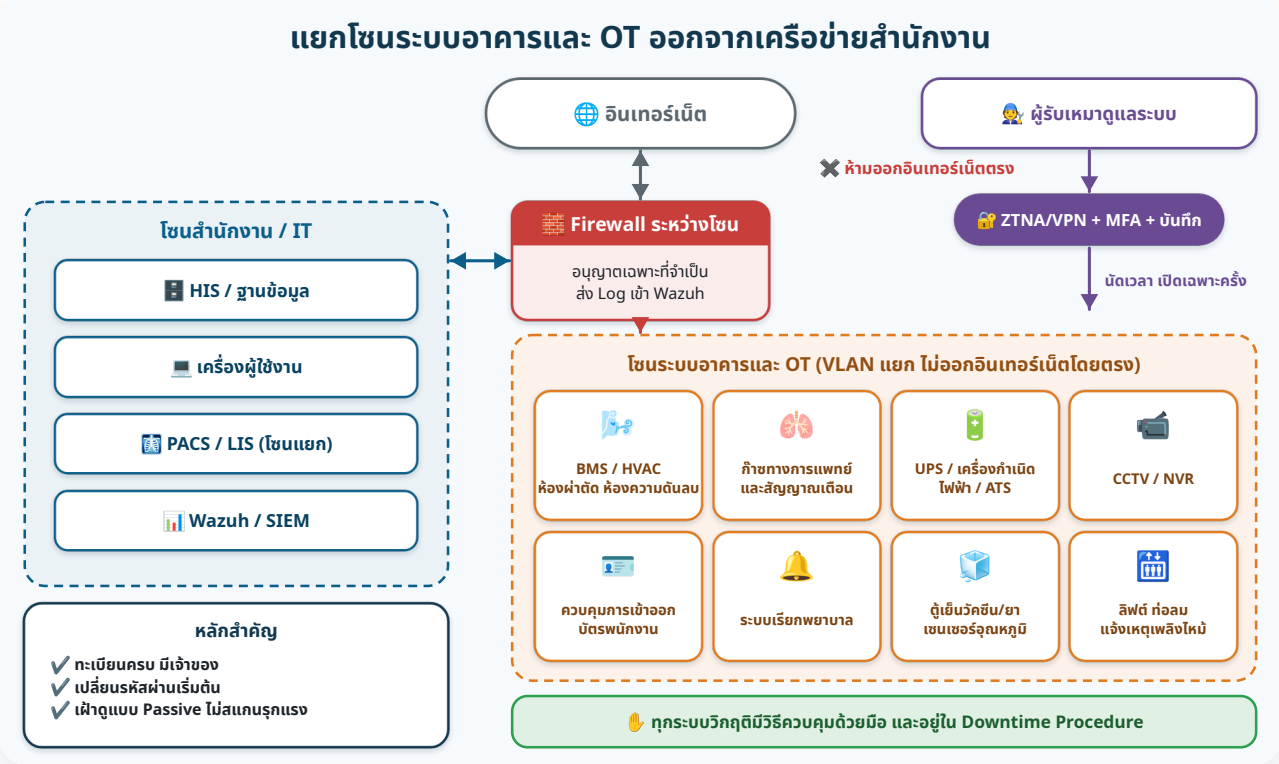
22.8 แผนสำรองเมื่ออุปกรณ์หรือ PACS ใช้ไม่ได้

- รังสี: Modality เก็บภาพในเครื่องชั่วคราว พิมพ์ฟิล์ม/บันทึกลงสื่อตามขั้นตอน แพทย์อ่านที่เครื่อง Modality
- Lab: เครื่องวิเคราะห์ทำงานแบบ Stand-alone พิมพ์ผลแล้วบันทึกเข้า HIS ภายหลังพร้อมตรวจทาน 2 คน
- Bedside: ใช้การเฝ้าระวังข้างเตียงและบันทึกกระดาษ
- รวมขั้นตอนเหล่านี้เป็นส่วนหนึ่งของ Downtime Procedure (บทที่ 13) และซ้อมพร้อมกัน

📋 **หลักฐาน**: ทะเบียนอุปกรณ์การแพทย์ที่เชื่อมเครือข่าย, Network Diagram ที่แสดง VLAN อุปกรณ์การแพทย์, กฎ Firewall ระหว่าง VLAN, บันทึก Remote Access ของ Vendor, TOR ที่มีข้อกำหนดความปลอดภัย

22.9 ระบบอาคารและเทคโนโลยีปฏิบัติการ (OT) ในโรงพยาบาล

นอกจากเครื่องมือแพทย์แล้ว โรงพยาบาลยังมีระบบควบคุมอาคารจำนวนมากที่เชื่อมเครือข่าย เรียกรวมว่า **เทคโนโลยีปฏิบัติการ (Operational Technology: OT)** ระบบเหล่านี้มักติดตั้งและดูแลโดยงานช่างหรือผู้รับเหมา ไม่อยู่ในทะเบียนของงาน IT ใช้รหัสผ่านเริ่มต้น และเปิดรีโมตให้ผู้รับเหมาไว้ถาวร ถ้าถูกโจมตี ผลกระทบตกถึงผู้ป่วยโดยตรง เช่น ห้องผ่าตัดเสียการควบคุมอุณหภูมิและความดัน หรือตู้เย็นวัคซีนไม่แจ้งเตือนเมื่ออุณหภูมิผิดปกติ



▲ ภาพที่ 22.2 ระบบอาคารและ OT ในโรงพยาบาล แยกโซนจากเครือข่ายสำนักงาน

ระบบ	ผลกระทบเมื่อถูกโจมตีหรือขัดข้อง	จุดอ่อนที่พบบ่อย
ระบบบริหารอาคาร (BMS) และระบบปรับอากาศ (HVAC)	ห้องผ่าตัด/ห้องแยกโรคความดันลบเสียสภาพ เสี่ยงติดเชื้อ	หน้าเว็บจัดการเปิดสู่อินเทอร์เน็ต, รหัสเริ่มต้น, โปรโตคอล BACnet/Modbus ไม่มีการยืนยันตัวตน
ระบบเฝ้าระวังก๊าซทางการแพทย์	สัญญาณเตือนออกซิเจนหรือสุญญากาศไม่ทำงาน	แผงควบคุมรุ่นเก่า ไม่มีการอัปเดต
ไฟฟ้าสำรอง (เครื่องกำเนิดไฟฟ้า, UPS, ATS)	ไฟดับในพื้นที่วิกฤติ ระบบ HIS และเครื่องช่วยชีวิตหยุด	การ์ดจัดการ UPS ใช้รหัสเริ่มต้น เปิด SNMP แบบ Community สาธารณะ
กล้องวงจรปิด (CCTV/NVR)	ภาพผู้ป่วยรั่วไหล, ถูกใช้เป็นฐานโจมตีหรือเครือข่ายบอต	NVR เปิดพอร์ตสู่อินเทอร์เน็ตให้ดูผ่านมือถือ, เฟิร์มแวร์เก่า
ระบบควบคุมการเข้าออกและบัตรพนักงาน	คนนอกเข้าพื้นที่หวงห้าม เช่น ห้องยา ห้องเซิร์ฟเวอร์	ฐานข้อมูลบัตรบนเครื่อง Windows รุ่นเก่า
ระบบเรียกพยาบาล (Nurse Call)	เสียงเรียกจากผู้ป่วยไม่ถึงพยาบาล	เชื่อมกับเครือข่ายทั่วไปโดยไม่แยกโซน

ระบบ	ผลกระทบเมื่อถูกโจมตีหรือขัดข้อง	จุดอ่อนที่พบบ่อย
ตู้เย็นเก็บวัคซีน/ยา และเซนเซอร์อุณหภูมิ	ยาและวัคซีนเสื่อมสภาพโดยไม่มีใครรู้	ส่งข้อมูลขึ้น Cloud ของผู้ผลิตโดยไม่มีการตรวจสอบ
ลิฟต์ ระบบท่อลมส่งเอกสาร ระบบแจ้งเหตุเพลิงไหม้	การเคลื่อนย้ายผู้ป่วยและสิ่งส่งตรวจหยุดชะงัก	ผู้รับเหมารีโมตเข้ามาดูแลโดยไม่มีบันทึก

หลักการป้องกัน OT (อ้างอิง NIST SP 800-82 Rev. 3 และ IEC 62443)

1. **รวมเข้าทะเบียนทรัพย์สิน** (บทที่ 7) ระบุเจ้าของฝั่งงานช่าง/วิศวกรรม ผู้รับเหมา IP รุ่น และวิธีรีโมต
2. **แยกโซน OT** เป็น VLAN เฉพาะ ไม่ให้ออกอินเทอร์เน็ตโดยตรง และให้ Firewall อนุญาตเฉพาะเครื่องที่ต้องคุยกันจริง
3. **รีโมตผ่านช่องทางเดียว** คือ ZTNA หรือ VPN ที่มี MFA เปิดเฉพาะเวลานัด และบันทึกทุกครั้ง (หัวข้อ 25.6)
4. **เปลี่ยนรหัสผ่านเริ่มต้น** ของทุกอุปกรณ์ รวมถึงการ์ดจัดการ UPS, NVR และแผง BMS
5. **ห้ามสแกนช่องโหว่แบบรุกแรงกับอุปกรณ์ OT** เพราะตัวควบคุมรุ่นเก่าอาจค้างหรือรีบูต ให้ใช้การเฝ้าดูทราฟฟิกแบบ Passive (NDR) และขอข้อมูลช่องโหว่จากผู้ผลิตแทน
6. **มีวิธีควบคุมด้วยมือ (Manual Override)** สำหรับระบบวิกฤติ และรวมไว้ใน BCP/Downtime Procedure (บทที่ 13)
7. **ใส่ข้อกำหนดความปลอดภัยในสัญญาผู้รับเหมา** แบบเดียวกับ TOR เครื่องมือแพทย์ (หัวข้อ 22.6) เช่น ห้ามใช้รหัสร่วมกันทุกไซต์ แจ้งช่องโหว่ และส่งมอบรหัสผ่านเมื่อสิ้นสัญญา
8. **ส่ง Log ของ Firewall ขอบโซน OT เข้า Wazuh** และแจ้งเตือนเมื่อมีการเชื่อมต่อจากโซนอื่นหรือออกอินเทอร์เน็ต

> ⚠️ ตรวจว่า **NVR หรือหน้าเว็บ BMS ของหน่วยงานถูกเปิดสู่อินเทอร์เน็ตหรือไม่** ด้วยการสแกนพอร์ต IP สาธารณะของตนเอง (บทที่ 16) อุปกรณ์กลุ่มนี้เป็นเป้าหมายหลักของบอตสแกนอัตโนมัติ ถ้าต้องดูกล้องจากภายนอก ให้ใช้ VPN/ZTNA แทนการเปิดพอร์ต

บทบาทร่วมกัน

กิจกรรม	งานช่าง/ซ่อมบำรุง	งาน IT	วิศวกรรมการแพทย์	ผู้รับเหมา	ผู้บริหาร
ทะเบียนอุปกรณ์ OT	**R**	C	C	C	A
แยกโซนเครือข่ายและ Firewall	C	**R**	I	C	A
อนุมัติรีโมตของผู้รับเหมา	**R**	**R**	I	I	A
อัปเดตเฟิร์มแวร์และเปลี่ยนรหัสเริ่มต้น	A	C	–	**R**	I
แผนควบคุมด้วยมือเมื่อระบบใช้ไม่ได้	**R**	C	C	C	A

Checklist ระบบอาคารและ OT

รายการ	ผ่าน
ทุกระบบ OT อยู่ในทะเบียนทรัพย์สินและมีเจ้าของ	☐
OT อยู่ใน VLAN แยก ไม่ออกอินเทอร์เน็ตโดยตรง	☐
ไม่มี NVR, BMS หรือการ์ด UPS เปิดสู่อินเทอร์เน็ต	☐
เปลี่ยนรหัสผ่านเริ่มต้นครบทุกอุปกรณ์	☐
รีโมตของผู้รับเหมาผ่านช่องทางเดียว มี MFA และบันทึก	☐
มีวิธีควบคุมด้วยมือและอยู่ใน Downtime Procedure	☐
สัญญาผู้รับเหมามีข้อกำหนดความปลอดภัย	☐

⭐ สรุปท้ายบท

- อุปกรณ์การแพทย์ Patch เองยาก จึงต้องป้องกันด้วยการแยกเครือข่ายและควบคุมการเข้าถึง
- PACS/DICOM และ HL7 ส่งข้อมูลผู้ป่วยโดยไม่เข้ารหัส ห้ามเปิดสู่อินเทอร์เน็ต และจำกัดผู้เชื่อมต่อ
- ความปลอดภัยต้องเริ่มตั้งแต่ TOR จัดซื้อ และวิศวกรรมการแพทย์กับ IT ต้องทำงานร่วมกัน
- ระบบอาคารและ OT เช่น HVAC ก๊าซทางการแพทย์ CCTV และไฟฟ้าสำรอง ต้องอยู่ในทะเบียน แยกโซน และมีวิธีควบคุมด้วยมือ

✏️ คำถามทบทวน

1. ทำไม PACS/DICOM และ HL7 จึงห้ามเปิดสู่อินเทอร์เน็ต
2. ใน TOR จัดซื้อเครื่องมือแพทย์ ควรขอเอกสารความปลอดภัยอะไรจากผู้ขาย
3. ระบบควบคุมความดันห้องแยกโรคเชื่อมกับเครือข่ายสำนักงาน และใช้รหัสผ่านเริ่มต้นของผู้ผลิต ควรแก้อย่างไร
4. ร่วมกับงานวิศวกรรมการแพทย์ทำทะเบียนอุปกรณ์ที่เชื่อมเครือข่าย 10 เครื่องแรก ระบุ OS ผู้ดูแล และโซนเครือข่าย



ภาค 7

รู้เขารู้เรา: ผู้โจมตี การประสานข้อมูล และเทคโนโลยีใหม่

Know Your Adversary & Next-Gen Defense

23 ผู้โจมตีเจาะระบบโรงพยาบาลอย่างไร: รู้ทันยุทธวิธีเพื่อป้องกัน

24 ระบบโฟลว์การประสานข้อมูลและแบ่งปันความรู้ด้านไซเบอร์

25 เทคโนโลยีใหม่ที่ช่วยป้องกันการเจาะระบบ



ภาค 7 · รู้เขารู้เรา: ผู้โจมตี การประสานข้อมูล และเทคโนโลยีใหม่ บทที่ 23

ผู้โจมตีเจาะระบบโรงพยาบาลอย่างไร: รู้ทันยุทธวิธีเพื่อป้องกัน

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ อธิบายขั้นตอนการโจมตีตาม Cyber Kill Chain และ MITRE ATT&CK ได้ด้วยภาษาที่ผู้บริหารเข้าใจ
- ✔️ รู้จักช่องทางเจาะระบบที่พบบ่อยในหน่วยบริการสุขภาพ พร้อมสัญญาณเตือนและวิธีปิดช่องทาง
- ✔️ จับคู่เทคนิคของผู้โจมตีกับมาตรการป้องกัน กฎตรวจจับใน Wazuh และเกณฑ์ CTAM+
- ✔️ ล่าภัยคุกคาม (Threat Hunting) ในระบบของตนเอง และซ้อมแผนจากสถานการณ์จำลอง

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 2, 3, 6, 7, 9, 10, 11, 14, 16 / NIST CSF 2.0 (DE, RS) / HHS 405(d) HICP Practice 8 (Security Operations Center and Incident Response)

⚠️ **ขอบเขตของบทนี้** อธิบายวิธีคิดและพฤติกรรมของผู้โจมตีในระดับแนวคิด เพื่อให้ผู้ดูแลระบบมองเห็นร่องรอยและวางแนวป้องกันได้ถูกจุด ไม่มีขั้นตอนเจาะระบบจริง การทดสอบใด ๆ กับระบบต้องได้รับอนุญาตเป็นลายลักษณ์อักษร (บทที่ 16) การเข้าถึงระบบคอมพิวเตอร์ของผู้อื่นโดยมิชอบเป็นความผิดตาม พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. 2550

23.1 ทำไมต้อง “รู้เขา”

ซุนวูกล่าวว่า “รู้เขารู้เรา รบร้อยครั้งชนะร้อยครั้ง” บทก่อนหน้าทั้งหมดคือการ “รู้เรา” ได้แก่ รู้ทรัพย์สิน รู้ช่องโหว่ และรู้กฎระเบียบ บทนี้คือการ “รู้เขา” ว่าผู้ไม่ประสงค์ดีคิดและทำงานอย่างไร

ความจริงที่สำคัญที่สุดของการป้องกันคือ **ผู้โจมตีต้องทำสำเร็จทุกขั้น แต่ผู้ป้องกันตรวจพบเพียงขั้นเดียวก็ตัดวงจรได้** การโจมตีแบบเรียกค่าไถ่หนึ่งครั้งต้องผ่านหลายขั้น ตั้งแต่เข้าระบบ ขโมยรหัสผ่าน เดินทางข้ามเครื่อง ขโมยข้อมูล ไปจนถึงเข้ารหัสไฟล์ ทุกขั้นทิ้งร่องรอยไว้ใน Log ถ้าเราเก็บ Log ครบและรู้ว่าต้องมองหาอะไร ก็มีโอกาสหยุดเหตุได้ก่อนระบบล่ม

ตัวเลขที่ต้องรู้ (รายงานล่าสุด)

แหล่งข้อมูล	ข้อค้นพบสำคัญ
Verizon DBIR 2026	การใช้ประโยชน์จากช่องโหว่ (Exploitation) ขึ้นเป็นช่องทางเข้าอันดับ 1 ที่ **31%** ของทุกอุตสาหกรรม แซงการใช้รหัสผ่านที่ถูกขโมยเป็นครั้งแรกในรอบ 19 ปี และ Ransomware อยู่ใน **48%** ของเหตุข้อมูลรั่ว
Verizon DBIR 2026 (ภาคสุขภาพ ตามที่สื่อเฉพาะทางสรุป)	ช่องทางเข้าในภาคสุขภาพ: ช่องโหว่ 20%, ฟิชชิง 14%, รหัสผ่านถูกขโมย 11%, ความผิดพลาดของบุคลากร 11% และราว 1 ใน 3 ของเหตุเกี่ยวข้องกับบุคคลที่สาม (Vendor/ผู้ให้บริการ)
Sophos State of Ransomware in Healthcare 2025	สาเหตุเชิงเทคนิคอันดับ 1 ของ Ransomware ในหน่วยบริการสุขภาพคือ **ช่องโหว่ที่ถูกใช้ประโยชน์ (33%)** รองลงมาคืออีเมลอันตราย (22%) และรหัสผ่านรั่ว (18%) ปัจจัยองค์กรที่พบบ่อยคือ **ขาดคนหรือขาดกำลังเฝ้าระวัง**
Mandiant M-Trends 2026	ค่ามัธยฐานเวลาที่ผู้บุกรุกแฝงตัวก่อนถูกพบ (Dwell Time) **14 วัน** ช่องทางเข้าอันดับ 1 คือ Exploit (32%) เป็นปีที่ 6 ติดต่อกัน และ **การหลอกทางโทรศัพท์ (Voice Phishing)** ขึ้นมาเป็นอันดับ 2 (11%)
CrowdStrike Global Threat Report 2026	เวลาเฉลี่ยตั้งแต่เข้าระบบได้จนเริ่มเคลื่อนที่ข้ามเครื่อง (Breakout Time) เหลือ **29 นาที** เร็วที่สุด 27 วินาที และราว 82% ของการตรวจพบ **ไม่ใช้มัลแวร์เลย** (ใช้เครื่องมือที่มีอยู่ในระบบ)

💡 ความหมายต่อโรงพยาบาล: (1) ต้องแพตช์อุปกรณ์ที่เปิดสู่อินเทอร์เน็ตให้เร็ว (2) แอนติไวรัสอย่างเดียวไม่พอ เพราะผู้โจมตีส่วนใหญ่ไม่ใช้มัลแวร์ ต้องเฝ้าดู “พฤติกรรม” (3) มีเวลาไม่ถึงชั่วโมงหลังผู้โจมตีเข้ามาได้ การแจ้งเตือนต้องถึงคนที่ตัดสินใจได้ทันที

23.2 ใครคือผู้โจมตี

กลุ่ม	แรงจูงใจ	สิ่งที่มักทำกับหน่วยบริการสุขภาพ	ตัวอย่างร่องรอย
กลุ่ม Ransomware และเครือข่ายพันธมิตร (RaaS Affiliate)	เงินค่าไถ่	เข้ารหัสระบบ HIS/PACS แล้วขู่เผยแพร่ข้อมูลผู้ป่วย (Double Extortion)	บัญชี VPN ล็อกอินจากต่างประเทศ, มีการติดตั้งโปรแกรมรีโมตใหม่
นายหน้าขายช่องทางเข้า (Initial Access Broker)	ขายสิทธิ์เข้าระบบให้กลุ่มอื่น	เจาะเข้าแล้วฝังช่องทางไว้ ไม่ทำลาย รอขายต่อ	บัญชีที่ไม่มีใครใช้กลับมาใช้งาน
แก๊งหลอกลวงและผู้ค้าข้อมูล	ขายข้อมูล หรือใช้ข้อมูลหลอกเหยื่อ	ขโมยรายชื่อผู้ป่วย เบอร์โทร สิทธิการรักษา ไปใช้โทรหลอก	การดึงข้อมูลจำนวนมากผ่าน API หรือรายงาน
แฮกทิวิสต์ (Hacktivist)	การเมือง ชื่อเสียง	เปลี่ยนหน้าเว็บ ยิง DDoS ช่วงเหตุการณ์สำคัญ	หน้าเว็บถูกแก้ไข, ปริมาณทราฟฟิกพุ่ง

กลุ่ม	แรงจูงใจ	สิ่งที่มักทำกับหน่วยบริการสุขภาพ	ตัวอย่างร่องรอย
ผู้โจมตีที่รัฐสนับสนุน (APT)	จารกรรมข้อมูล	ขโมยข้อมูลวิจัย วัคซีน ข้อมูลบุคคลสำคัญ แฝงตัวนาน	การเชื่อมต่อออกสม่ำเสมอไปยังปลายทางแปลก
คนใน (Insider)	อยากรู้ ไม่พอใจ ถูกจ้าง	เปิดดูเวชระเบียนคนดัง ส่งข้อมูลออกทางแชต	การเปิดเวชระเบียนที่ไม่เกี่ยวกับงานของตน
บอตสแกนอัตโนมัติ	ฉวยโอกาส	สแกนพอร์ต RDP, ฐานข้อมูล, phpMyAdmin ทั้งอินเทอร์เน็ตตลอด 24 ชั่วโมง	Log Firewall เต็มไปด้วยการเชื่อมต่อขาเข้าที่ถูกปฏิเสธ

23.3 Cyber Kill Chain และ MITRE ATT&CK

Cyber Kill Chain: ภาพรวมแบบเข้าใจง่าย

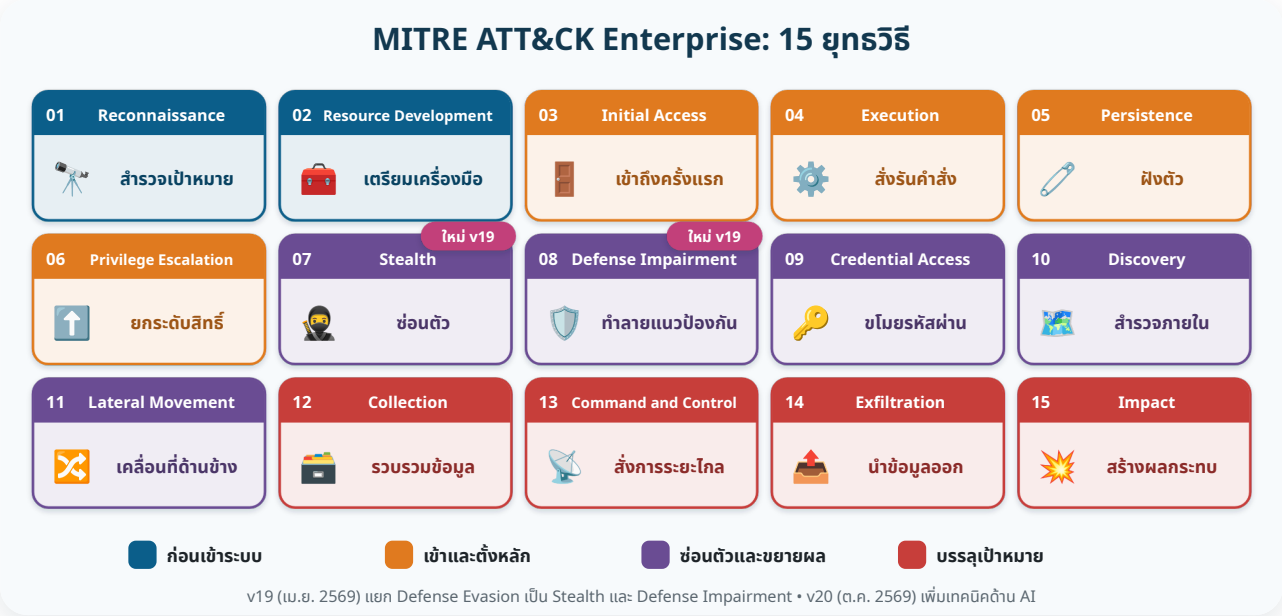
Lockheed Martin เสนอแนวคิด **Cyber Kill Chain** (2554) แบ่งการโจมตีเป็นขั้นตอนต่อเนื่อง แนวคิดหลักคือ “ตัดห่วงโซ่ขั้นใดขั้นหนึ่ง การโจมตีก็ล้มเหลว” หนังสือเล่มนี้ปรับเป็น 7 ขั้นที่เห็นได้จริงในโรงพยาบาล ดังภาพ



▲ ภาพที่ 23.1 วงจรการโจมตีและจุดตัดวงจรในแต่ละขั้น

MITRE ATT&CK: พจนานุกรมพฤติกรรมผู้โจมตี

MITRE ATT&CK (attack.mitre.org) เป็นฐานความรู้สาธารณะที่รวบรวมพฤติกรรมของผู้โจมตีจากเหตุการณ์จริงทั่วโลก จัดเป็น **ยุทธวิธี (Tactic)** คือ “ต้องการทำอะไร” และ **เทคนิค (Technique)** คือ “ทำอย่างไร” แต่ละเทคนิคมีรหัส เช่น T1566 Phishing ทำให้ทีมต่าง ๆ สื่อสารตรงกัน และใช้ตรวจว่าเรามีการตรวจจับครอบคลุมพฤติกรรมใดบ้าง



▲ ภาพที่ 23.2 ยุทธวิธี 15 กลุ่มของ MITRE ATT&CK Enterprise (v19 ขึ้นไป)

📌 **อัปเดตปี 2569**: ATT&CK **v19 (28 เม.ย. 2569)** แยกยุทธวิธี Defense Evasion เดิมออกเป็น **Stealth** (ซ่อนตัว) และ **Defense Impairment** (ทำให้ระบบป้องกันอ่อนแอ) ทำให้ Enterprise มี 15 ยุทธวิธี และ **v20 (13 ต.ค. 2569)** เพิ่มเทคนิคที่เกี่ยวกับ AI เช่น Prompt Injection และการขโมยข้อมูลผ่านระบบ AI รหัสเทคนิคบางรายการจึงเปลี่ยนไป ก่อนใช้อ้างอิงในรายงานให้ตรวจเวอร์ชันล่าสุดที่ attack.mitre.org ทุกครั้ง

ยุทธวิธี	คำถามที่ผู้โจมตีตอบ	ตัวอย่างในโรงพยาบาล
Reconnaissance (สำรวจเป้าหมาย)	ใครทำงานที่นี่ ใช้ระบบอะไร	ค้นรายชื่อบุคลากรจากเว็บ รพ., สแกนหา VPN ที่เปิดอยู่
Resource Development (เตรียมเครื่องมือ)	ต้องใช้อะไรบ้าง	จดโดเมนคล้ายชื่อ รพ., ซื้อรหัสผ่านที่รั่ว
Initial Access (เข้าถึงครั้งแรก)	เข้าทางไหน	ช่องโหว่ Firewall/VPN, อีเมลฟิชชิง, บัญชี Vendor
Execution (สั่งรันคำสั่ง)	รันโค้ดได้อย่างไร	ใช้ PowerShell หรือสคริปต์ที่มีอยู่ในเครื่อง
Persistence (ฝังตัว)	กลับเข้ามาใหม่ได้อย่างไร	สร้างบัญชีใหม่, ตั้ง Scheduled Task, ติดตั้งโปรแกรมรีโมต
Privilege Escalation (ยกระดับสิทธิ์)	ได้สิทธิ์ Admin อย่างไร	ใช้ช่องโหว่ที่ยังไม่แพตช์, รหัส Admin ที่ใช้ซ้ำทุกเครื่อง
Stealth (ซ่อนตัว)	ทำอย่างไรไม่ให้ถูกเห็น	ตั้งชื่อไฟล์เลียนแบบโปรแกรมระบบ, ลบ Log
Defense Impairment (ทำลายแนวป้องกัน)	ปิดระบบป้องกันได้ไหม	ปิดแอนติไวรัส/EDR, ปิดการส่ง Log
Credential Access (ขโมยรหัสผ่าน)	หารหัสผ่านเพิ่มได้ที่ไหน	ดึงรหัสจากหน่วยความจำ, ไฟล์ Excel รหัสผ่านบน Share Drive

ยุทธวิธี	คำถามที่ผู้โจมตีตอบ	ตัวอย่างในโรงพยาบาล
Discovery (สำรวจภายใน)	ในเครือข่ายมีอะไร	สแกนหาเซิร์ฟเวอร์ HIS, Backup, Domain Controller
Lateral Movement (เคลื่อนที่ด้านข้าง)	ไปเครื่องอื่นอย่างไร	RDP/SMB ด้วยบัญชีที่ขโมยมา
Collection (รวบรวมข้อมูล)	ข้อมูลมีค่าอยู่ที่ไหน	Dump ฐานข้อมูลผู้ป่วย, รวมไฟล์ PDF ผลแล็บ
Command and Control (สั่งการระยะไกล)	ควบคุมเครื่องเหยื่ออย่างไร	การเชื่อมต่อ HTTPS ออกไปยังเซิร์ฟเวอร์ผู้โจมตี
Exfiltration (นำข้อมูลออก)	ส่งข้อมูลออกอย่างไร	อัปโหลดขึ้น Cloud Storage สาธารณะตอนกลางคืน
Impact (สร้างผลกระทบ)	บรรลุเป้าหมาย	ลบ Backup, เข้ารหัสไฟล์, ทำให้ระบบหยุด

23.4 ช่องทางเจาะระบบที่พบบ่อยในหน่วยบริการสุขภาพ

#	ช่องทาง	ทำไมได้ผลกับโรงพยาบาล	สัญญาณเตือน	ปิดช่องทาง (บทที่)
1	**ช่องโหว่อุปกรณ์ขอบเครือข่าย** (Firewall, VPN, Remote Gateway)	อุปกรณ์เปิดสู่อินเทอร์เน็ตตลอด แพตช์ช้าเพราะกลัวระบบสะดุด	Config เปลี่ยนโดยไม่มีใครแก้, บัญชี Admin ใหม่บน Firewall	แพตช์ตาม CISA KEV ภายใน 72 ชม., ปิดหน้าจัดการจากภายนอก (9, 16)
2	**บริการเปิดตรงสู่อินเทอร์เน็ต** (RDP, ฐานข้อมูล, DICOM, phpMyAdmin)	เปิดไว้ให้ Vendor หรือแพทย์ทำงานจากบ้าน แล้วลืมปิด	Log การล็อกอินล้มเหลวจำนวนมากจาก IP ต่างประเทศ	ปิดพอร์ต ใช้ VPN+MFA หรือ ZTNA (9, 25)
3	**อีเมลฟิชชิงและ QR Code หลอก**	บุคลากรจำนวนมาก งานเร่ง อีเมลอ้างเรื่องเงินเดือน/ประชุม	อีเมลจากโดเมนคล้าย, ผู้ใช้กรอกรหัสในหน้าเว็บปลอม	DMARC, อบรม, รายงานอีเมลต้องสงสัย (18, 21)
4	**หลอกทางโทรศัพท์ (Vishing) ไปที่ Help Desk**	โทรอ้างเป็นแพทย์ “ลืมรหัสอยู่หน้าห้องผ่าตัด” ขอรีเซ็ตรหัส/MFA	คำขอรีเซ็ต MFA นอกเวลา, ผู้โทรเร่งรัด	ขั้นตอนยืนยันตัวตนก่อนรีเซ็ต, โทรกลับเบอร์ในทะเบียน (8, 18)
5	**รหัสผ่านรั่วและการเดารหัส**	รหัสผ่านซ้ำกับเว็บอื่น, ไม่มี MFA	ล็อกอินสำเร็จหลังล้มเหลวหลายครั้ง, ล็อกอินจากสองประเทศในเวลาใกล้กัน	MFA ทุกบัญชีที่เข้าจากภายนอก, Password Policy (8)
6	**ผู้ให้บริการภายนอก (Supply Chain)**	Vendor HIS/PACS มีบัญชีรีโมตถาวร ใช้รหัสเดียวกันทุก รพ.	การเชื่อมต่อของ Vendor นอกเวลาที่นัด	เปิดสิทธิ์เฉพาะเวลานัด, MFA, บันทึกหน้าจอ (8, 22)
7	**เว็บแอปพลิเคชัน**	CMS/Plugin เก่า, ระบบนัดหมายที่พัฒนาเอง	ไฟล์แปลกในโฟลเดอร์อัปโหลด, Error SQL ใน Log	WAF, อัปเดต CMS, OWASP (11)
8	**ดาวน์โหลดโปรแกรมปลอม / โฆษณาหลอก**	ค้นหาโปรแกรมรีโมตหรือไดรเวอร์จาก Google แล้วได้ตัวปลอม	โปรแกรมใหม่ที่ไม่ได้อนุมัติ	ใช้แหล่งติดตั้งกลาง, Application Allow List (10)

#	ช่องทาง	ทำไมได้ผลกับโรงพยาบาล	สัญญาณเตือน	ปิดช่องทาง (บทที่)
9	**USB และคนใน**	เครื่องสาธารณะในจุดบริการ, การแชร์บัญชี	อุปกรณ์ USB ใหม่, การเปิดเวชระเบียนจำนวนมาก	ควบคุม USB, Audit Log การเข้าถึงเวชระเบียน (10, 12)

> 💡 **สังเกต**: ช่องทาง 1, 2, 5 และ 6 ปิดได้ด้วยมาตรการพื้นฐานที่ไม่ต้องซื้อระบบใหม่ คือ แพตช์ ปิดพอร์ต และ MFA ซึ่งตรงกับ CTAM+ ข้อ 3, 6, 7 และ 13

23.5 กรณีจำลอง: Ransomware โจมตีโรงพยาบาลใน 14 วัน

สถานการณ์ต่อไปนี้รวบรวมจากรูปแบบที่พบซ้ำในรายงานเหตุการณ์จริงทั้งในและต่างประเทศ ใช้เพื่อการเรียนรู้ว่า “แต่ละขั้นทิ้งร่องรอยอะไร และตัดวงจรได้ที่ไหน”



▲ ภาพที่ 23.3 ลำดับเหตุการณ์ Ransomware จำลอง 14 วัน และโอกาสตรวจพบ

ช่วงเวลา	สิ่งที่ผู้โจมตีทำ (ยุทธวิธี)	ร่องรอยที่ตรวจพบได้	จุดตัดวงจร
วันที่ 0	ใช้รหัสผ่านที่รั่วล็อกอิน VPN ของเจ้าหน้าที่ที่ไม่มี MFA (Initial Access)	Log VPN: ล็อกอินจาก IP ต่างประเทศ เวลา 02:13	MFA บน VPN, Geo-IP, แจ้งเตือนล็อกอินนอกประเทศ
วันที่ 0–1	สแกนเครือข่ายภายในหาเซิร์ฟเวอร์และ Domain Controller (Discovery)	Firewall/IDS: เครื่องเดียวเชื่อมต่อหลายร้อย IP ในเวลาสั้น	แบ่ง VLAN, กฎตรวจจับการสแกนภายใน
วันที่ 2–5	ขโมยรหัสผ่านจากหน่วยความจำได้บัญชี Domain Admin (Credential Access, Privilege Escalation)	Sysmon Event 10: โปรเซสแปลกเข้าถึง LSASS	Credential Guard, Windows LAPS, แยกบัญชี Admin ออกจากบัญชีใช้งาน

ช่วงเวลา	สิ่งที่ผู้โจมตีทำ (ยุทธวิธี)	ร่องรอยที่ตรวจพบได้	จุดตัดวงจร
วันที่ 5–10	RDP ไปยังเซิร์ฟเวอร์ HIS, File Server, Backup และติดตั้งโปรแกรมรีโมตไว้กลับเข้ามา (Lateral Movement, Persistence)	Event 4624 Logon Type 10 นอกเวลา, Event 7045 บริการใหม่	จำกัด RDP เฉพาะจาก Jump Host, แจ้งเตือนบริการใหม่
วันที่ 10–13	บีบอัดฐานข้อมูลและไฟล์ผู้ป่วย แล้วอัปโหลดออกไปยัง Cloud Storage (Collection, Exfiltration)	Firewall: ปริมาณข้อมูลขาออกผิดปกติตอนกลางคืน	Egress Filtering, แจ้งเตือนปริมาณขาออก, DLP
วันที่ 14 (ศุกร์ 02:00)	ลบ Shadow Copy และ Backup ที่เข้าถึงได้ ปิดแอนติไวรัส แล้วเข้ารหัสไฟล์ทั้งหมด (Defense Impairment, Impact)	Event 1102 Log ถูกล้าง, คำสั่งลบ Shadow Copy, ไฟล์ถูกเปลี่ยนนามสกุลจำนวนมาก	Backup แบบ Offline/Immutable, แจ้งเตือนระดับวิกฤติไปยังผู้รับผิดชอบทันที
วันที่ 14 เช้า	ทิ้งไฟล์เรียกค่าไถ่ ขู่เผยแพร่ข้อมูลบนเว็บไซต์ของกลุ่ม	หน้าจอทุกเครื่องแสดงข้อความ	เปิดใช้ BCP/Downtime Procedure, แจ้งเหตุตามบทที่ 17

📌 **บทเรียนจากกรณีจำลอง**: ผู้โจมตีอยู่ในระบบ **14 วัน** ก่อนเข้ารหัส ซึ่งตรงกับค่ามัธยฐานใน M-Trends 2026 ตลอดช่วงนี้มีโอกาสตรวจพบอย่างน้อย 6 ครั้ง โรงพยาบาลที่มี Wazuh เก็บ Log ครบ (บทที่ 14) และมีคนดูการแจ้งเตือนทุกวัน มีโอกาสสูงที่จะหยุดเหตุได้ตั้งแต่วันแรก ๆ

Living off the Land: ทำไมแอนติไวรัสไม่เห็น

ผู้โจมตีสมัยใหม่นิยม **ใช้เครื่องมือที่มีอยู่แล้วในระบบ** (Living off the Land) เช่น PowerShell, เครื่องมือจัดการ Windows, โปรแกรมรีโมตที่ถูกกฎหมาย และบริการ Cloud Storage ทั่วไป เพราะไม่ถูกแอนติไวรัสจับว่าเป็นมัลแวร์ การป้องกันจึงต้องเปลี่ยนจาก “ไฟล์นี้อันตรายไหม” เป็น “**พฤติกรรมนี้ปกติไหม**” เช่น

- ทำไมเครื่องของงานการเงินถึงรัน PowerShell ที่ดาวน์โหลดสคริปต์จากอินเทอร์เน็ต
- ทำไมบัญชีของพยาบาลจึงล็อกอินเข้าเซิร์ฟเวอร์ Backup
- ทำไมมีการติดตั้งโปรแกรมรีโมตบนเซิร์ฟเวอร์ HIS ตอนตีสาม

23.6 ตารางจับคู่: เทคนิคผู้โจมตี → การป้องกัน → การตรวจจับ

ตารางนี้ใช้เป็นเช็กลิสต์ว่า “ถ้าผู้โจมตีทำสิ่งนี้ เรามีทั้งการป้องกันและการตรวจจับหรือยัง”

ยุทธวิธี	เทคนิค (รหัส ATT&CK)	ป้องกัน	ตรวจจับ (Windows Event / Wazuh)	CTAM +
Initial Access	Exploit Public-Facing Application (T1190)	แพตช์ตาม KEV, WAF, ลดบริการที่เปิด	Log WAF/Firewall, VA Scan	6, 8, 11

ยุทธวิธี	เทคนิค (รหัส ATT&CK)	ป้องกัน	ตรวจจับ (Windows Event / Wazuh)	CTAM +
Initial Access	External Remote Services (T1133)	VPN+MFA, ปิด RDP ภายนอก	ล็อกอิน VPN จากต่างประเทศ	3, 7
Initial Access	Phishing (T1566)	DMARC, กรองอีเมล, อบรม	รายงานจากผู้ใช้, Log Mail Gateway	17
Initial Access / Persistence	Valid Accounts (T1078)	MFA, ปิดบัญชีที่ไม่ใช้, ทบทวนสิทธิ์	4624 นอกเวลา/นอกพื้นที่	3, 4, 7
Credential Access	Brute Force (T1110)	Account Lockout, MFA	4625 จำนวนมาก, 4740	3, 10
Credential Access	OS Credential Dumping (T1003)	Credential Guard, ไม่ล็อกอิน Admin บนเครื่องผู้ใช้	Sysmon 10 (เข้าถึง lsass.exe)	2, 4
Execution	PowerShell (T1059.001)	Constrained Language Mode, จำกัดผู้ใช้	4104 Script Block Logging, Sysmon 1	2, 10
Persistence	Create Account (T1136)	ทบทวนบัญชีรายเดือน	4720, 4728/4732/4756 (เพิ่มเข้ากลุ่ม Admin)	3, 4
Persistence	Scheduled Task (T1053.005)	จำกัดสิทธิ์ Admin	4698	4, 10
Persistence / C2	Remote Access Software (T1219)	Allow List โปรแกรมรีโมตที่อนุมัติ	7045 บริการใหม่, Sysmon 1	3, 15
Discovery	Network Service Discovery (T1046)	แบ่ง VLAN, ACL ระหว่างโซน	IDS/Firewall เห็นการสแกนภายใน	14
Lateral Movement	Remote Desktop Protocol (T1021.001)	RDP เฉพาะจาก Jump Host, NLA, MFA	4624 Logon Type 10	3, 14
Lateral Movement	SMB/Windows Admin Shares (T1021.002)	ปิด Admin Share ที่ไม่จำเป็น, LAPS	5140/5145, 4624 Logon Type 3 จากเครื่องผู้ใช้ไปเครื่องผู้ใช้	4, 14
Stealth	ล้าง Log (Clear Windows Event Logs)	ส่ง Log ออกไปเก็บที่ SIEM ทันที	1102, 104	9, 10
Defense Impairment	ปิดหรือแก้ไขเครื่องมือป้องกัน	Tamper Protection ของ AV/EDR	Agent หยุดส่ง Log (Wazuh Agent Disconnected)	2, 10
Exfiltration	Exfiltration to Cloud Storage (T1567.002)	Egress Filtering, บล็อกบริการแชร์ไฟล์ที่ไม่ได้อนุมัติ	ปริมาณขาออกผิดปกติ, DNS ไปยังบริการแชร์ไฟล์	9, 14
Impact	Inhibit System Recovery (T1490)	Backup Offline/Immutable	Sysmon 1: คำสั่งลบ Shadow Copy	1, 5
Impact	Data Encrypted for Impact (T1486)	EDR ที่ตรวจพฤติกรรม, แบ่งสิทธิ์ไฟล์แชร์	ไฟล์ถูกแก้ไข/เปลี่ยนชื่อจำนวนมาก (FIM)	1, 2

ยุทธวิธี	เทคนิค (รหัส ATT&CK)	ป้องกัน	ตรวจจับ (Windows Event / Wazuh)	CTAM +
Impact	Defacement (T1491)	WAF, จำกัดสิทธิ์เขียนไฟล์เว็บ	FIM บนโฟลเดอร์เว็บ	8

⚠️ รหัสเทคนิคข้างต้นอ้างอิง ATT&CK Enterprise ส่วนเทคนิคในกลุ่ม Stealth และ Defense Impairment ถูกจัดหมวดใหม่ใน v19 จึงไม่ได้ระบุรหัสไว้ ให้ตรวจรหัสล่าสุดก่อนใช้งาน

23.7 เปิด Log ให้พร้อมสำหรับการตรวจจับ

การตรวจจับในหัวข้อก่อนหน้าทำไม่ได้ถ้า Windows ไม่ได้บันทึกเหตุการณ์ไว้ ค่าเริ่มต้นของ Windows บันทึกไม่ครบ ให้ตั้งค่าดังนี้ผ่าน Group Policy

ตั้งค่า	ตำแหน่งใน Group Policy	ได้ Event
Audit Process Creation + บันทึก Command Line	Advanced Audit Policy > Detailed Tracking และ Administrative Templates > System > Audit Process Creation	4688 พร้อมคำสั่งเต็ม
PowerShell Script Block Logging	Administrative Templates > Windows Components > Windows PowerShell	4104
Audit Logon, Account Lockout	Advanced Audit Policy > Logon/Logoff	4624, 4625, 4740
Audit User Account / Security Group Management	Advanced Audit Policy > Account Management	4720, 4728, 4732, 4756
Audit Other Object Access (Scheduled Task)	Advanced Audit Policy > Object Access	4698
ติดตั้ง **Sysmon** พร้อมไฟล์ตั้งค่าที่ชุมชนดูแล	ติดตั้งผ่าน GPO/Software Deployment	Sysmon 1, 3, 10, 11, 22

ส่ง Log ของ Sysmon เข้า Wazuh โดยเพิ่มใน `ossec.conf` ของ Agent (หรือใน Agent Group ที่ Manager)

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
<localfile>
  <location>Microsoft-Windows-PowerShell/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

กฎตรวจจับเพิ่มเติมใน Wazuh

เพิ่มต่อจากกฎในบทที่ 14 ใน `/var/ossec/etc/rules/local_rules.xml` แล้วรีสตาร์ต Manager

```
<group name="local,attack_chain,">

  <!-- ลบ Shadow Copy: สัญญาณสำคัญก่อนเข้ารหัสไฟล์ -->
  <rule id="100310" level="15">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine" type="pcre2">(?i)(vssadmin|wmic).*
(delete\s+shadows|shadowcopy\s+delete)</field>
    <description>ตรวจพบคำสั่งลบ Shadow Copy (สัญญาณ Ransomware)</description>
    <mitre><id>T1490</id></mitre>
  </rule>

  <!-- ติดตั้งบริการโปรแกรมรีโมตใหม่ -->
  <rule id="100311" level="12">
    <if_group>windows</if_group>
    <field name="win.system.eventID">^7045$</field>
    <field name="win.eventdata.serviceName" type="pcre2">(?i)
(anydesk|teamviewer|screenconnect|rustdesk|splashtop|atera)</field>
    <description>มีการติดตั้งบริการโปรแกรมรีโมต: $(win.eventdata.serviceName)</description>
    <mitre><id>T1219</id></mitre>
  </rule>

  <!-- Security Log ถูกล้าง -->
  <rule id="100312" level="14">
    <if_group>windows</if_group>
    <field name="win.system.eventID">^1102$</field>
    <description>Security Event Log ถูกล้างบนเครื่อง $(win.system.computer)</description>
  </rule>

  <!-- เพิ่มสมาชิกเข้ากลุ่มสิทธิ์สูง -->
  <rule id="100313" level="13">
    <if_group>windows</if_group>
    <field name="win.system.eventID">^4728$|^4732$|^4756$</field>
    <field name="win.eventdata.targetUserName" type="pcre2">(?i)(domain admins|enterprise
admins|administrators)</field>
    <description>มีการเพิ่มสมาชิกเข้ากลุ่ม $(win.eventdata.targetUserName)</description>
    <mitre><id>T1098</id></mitre>
  </rule>

</group>
```

💡 ทดสอบกฎด้วย `/var/ossec/bin/wazuh-logtest` ก่อนใช้งานจริง และตั้งให้การแจ้งเตือนระดับ 12 ขึ้นไปส่งถึงผู้รับผิดชอบทันที (หัวข้อ 14.9) ชื่อฟิลด์และกลุ่มกฎอาจต่างกันตามเวอร์ชันของ Wazuh ให้ตรวจจาก Alert จริงในหน้า Discover

23.8 Lab: ล่าภัยคุกคาม (Threat Hunting) ด้วย Wazuh LAB

การล่าภัยคุกคามคือ **การตั้งสมมติฐานว่าผู้โจมตีอาจอยู่ในระบบแล้ว แล้วออกไปค้นหาร่องรอย** แทนที่จะรอการแจ้งเตือน ทำได้สัปดาห์ละ 1 ชั่วโมงด้วยหน้า Threat Hunting / Discover ของ Wazuh Dashboard

#	สมมติฐาน	คำค้น (DQL ใน Wazuh Dashboard)	สิ่งที่ต้องดู
H1	มีคน RDP เข้าเซิร์ฟเวอร์นอกเวลาราชการ	`data.win.system.eventID:4624 and data.win.eventdata.logonType:10`	เลือกช่วง 20:00–06:00 แล้วดูชื่อผู้ใช้และเครื่องต้นทาง
H2	มีบัญชีใหม่หรือมีคนถูกเพิ่มเข้ากลุ่ม Admin	`data.win.system.eventID: (4720 or 4728 or 4732 or 4756)`	ทุกรายการต้องมีใบคำขอรองรับ
H3	มีการติดตั้งโปรแกรมหรือบริการแปลก	`data.win.system.eventID:7045`	ชื่อบริการที่ไม่รู้จัก ตำแหน่งไฟล์ใน Temp/AppData
H4	มีการเดารหัสผ่าน	`data.win.system.eventID:4625` แล้วจัดกลุ่มตาม `data.win.eventdata.ipAddress`	IP ที่ล้มเหลวเกิน 20 ครั้ง/ชั่วโมง
H5	มีการใช้ PowerShell ดาวน์โหลดจากอินเทอร์เน็ต	`data.win.eventdata.scriptBlockText:*DownloadString* or data.win.eventdata.scriptBlockText:*Invoke-WebRequest*`	เครื่องที่ไม่ใช่ของทีม IT
H6	Agent หยุดส่ง Log	หน้า Agents: สถานะ Disconnected	เครื่องที่หายไปโดยไม่มีแผนปิดเครื่อง
H7	มีการตรวจพบตามยุทธวิธีใด ๆ ของ ATT&CK	เปิดโมดูล **MITRE ATT&CK** ใน Wazuh หรือค้น `rule.mitre.tactic:*`	ยุทธวิธีที่ไม่เคยเห็นมาก่อน

ขั้นตอน

1. เลือกสมมติฐาน 1–2 ข้อต่อสัปดาห์ หมุนเวียนให้ครบทุกเดือน
2. ค้นย้อนหลัง 7 วัน บันทึกผลลงแบบฟอร์ม (วันที่ ผู้ค้น สมมติฐาน ผลที่พบ การดำเนินการ)
3. ถ้าพบสิ่งผิดปกติ ให้เปิดเหตุตามบทที่ 17 ถ้าไม่พบ ให้พิจารณาสร้างกฎแจ้งเตือนอัตโนมัติจากคำค้นนั้น
4. สรุปผลรายเดือนให้ CISO เป็นหลักฐานการเฝ้าระวังเชิงรุก

📋 หลักฐาน: แบบบันทึกการล่าภัยคุกคามรายสัปดาห์ ภาพหน้าจอคำค้นและผลลัพธ์ ใช้ประกอบ CTAM+ ข้อ 10 (SIEM 6 ด้าน)

23.9 วัดความครอบคลุมด้วย ATT&CK Navigator และ D3FEND

- **ATT&CK Navigator** เป็นเว็บแอปฟรีของ MITRE ใช้ระบายสีเทคนิคที่เรา “ป้องกันได้” “ตรวจจับได้” หรือ “ยังไม่มี” ได้ผลเป็นแผนที่ความร้อน (Heat Map) ที่ผู้บริหารเข้าใจทันทีว่าจุดอ่อนอยู่ที่ใด
- **MITRE D3FEND** (d3fend.mitre.org) เป็นฐานความรู้ฝั่งผู้ป้องกัน จับคู่มาตรการป้องกัน เช่น การยืนยันตัวตนหลายปัจจัย การแยกเครือข่าย กับเทคนิคของผู้โจมตีที่มาตรการนั้นรับมือได้ ใช้ตอบคำถามว่า “ถ้าลงทุนมาตรการนี้ จะครอบคลุมภัยอะไรบ้าง”

วิธีเริ่มต้นสำหรับโรงพยาบาล

1. เลือก 20 เทคนิคจากตาราง 23.6
2. ให้คะแนนแต่ละเทคนิค 0 = ไม่มีอะไร, 1 = ป้องกันได้บางส่วน, 2 = ป้องกันและตรวจจับได้
3. ระบายสีใน Navigator แล้วส่งออกเป็นภาพ แนบในรายงานความเสี่ยงประจำปี (บทที่ 7)
4. ทำซ้ำทุก 6 เดือนเพื่อดูพัฒนาการ

23.10 Purple Team: ทดสอบว่าการตรวจจับทำงานจริง

Purple Team คือการให้ฝ่ายทดสอบ (Red) และฝ่ายป้องกัน (Blue) ทำงานร่วมกัน ฝ่ายทดสอบจำลองพฤติกรรมทีละเทคนิค ฝ่ายป้องกันดูว่าแจ้งเตือนขึ้นหรือไม่ แล้วปรับกฎทันที

- เครื่องมือโอเพนซอร์สที่นิยมสำหรับจำลองพฤติกรรมแบบควบคุมได้ เช่น **Atomic Red Team** (ชุดทดสอบเล็ก ๆ ที่ผูกกับรหัส ATT&CK) และ **MITRE Caldera**
- ทดสอบเฉพาะบน **เครื่องทดสอบที่แยกจากระบบจริง** และต้องมีหนังสืออนุมัติ ขอบเขต และแผนย้อนกลับ (บทที่ 16)
- เลือกทดสอบเทคนิคที่สำคัญต่อ Ransomware ก่อน ได้แก่ การลบ Shadow Copy, การสร้างบัญชี Admin, การติดตั้งบริการ และการล้าง Log
- บันทึกผลเป็นตาราง: เทคนิค / แจ้งเตือนขึ้นหรือไม่ / เวลาที่แจ้งเตือนถึงคน / สิ่งที่ปรับปรุง

23.11 ซ้อมแผน Tabletop: “คืนวันศุกร์ที่ HIS ล่ม”

ใช้เวลา 2 ชั่วโมง ผู้เข้าร่วม: ผู้อำนวยการหรือรองฯ, CISO, หัวหน้างาน IT, DPO, หัวหน้าพยาบาล, หัวหน้า OPD/ER, ประชาสัมพันธ์

ช่วง	สถานการณ์ที่ผู้ดำเนินการแจ้ง (Inject)	คำถามให้ทีมตอบ
1	วันจันทร์ Wazuh แจ้งว่าบัญชี VPN ของเจ้าหน้าที่การเงินล็อกอินจากต่างประเทศตอนตีสอง	ใครเห็นการแจ้งเตือนนี้ ภายในกี่นาที ทำอะไรต่อ
2	วันพุธ พบบริการ AnyDesk ถูกติดตั้งบนเซิร์ฟเวอร์ File Server โดยไม่มีใบงาน	ตัดเครื่องออกจากเครือข่ายได้ไหมโดยไม่กระทบบริการ ใครอนุมัติ
3	วันพฤหัส Firewall แสดงข้อมูลขาออก 40 GB ไปยังบริการแชร์ไฟล์ตอนกลางคืน	นี่คือเหตุข้อมูลรั่วหรือยัง นับเวลา 72 ชั่วโมงเริ่มเมื่อใด (บทที่ 4)
4	วันศุกร์ 02:00 ทุกเครื่องขึ้นข้อความเรียกค่าไถ่ HIS ใช้ไม่ได้	เปิด Downtime Procedure อย่างไร ER รับผู้ป่วยต่อได้ไหม แจ้งใครบ้าง
5	สื่อมวลชนโทรถาม ผู้ป่วยโพสต์ว่าได้รับ SMS หลอกที่มีชื่อและสิทธิการรักษาของตน	ใครให้ข่าว พูดอะไร แจ้งเจ้าของข้อมูลอย่างไร
6	พบว่า Backup ล่าสุดที่ใช้ได้คือ 9 วันก่อน	ยอมรับข้อมูลที่หายได้ไหม กู้ระบบใดก่อน (RTO/RPO บทที่ 13)

หลังซ้อม ให้สรุปช่องว่าง 3–5 ข้อ พร้อมผู้รับผิดชอบและกำหนดเสร็จ ใช้เป็นหลักฐานการซ้อมแผนของ CTAM+ ข้อ 5

23.12 สิบจุดตัดวงจรที่คุ้มค่าที่สุด

ถ้าทำได้เพียง 10 ข้อ ให้เลือกมาตรการที่ตัดวงจรการโจมตีได้หลายขั้นพร้อมกัน

1. **MFA ทุกบัญชีที่เข้าจากภายนอก** (VPN, อีเมล, Cloud, Vendor) และบัญชีผู้ดูแลระบบทุกบัญชี
2. **แพตช์อุปกรณ์ที่เปิดสู่อินเทอร์เน็ตภายใน 72 ชั่วโมง** เมื่อช่องโหว่อยู่ใน CISA KEV หรือมีคำเตือนจาก สกมช./Health CERT
3. **ไม่มี RDP ฐานข้อมูล หรือ DICOM เปิดตรงสู่อินเทอร์เน็ต**
4. **รหัสผ่าน Local Admin ไม่ซ้ำกันทุกเครื่อง** ด้วย Windows LAPS และแยกบัญชี Admin ออกจากบัญชีใช้งานประจำวัน
5. **EDR หรือการตรวจจับพฤติกรรม** ร่วมกับ Sysmon และ Wazuh บนเซิร์ฟเวอร์สำคัญทุกเครื่อง
6. **แบ่งเครือข่าย** และจำกัด RDP/SMB ระหว่างเครื่องผู้ใช้ด้วยกัน
7. **Backup แบบ Offline หรือ Immutable** ที่บัญชีโดเมนลบไม่ได้ และทดสอบกู้คืนทุกเดือน
8. **ควบคุมทราฟฟิกขาออก** และแจ้งเตือนเมื่อปริมาณผิดปกติ
9. **แจ้งเตือนเหตุการณ์สำคัญ** (ตาราง 23.6) ถึงคนจริงภายในไม่กี่นาที ไม่ใช่แค่เก็บใน Dashboard
10. **ขั้นตอนยืนยันตัวตนของ Help Desk** ก่อนรีเซ็ตรหัสผ่านหรือ MFA ทุกครั้ง

⭐ สรุปท้ายบท

- ผู้โจมตีต้องสำเร็จทุกขั้น ผู้ป้องกันตรวจพบขั้นเดียวก็หยุดเหตุได้ ถ้ามี Log และมีคนดู
- ช่องทางเข้าหลักของภาคสุขภาพในปัจจุบันคือช่องโหว่ของอุปกรณ์ที่เปิดสู่อินเทอร์เน็ต ตามด้วยฟิชชิงและรหัสผ่านรั่ว
- ผู้โจมตีส่วนใหญ่ใช้เครื่องมือที่มีอยู่ในระบบ การตรวจจับจึงต้องดูพฤติกรรม ไม่ใช่ดูแค่ไฟล์มัลแวร์
- MITRE ATT&CK เป็นภาษากลางในการสื่อสารและวัดความครอบคลุม ต้องติดตามเวอร์ชันล่าสุดเพราะมีการปรับโครงสร้างในปี 2569
- การล่าภัยคุกคามสัปดาห์ละชั่วโมงและการซ้อม Tabletop ทำได้ทันทีโดยไม่ต้องลงทุนเพิ่ม

✏️ คำถามทบทวน

1. อธิบายว่าทำไม “ผู้ป้องกันตรวจพบขั้นเดียวก็ตัดวงจรได้” พร้อมยกตัวอย่างจากกรณีจำลอง 14 วัน
2. ช่องทางเจาะระบบ 3 อันดับแรกของหน่วยงานท่านคืออะไร มีมาตรการปิดช่องทางครบหรือยัง
3. เลือกเทคนิค 5 ข้อจากตาราง 23.6 แล้วตรวจว่า Wazuh ของหน่วยงานแจ้งเตือนได้หรือไม่
4. ร่างขั้นตอนยืนยันตัวตนของ Help Desk ก่อนรีเซ็ตรหัสผ่านให้แพทย์ที่โทรมาขอ
5. ออกแบบ Tabletop 1 สถานการณ์ที่เหมาะกับหน่วยงานของท่าน โดยมีอย่างน้อย 4 Inject



ภาค 7 · รู้เขารู้เรา: ผู้โจมตี การประสานข้อมูล และเทคโนโลยีใหม่ บทที่ 24

ระบบโฟลว์การประสานข้อมูลและแบ่งปันความรู้ด้านไซเบอร์

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ เข้าใจเครือข่ายประสานงานด้านไซเบอร์ของภาคสาธารณสุข ตั้งแต่หน่วยบริการปฐมภูมิจนถึงระดับชาติ
- ✔️ ใช้โฟลว์มาตรฐาน 6 แบบ ได้แก่ คำเตือนภัย แจ้งเหตุ แบ่งปันข้อมูลบ่งชี้ภัย ขอความช่วยเหลือ รายงานสถานะ และถอดบทเรียน
- ✔️ จัดชั้นการเผยแพร่ข้อมูลด้วย TLP 2.0 และแบ่งปันอย่างปลอดภัยตาม PDPA
- ✔️ ตั้งระบบจัดการความรู้ (KM) และชุมชนนักปฏิบัติ (CoP) ระดับจังหวัดและเขตสุขภาพ

📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 5, 10, 11, 17 / หน้าที่หน่วยงาน CII ตาม พ.ร.บ.ไซเบอร์ (บทที่ 3) / NIST CSF 2.0 (GV, RS.CO, ID.IM) / NIST SP 800-150 (Cyber Threat Information Sharing)

24.1 ข้อมูลที่ไม่ถูกส่งต่อ คือภัยที่จะเกิดซ้ำ

ผู้โจมตีไม่ได้เลือกโจมตีโรงพยาบาลเพียงแห่งเดียว เมื่อพบช่องโหว่ในอุปกรณ์รุ่นหนึ่ง เขาจะสแกนหาอุปกรณ์รุ่นเดียวกันทั้งประเทศ เมื่อหลอกเอารหัสผ่านจาก รพ. หนึ่งได้ ก็มักใช้อีเมลหลอกแบบเดียวกันกับ รพ. อื่นในจังหวัดในสัปดาห์เดียวกัน

ถ้า รพ. แรกที่พบเหตุส่งต่อ IP โดเมน และรูปแบบการโจมตีให้เครือข่ายภายในไม่กี่ชั่วโมง โรงพยาบาลที่เหลือจะบล็อกได้ก่อนถูกโจมตี แนวคิดนี้เรียกว่า **การป้องกันร่วม (Collective Defense)** ซึ่งเป็นหัวใจของ CERT ทุกระดับทั่วโลก

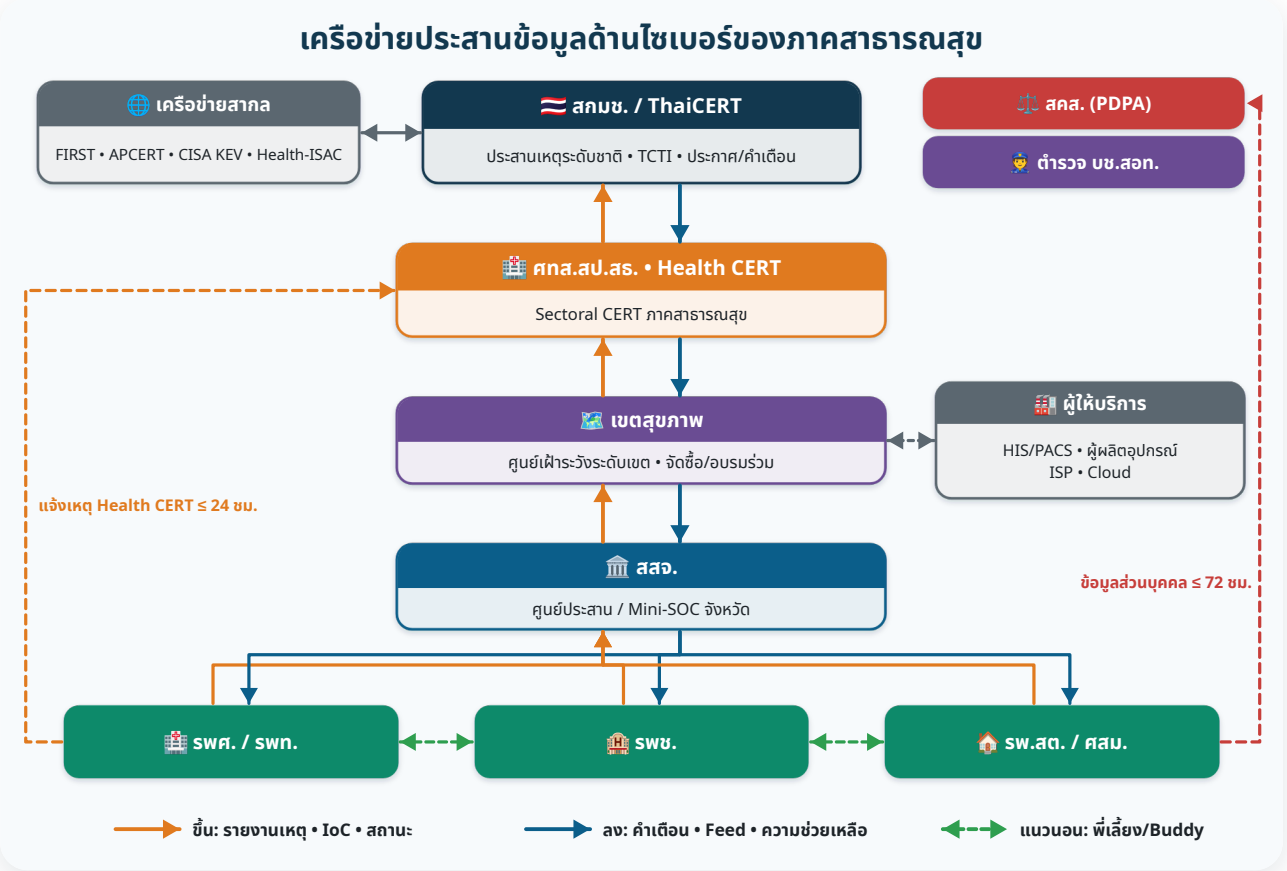
📌 **ตัวอย่างการประสานจริง**: เมื่อมีข่าวโรงพยาบาลรัฐแห่งหนึ่งถูกขโมยข้อมูลและเรียกค่าไถ่ ThaiCERT ของ สกมช. ได้ประชุมหารือร่วมกับสำนักงานปลัดกระทรวงสาธารณสุข ศูนย์ Health CERT และโรงพยาบาลที่เกิดเหตุ เพื่อประเมินสถานการณ์และวางแนวทางแก้ไขร่วมกัน แสดงให้เห็นว่าการประสานหลายระดับเกิดขึ้นจริง และจะเร็วขึ้นมากถ้าทุกฝ่ายรู้บทบาทและช่องทางล่วงหน้า

ปัญหาที่พบบ่อยเมื่อไม่มีระบบประสาน

- คำเตือนช่องโหว่ถูกส่งต่อในกลุ่มแชตแล้วจมหายไป ไม่มีใครยืนยันว่าแก้แล้ว

- รพ. ที่เกิดเหตุไม่กล้าบอกเพราะกลัวเสียชื่อ ทำให้ รพ. อื่นถูกโจมตีด้วยวิธีเดิม
- ความรู้อยู่ในหัวของเจ้าหน้าที่ IT คนเดียว เมื่อย้ายงาน ความรู้หายไปด้วย
- ส่งภาพหน้าจอที่มีข้อมูลผู้ป่วยหรือรหัสผ่านในกลุ่มแชต จนกลายเป็นเหตุข้อมูลรั่วเสียเอง

24.2 เครือข่ายประสานงานด้านไซเบอร์ของภาคสาธารณสุข



▲ ภาพที่ 24.1 เครือข่ายประสานข้อมูลด้านไซเบอร์ของภาคสาธารณสุข

ระดับ	หน่วยงาน	บทบาทหลักในการประสานข้อมูล
หน่วยบริการ	รพ.สต./ศสม., รพช., รพท./รพศ. (ทีม IT, CISO, DPO, ผู้อำนวยการ)	ตรวจจับ รายงานเหตุ ดำเนินการตามคำเตือน แบ่งปันบทเรียน
จังหวัด	สสจ. (ศูนย์ประสาน/Mini-SOC จังหวัด ตามบทที่ 19)	กระจายคำเตือน ติดตามการแก้ไข รวบรวมสถานะ ช่วยเหลือหน่วยบริการขนาดเล็ก
เขตสุขภาพ	สำนักงานเขตสุขภาพ, CIO เขต, ศูนย์เฝ้าระวังระดับเขต (ถ้ามี)	เฝ้าระวังต่อเนื่อง ประสานข้ามจังหวัด จัดซื้อและจัดอบรมร่วม
กระทรวง	ศทส.สป.สธ. และ Health CERT	ศูนย์ประสานด้านไซเบอร์ของภาคสาธารณสุข รับแจ้งเหตุ ออกคำเตือนระดับกระทรวง ประสาน สกมช.
ชาติ	สกมช. / ThaiCERT	ประสานเหตุระดับประเทศ ข่าวกรองภัยคุกคาม แพลตฟอร์ม TCTI ออกประกาศและคำแนะนำ

ระดับ	หน่วยงาน	บทบาทหลักในการประสานข้อมูล
ชาติ (เฉพาะเรื่อง)	สคส., บช.สอท. (ตำรวจ), สพร.	รับแจ้งเหตุละเมิดข้อมูลส่วนบุคคล ดำเนินคดี มาตรฐานรัฐบาลดิจิทัล
ภาคเอกชน	ผู้พัฒนา HIS/PACS, ผู้ผลิตอุปกรณ์, ISP, Cloud	แพตช์ ข้อมูลทางเทคนิค ช่วยกู้ระบบ
ต่างประเทศ	FIRST, APCERT (ผ่าน ThaiCERT), Health-ISAC, CISA KEV	ข้อมูลภัยระดับโลก รายการช่องโหว่ที่ถูกใช้โจมตีจริง

⚠️ ช่องทางติดต่อที่ใช้ต้องเป็น **ช่องทางทางการ** เท่านั้น เช่น Health CERT (`health-cirt.moph.go.th` , `health-cirt@moph.go.th` , LINE `@health-cirt`) และ ThaiCERT (`thaicert.or.th`) ตรวจสอบช่องทางล่าสุดก่อนใช้ และบันทึกไว้ในเอกสารที่เข้าถึงได้แม้ระบบอีเมลล่ม

ตาราง RACI: ใครทำอะไร

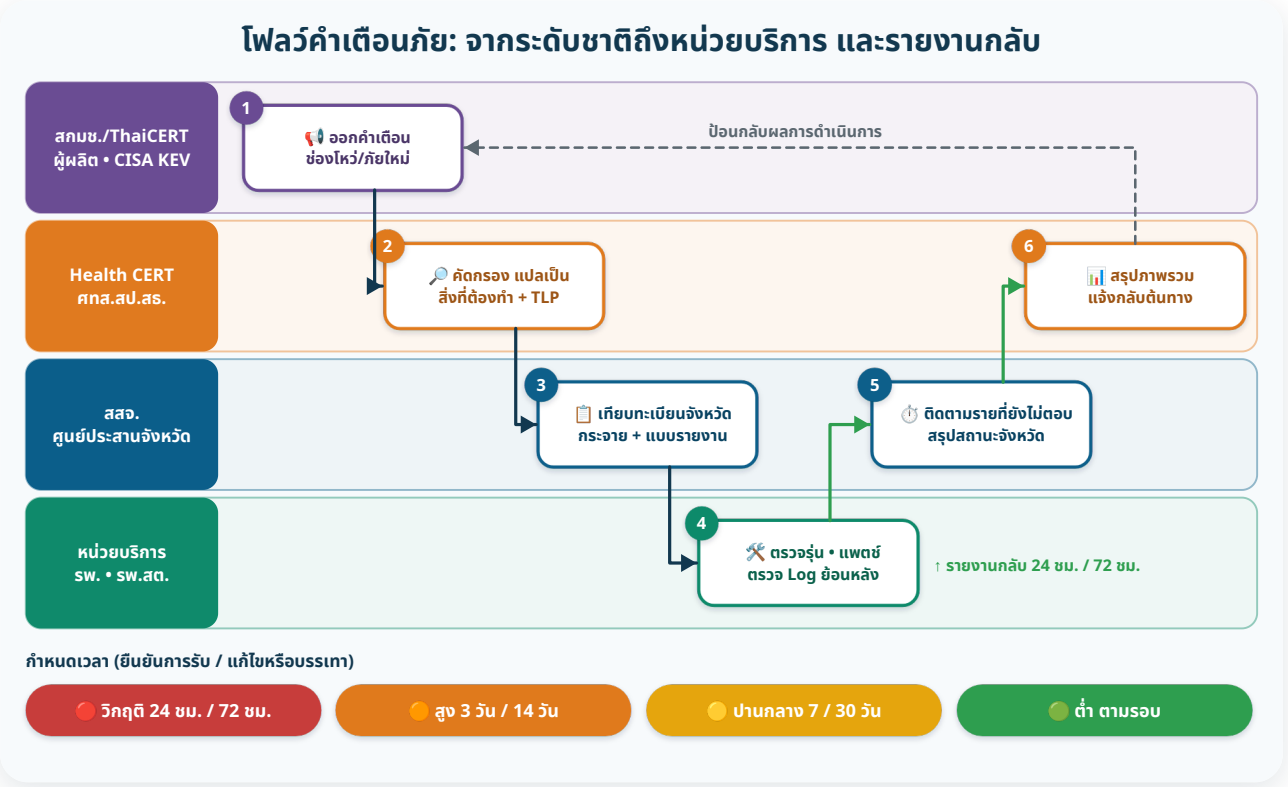
R = ผู้ลงมือทำ, A = ผู้รับผิดชอบผลลัพธ์, C = ผู้ให้คำปรึกษา, I = ผู้รับทราบ (เป็นตัวอย่างที่ปรับใช้ได้ตามโครงสร้างจริงของแต่ละเขต)

กิจกรรม	รพ.	สสจ.	เขต	Health CERT	สกมช.	สคส.
ตรวจพบและรายงานเหตุเบื้องต้น	R/A	I	I	I	I	–
คัดกรองและยกระดับเหตุ	C	R	C	A	I	–
ออกคำเตือนช่องโหว่ระดับประเทศ	I	I	I	C	R/A	–
แปลคำเตือนเป็นสิ่งที่ต้องทำในภาคสุขภาพ	I	C	C	R/A	C	–
กระจายและติดตามการแก้ไขในจังหวัด	R	A	I	I	–	–
แจ้งเหตุละเมิดข้อมูลส่วนบุคคล (72 ชม.)	R/A	I	I	I	–	I
แบ่งปันข้อมูลบ่งชี้ภัย (IoC)	R	R	R	A	C	–
ถอดบทเรียนและเผยแพร่ความรู้	R	A	R	C	–	–

24.3 โฟลว์มาตรฐาน 6 แบบ

#	โฟลว์	ทิศทาง	เริ่มเมื่อ	ผลลัพธ์ที่ต้องได้
W1	คำเตือนภัยและช่องโหว่ (Advisory)	บนลงล่าง	มีประกาศจาก สกมช./Health CERT/ผู้ผลิต หรือช่องโหว่เข้า CISA KEV	ทุก รพ. ยืนยันว่าได้รับ ตรวจแล้ว และแก้แล้ว
W2	แจ้งเหตุและยกระดับ (Escalation)	ล่างขึ้นบน	พบเหตุภัยคุกคาม	ได้รับความช่วยเหลือทันเวลา และแจ้งตามกฎหมายครบ
W3	แบ่งปันข้อมูลบ่งชี้ภัย (IoC/TTP)	ทุกทิศทาง	วิเคราะห์เหตุแล้วได้ IP โดเมน แฮช หรือรูปแบบการโจมตี	หน่วยงานอื่นบล็อกและเฝ้าระวังได้ก่อนถูกโจมตี
W4	ขอความช่วยเหลือ (Mutual Aid)	แนวนอนและขึ้นบน	หน่วยงานรับมือเองไม่ไหว	มีทีมและอุปกรณ์ช่วยภายในเวลาที่ตกลง
W5	รายงานสถานะประจำ (Status)	ล่างขึ้นบน ตามรอบ	ทุกเดือน/ไตรมาส	ภาพรวมความพร้อมของจังหวัดและเขต
W6	ถอดบทเรียนและจัดการความรู้ (KM)	ทุกทิศทาง	หลังเหตุ หลังซ้อม หรือเมื่อมีวิธีทำงานที่ดี	ความรู้ถูกบันทึก ค้นได้ และใช้ซ้ำได้

24.4 W1: โฟลว์คำเตือนภัยและช่องโหว่



▲ ภาพที่ 24.2 โฟลว์คำเตือนภัยจากระดับชาติถึงหน่วยบริการ และการรายงานกลับ

ขั้นตอน

1. **รับ**: Health CERT หรือศูนย์ประสานจังหวัดได้รับคำเตือนจาก สกมช./ThaiCERT ผู้ผลิต หรือพบช่องโหว่ใหม่ใน CISA KEV
2. **คัดกรอง**: ตรวจว่ากระทบผลิตภัณฑ์ที่ใช้ในภาคสาธารณสุขหรือไม่ เทียบกับทะเบียนทรัพย์สินรวมของจังหวัด (บทที่ 7) แล้วกำหนดระดับความเร่งด่วน
3. **แปลเป็นสิ่งที่ต้องทำ**: เขียนคำเตือนสั้น ๆ เป็นภาษาไทยที่บอกชัดว่า “ใครต้องทำอะไร ภายในเมื่อใด” ใส่ระดับ TLP
4. **กระจาย**: ส่งผ่านช่องทางทางการของจังหวัด (อีเมลกลุ่ม + กลุ่มแชตของผู้รับผิดชอบ) พร้อมแบบรายงานกลับ
5. **ดำเนินการ**: รพ. ตรวจรุ่นในทะเบียน อัปเดตหรือใช้มาตรการบรรเทา และตรวจ Log ย้อนหลังว่าเคยถูกโจมตีแล้วหรือไม่
6. **รายงานกลับ**: ยืนยันการรับและผลการแก้ไขตามกำหนด ถ้าแก้ไม่ได้ให้แจ้งเหตุผลและมาตรการชดเชย
7. **ติดตามและปิด**: ศูนย์ประสานติดตามรายที่ยังไม่ตอบ สรุปผลส่งผู้บริหารและหน่วยงานต้นทาง

ระดับความเร่งด่วนและกำหนดเวลา (ตัวอย่างที่แนะนำ)

ระดับ	เงื่อนไข	ยืนยันการรับและตรวจทะเบียน	แก้ไขหรือบรรเทา
🔴 วิกฤติ	ถูกใช้โจมตีจริงแล้ว (อยู่ใน KEV หรือ สกมช. แจ้ง) และอุปกรณ์เปิดสู่อินเทอร์เน็ต	24 ชั่วโมง	72 ชั่วโมง
🟠 สูง	CVSS ≥ 7 หรือกระทบระบบสำคัญ (HIS, PACS, Firewall)	3 วันทำการ	14 วัน
🟡 ปานกลาง	ต้องอยู่ในเครือข่ายภายในจึงใช้ประโยชน์ได้	7 วัน	30 วัน
🟢 ต่ำ	ข้อมูลเพื่อทราบ แนวปฏิบัติทั่วไป	ตามรอบ	ตามรอบบำรุงรักษา

แม่แบบข้อความคำเตือน

```
[TLP:AMBER] คำเตือนภัยไซเบอร์ จังหวัด..... ฉบับที่ 69-0__
เรื่อง       : ช่องโหว่ร้ายแรงใน (ผลิตภัณฑ์) รุ่น .....
ระดับ        : วิกฤติ (มีการโจมตีจริง / อยู่ในรายการ CISA KEV)
ผลกระทบ     : ผู้โจมตีจากภายนอกอาจควบคุมอุปกรณ์ได้โดยไม่ต้องล็อกอิน
ผู้ต้องดำเนินการ: หน่วยบริการที่ใช้ (ผลิตภัณฑ์) รุ่น .....
สิ่งที่ต้องทำ : 1) ตรวจรุ่นในทะเบียนทรัพย์สิน
                2) อัปเดตเป็นรุ่น ..... หรือปิดหน้าจัดการจากอินเทอร์เน็ต
                3) ตรวจ Log ย้อนหลัง 14 วัน หาการล็อกอิน/Config ที่ผิดปกติ
รายงานกลับ  : ภายใน 24 ชม. (มี/ไม่มีอุปกรณ์) และภายใน 72 ชม. (แก้ไขแล้ว)
อ้างอิง      : ประกาศผู้ผลิต / สกมช. / Health CERT (ลิงก์)
ผู้ประสาน    : ศูนย์ประสานไซเบอร์ สสจ. (ช่องทางทางการ)
```

แบบรายงานกลับ (ทำเป็นแบบฟอร์มออนไลน์หรือตารางกลาง)

ช่อง	ตัวอย่าง
เลขที่คำเตือน	69-014
หน่วยบริการ / ผู้รายงาน	รพ.ตัวอย่าง / งาน IT

ช่อง	ตัวอย่าง
มีอุปกรณ์ที่กระทบหรือไม่	มี 1 เครื่อง
สถานะ	แก้ไขแล้ว / บรรเทาแล้ว / อยู่ระหว่างดำเนินการ / แก้ไม่ได้
พบร่องรอยการโจมตีหรือไม่	ไม่พบ (ตรวจ Log 14 วัน)
วันเวลาที่ดำเนินการเสร็จ	5 พ.ย. 69 16:30
หลักฐาน	ภาพหน้าจอเวอร์ชันหลังอัปเดต

24.5 W2: โฟลว์แจ้งเหตุและยกระดับ

เส้นทางแจ้งเหตุตามกฎหมายอยู่ในบทที่ 17 (Health CERT ภายใน 24 ชั่วโมง และ สคส. ภายใน 72 ชั่วโมงเมื่อเกี่ยวกับข้อมูลส่วนบุคคล) หัวข้อนี้เน้น **การไหลของข้อมูลระหว่างเกิดเหตุ**

ระดับเหตุ (บทที่ 17)	ภายในหน่วยงาน	สสจ./เขต	Health CERT	หน่วยงานอื่น
ต่ำ	หัวหน้างาน IT	สรุปรายเดือน	–	–
ปานกลาง	CISO ภายใน 4 ชม.	แจ้งภายในวันเดียวกัน	ตามดุลยพินิจ	–
สูง	ผู้อำนวยการ ทันที	แจ้งทันที ขอความช่วยเหลือได้	ภายใน 24 ชม.	สคส. 72 ชม. (ถ้าเกี่ยวกับข้อมูลส่วนบุคคล)
วิกฤติ	ผู้อำนวยการ + ทีมบริหารวิกฤติ	แจ้งทันที เปิดศูนย์ประสานเหตุ	ทันที	สกมช./ThaiCERT ผ่านกระทรวง, ตำรวจถ้าจะดำเนินคดี

สื่อสารนอกช่องทางปกติ (Out-of-band)

เมื่อระบบอีเมลหรือ Active Directory อาจถูกยึด **อย่าคุยเรื่องการรับมือผ่านระบบที่ถูกเจาะ** เพราะผู้โจมตีอาจอ่านได้

- เตรียมรายชื่อและเบอร์โทรผู้เกี่ยวข้องเป็นเอกสารกระดาษ เก็บไว้ในห้องที่หยิบได้ทันที
- ตั้งกลุ่มสื่อสารฉุกเฉินที่ใช้บัญชีแยกจากระบบของหน่วยงาน และกำหนดล่วงหน้าว่าใครอยู่ในกลุ่ม
- ใช้การโทรศัพท์ยืนยันคำสั่งสำคัญ เช่น การตัดเครือข่าย การกู้ระบบ หรือการแจ้งหน่วยงานภายนอก

รายงานสถานการณ์ (SITREP) ระหว่างเหตุ

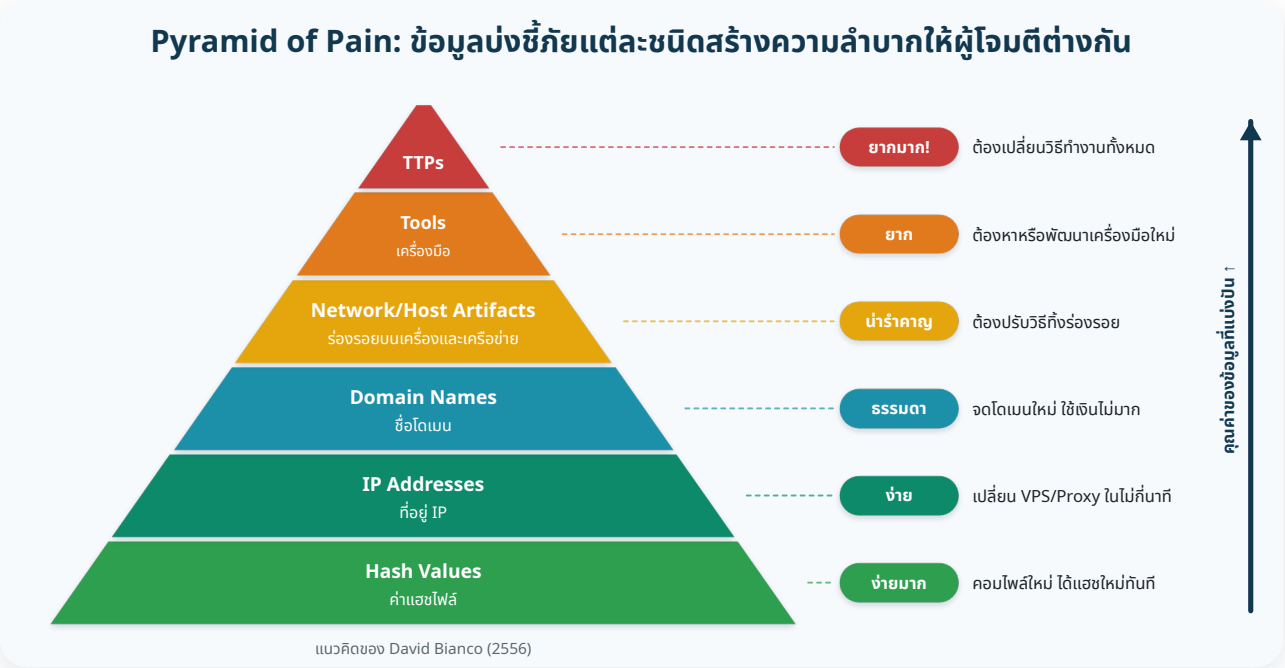
ส่งทุก 4–6 ชั่วโมงในเหตุระดับสูงขึ้นไป ใช้แม่แบบเดียวกันทุกครั้งเพื่อให้ผู้รับเทียบความคืบหน้าได้

```
SITREP ฉบับที่ __  เวลา ____ น.  [TLP:AMBER]
1. สถานะโดยรวม : ควบคุมได้บางส่วน / ยังไม่ควบคุมได้ / ควบคุมได้แล้ว
2. ระบบที่กระทบ : HIS (ใช้ไม่ได้), PACS (ปกติ), LIS (ใช้ Downtime)
3. ผลต่อบริการผู้ป่วย : OPD ใช้บัตรกระดาษ, ER ปกติ, งดรับส่งต่อแผนก...
4. สิ่งที่ทำตั้งแต่รายงานก่อน : แยกเครือข่ายเซิร์ฟเวอร์, รีเซ็ตรหัส Admin
5. ข้อมูลส่วนบุคคล : กำลังประเมิน / แจ้ง สคส. แล้วเมื่อ ____
6. ความช่วยเหลือที่ต้องการ : ผู้เชี่ยวชาญวิเคราะห์มัลแวร์, เครื่องสำรอง 3 เครื่อง
7. รายงานครั้งถัดไป : ____ น.
```

24.6 W3: แบ่งปันข้อมูลบ่งชี้ภัย (IoC) และพฤติกรรม (TTP)

ข้อมูลอะไรมีค่าที่สุด: Pyramid of Pain

David Bianco เสนอแนวคิด **Pyramid of Pain** (2556) ว่าข้อมูลบ่งชี้แต่ละชนิด “สร้างความลำบาก” ให้ผู้โจมตีต่างกัน ค่าแฮชและ IP เปลี่ยนได้ง่ายมาก แต่ถ้าเรารู้ทันพฤติกรรม (TTP) ผู้โจมตีต้องเปลี่ยนวิธีทำงานทั้งหมด



▲ ภาพที่ 24.3 Pyramid of Pain: ยิ่งแบ่งปันข้อมูลระดับสูง ผู้โจมตียิ่งลำบาก

ดังนั้นเมื่อแบ่งปัน ให้ส่งทั้ง **IoC** (ใช้บล็อกได้ทันที) และ **คำอธิบายพฤติกรรม** (ใช้ตั้งกฎตรวจจับระยะยาว) เช่น “ผู้โจมตีใช้บัญชี VPN ที่ไม่มี MFA แล้ว RDP ไปยังเซิร์ฟเวอร์ Backup ตอนตีสอง และติดตั้งโปรแกรมรีโมตเป็นบริการ”

ขั้นตอนแบ่งปัน

1. **สกัด**: รวบรวม IP โดเมน URL อีเมลผู้ส่ง แฮชไฟล์ และลำดับพฤติกรรมจากการวิเคราะห์เหตุ (บทที่ 17)
2. **ตรวจยืนยัน**: ตัด IP ของบริการที่ใช้ร่วมกัน (CDN, Cloud สาธารณะ) และ IP ของหน่วยงานตนเองออก เพื่อลด False Positive
3. **ลบข้อมูลอ่อนไหว**: ไม่มีชื่อผู้ป่วย เลขบัตรประชาชน รหัสผ่าน IP ภายใน หรือชื่อเครื่องภายในที่ระบุตัวตนได้
4. **ติดป้าย TLP**: เลือกระดับการเผยแพร่ (หัวข้อ 24.8)
5. **ส่ง**: Health CERT, ศูนย์ประสานจังหวัด, แพลตฟอร์ม TCTI (ถ้าเข้าร่วม) หรือ NCSA Blacklist SOC Dashboard (บทที่ 15)
6. **นำไปใช้**: ผู้รับนำเข้า Firewall, DNS และ Wazuh CDB List (บทที่ 15) แล้วค้นย้อนหลังว่าเคยพบหรือไม่
7. **ป้อนกลับ**: ผู้รับแจ้งกลับเมื่อพบ (Sighting) หรือพบว่าเป็น False Positive เพื่อปรับคุณภาพข้อมูล

แม่แบบตาราง IoC

ตัวอย่างใช้ IP และโดเมนสำหรับเอกสาร (RFC 5737 และ `.example`) ไม่ใช่ข้อมูลจริง

ประเภท	ค่า	บริบท	ความมั่นใจ	TLP	พบครั้งแรก
IPv4	`203.0.113.45`	ล็อกอิน VPN สำเร็จด้วยบัญชีเจ้าหน้าที่ เวลา 02:13	สูง	AMBER	3 พ.ย. 69
Domain	`moph-salary-update.example`	หน้าเว็บปลอมเก็บรหัสผ่านจากอีเมลแจ้งเงินเดือน	สูง	GREEN	2 พ.ย. 69
Email	`hr-notice@mail.example`	ผู้ส่งอีเมลฟิชชิงถึงบุคลากร 3 รพ.	ปานกลาง	GREEN	2 พ.ย. 69
SHA-256	(ค่าแฮช 64 ตัวอักษร)	ไฟล์ที่ทิ้งไว้บนเซิร์ฟเวอร์	สูง	AMBER	4 พ.ย. 69
TTP	T1133 → T1021.001 → T1219 → T1490	VPN → RDP ไป Backup → ติดตั้งรีโมต → ลบ Shadow Copy	สูง	AMBER	4 พ.ย. 69

24.7 W4 และ W5: ขอความช่วยเหลือ และรายงานสถานะประจำ

W4 เครือข่ายช่วยเหลือซึ่งกันและกัน (Mutual Aid)

หน่วยบริการขนาดเล็กมักมีเจ้าหน้าที่ IT เพียง 1–2 คน เมื่อเกิดเหตุใหญ่จะรับมือเองไม่ไหว จังหวัดควรตกลงล่วงหน้าเรื่องต่อไปนี้

- **ทีมตอบสนองเร่งด่วนระดับจังหวัด** จากโรงพยาบาลขนาดใหญ่และ สสจ. พร้อมรายชื่อและลำดับการเรียกตัว
- **ชุดอุปกรณ์ฉุกเฉิน** เช่น โน้ตบุ๊กสะอาด ฮาร์ดดิสก์สำหรับเก็บหลักฐาน ตัวติดตั้งระบบปฏิบัติการและ Agent แบบออฟไลน์ สวิตช์สำรอง
- **ข้อตกลงความร่วมมือ** ระบุขอบเขต ความลับ และผู้อนุมัติ เพื่อให้เจ้าหน้าที่ข้ามหน่วยงานเข้าช่วยได้ถูกต้อง
- **ลำดับขอความช่วยเหลือ**: สสจ. → เขตสุขภาพ → Health CERT → ThaiCERT (ผ่านกระทรวง) และผู้ให้บริการที่มีสัญญา

W5 รายงานสถานะประจำเดือน

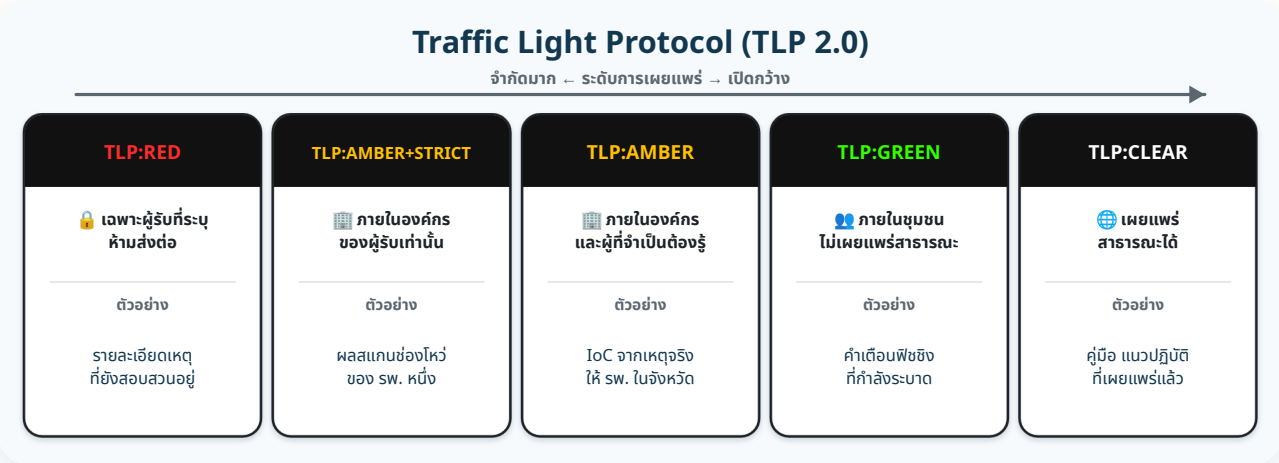
ใช้ตัวชี้วัดชุดเดียวกันทั้งจังหวัด เพื่อเทียบและช่วยเหลือหน่วยที่ตามหลัง

ตัวชี้วัด	ความหมาย	เป้าหมายที่แนะนำ
ความคืบหน้า CTAM+	จำนวนข้อที่มีหลักฐานครบ	17/17 ภายในรอบประเมิน
ยืนยันคำเตือนตรงเวลา	ร้อยละของคำเตือนระดับวิกฤติที่ตอบภายใน 24 ชม.	≥ 95%
เวลาแก้ช่องโหว่วิกฤติ	ค่ามัธยฐานตั้งแต่ได้รับคำเตือนถึงแก้เสร็จ	≤ 3 วัน
ความครอบคลุม Wazuh Agent	ร้อยละของเซิร์ฟเวอร์และเครื่องสำคัญที่ส่ง Log	≥ 95%

ตัวชี้วัด	ความหมาย	เป้าหมายที่แนะนำ
ทดสอบกู้คืนข้อมูล	ทำในเดือนนี้หรือไม่	ทุกเดือน
บุคลากรผ่านการอบรม	ร้อยละสะสมในปีงบประมาณ	≥ 80%
เหตุที่รายงาน	จำนวนและระดับ	รายงานครบ ไม่ใช่ศูนย์เพราะไม่ได้ดู
IoC ที่แบ่งปัน/นำเข้า	จำนวนรายการ	มีการแลกเปลี่ยนทุกเดือน

24.8 TLP 2.0: ป้ายบอกว่าส่งต่อได้แค่ไหน

Traffic Light Protocol (TLP) เป็นมาตรฐานของ FIRST (ฉบับ 2.0 ใช้ตั้งแต่ ส.ค. 2565) ผู้ส่งติดป้ายสีบนข้อมูล ผู้รับปฏิบัติตามสีนั้น ช่วยให้กล้าแบ่งปันข้อมูลอ่อนไหวโดยไม่หลุดออกไปนอกวง



▲ ภาพที่ 24.4 ระดับ TLP 2.0 และตัวอย่างการใช้ในภาคสาธารณสุข

ป้าย	ส่งต่อได้ถึง	ตัวอย่างในภาคสาธารณสุข
TLP:RED	เฉพาะผู้อยู่ในการประชุม/ผู้รับที่ระบุชื่อ ห้ามส่งต่อ	รายละเอียดเหตุที่ยังสอบสวนอยู่ ชื่อระบบที่ยังมีช่องโหว่และยังแก้ไม่ได้
TLP:AMBER+STRICT	เฉพาะภายในองค์กรของผู้รับ	ผลสแกนช่องโหว่ของ รพ. หนึ่งที่ส่งให้ทีม IT ของ รพ. นั้น
TLP:AMBER	ภายในองค์กรของผู้รับและลูกค้า/ผู้รับบริการที่จำเป็นต้องรู้	IoC จากเหตุจริงที่ส่งให้ รพ. ในจังหวัดใช้บล็อก
TLP:GREEN	ภายในชุมชน (เช่น เครือข่ายสาธารณสุขทั้งหมด) แต่ไม่เผยแพร่สาธารณะ	คำเตือนฟิชชิงที่กำลังระบาด บทเรียนจากเหตุที่ไม่ระบุชื่อหน่วยงาน
TLP:CLEAR	เผยแพร่สาธารณะได้	คู่มือ แนวปฏิบัติ ประกาศที่เผยแพร่แล้ว

กติกากลุ่มแชตประสานงานไซเบอร์ (แนะนำให้ปักหมุดไว้ในกลุ่ม)

1. สมาชิกต้องเป็นผู้รับผิดชอบที่ได้รับมอบหมาย ยืนยันตัวตนก่อนเพิ่ม และนำออกทันทีเมื่อย้ายงาน
2. ทุกข้อความที่เป็นข้อมูลภัยต้องขึ้นต้นด้วยป้าย TLP

3. **ห้ามส่ง** รหัสผ่าน ไฟล์ Config เต็ม ภาพหน้าจอที่มีข้อมูลผู้ป่วย หรือ IP ภายในพร้อมชื่อระบบ
4. เรื่องเหตุจริงระดับสูงให้ย้ายไปช่องทางที่จำกัดสมาชิก และใช้โทรศัพท์ยืนยัน
5. ตอบรับคำเตือนด้วยแบบรายงานกลับ ไม่ใช่แค่กดอีโมจิ
6. ไม่นำข้อความในกลุ่มไปเผยแพร่ต่อสาธารณะหรือสื่อมวลชน

24.9 มาตรฐานและแพลตฟอร์มแบ่งปันข้อมูล

ชื่อ	คืออะไร	ใช้อย่างไรในภาคสาธารณสุข
STIX 2.1 (OASIS)	รูปแบบข้อมูลมาตรฐานสำหรับ IoC, มัลแวร์, กลุ่มผู้โจมตี, ความสัมพันธ์	ให้ระบบต่าง ๆ อ่านข้อมูลเดียวกันได้โดยไม่ต้องแปลงเอง
TAXII 2.1 (OASIS)	โปรโตคอลส่งและรับข้อมูล STIX ผ่าน HTTPS	Firewall/SIEM ดึงข้อมูลภัยจากศูนย์กลางอัตโนมัติ
MISP	แพลตฟอร์มโอเพนซอร์สสำหรับแบ่งปันข้อมูลภัยคุกคาม	ตั้งเป็นศูนย์กลางระดับเขต/จังหวัด เชื่อมกับแพลตฟอร์มระดับชาติ
TCTI (สกมช.)	Thailand Cyber Threat Intelligence แพลตฟอร์มแบ่งปันข่าวกรองภัยระดับชาติ พัฒนาบน MISP	รับข้อมูลภัยระดับชาติ เชื่อมกับ SIEM/Firewall ได้ ThaiCERT แจ้งว่าใช้ได้โดยไม่มีค่าลิขสิทธิ์ซอฟต์แวร์ และเคยประกาศสนับสนุนภาคสาธารณสุขให้เชื่อมต่อในปี 2569
OpenCTI	แพลตฟอร์มโอเพนซอร์สจัดการข่าวกรองภัย เน้นความสัมพันธ์และ ATT&CK	ใช้วิเคราะห์เชิงลึกระดับเขต/กระทรวง
NCSA Blacklist SOC Dashboard	ระบบรวม Feed IP/โดเมนอันตรายสำหรับหน่วยบริการ (บทที่ 15)	ส่ง Feed ให้ Firewall, DNS และ Wazuh ทุก รพ.

> 💡 การเข้าร่วม TCTI ให้ติดต่อผ่านช่องทางทางการของ ThaiCERT (`thaicert.or.th`) โดยประสานผ่าน Health CERT หรือหน่วยงานต้นสังกัด เพื่อให้การเชื่อมต่อเป็นไปตามนโยบายของกระทรวง

ตัวอย่างข้อมูล STIX 2.1 (Indicator)

```json
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f",
  "created": "2026-11-03T09:00:00.000Z",
  "modified": "2026-11-03T09:00:00.000Z",
  "name": "IP ที่ใช้ล็อกอิน VPN โดยมิชอบ",
  "description": "พบล็อกอินสำเร็จด้วยบัญชีเจ้าหน้าที่ เวลา 02:13 ก่อนมีการ RDP ไปยังเซิร์ฟเวอร์สำรองข้อมูล",
  "indicator_types": ["malicious-activity"],
  "pattern": "[ipv4-addr:value = '203.0.113.45']",
  "pattern_type": "stix",
  "valid_from": "2026-11-03T09:00:00Z"
}
```

24.10 แบ่งปันอย่างปลอดภัยและถูกกฎหมาย

- **แบ่งปันข้อมูลทางเทคนิค ไม่แบ่งปันข้อมูลผู้ป่วย** ข้อมูลบ่งชี้ภัยส่วนใหญ่ (IP โดเมน แฮช พฤติกรรม) ไม่ใช่ข้อมูลส่วนบุคคลของผู้ป่วย แต่ Log ดิบมักมีชื่อผู้ใช้ เลขบัตร หรือ HN ปะปน ต้องตัดออกก่อนเสมอ
- **ใช้หลักน้อยที่สุดเท่าที่จำเป็น** ตาม PDPA ถ้าจำเป็นต้องส่งข้อมูลส่วนบุคคลให้หน่วยงานภายนอก เช่น ส่งตัวอย่างอีเมลฟิชชิงที่มีชื่อผู้รับ ให้ปรึกษา DPO และปิดบังส่วนที่ไม่จำเป็น
- **รายงานตามหน้าที่ CII** การรายงานเหตุต่อ สกมช. และหน่วยงานควบคุมกำกับดูแลเป็นหน้าที่ตาม พ.ร.บ.ไซเบอร์ (บทที่ 3) ไม่ใช่เรื่องเลือกทำ
- **สัญญากับ Vendor** กำหนดให้ผู้ให้บริการต้องแจ้งเหตุและช่องโหว่ที่กระทบหน่วยงานภายในเวลาที่ตกลง และรักษาความลับของข้อมูลที่ได้รับระหว่างช่วยแก้เหตุ
- **บันทึกการแบ่งปัน** เก็บว่าส่งอะไร ให้ใคร เมื่อใด ด้วยป้าย TLP ใด เพื่อใช้ตรวจสอบย้อนหลัง

24.11 W6: ระบบจัดการความรู้ (Knowledge Management)

ความรู้ด้านไซเบอร์ของโรงพยาบาลจำนวนมากอยู่ในหัวของคนไม่กี่คน เช่น วิธีตั้งค่า Firewall รหัสเข้าระบบสำคัญ หรือขั้นตอนกู้ HIS เมื่อคนนั้นย้ายงานหรือป่วยในวันที่เกิดเหตุ หน่วยงานจะเสียเวลามาก ระบบ KM ทำให้ **ความรู้ของบุคคลกลายเป็นความรู้ขององค์กร**



▲ ภาพที่ 24.5 วงจรจัดการความรู้ด้านไซเบอร์

SECI: เปลี่ยนความรู้ในหัวให้เป็นเอกสารที่ใช้ได้

โมเดล SECI ของ Nonaka และ Takeuchi อธิบายการเปลี่ยนรูปความรู้ 4 แบบ

ขั้น	ความหมาย	ตัวอย่างในงานไซเบอร์ของโรงพยาบาล
Socialization	แลกเปลี่ยนความรู้จากประสบการณ์ตรง	พี่เลี้ยงพาน้องใหม่ดู Wazuh ด้วยกัน, เล่าเหตุจริงในวง CoP
Externalization	เขียนความรู้ในหัวออกมาเป็นเอกสาร	เขียน Runbook กู้ระบบ HIS, บันทึกขั้นตอนตั้งค่า Firewall
Combination	รวมเอกสารหลายแหล่งเป็นชุดความรู้	รวม Playbook ของทุก รพ. ในจังหวัดเป็นคลังกลาง
Internalization	นำความรู้ไปฝึกจนทำได้เอง	ซ้อม Tabletop, ทำ Lab ตามคู่มือ

คลังความรู้ที่ควรมี

ประเภท	ตัวอย่าง	เจ้าของ	ทบทวน
แม่แบบนโยบายและคำสั่ง	นโยบายความมั่นคงปลอดภัย, คำสั่งแต่งตั้งทีม	สสจ.	ปีละครั้ง
Baseline การตั้งค่า	Hardening Windows/Linux, Firewall Policy มาตรฐาน	ทีมเทคนิคจังหวัด	ทุก 6 เดือน
Playbook และ Runbook	Ransomware, Data Breach, กู้ HIS, Downtime Procedure	แต่ละ รพ. + กลาง	หลังเหตุ/หลังซ้อม
กฎตรวจจับ	Wazuh local_rules.xml, คำค้น Threat Hunting	ทีม SOC/จังหวัด	ทุกไตรมาส
คลังกรณีศึกษา	เหตุจริงแบบไม่ระบุชื่อหน่วยงาน พร้อมบทเรียน	Health CERT/จังหวัด	ต่อเนื่อง
สื่ออบรม	สไลด์ คลิปสั้น แบบทดสอบ	งานพัฒนาบุคลากร	ปีละครั้ง

เครื่องมือ: ใช้ระบบที่หน่วยงานควบคุมได้ เช่น Wiki โอเพนซอร์ส (Wiki.js, BookStack) หรือไดรฟ์กลางที่แบ่งสิทธิ์ สำหรับไฟล์ Config และกฎตรวจจับให้ใช้ Git ส่วนตัวของหน่วยงาน (เช่น Gitea) เพื่อเก็บประวัติการแก้ไข และ **ห้ามเก็บรหัสผ่านในคลังความรู้** ให้ใช้ Password Vault (บทที่ 8)

แบบถอดบทเรียน (After Action Review)

คำถาม	ตัวอย่างคำตอบ
คาดว่าจะเกิดอะไร	Wazuh แจ้งเตือนภายใน 5 นาทีเมื่อมีการลบ Shadow Copy
เกิดอะไรจริง	แจ้งเตือนขึ้น แต่ส่งเข้าอีเมลที่ไม่มีใครเปิดตอนกลางคืน
ทำไมจึงต่างกัน	ไม่มีช่องทางแจ้งเตือนเวรนอกเวลา
อะไรที่ควรทำต่อ	การเก็บ Log และกฎตรวจจับทำงานดี
อะไรต้องปรับ	เพิ่มการแจ้งเตือนระดับ ≥ 12 ไปยังโทรศัพท์เวร ภายใน 30 วัน (ผู้รับผิดชอบ: หัวหน้า IT)

ชุมชนนักปฏิบัติ (Community of Practice)

- **ประชุมออนไลน์ระดับจังหวัดเดือนละ 1 ชั่วโมง**: 15 นาทีอัปเดตภัย, 20 นาทีเล่าเหตุหรือบทเรียน, 20 นาทีสาธิตเทคนิค, 5 นาทีสรุปงานที่ต้องทำ
- **วันแลกเปลี่ยนเรียนรู้ระดับเขตปีละครั้ง** พร้อมการแข่งขันจับผิดอีเมลฟิชชิงหรือ Lab สั้น ๆ
- **ระบบพี่เลี้ยง** จับคู่ รพท./รพศ. กับ รพช. และ รพช. กับ รพ.สต. ในอำเภอ
- **เพื่อนคู่เวร (Buddy)** ระหว่างโรงพยาบาลใกล้กัน เพื่อดูการแจ้งเตือนแทนกันในวันหยุด
- **ส่งมอบงานเมื่อย้ายตำแหน่ง** ใช้ Checklist: โอนบัญชีผู้ดูแล, อัปเดตเอกสาร, ส่งต่อรหัสผ่านผ่าน Vault, แจ้งเปลี่ยนผู้ติดต่อกับ Health CERT และ Vendor

24.12 Lab: ระบบเตือนช่องโหว่อัตโนมัติจาก CISA KEV เทียบกับทะเบียนทรัพย์สิน 🧪 LAB

ศูนย์ประสานจังหวัดสามารถตั้งสคริปต์ตรวจทุกเช้าว่า มีช่องโหว่ที่ถูกใช้โจมตีจริงรายการใหม่ใน **CISA KEV** ที่ตรงกับอุปกรณ์ในทะเบียนของจังหวัดหรือไม่ แล้วออกคำเตือนตามโฟลว์ W1 ได้ทันที

1) เตรียมทะเบียน `assets.csv` (ดึงจากทะเบียนทรัพย์สินบทที่ 7 เฉพาะอุปกรณ์และซอฟต์แวร์สำคัญ)

```
hospital,asset,vendor,product,version,owner
sw.ตัวอย่าง,Firewall หลัก,Fortinet,FortiOS,7.2,งาน IT
sw.ตัวอย่าง,VPN Gateway,Ivanti,Connect Secure,22.7,งาน IT
sw.สต.ตัวอย่าง,NAS สำรองข้อมูล,QNAP,QTS,5.1,ผู้รับผิดชอบ IT
รพช.ตัวอย่าง,ระบบไฟล์แชร์,Microsoft,Windows,Server 2019,งาน IT
```

2) สคริปต์ `kev_check.py`

```
#!/usr/bin/env python3
"""เทียบช่องโหว่ใหม่ใน CISA KEV กับทะเบียนทรัพย์สิน แล้วสรุปรายการที่ต้องเตือน"""
import csv, json, sys, urllib.request
from datetime import date, timedelta
```

```
KEV_URL = "https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json"
DAYS = int(sys.argv[1]) if len(sys.argv) > 1 else 30   # ดูรายการที่เพิ่มใน N วันล่าสุด

with urllib.request.urlopen(KEV_URL, timeout=60) as r:
    kev = json.load(r)["vulnerabilities"]
with open("assets.csv", encoding="utf-8-sig") as f:
    assets = list(csv.DictReader(f))

since = date.today() - timedelta(days=DAYS)
hits = []
for v in kev:
    if date.fromisoformat(v["dateAdded"]) < since:
        continue
    for a in assets:
        if not a["vendor"] or not a["product"]:
            continue
        if a["vendor"].lower() in v["vendorProject"].lower() and a["product"].lower() in
v["product"].lower():
            hits.append({"hospital": a["hospital"], "asset": a["asset"], "version": a["version"],
                         "cve": v["cveID"], "name": v["vulnerabilityName"],
                         "ransomware": v.get("knownRansomwareCampaignUse", ""),
                         "action": v["requiredAction"], "date_added": v["dateAdded"]})

fields = ["hospital", "asset", "version", "cve", "name", "ransomware", "action", "date_added"]
with open("kev_matches.csv", "w", newline="", encoding="utf-8-sig") as f:
    w = csv.DictWriter(f, fieldnames=fields)
    w.writeheader()
    w.writerows(hits)

print(f"KEV ใหม่ใน {DAYS} วัน ตรงกับทะเบียน {len(hits)} รายการ (บันทึกใน kev_matches.csv)")
for h in hits:
    print(f"- {h['hospital']} | {h['asset']} {h['version']} | {h['cve']} | Ransomware:
{h['ransomware']}")
```

3) ตั้งให้รันทุกเช้า บนเครื่อง Linux ของศูนย์ประสาน

```
mkdir -p /opt/kev && cp kev_check.py assets.csv /opt/kev/
crontab -e
# เพิ่มบรรทัดนี้: ตรวจ KEV ที่เพิ่มใน 2 วันล่าสุด ทุกวันเวลา 07:00
0 7 * * * cd /opt/kev && /usr/bin/python3 kev_check.py 2 >> kev.log 2>&1
```

4) นำผลไปใช้: ทุกรายการที่ตรงกันคือคำเตือนระดับ 🔴 วิกฤติ ตามตาราง 24.4 ให้ผู้ประสานตรวจรุ่นจริงกับ รพ. ที่เกี่ยวข้อง แล้วส่งคำเตือนตามแม่แบบ ถ้าต้องการส่งแจ้งเตือนอัตโนมัติ ให้ต่อกับระบบอีเมลของหน่วยงานหรือ LINE Messaging API

⚠️ **LINE Notify ยุติบริการแล้วเมื่อ 31 มี.ค. 2568** สคริปต์หรือคู่มือเก่าที่ส่งแจ้งเตือนผ่าน LINE Notify ต้องเปลี่ยนไปใช้ LINE Messaging API หรือช่องทางอื่น

💡 การจับคู่ด้วยชื่อผู้ผลิตและชื่อผลิตภัณฑ์เป็นการคัดกรองเบื้องต้น ผลที่ได้ต้องตรวจรุ่นและเงื่อนไขของช่องโหว่ด้วยคนอีกครั้งเสมอ นอกจาก KEV แล้ว ให้ติดตามประกาศของ สกมช./ThaiCERT และ Health CERT ด้วย เพราะอาจมีช่องโหว่ที่กระทบผลิตภัณฑ์ที่ใช้เฉพาะในประเทศไทย

📋 หลักฐาน: ทะเบียนคำเตือนพร้อมสถานะรายงานกลับของทุก รพ., ไฟล์ `kev_matches.csv` และ `kev.log` ใช้ประกอบ CTAM+ ข้อ 11 (VA Scan) และข้อ 13 (Software Patch)

⭐ สรุปท้ายบท

- การป้องกันร่วมทำให้เหตุที่เกิดกับโรงพยาบาลหนึ่งกลายเป็นภูมิคุ้มกันของทั้งเครือข่าย ถ้าข้อมูลถูกส่งต่อเร็วและถูกช่องทาง
- ใช้โฟลว์มาตรฐาน 6 แบบ กำหนดผู้รับผิดชอบด้วย RACI และกำหนดเวลาตอบรับให้ชัด
- แบ่งปันทั้ง IoC และพฤติกรรม (TTP) ติดป้าย TLP ทุกครั้ง และไม่แบ่งปันข้อมูลผู้ป่วย
- เชื่อมต่อแหล่งข้อมูลระดับชาติและสากล เช่น TCTI ของ สกมช., Health CERT และ CISA KEV
- ระบบจัดการความรู้และชุมชนนักปฏิบัติทำให้ความรู้ไม่หายไปเมื่อคนย้ายงาน

✏️ คำถามทบทวน

1. วาดผังเครือข่ายประสานงานด้านไซเบอร์ของจังหวัดท่าน ระบุช่องทางทางการของแต่ละหน่วยงาน
2. เขียนคำเตือนภัยตามแม่แบบในหัวข้อ 24.4 สำหรับช่องโหว่ Firewall ที่ถูกใช้โจมตีจริง
3. แยกข้อมูลต่อไปนี้ตามระดับ TLP ที่เหมาะสม: ผลสแกนช่องโหว่ของ รพ., อีเมลฟิชชิงที่กำลังระบาด, คู่มือตั้งค่า MFA
4. ทำไมการแบ่งปันพฤติกรรมของผู้โจมตีจึงมีค่ามากกว่าการแบ่งปันค่าแฮชไฟล์
5. ออกแบบการประชุม CoP ระดับจังหวัด 1 ครั้ง พร้อมหัวข้อและผู้รับผิดชอบ



ภาค 7 · รู้เขารู้เรา: ผู้โจมตี การประสานข้อมูล และเทคโนโลยีใหม่ บทที่ 25

เทคโนโลยีใหม่ที่ช่วยป้องกันการเจาะระบบ

เมื่ออ่านบทนี้จบ ผู้อ่านจะ

- ✔️ รู้จักเทคโนโลยีป้องกันยุคใหม่ และประเมินได้ว่าแบบใดเหมาะกับขนาดและกำลังคนของหน่วยงาน
- ✔️ วางแผน Zero Trust ตาม NIST SP 800-207, SP 1800-35 และ CISA Zero Trust Maturity Model 2.0
- ✔️ เลือกใช้ MFA ที่ต้านฟิชชิง, EDR/XDR/MDR, SOAR, Deception และการบริหารพื้นผิวการโจมตี
- ✔️ เตรียมรับมือภัยจาก AI และวางแผนเปลี่ยนผ่านสู่การเข้ารหัสหลังยุคควอนตัม

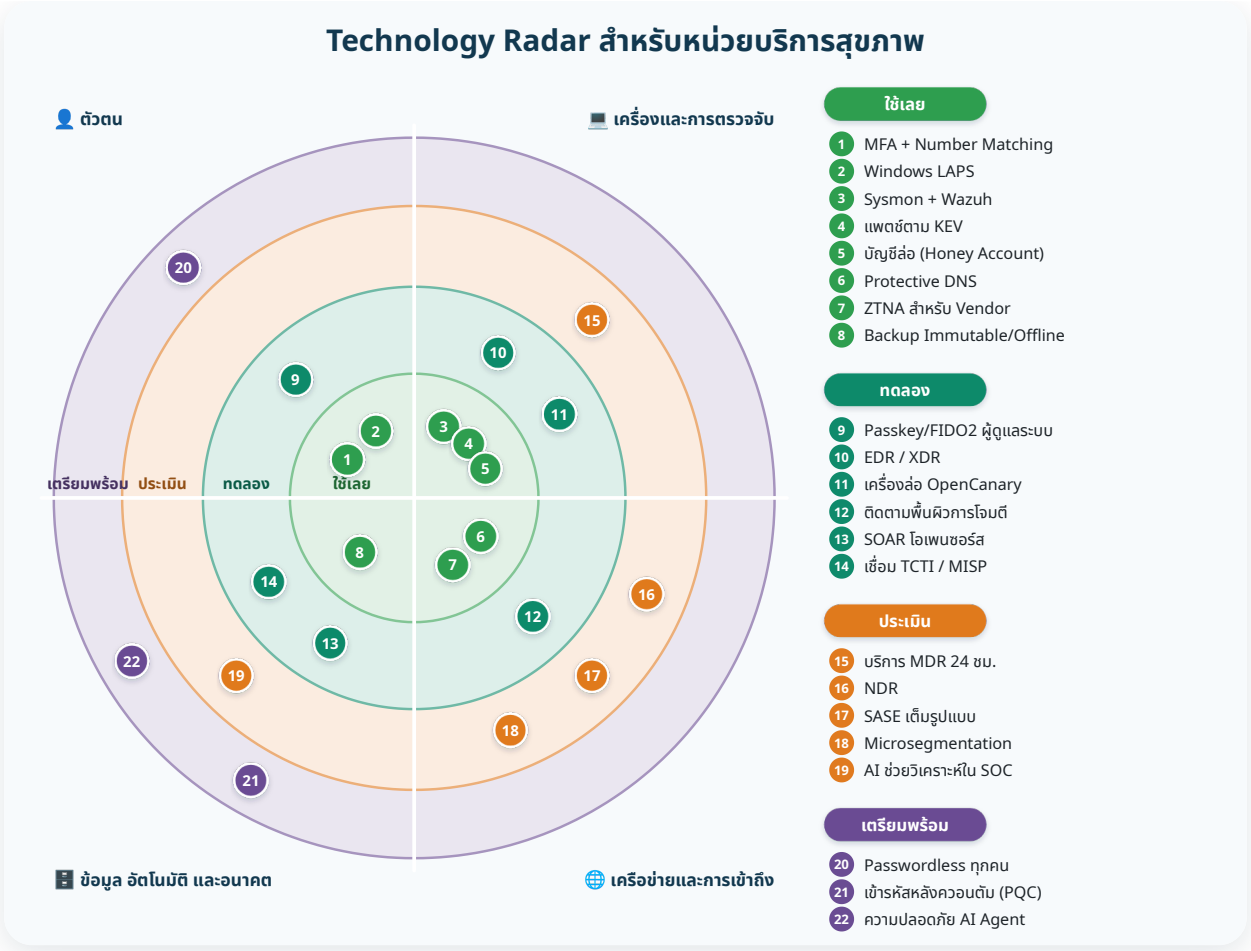
📋 เกณฑ์ที่เกี่ยวข้อง: CTAM+ ข้อ 2, 3, 4, 7, 9, 10, 14 / HPH CPGs (Enhanced) / CISA ZTMM 2.0 / NIST CSF 2.0 (PR, DE)

25.1 หลักเลือกเทคโนโลยี: พื้นฐานก่อน ของใหม่ทีหลัง

เทคโนโลยีใหม่ช่วยได้มาก แต่ **ไม่สามารถแทนพื้นฐาน** ได้ โรงพยาบาลที่ยังไม่มี MFA ยังไม่แพตช์ Firewall และไม่มี Backup Offline จะไม่ปลอดภัยขึ้นเพราะซื้อระบบ AI ราคาแพง ให้ทำ CTAM+ 17 ข้อ (บทที่ 6) ให้ครบก่อน แล้วจึงเลือกเทคโนโลยีในบทนี้มาเสริมจุดที่ยังอ่อน

คำถาม 6 ข้อก่อนลงทุน

1. เทคโนโลยีนี้แก้ปัญหาใด และปัญหานั้นอยู่ในความเสี่ยงสูงสุด 5 อันดับแรกของเรา (บทที่ 7) หรือไม่
2. **ใครจะดูแลและดูการแจ้งเตือน** ทุกวัน รวมถึงวันหยุด ถ้าไม่มีคน ควรพิจารณาบริการแบบ Managed
3. ค่าใช้จ่ายต่อปีเท่าไร (หลายระบบเป็นค่าสมาชิกรายปี ไม่ใช่ซื้อครั้งเดียว)
4. เชื่อมกับ Wazuh, Firewall และระบบที่มีอยู่ได้หรือไม่
5. ข้อมูลถูกส่งไปเก็บที่ใด (หลายระบบส่ง Telemetry ไปต่างประเทศ) ต้องทำสัญญาประมวลผลข้อมูลตาม PDPA หรือไม่
6. กระทบเครื่องมือแพทย์หรือระบบที่ผู้ผลิตห้ามติดตั้งซอฟต์แวร์เพิ่มหรือไม่ (บทที่ 22)



▲ ภาพที่ 25.1 Technology Radar สำหรับหน่วยบริการสุขภาพไทย

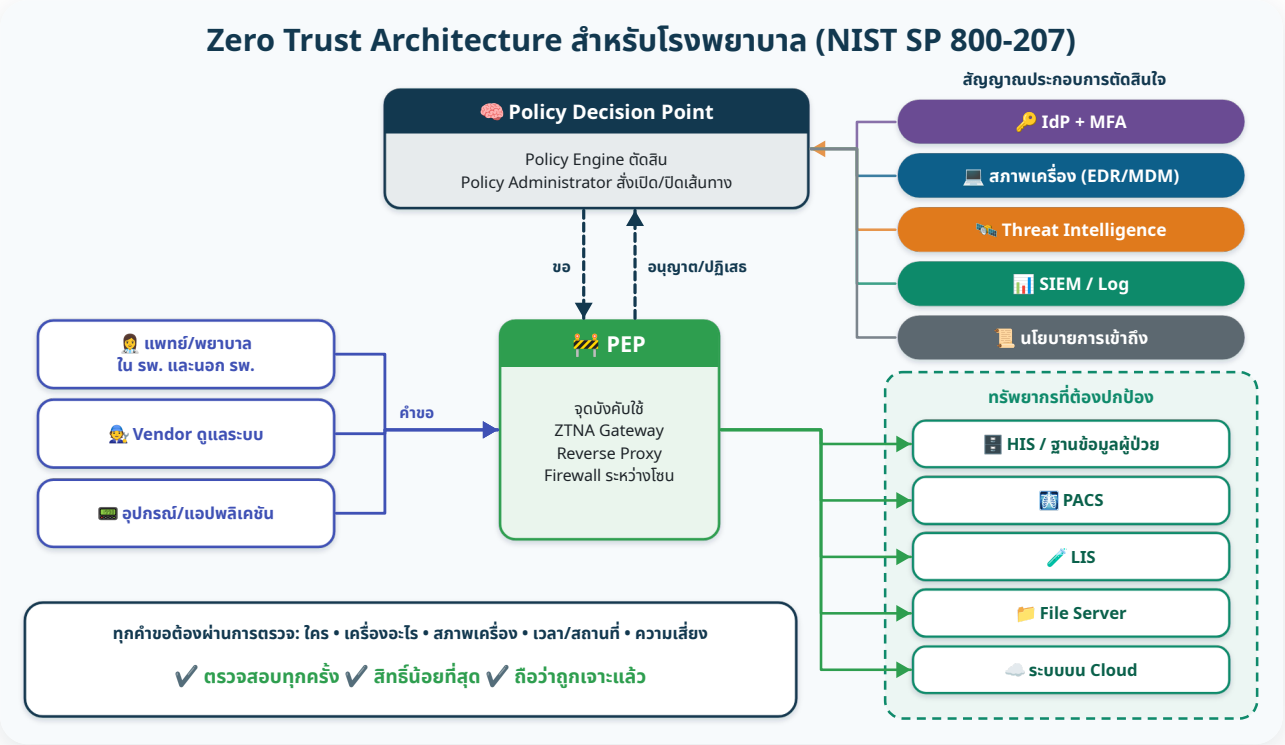
วง	ความหมาย	ตัวอย่าง
ใช้เลย	คุ้มค่า พิสูจน์แล้ว ทำได้ด้วยงบน้อย	MFA + Number Matching, Windows LAPS, Sysmon + Wazuh, Backup Immutable/Offline, Protective DNS, บัญชีล่อ (Honey Account), แพตช์ตาม KEV, ZTNA สำหรับ Vendor
ทดลอง	เริ่มใช้ในระบบสำคัญก่อน แล้วขยาย	EDR/XDR, Passkey/FIDO2 สำหรับผู้ดูแลระบบ, SOAR โอเพนซอร์ส, เครื่องล่อ OpenCanary, ติดตามพื้นผิวการโจมตี, เชื่อม TCTI/MISP
ประเมิน	ศึกษาความคุ้มค่าและความพร้อม	บริการ MDR, NDR, AI ช่วยวิเคราะห์ใน SOC, SASE เต็มรูปแบบ, Microsegmentation, BAS
เตรียมพร้อม	ยังไม่เร่งด่วน แต่ต้องเริ่มวางแผน	การเข้ารหัสหลังยุคควอนตัม (PQC), ความปลอดภัยของ AI Agent, Passwordless สำหรับบุคลากรทุกคน

25.2 Zero Trust Architecture แบบลงมือทำ

บทที่ 2 อธิบายหลักการ Zero Trust (Verify explicitly, Least privilege, Assume breach) หัวข้อนี้ลงรายละเอียดว่าจะสร้างจริงอย่างไร

องค์ประกอบตาม NIST SP 800-207

- **Policy Decision Point (PDP)** ประกอบด้วย Policy Engine ที่ตัดสินว่า “คำขอนี้ควรอนุญาตหรือไม่” และ Policy Administrator ที่สั่งเปิดหรือปิดเส้นทาง
- **Policy Enforcement Point (PEP)** จุดบังคับใช้ที่ยืนอยู่หน้าทรัพยากร เช่น ZTNA Gateway, Reverse Proxy ที่ตรวจตัวตน หรือ Firewall ระหว่างโซน
- **แหล่งสัญญาณ** ที่ PDP ใช้ตัดสิน เช่น ระบบยืนยันตัวตน (IdP) และ MFA, สภาพเครื่อง (อัปเดตแล้วหรือยัง มี EDR หรือไม่), ข้อมูลภัยคุกคาม, Log จาก SIEM และนโยบายการเข้าถึง



▲ ภาพที่ 25.2 Zero Trust Architecture สำหรับโรงพยาบาล

📌 **NIST SP 1800-35** (Implementing a Zero Trust Architecture) ฉบับสมบูรณ์เผยแพร่เมื่อ มิ.ย. 2568 เป็นคู่มือปฏิบัติจากศูนย์ NCCoE ที่สร้างตัวอย่างระบบจริงร่วมกับผู้ผลิตหลายราย (รายงานว่ามี 19 ตัวอย่างจากผู้ร่วมพัฒนา 24 ราย) ใช้คู่กับ SP 800-207 ซึ่งเป็นกรอบแนวคิด

CISA Zero Trust Maturity Model 2.0

CISA (เม.ย. 2566) แบ่ง Zero Trust เป็น **5 เสาหลัก** (Identity, Devices, Networks, Applications & Workloads, Data) และ **3 ความสามารถร่วม** (Visibility & Analytics, Automation & Orchestration, Governance) แต่ละเสามี 4 ระดับ คือ Traditional, Initial, Advanced และ Optimal

เสาหลัก	Traditional (เริ่มต้น)	Initial	Advanced	Optimal
Identity	รหัสผ่านอย่างเดียว บัญชีแชร์	MFA บน VPN/อีเมล	MFA ทุกระบบ, SSO, ทบทวนสิทธิ์อัตโนมัติ	MFA ต้านฟิชชิง, ประเมินความเสี่ยงทุกครั้งที่เข้าถึง
Devices	ไม่รู้ว่ามีเครื่องอะไร	ทะเบียนทรัพย์สิน, AV ทุกเครื่อง	EDR, ตรวจสภาพเครื่องก่อนให้เข้า HIS	เครื่องที่ไม่ผ่านถูกจำกัดสิทธิ์อัตโนมัติ
Networks	เครือข่ายแบน ทุกเครื่องคุยกันได้	แยก VLAN หลัก	Firewall ระหว่างโซน, ZTNA แทน VPN	Microsegmentation ระดับแอปพลิเคชัน
Applications	เปิดพอร์ตตรงสู่อินเทอร์เน็ต	Reverse Proxy + WAF	เข้าแอปผ่าน ZTNA พร้อมตรวจตัวตน	อนุญาตทีละคำขอตามบริบท
Data	ไม่รู้ว่าข้อมูลอ่อนไหวอยู่ที่ไหน	จัดชั้นข้อมูล, เข้ารหัส Backup	เข้ารหัสฐานข้อมูล, DLP เบื้องต้น	ควบคุมสิทธิ์ระดับข้อมูลและติดตามการใช้

เส้นทาง 3 ระยะสำหรับโรงพยาบาล

1. **ระยะ 1 (0–6 เดือน)**: MFA ทุกบัญชีจากภายนอกและบัญชีผู้ดูแล, ทะเบียนทรัพย์สิน, แยก VLAN, เลิกเปิดพอร์ตตรง (Cloudflare Tunnel/Reverse Proxy บทที่ 9)
2. **ระยะ 2 (6–18 เดือน)**: SSO สำหรับระบบหลัก, EDR บนเซิร์ฟเวอร์, ZTNA สำหรับ Vendor และผู้ทำงานจากภายนอก, Firewall ระหว่างโซนแบบ Deny All
3. **ระยะ 3 (18–36 เดือน)**: ตรวจสภาพเครื่องก่อนเข้า HIS, MFA ต้านฟิชชิงสำหรับผู้ดูแลระบบ, Microsegmentation ของเซิร์ฟเวอร์ข้อมูลผู้ป่วย, การตอบสนองอัตโนมัติ

25.3 MFA ที่ต้านฟิชชิง: Passkey และ FIDO2

งานวิจัยของ Microsoft (2566) พบว่า MFA ลดความเสี่ยงที่บัญชีจะถูกยึดได้ประมาณ **99.22%** แต่ MFA ไม่ได้แข็งแรงเท่ากันทุกแบบ ผู้โจมตีมีวิธีเลี่ยง MFA แบบเดิม เช่น หน้าเว็บตัวกลางที่ดักทั้งรหัสผ่านและรหัส OTP แบบเรียลไทม์ (Adversary-in-the-Middle) หรือส่งคำขอ Push ซ้ำ ๆ จนผู้ใช้กดอนุมัติเพราะรำคาญ (MFA Fatigue)

ชนิด MFA	ต้านฟิชชิง	ข้อสังเกต
SMS / โทรศัพท์	ต่ำ	ถูกสลับซิม (SIM Swap) หรือหลอกถามรหัสได้ ใช้เมื่อไม่มีทางเลือกอื่น
OTP จากแอป (TOTP)	ปานกลาง	ดีกว่า SMS มาก แต่ยังถูกหน้าเว็บตัวกลางดักได้
Push แบบกดอนุมัติ	ปานกลาง	ต้องเปิด **Number Matching** (พิมพ์ตัวเลขที่แสดงบนจอ) เพื่อลด MFA Fatigue
FIDO2 / WebAuthn / Passkey	**สูง**	ผูกกับโดเมนจริง หน้าเว็บปลอมจึงใช้ไม่ได้ ใช้ได้ทั้งกุญแจฮาร์ดแวร์และ Passkey บนโทรศัพท์/คอมพิวเตอร์
สมาร์ตการ์ด/ใบรับรอง (PKI)	สูง	เหมาะกับองค์กรที่มีระบบบัตรอยู่แล้ว

แนวทางในโรงพยาบาล (สอดคล้องคำแนะนำ Implementing Phishing-Resistant MFA ของ CISA)

- **ผู้ดูแลระบบ ผู้ดูแลโดเมน และบัญชี Cloud Admin** ใช้กุญแจ FIDO2 แบบฮาร์ดแวร์ คนละ 2 อัน (ใช้งาน + สำรอง)
- **ผู้บริหารและงานการเงิน** ที่เป็นเป้าของ BEC ใช้ Passkey หรือ FIDO2
- **บุคลากรทั่วไป** อย่างน้อยใช้แอป Authenticator พร้อม Number Matching
- **เครื่องที่ใช้ร่วมกันในหอผู้ป่วย/ห้องตรวจ** พิจารณาบัตรพนักงานแบบแตะ (Tap-and-go) เชื่อม SSO เพื่อให้สลับผู้ใช้เร็วโดยไม่ลดความปลอดภัย และไม่ทำให้บุคลากรเลี่ยงไปแชร์บัญชี

25.4 EDR, XDR, NDR และ MDR: จากแอนติไวรัสสู่การตรวจจับพฤติกรรม

รายงานปี 2569 ระบุว่าการตรวจพบส่วนใหญ่ไม่มีไฟล์มัลแวร์เลย และผู้โจมตีใช้เวลาเฉลี่ยไม่ถึงครึ่งชั่วโมงก่อนเคลื่อนที่ข้ามเครื่อง (บทที่ 23) แอนติไวรัสแบบเดิมที่ตรวจลายเซ็นไฟล์จึงไม่พอ



▲ ภาพที่ 25.3 ชั้นของการตรวจจับและตอบสนอง จาก EDR ถึง MDR

เทคโนโลยี	ทำอะไร	ตัวอย่างการใช้ในโรงพยาบาล	ทางเลือก
EDR (Endpoint Detection & Response)	บันทึกพฤติกรรมบนเครื่อง ตรวจจับ และสั่งแยกเครื่องออกจากเครือข่ายได้	หยุดโปรเซสที่กำลังเข้ารหัสไฟล์บน File Server	Microsoft Defender for Endpoint/Business, EDR เชิงพาณิชย์, Wazuh + Sysmon (ความสามารถบางส่วน)
NDR (Network Detection & Response)	วิเคราะห์ทราฟฟิกเครือข่าย เห็นสิ่งที่ลง Agent ไม่ได้	เห็นเครื่องมือแพทย์คุยกับ IP แปลก, การสแกนภายใน	Suricata, Zeek, Security Onion (โอเพนซอร์ส)
SIEM	รวม Log ทุกแหล่ง ค้นหา และแจ้งเตือน	Wazuh ระดับ รพ./จังหวัด (บทที่ 14)	Wazuh, Elastic, Graylog
XDR (Extended Detection & Response)	รวมข้อมูล EDR, อีเมล, ตัวตน, เครือข่าย และ Cloud มาวิเคราะห์ร่วมกัน	เชื่อมเหตุ “อีเมลฟิชชิง → ล็อกอินแปลก → โปรเซสอันตราย” เป็นเหตุเดียว	ชุด XDR ของผู้ผลิต, Wazuh ร่วมกับ EDR
MDR (Managed Detection & Response)	บริการจากผู้เชี่ยวชาญภายนอกเฝ้าระวังและตอบสนอง 24 ชม.	เหมาะกับ รพ. ที่มี IT 1–2 คน หรือจัดซื้อร่วมระดับเขต	ผู้ให้บริการ MDR/SOC, CSOC ที่กระทรวงจัดหา (ถ้ามี)
Velociraptor / osquery	เครื่องมือโอเพนซอร์สสำหรับสืบสวนและล่าภัยบนเครื่องจำนวนมากพร้อมกัน	ค้นหาไฟล์หรือโปรเซสต้องสงสัยทุกเครื่องในจังหวัดภายในไม่กี่นาที	ใช้คู่กับ Wazuh

⚠️ **ข้อควรระวัง**: (1) EDR ที่ตั้งให้แยกเครื่องอัตโนมัติ อาจตัดเซิร์ฟเวอร์ HIS ระหว่างให้บริการ ให้กำหนดรายการเครื่องที่ต้องให้คนอนุมัติก่อน (2) อย่าติดตั้ง EDR บนเครื่องมือแพทย์โดยไม่ได้รับความเห็นชอบจากผู้ผลิต (3) เปิด Tamper Protection เพื่อไม่ให้ผู้โจมตีปิด EDR ได้ (4) รายงาน Sophos ปี 2568 พบว่าการ **ขาดคนเฝ้าระวัง** เป็นปัจจัยองค์กรที่พบบ่อยที่สุดในเหตุ Ransomware ของภาคสุขภาพ เครื่องมือดีแค่ไหนก็ต้องมีคนดู

25.5 SOAR และระบบอัตโนมัติ

SOAR (Security Orchestration, Automation and Response) คือการเขียน “สูตรการทำงาน” ให้ระบบทำงานซ้ำ ๆ แทนคน เช่น ตรวจชื่อเสียงของ IP เปิดเคส แจ้งผู้รับผิดชอบ และบล็อกอัตโนมัติ ช่วยให้ทีมเล็กรับมือการแจ้งเตือนจำนวนมากได้

สูตรตัวอย่าง	ขั้นตอนอัตโนมัติ	จุดที่ให้คนตัดสินใจ
เดารหัสผ่านจาก IP ภายนอก	Wazuh แจ้งเตือน → ตรวจ IP กับ Feed (บทที่ 15) → บล็อกบน Firewall 24 ชม. → เปิดเคส	ปลดบล็อกถ้าเป็น IP คู่ค้า
ผู้ใช้รายงานอีเมลฟิชชิง	ดึง URL/ไฟล์แนบ → ตรวจชื่อเสียง → ค้นว่าใครได้รับอีเมลเดียวกัน → บล็อกโดเมนบน DNS	ลบอีเมลออกจากทุกกล่อง
บัญชีล่อถูกใช้	แจ้งเตือนระดับวิกฤติ → ปิดบัญชีที่ใช้จากเครื่องต้นทาง → เก็บ Log เครื่องต้นทาง	แยกเครื่องต้นทางออกจากเครือข่าย
ช่องโหว่ KEV ใหม่ตรงทะเบียน	สคริปต์หัวข้อ 24.12 → สร้างคำเตือน → ส่งผู้รับผิดชอบ	ยืนยันรุ่นจริงก่อนส่ง

เครื่องมือโอเพนซอร์สที่ใช้ได้ เช่น **Shuffle** (SOAR), **TheHive + Cortex** (จัดการเคสและวิเคราะห์อัตโนมัติ) และ Active Response ของ Wazuh (หัวข้อ 14.7) เริ่มจากงานที่ทำซ้ำบ่อยและผลผิดพลาดไม่ร้ายแรงก่อน ส่วนการกระทำที่กระทบบริการผู้ป่วยต้องมีคนอนุมัติเสมอ (Human-in-the-loop)

25.6 SASE, SSE และ ZTNA: เลิกเปิด VPN ให้ทุกคน

- **ZTNA** (Zero Trust Network Access) ให้ผู้ใช้เข้าถึง “เฉพาะแอปที่ได้รับอนุญาต” หลังตรวจตัวตนและสภาพเครื่อง ต่างจาก VPN ที่เมื่อเข้าได้แล้วมักเห็นทั้งเครือข่าย เหมาะมากสำหรับ **Vendor ที่ต้องรีโมตมาดูแล HIS/PACS** และแพทย์ที่อ่านภาพจากนอกโรงพยาบาล
- **SSE** (Security Service Edge) รวม ZTNA, Secure Web Gateway (กรองเว็บ), CASB (ควบคุมการใช้ Cloud) ไว้ในบริการ Cloud เดียว
- **SASE** (Secure Access Service Edge) คือ SSE รวมกับระบบเครือข่าย WAN (SD-WAN) เหมาะกับเครือข่ายหลายสาขา เช่น รพ. กับ รพ.สต. ทั้งอำเภอ

เริ่มต้นแบบงบน้อย: ใช้ Cloudflare Tunnel/Access ที่แนะนำในบทที่ 9 (มีแผนใช้ฟรีสำหรับผู้ใช้จำนวนจำกัด ตรวจเงื่อนไขล่าสุด) หรือ Reverse Proxy ที่ตรวจตัวตนก่อนส่งต่อ แล้วค่อยขยายเป็น SSE เต็มรูปแบบ อย่าลืมประเมินว่าข้อมูลผ่านผู้ให้บริการต่างประเทศ และทำข้อตกลงการประมวลผลข้อมูลตาม PDPA

25.7 Deception: วางกับดักให้ผู้บุกรุกเผยตัว

แนวคิดคือ **สร้างสิ่งที่ไม่มีใครในองค์กรควรแตะ** ถ้ามีคนแตะ แสดงว่าเป็นผู้บุกรุกหรือการกระทำผิดปกติเกือบแน่นอน จึงเป็นการแจ้งเตือนที่แม่นยำสูงมาก (False Positive ต่ำ) และทำได้ด้วยงบเกือบเป็นศูนย์

กับดัก	วิธีทำ	สัญญาณเมื่อถูกแตะ
บัญชีล่อ (Honey Account)	สร้างบัญชีชื่อน่าสนใจ เช่น `adm_his_backup` ไม่ใช้งานจริง ตั้งรหัสยาวมาก	มีการล็อกอินหรือลองล็อกอินด้วยบัญชีนี้
ไฟล์ล่อ (Honey File)	วางไฟล์ชื่อน่าสนใจบน File Server เช่น “รหัสผ่านระบบ HIS.xlsx” (ไม่มีข้อมูลจริง) แล้วเปิด Audit การเปิดไฟล์	มีการเปิดหรือคัดลอกไฟล์
เครื่องล่อ (Honeypot)	ใช้ **OpenCanary** (โอเพนซอร์สของ Thinkst) จำลองบริการ SMB, RDP, SSH, MSSQL บน VM เล็ก ๆ ในแต่ละ VLAN	มีการเชื่อมต่อเครื่องนี้ ซึ่งไม่มีใครควรเชื่อมต่อ
ระเบียนล่อในฐานข้อมูล	เพิ่มระเบียนผู้ป่วยสมมติที่ไม่มีอยู่จริงในตารางสำคัญ	ระเบียนนี้ถูกค้นหรือถูกส่งออก (พบในข้อมูลที่รั่ว)
โทเคนล่อ (Canary Token)	ลิงก์หรือเอกสารที่ส่งสัญญาณกลับเมื่อถูกเปิด	เอกสารถูกเปิดนอกองค์กร

กฎ Wazuh สำหรับบัญชีล่อ

```
<group name="local,deception,">
  <rule id="100320" level="15">
    <if_group>authentication_success</if_group>
    <field name="win.eventdata.targetUserName" type="pcre2">(?i)^adm_his_backup$</field>
    <description>บัญชีล่อถูกใช้ล็อกอินสำเร็จ: สงสัยผู้บุกรุกในระบบ</description>
    <mitre><id>T1078</id></mitre>
  </rule>
  <rule id="100321" level="12">
    <if_group>authentication_failed</if_group>
    <field name="win.eventdata.targetUserName" type="pcre2">(?i)^adm_his_backup$</field>
    <description>มีการลองล็อกอินด้วยบัญชีล่อ</description>
    <mitre><id>T1110</id></mitre>
  </rule>
</group>
```

เครื่องล่อด้วย OpenCanary (บน Ubuntu VM เล็ก ๆ)

```
sudo apt install -y python3-dev python3-pip python3-virtualenv python3-venv python3-scapy libssl-dev
libpcap-dev
virtualenv env/ && . env/bin/activate
pip install opencanary
opencanaryd --copyconfig          # สร้าง /etc/opencanaryd/opencanary.conf
# แก้ไฟล์ conf: เปิดบริการที่ต้องการ เช่น "smb.enabled": true, "rdp.enabled": true
opencanaryd --start
```

ให้ Wazuh Agent บนเครื่องล่ออ่าน Log แบบ JSON แล้วสร้างกฎแจ้งเตือน

```
<!-- ossec.conf ของ Agent บนเครื่องล่อ -->
<localfile>
```

```
  <log_format>json</log_format>
  <location>/var/tmp/opencanary.log</location>
</localfile>

<!-- local_rules.xml ที่ Manager -->
<group name="local,deception,">
  <rule id="100330" level="13">
    <decoded_as>json</decoded_as>
    <field name="src_host">\d+\.\d+\.\d+\.\d+</field>
    <field name="dst_port">^\d+$</field>
    <description>มีการเชื่อมต่อเครื่องล่อจาก $(src_host) พอร์ต $(dst_port)</description>
  </rule>
</group>
```



ตำแหน่ง Log และชื่อฟิลด์ขึ้นกับเวอร์ชันและการตั้งค่า OpenCanary ให้ตรวจจาก Log จริงก่อน และ **อย่าให้เครื่องล่อเข้าถึงอินเทอร์เน็ตหรือมีข้อมูลจริง** ส่วน Canary Token จากบริการภายนอกจะส่งข้อมูลการเปิดเอกสารออกไปยังผู้ให้บริการ ให้พิจารณาเรื่องความเป็นส่วนตัวก่อนใช้

25.8 บริหารพื้นผิวการโจมตีอย่างต่อเนื่อง (ASM และ CTEM)

ผู้โจมตีสแกนอินเทอร์เน็ตทุกวัน เราจึงต้อง **มองตัวเองจากภายนอกให้บ่อยกว่าผู้โจมตี**

- **External Attack Surface Management (EASM)**: รายการทุกสิ่งที่เปิดสู่อินเทอร์เน็ต ได้แก่ IP, โดเมนย่อย, พอร์ต, ใบรับรอง และหน้า Login
  - สแกนพอร์ต IP สาธารณะของตนเองทุกสัปดาห์ (บทที่ 16) แล้วเทียบกับรายการที่อนุญาต
  - ติดตามโดเมนย่อยใหม่จาก Certificate Transparency (เช่น ค้นใน crt.sh) เพื่อพบระบบที่ตั้งขึ้นโดยไม่แจ้งงาน IT
  - ใช้บริการแจ้งเตือนเมื่อ IP ของหน่วยงานเปิดบริการใหม่ (เช่น Shodan Monitor) หรือรับรายงานจาก สกมช. ที่สแกนพบ
- **CTEM** (Continuous Threat Exposure Management) เป็นแนวคิดของ Gartner ทำเป็นวงรอบ 5 ขั้น: กำหนดขอบเขต → ค้นหา → จัดลำดับความสำคัญ → ตรวจยืนยัน → ลงมือแก้ ต่างจาก VA Scan ปีละครั้ง ตรงที่ทำต่อเนื่องและเน้นสิ่งที่ผู้โจมตีใช้ได้จริง
- **Breach and Attack Simulation (BAS)**: ระบบจำลองการโจมตีอัตโนมัติเพื่อตรวจว่ามาตรการป้องกันทำงานจริง (แนวคิดเดียวกับ Purple Team หัวข้อ 23.10)

25.9 AI: ดาบสองคม

AI ช่วยฝ่ายป้องกัน

- สรุปและจัดลำดับการแจ้งเตือนจำนวนมากใน SOC ช่วยให้ทีมเล็กทำงานได้เร็วขึ้น
- ตรวจจับพฤติกรรมผิดปกติของผู้ใช้และเครื่อง (UEBA) เช่น การเปิดเวชระเบียนจำนวนมากผิดปกติ

- ช่วยเขียนและอธิบายกฎตรวจจับ คำค้น และสคริปต์ (ต้องตรวจโดยคนทุกครั้ง)

> ⚠️ **ห้ามนำ Log ดิบ ข้อมูลผู้ป่วย หรือ Config ที่มีรหัสผ่าน ไปวางในบริการ AI สาธารณะ** ให้ใช้บริการ AI ที่หน่วยงานอนุมัติ มีสัญญาคุ้มครองข้อมูล และตัดข้อมูลอ่อนไหวออกก่อนเสมอ คำตอบของ AI อาจผิดได้ (Hallucination) จึงใช้เป็นผู้ช่วย ไม่ใช่ผู้ตัดสินใจ

AI ช่วยฝ่ายโจมตี

- **อีเมลฟิชชิงภาษาไทยที่แนบเนียน** ไม่มีคำผิดให้จับได้อีกต่อไป
- **เสียงและวิดีโอปลอม (Deepfake)** ของผู้อำนวยการหรือแพทย์ เพื่อสั่งโอนเงินหรือขอข้อมูล กรณีที่สื่อรายงานอย่างกว้างขวางคือบริษัทข้ามชาติในฮ่องกงที่พนักงานโอนเงินราว 25 ล้านดอลลาร์สหรัฐ (ต้นปี 2567) หลังประชุมวิดีโอกับ “ผู้บริหาร” ที่สร้างด้วย Deepfake
- รายงาน CrowdStrike 2026 ระบุว่าปฏิบัติการของผู้โจมตีที่ใช้ AI เพิ่มขึ้นราว 89% และรายงานของ Health-ISAC ปี 2026 พบว่าผู้ทำงานด้านความปลอดภัยในภาคสุขภาพจัดให้ **การโจมตีที่ใช้ AI** เป็นความกังวลอันดับ 1
- ATT&CK v20 (ต.ค. 2569) เพิ่มเทคนิคที่โจมตีระบบ AI โดยตรง เช่น **Prompt Injection** ทั้งแบบตรงและแบบแฝงในเนื้อหาภายนอก

มาตรการรับมือ Deepfake และ AI Phishing

1. กำหนดว่า **คำสั่งโอนเงิน เปลี่ยนบัญชีรับเงิน หรือขอข้อมูลผู้ป่วยจำนวนมาก ต้องยืนยันผ่านช่องทางที่สอง** เช่น โทรกลับเบอร์ในทะเบียน หรือยืนยันต่อหน้า
2. ใช้ “คำรหัสยืนยัน” ระหว่างผู้บริหารกับงานการเงินสำหรับกรณีเร่งด่วน
3. ปรับหลักสูตรอบรม (บทที่ 18) ให้รวมตัวอย่างเสียงและวิดีโอปลอม และเน้นว่า “ความเร่งด่วนผิดปกติ” คือสัญญาณเตือน
4. ใช้ DMARC (บทที่ 21) และ MFA ต้านฟิชชิง เพื่อให้แม้หลอกได้ ก็ยึดบัญชีไม่ได้

ถ้าโรงพยาบาลนำ AI มาใช้เอง (เช่น แชตบอตตอบผู้ป่วย)

ใช้ **OWASP Top 10 for LLM Applications 2025** เป็นเช็กลิสต์ ความเสี่ยงสำคัญ ได้แก่ Prompt Injection, การเปิดเผยข้อมูลอ่อนไหว, การให้สิทธิ์ AI มากเกินไป (Excessive Agency) และการรั่วของ System Prompt

หลักการ	ตัวอย่างการปฏิบัติ
สิทธิ์น้อยที่สุด	แชตบอตเรียก API ที่คืนข้อมูลของผู้ป่วยที่ยืนยันตัวตนแล้วเท่านั้น ไม่ต่อฐานข้อมูล HIS ตรง
แยกเนื้อหาภายนอก	เอกสารหรือเว็บที่ AI อ่าน ต้องไม่ถูกตีความเป็นคำสั่ง
คนอนุมัติการกระทำ	AI เสนอการนัดหมายหรือเปลี่ยนข้อมูลได้ แต่ระบบหรือเจ้าหน้าที่ต้องยืนยัน
บันทึกและทดสอบ	เก็บ Log การสนทนาตามนโยบาย PDPA และทดสอบ Prompt Injection ก่อนเปิดใช้

25.10 การเข้ารหัสหลังยุคควอนตัม (Post-Quantum Cryptography)

คอมพิวเตอร์ควอนตัมที่มีขนาดเพียงพอในอนาคตจะถอดรหัสแบบกุญแจสาธารณะที่ใช้ทุกวันนี้ (RSA, ECC) ได้ ภัยที่เกิดแล้วตั้งแต่วันนี้คือ **"เก็บไว้ก่อน ถอดรหัสทีหลัง" (Harvest Now, Decrypt Later)** ผู้โจมตีดักเก็บข้อมูลที่เข้ารหัสไว้รอวันถอดได้ ข้อมูลสุขภาพมีอายุความสำคัญยาวหลายสิบปี จึงเป็นกลุ่มที่ควรเริ่มเตรียมก่อน

เหตุการณ์	รายละเอียด
ส.ค. 2567	NIST ประกาศมาตรฐาน **FIPS 203 (ML-KEM)** สำหรับแลกเปลี่ยนกุญแจ, **FIPS 204 (ML-DSA)** และ **FIPS 205 (SLH-DSA)** สำหรับลายมือชื่อดิจิทัล
ปลายปี 2567–2568	เบราว์เซอร์หลัก ผู้ให้บริการ CDN และซอฟต์แวร์พื้นฐาน เช่น OpenSSL และ OpenSSH เริ่มรองรับหรือเปิดใช้การแลกเปลี่ยนกุญแจแบบผสม (Hybrid) ที่มี ML-KEM
มี.ค. 2568	NIST เลือก **HQC** เป็นอัลกอริทึมสำรองสำหรับแลกเปลี่ยนกุญแจ
ต.ค. 2569	สื่อเฉพาะทางรายงานว่า NIST เผยแพร่ **IR 8547** ฉบับสมบูรณ์ คงกรอบเวลา **เลิกแนะนำ (Deprecate) อัลกอริทึมที่เสี่ยงต่อควอนตัมหลังปี 2030 และห้ามใช้ (Disallow) หลังปี 2035** (ตรวจตัวเอกสารที่ csrc.nist.gov)

สิ่งที่โรงพยาบาลทำได้ตั้งแต่วันนี้

1. **สำรวจการเข้ารหัส (Crypto Inventory)**: ระบบใดใช้ใบรับรอง RSA/ECC บ้าง เช่น เว็บ HTTPS, VPN, การเชื่อมต่อ HIS กับฐานข้อมูล, ลายมือชื่อดิจิทัลบนเอกสาร
2. **ถามผู้ขายและผู้พัฒนา** ว่ามีแผนรองรับ PQC เมื่อใด ใส่เป็นเงื่อนไขในการจัดซื้อระบบใหม่ที่จะใช้เกิน 5 ปี
3. **ใช้ TLS 1.3 และซอฟต์แวร์รุ่นปัจจุบัน** เพื่อให้ได้การแลกเปลี่ยนกุญแจแบบผสมโดยอัตโนมัติเมื่อทั้งสองฝั่งรองรับ
4. **ออกแบบให้เปลี่ยนอัลกอริทึมได้ง่าย (Crypto Agility)** ไม่ฝังค่าการเข้ารหัสไว้ในโค้ดแบบแก้ไม่ได้

25.11 เทคโนโลยีอื่นที่ควรรู้จัก

เทคโนโลยี	ช่วยอะไร	หมายเหตุสำหรับโรงพยาบาล
Windows LAPS	สุ่มรหัส Local Admin ไม่ซ้ำกันทุกเครื่อง เก็บใน AD/Entra ID	มีใน Windows รุ่นปัจจุบันแล้ว ไม่มีค่าใช้จ่ายเพิ่ม ตัดวงจร Lateral Movement ได้มาก
Protective DNS	บล็อกโดเมนอันตรายตั้งแต่ขั้นค้นหาชื่อ	ตั้ง DNS ภายในให้ส่งต่อไปยังบริการ DNS ที่กรองมัลแวร์ (เช่น Quad9 `9.9.9.9`, Cloudflare `1.1.1.2`) ร่วมกับ Feed บทที่ 15
Immutable Backup	สำเนาที่ลบหรือแก้ไม่ได้ภายในระยะเวลาที่กำหนด	ใช้ Object Lock บน Storage ที่รองรับ หรือเทปที่เก็บแยก (บทที่ 13)
Microsegmentation	กำหนดว่าเครื่องไหนคุยกับเครื่องไหนได้ ละเอียดถึงระดับเซิร์ฟเวอร์	เริ่มจากโซนฐานข้อมูลผู้ป่วยและ Backup

เทคโนโลยี	ช่วยอะไร	หมายเหตุสำหรับโรงพยาบาล
Privileged Access Workstation (PAW)	เครื่องเฉพาะสำหรับงานผู้ดูแลระบบ ไม่ใช้อ่านอีเมลหรือเว็บ	ลดโอกาสที่รหัส Admin ถูกขโมยจากเครื่องที่ติดมัลแวร์
Application Allow List	อนุญาตเฉพาะโปรแกรมที่อนุมัติ	เหมาะกับเครื่องจุดบริการและเครื่องที่ใช้งานเฉพาะ (เช่น เครื่องลงทะเบียน)
SBOM และ VEX	รายการส่วนประกอบซอฟต์แวร์และสถานะช่องโหว่	ขอจากผู้ขายเครื่องมือแพทย์และ HIS (บทที่ 22)
Browser Isolation	เปิดเว็บเสี่ยงในสภาพแวดล้อมแยก	พิจารณาสำหรับเครื่องที่ต้องเข้าเว็บภายนอกและระบบสำคัญพร้อมกัน
CSPM/CNAPP	ตรวจการตั้งค่า Cloud ผิดพลาด	สำหรับหน่วยงานที่ใช้ Cloud สาธารณะมากขึ้น

25.12 จัดลำดับการลงทุนตามขนาดหน่วยบริการ

ช่วงเวลา	รพ.สต./ศสม.	รพช.	รพท./รพศ.	บริการกลางระดับจังหวัด/เขต
ทำทันที (งบน้อย)	MFA อีเมล/บัญชีออนไลน์, Protective DNS, Backup Offline, อัปเดตอัตโนมัติ	ทั้งหมดของ รพ.สต. + Windows LAPS, Sysmon + Wazuh Agent, บัญชีล่อ, ZTNA สำหรับ Vendor	ทั้งหมดของ รพช. + Firewall ระหว่างโซน, OpenCanary ทุก VLAN, Threat Hunting รายสัปดาห์	Wazuh กลาง, NCSA Blacklist Feed, สคริปต์ KEV, กลุ่มประสาน TLP
ภายใน 1 ปี	ใช้เครื่องที่รองรับ Windows รุ่นปัจจุบัน, รับ Feed จากจังหวัด	EDR บนเซิร์ฟเวอร์, FIDO2 สำหรับผู้ดูแลระบบ, SOAR เบื้องต้น	EDR ทุกเครื่องสำคัญ, NDR ที่ Core Switch, SSO	เชื่อม TCTI/MISP, จัดซื้อ EDR ร่วม, ทีมตอบสนองเร่งด่วน
ภายใน 2–3 ปี	เชื่อมผ่าน SASE/ZTNA ของจังหวัด	ตรวจสภาพเครื่องก่อนเข้า HIS	Microsegmentation, MFA ต้านฟิชชิงกลุ่มเสี่ยง, Crypto Inventory	MDR/SOC 24 ชม. ระดับเขต, แผน PQC ร่วม

💡 **หลักคิด**: หน่วยบริการขนาดเล็กไม่จำเป็นต้องมีทุกอย่างเอง ให้ “ใช้ร่วม” กับจังหวัดหรือเขต ทั้งระบบเฝ้าระวัง ข้อมูลภัย และทีมผู้เชี่ยวชาญ ตามแนวทางบริการกลางในบทที่ 19 และการประสานในบทที่ 24

⭐ สรุปท้ายบท

- เทคโนโลยีใหม่เสริมพื้นฐานได้ แต่ไม่แทนพื้นฐาน ให้ทำ CTAM+ ให้ครบก่อน และเลือกเทคโนโลยีตามความเสี่ยงและกำลังคน
- Zero Trust สร้างได้ทีละระยะตามเสาหลักของ CISA ZTMM 2.0 โดยเริ่มจากตัวตน อุปกรณ์ และการเลิกเปิดพอร์ตตรง
- MFA ต้านฟิชชิง EDR/XDR และการตรวจจับพฤติกรรม คือคำตอบของการโจมตีที่ไม่ใช้มัลแวร์และเคลื่อนที่เร็ว
- Deception เป็นเทคนิคงบน้อยที่ให้การแจ้งเตือนแม่นยำสูง เหมาะกับโรงพยาบาลทุกขนาด
- AI ช่วยทั้งฝ่ายป้องกันและฝ่ายโจมตี ต้องมีขั้นตอนยืนยันคำสั่งสำคัญและนโยบายการใช้ AI ที่คุ้มครองข้อมูลผู้ป่วย
- เริ่มสำรวจการเข้ารหัสและวางแผน PQC ตั้งแต่วันนี้ เพราะข้อมูลสุขภาพต้องปลอดภัยไปอีกหลายสิบปี

✏️ คำถามทบทวน

1. ใช้คำถาม 6 ข้อในหัวข้อ 25.1 ประเมินเทคโนโลยี 1 อย่างที่หน่วยงานกำลังพิจารณาจัดซื้อ
2. ประเมินระดับ Zero Trust ของหน่วยงานท่านในแต่ละเสาหลักตามตาราง 25.2 และเลือก 2 เสาที่จะยกระดับในปีนี้
3. อธิบายความต่างระหว่าง OTP กับ Passkey ในมุมของการต้านฟิชชิง
4. ออกแบบกับดัก 3 แบบที่เหมาะกับเครือข่ายของหน่วยงาน พร้อมระบุผู้รับการแจ้งเตือน
5. เขียนขั้นตอนยืนยันคำสั่งโอนเงินเร่งด่วนเพื่อป้องกัน Deepfake ของผู้บริหาร

ภาคผนวก

ภาคผนวก ก Checklist หลักฐาน CTAM+ 17 ข้อ (พร้อมพิมพ์)

หน่วยงาน ..... ผู้ตรวจสอบ ..... วันที่ .....

ข้อ	เกณฑ์	หลักฐานที่ต้องมี	มี	ไม่มี	ไฟล์/หมายเหตุ
1	Backup 3-2-1, วันละ 1 ครั้ง, ย้อนหลัง ≥ 7 วัน	Log/หน้าจอ Backup 7 วัน, รายการระบบ + ที่เก็บ 3 ชุด	☐	☐	
2	AV/EDR บนเครื่องสำคัญ	หน้าจอ Console สถานะอัปเดต, รายงาน Alert	☐	☐	
3	Access Control 12 เงื่อนไข	Policy Firewall, Geo-IP, IPS, VPN, Diagram, ตารางสิทธิ์, Password Policy, NTP, บัญชี Default, ทบทวนบัญชี/Log, Threat Feed	☐	☐	
4	PAM	Access Rights Matrix, บัญชี Admin ถูก Disable, Timeout, บันทึกทบทวน	☐	☐	
5	BCP/DRP ทดสอบปีละครั้ง	เอกสาร BCP, DRP, รายงานผลทดสอบ	☐	☐	
6	OS Patching + Change Management	Windows Update/apt history, Firmware, Change Request	☐	☐	
7	MFA (VPN, Network, Security, Hypervisor, OS)	ภาพหน้าจอขอ OTP แต่ละระบบ	☐	☐	
8	WAF	ภาพการติดตั้ง/ตั้งค่า, รายงานการโจมตีที่ถูกบล็อก	☐	☐	
9	Log ≥ 90 วัน	ภาพค้น Log ของวันที่ 90 ย้อนหลัง	☐	☐	
10	SIEM 6 ด้าน	รายละเอียดระบบ, ภาพ Alert ครบ 6 ด้าน	☐	☐	
11	VA ปีละครั้ง	รายงาน VA, ทะเบียนติดตามแก้ไข	☐	☐	
12	Asset Inventory + ปิดระบบที่ไม่ใช้	ทะเบียนระบบ, หลักฐานการปิดระบบ	☐	☐	
13	Software Patching (เช่น HIS)	รายงานเวอร์ชันก่อน/หลัง	☐	☐	

ข้อ	เกณฑ์	หลักฐานที่ต้องมี	มี	ไม่มี	ไฟล์/หมายเหตุ
14	Network Segmentation	Diagram, Firewall/ACL ระหว่าง Segment	☐	☐	
15	Licensed Software	Software Inventory, หลักฐาน License	☐	☐	
16	Pentest ปีละครั้ง	รายงาน Pentest + Retest ไม่มี Critical/High	☐	☐	
17	นโยบายไซเบอร์/PDPA + อบรม	นโยบายที่ลงนาม, หลักฐานอบรม	☐	☐	

สรุป: ผ่าน ..... / 17 ข้อ ลงชื่อ CISO ..... ลงชื่อผู้บริหาร .....

ภาคผนวก ข แม่แบบเอกสาร

ข.1 นโยบายการรักษาความมั่นคงปลอดภัยไซเบอร์ (ฉบับย่อ)

ประกาศ [ชื่อหน่วยงาน] เรื่อง นโยบายการรักษาความมั่นคงปลอดภัยไซเบอร์และการคุ้มครองข้อมูลส่วนบุคคล

1. วัตถุประสงค์ เพื่อให้ระบบสารสนเทศและข้อมูลของ [หน่วยงาน] มีความลับ ความถูกต้อง และความพร้อมใช้ สอดคล้องกับ พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562 พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 และนโยบายของกระทรวงสาธารณสุข

2. ขอบเขต ใช้กับบุคลากร นักศึกษา และผู้ให้บริการภายนอกทุกคนที่ใช้ระบบสารสนเทศของหน่วยงาน

3. ความรับผิดชอบ ผู้อำนวยการเป็นผู้รับผิดชอบสูงสุด มอบหมาย [ตำแหน่ง] เป็น CISO และ [ตำแหน่ง] เป็น DPO

4. มาตรการหลัก 4.1 ทะเบียนทรัพย์สินและการบริหารความเสี่ยงอย่างน้อยปีละ 1 ครั้ง 4.2 การควบคุมการเข้าถึงตามบทบาท รหัสผ่านอย่างน้อย 12 ตัวอักษร และ MFA สำหรับผู้ดูแลระบบและการเข้าถึงจากภายนอก 4.3 การปรับปรุงซอฟต์แวร์ ป้องกันมัลแวร์ และแบ่งเครือข่าย 4.4 การสำรองข้อมูลแบบ 3-2-1 และทดสอบ BCP/DRP ปีละ 1 ครั้ง 4.5 การเก็บ Log อย่างน้อย 90 วัน และการเฝ้าระวังภัยคุกคาม 4.6 การประเมินช่องโหว่และทดสอบเจาะระบบปีละ 1 ครั้ง 4.7 การรับมือและแจ้งเหตุตามขั้นตอนของกระทรวงและ PDPA 4.8 การอบรมบุคลากรอย่างน้อยปีละ 1 ครั้ง 4.9 การควบคุมผู้ให้บริการภายนอกด้วยสัญญา NDA/DPA

5. การฝ่าฝืน ผู้ฝ่าฝืนอาจถูกพิจารณาทางวินัยและรับผิดตามกฎหมาย

6. การทบทวน ทบทวนนโยบายอย่างน้อยปีละ 1 ครั้ง หรือเมื่อมีการเปลี่ยนแปลงที่สำคัญ

ประกาศ ณ วันที่ ..... (ลงชื่อ) ผู้อำนวยการ

ข.2 ทะเบียนความเสี่ยง (Risk Register)

ID	ทรัพย์สิน	ภัยคุกคาม	ช่องโหว่	โอกาส (1–5)	ผลกระทบ (1–5)	คะแนน	ระดับ	การจัดการ	มาตรการ	ผู้รับผิดชอบ	กำหนดเสร็จ	ความเสี่ยงคงเหลือ
R-01	HIS Database	Ransomware	Backup อยู่ในเครือข่ายเดียวกัน	4	5	20	สูงมาก	ลด	Backup Offline + Immutable	งาน IT	ธ.ค.	8

ข.3 ตารางสิทธิ์การเข้าถึง (Access Rights Matrix)

บทบาท	HIS ลงทะเบียน	HIS ตรวจรักษา	HIS การเงิน	รายงาน/ส่งออก	ผู้ดูแล HIS	DB (อ่าน)	DB (เขียน)	Server/Firewall
เวชระเบียน	RW	R	–	–	–	–	–	–
แพทย์/พยาบาล	R	RW	–	–	–	–	–	–
การเงิน	R	–	RW	R	–	–	–	–

บทบาท	HIS ลงทะเบียน	HIS ตรวจรักษา	HIS การเงิน	รายงาน/ส่งออก	ผู้ดูแล HIS	DB (อ่าน)	DB (เขียน)	Server/Firewall
งานประกันฯ/สารสนเทศ	R	R	R	RW	–	R	–	–
ผู้ดูแล HIS	–	–	–	–	RW	R	RW (ผ่านการอนุมัติ)	–
ผู้ดูแลระบบ/เครือข่าย	–	–	–	–	–	–	–	RW + MFA
Vendor	เปิดตามคำขอเป็นครั้ง มี MFA และบันทึก Log							

R = อ่าน, RW = อ่าน/เขียน, – = ไม่มีสิทธิ์ ทบทวนทุก 6 เดือน (ลงชื่อผู้ทบทวน/วันที่)

ข.4 แบบรายงานเหตุการณ์ภัยคุกคามไซเบอร์ (ภายในหน่วยงาน)

```
เลขที่เหตุ .....  วันเวลาที่เกิด .....  วันเวลาที่ทราบ .....
ผู้พบ/ผู้แจ้ง .....  ช่องทางติดต่อ .....
ประเภท  □ Ransomware □ Malware □ Phishing/บัญชีถูกยึด □ Data Breach
        □ Web Defacement □ DDoS □ Unauthorized Access □ อื่น ๆ .....
ระบบ/ทรัพย์สินที่ได้รับผลกระทบ .....
ผลกระทบต่อบริการผู้ป่วย  □ ไม่มี □ ช้าลง □ ใช้ Downtime Procedure □ หยุดบริการ
ข้อมูลส่วนบุคคลเกี่ยวข้อง  □ ไม่ □ ใช่ (ประเภท ..... จำนวนประมาณ ..... ราย)
ระดับความสำคัญ  □ P1 □ P2 □ P3 □ P4   ระดับภัยตามประกาศ กมช. □ ไม่ร้ายแรง □ ร้ายแรง □ วิกฤติ
สิ่งที่ดำเนินการแล้ว (พร้อมเวลา) .....
การแจ้ง  □ ผู้บริหาร (เวลา .....)  □ Health CERT (เวลา .....)
         □ DPO (เวลา .....)  □ สคส. (เวลา .....)  □ เจ้าของข้อมูล  □ สบส./หน่วยงานกำกับ
ผู้รายงาน .....  หัวหน้าหน่วยงาน (ลงนาม) .....
```

ข.5 แบบบันทึกการทดสอบกู้คืนข้อมูล

วันที่	ระบบ	Backup ที่ใช้ (วันที่/ที่เก็บ)	เริ่ม	เสร็จ	เวลาจริง	RTO เป้าหมาย	ข้อมูลครบถูกต้อง	ปัญหา/ปรับปรุง	ผู้ทดสอบ

ภาคผนวก ค คำสั่งที่ใช้บ่อย

Linux

งาน	คำสั่ง
อัปเดตแพ็กเกจความปลอดภัย	`sudo apt update && sudo apt upgrade`
ดูพอร์ตที่เปิดรอรับ	`sudo ss -tulpn`
ดูผู้ใช้ที่ Login ล่าสุด / ล้มเหลว	`last -n 20` / `sudo lastb -n 20`
ดู Log การยืนยันตัวตน	`sudo journalctl -u ssh --since today` หรือ `sudo tail -f /var/log/auth.log`
ไฟล์ที่ถูกแก้ใน 7 วัน	`find /var/www -type f -mtime -7 -ls`
สถานะ Firewall	`sudo ufw status verbose`
ไอพีที่ fail2ban บล็อก	`sudo fail2ban-client status sshd`
ตรวจ Hardening	`sudo lynis audit system`
สแกนไวรัส	`sudo clamscan -ri /home`
ตรวจเวลา NTP	`timedatectl status`

Windows (PowerShell ในสิทธิ์ผู้ดูแล)

งาน	คำสั่ง
ดู Patch ที่ติดตั้ง	`Get-HotFix | Sort-Object InstalledOn -Descending | Select -First 10`
สถานะ Defender	`Get-MpComputerStatus | Select AMServiceEnabled,AntivirusSignatureLastUpdated`
สแกนด่วน	`Start-MpScan -ScanType QuickScan`
บัญชีผู้ดูแลในเครื่อง	`Get-LocalGroupMember Administrators`
ปิด SMBv1	`Set-SmbServerConfiguration -EnableSMB1Protocol $false`
พอร์ตที่เปิดรอรับ	`Get-NetTCPConnection -State Listen`
Login ล้มเหลว (4625)	`Get-WinEvent -FilterHashtable @{LogName='Security';Id=4625} -MaxEvents 20`
นโยบายรหัสผ่าน	`net accounts`

MySQL / MariaDB

งาน	คำสั่ง
บัญชีทั้งหมด	`SELECT user,host FROM mysql.user;`
สิทธิ์ของบัญชี	`SHOW GRANTS FOR 'report_ro'@'10.10.30.%';`
ใครกำลังเชื่อมต่อ	`SHOW FULL PROCESSLIST;`
ตรวจ bind-address	`SHOW VARIABLES LIKE 'bind_address';`
สำรองแบบไม่ล็อกตาราง	`mysqldump --single-transaction --routines hosxp | gzip > hosxp.sql.gz`

Wazuh

งาน	คำสั่ง
สถานะ Manager	`sudo systemctl status wazuh-manager`
รายชื่อ Agent	`sudo /var/ossec/bin/agent_control -l`
ทดสอบกฎ	`sudo /var/ossec/bin/wazuh-logtest`
ดู Alert สด	`sudo tail -f /var/ossec/logs/alerts/alerts.json`

Nmap

งาน	คำสั่ง
ค้นเครื่องในวง	`sudo nmap -sn 10.10.20.0/24`
พอร์ต + เวอร์ชัน	`sudo nmap -sS -sV --top-ports 1000 <IP>`
TLS	`nmap --script ssl-enum-ciphers -p 443 <host>`

⚠️ IP Address ในตัวอย่างเป็นค่าสมมติ ให้เปลี่ยนเป็นของหน่วยงานตนเอง และสแกนเฉพาะระบบที่ได้รับอนุญาต

ภาคผนวก ง ช่องทางติดต่อและแหล่งข้อมูล

หน่วยงาน	ช่องทางทางการ	ใช้เมื่อ
Health CERT (ศทส.สป.สธ.)	`health-cirt.moph.go.th`, `health-cirt@moph.go.th`, LINE `@health-cirt`	แจ้งเหตุภายใน 24 ชม., ขอความช่วยเหลือ
ศทส.สป.สธ. (Cyber)	`cyber.moph.go.th`, ระบบ CTAM+	นโยบาย, CTAM+, ตัวชี้วัด
PDPA สธ.	`pdpa.moph.go.th`	แนวทาง PDPA ของกระทรวง
สกมช. / ThaiCERT	`ncsa.or.th`, `thaicert.or.th`	ประกาศเตือน, Pentest (OP01), NCSA Blacklist
สคส. (PDPC)	`pdpc.or.th`	แจ้งเหตุละเมิดข้อมูลส่วนบุคคลภายใน 72 ชม.
สบส.	`hss.moph.go.th`	สถานพยาบาลเอกชน
สพร. (DGA)	`dga.or.th`, `standard.dga.or.th`	มาตรฐานรัฐบาลดิจิทัล
สพธอ. (ETDA)	`etda.or.th`	ธุรกรรม/ลายมือชื่ออิเล็กทรอนิกส์
ตำรวจไซเบอร์	`thaipoliceonline.go.th`	แจ้งความคดีออนไลน์

> หมายเลขโทรศัพท์และช่องทางอาจเปลี่ยน ให้ตรวจสอบจากเว็บไซต์ทางการก่อนพิมพ์ติดประกาศ และจัดทำรายชื่อผู้ติดต่อภายในของหน่วยงานเองแนบท้ายแผน IR

ภาคผนวก จ อภิธานศัพท์

คำ	ความหมาย
2FA / MFA	การยืนยันตัวตนหลายปัจจัย เช่น รหัสผ่าน + รหัส OTP
ACL	รายการควบคุมการเข้าถึง กำหนดว่าผู้ใช้หรือเครื่องใดเข้าถึงทรัพยากรใดได้
API	ช่องทางให้โปรแกรมแลกเปลี่ยนข้อมูลกัน
ASM / CTEM	การสำรวจพื้นผิวการโจมตีจากมุมมองภายนอกอย่างต่อเนื่อง / การบริหารการเปิดรับภัยแบบเป็นรอบ ตั้งแต่สำรวจจนถึงยืนยันการแก้ไข
ATT&CK (MITRE)	ฐานความรู้สาธารณะเรื่องยุทธวิธีและเทคนิคของผู้โจมตี ใช้เป็นภาษากลางในการตรวจจับและวัดความครอบคลุม
BCP / DRP	แผนความต่อเนื่องทางธุรกิจ / แผนกู้คืนระบบจากภัยพิบัติ
BMS / HVAC	ระบบบริหารอาคารและระบบปรับอากาศ รวมถึงการควบคุมความดันห้องผ่าตัดและห้องแยกโรค
BOLA	ช่องโหว่ที่ผู้ใช้เข้าถึงข้อมูลรายการของผู้อื่นได้โดยเปลี่ยนรหัสอ้างอิง
Breakout Time	เวลาตั้งแต่ผู้โจมตีเข้าระบบได้จนเริ่มเคลื่อนที่ไปยังเครื่องอื่น
CDB List	รายการค่าที่ Wazuh ใช้เทียบในกฎ เช่น IP Blacklist
CIA Triad	ความลับ ความถูกต้องครบถ้วน ความพร้อมใช้
CII	โครงสร้างพื้นฐานสำคัญทางสารสนเทศ
CISA	หน่วยงานความมั่นคงปลอดภัยไซเบอร์และโครงสร้างพื้นฐานของสหรัฐฯ ผู้ดูแลรายการ KEV
CISO / CIO / DPO	ผู้บริหารความปลอดภัยสารสนเทศ / ผู้บริหารเทคโนโลยีสารสนเทศ / เจ้าหน้าที่คุ้มครองข้อมูลส่วนบุคคล
CMS	ระบบจัดการเนื้อหาเว็บไซต์ เช่น WordPress หรือ Joomla ต้องอัปเดตทั้งตัวระบบและ Plugin
CSF (NIST)	กรอบความมั่นคงปลอดภัยไซเบอร์ของ NIST รุ่น 2.0 มี 6 ฟังก์ชัน: Govern, Identify, Protect, Detect, Respond, Recover
CSIRT / CERT	ทีมรับมือเหตุการณ์ความมั่นคงปลอดภัยคอมพิวเตอร์
CSOC / SOC	ศูนย์ปฏิบัติการเฝ้าระวังความปลอดภัย
CTAM / CTAM+	เกณฑ์ประเมินความปลอดภัยไซเบอร์ของกระทรวงสาธารณสุข
CVE / CVSS	รหัสอ้างอิงช่องโหว่สากล / คะแนนความรุนแรงช่องโหว่
Deception / Honeypot	การวางกับดัก เช่น บัญชี ไฟล์ หรือเครื่องล่อ เพื่อให้ผู้บุกรุกเผยตัว
Defacement	การเปลี่ยนหน้าเว็บไซต์โดยผู้บุกรุก

คำ	ความหมาย
DICOM	มาตรฐานรูปแบบและการรับส่งภาพทางการแพทย์ ใช้ในระบบ PACS
DMARC / DKIM / SPF	ระเบียน DNS ที่ช่วยยืนยันว่าอีเมลมาจากผู้ส่งที่โดเมนอนุญาต และบอกผู้รับว่าจะทำอย่างไรกับอีเมลปลอม (บทที่ 21)
DMZ	โซนเครือข่ายสำหรับเซิร์ฟเวอร์ที่ให้บริการภายนอก เช่น เว็บไซต์ แยกจากเครือข่ายภายใน
DNS / DNSSEC	ระบบแปลงชื่อโดเมนเป็น IP Address / ส่วนขยายที่ลงลายมือชื่อดิจิทัลเพื่อป้องกันการปลอมคำตอบ DNS
DPA / DSA	ข้อตกลงการประมวลผลข้อมูลส่วนบุคคลกับผู้ประมวลผล / ข้อตกลงแบ่งปันข้อมูลกับหน่วยงานอื่น
Dwell Time	ระยะเวลาที่ผู้บุกรุกแฝงอยู่ในระบบก่อนถูกตรวจพบ
EDR / XDR	ระบบตรวจจับและตอบสนองภัยที่เครื่องปลายทาง / ข้ามหลายแหล่ง
ENISA	หน่วยงานความมั่นคงปลอดภัยไซเบอร์ของสหภาพยุโรป
EOL	สิ้นสุดการสนับสนุนจากผู้ผลิต ไม่มี Patch อีก
FHIR	มาตรฐาน HL7 สำหรับแลกเปลี่ยนข้อมูลสุขภาพผ่าน API
FIM	การตรวจการเปลี่ยนแปลงไฟล์
Firewall / NGFW	อุปกรณ์ควบคุมการรับส่งข้อมูลระหว่างโซนเครือข่าย / ไฟร์วอลล์รุ่นใหม่ที่ตรวจถึงระดับแอปพลิเคชันและมี IPS ในตัว
GDCC	คลาวด์กลางภาครัฐ
GPO	Group Policy Object ชุดนโยบายที่ใช้ตั้งค่าเครื่อง Windows ในโดเมนจากส่วนกลาง
HAIT	การรับรองคุณภาพด้านไอทีของโรงพยาบาล (Hospital Accreditation for Information Technology)
HDC	Health Data Center คลังข้อมูลสุขภาพของกระทรวงสาธารณสุข รับข้อมูลมาตรฐาน 43 แฟ้มจากหน่วยบริการ
HHS / HICP	กระทรวงสาธารณสุขและบริการมนุษย์ของสหรัฐฯ / เอกสาร Health Industry Cybersecurity Practices ภายใต้โครงการ 405(d)
HIS	ระบบสารสนเทศโรงพยาบาล
HL7	มาตรฐานรับส่งข้อมูลระหว่างระบบสุขภาพ เช่น HIS กับ LIS ฉบับ v2 ที่ใช้แพร่หลายมักไม่เข้ารหัส
HTTPS / TLS	การเข้ารหัสการสื่อสารบนเว็บ ควรใช้ TLS 1.2 ขึ้นไป ส่วน SSL รุ่นเก่าเลิกใช้แล้ว
IDS / IPS	ระบบตรวจจับ / ป้องกันการบุกรุกทางเครือข่าย
IOC	ตัวบ่งชี้การถูกโจมตี เช่น IP, Domain, Hash
IoMT	อุปกรณ์การแพทย์ที่เชื่อมเครือข่าย

คำ	ความหมาย
KEV	รายการช่องโหว่ที่ถูกใช้โจมตีจริง (ของ CISA)
Kill Chain	ลำดับขั้นของการโจมตีตั้งแต่สำรวจเป้าหมายจนบรรลุผล
LAPS	ระบบของ Microsoft ที่สุ่มและหมุนรหัสผ่าน Administrator ของแต่ละเครื่องไม่ให้ซ้ำกัน
Least Privilege	ให้สิทธิ์เท่าที่จำเป็นต่อการทำงาน
Living off the Land	การโจมตีโดยใช้เครื่องมือที่มีอยู่แล้วในระบบ ทำให้แอนติไวรัสตรวจไม่พบ
Maturity Level	ระดับวุฒิภาวะ บอกว่าการปฏิบัติด้านหนึ่งทำเป็นระบบและวัดผลได้มากเพียงใด (ภาคผนวก ฉ)
MDR	บริการเฝ้าระวังและตอบสนองโดยผู้เชี่ยวชาญภายนอกตลอด 24 ชั่วโมง
MDS2	แบบเปิดเผยข้อมูลความปลอดภัยของเครื่องมือแพทย์ที่ผู้ผลิตจัดทำ ใช้ประกอบการจัดซื้อ
MISP	แพลตฟอร์มโอเพนซอร์สสำหรับเก็บและแบ่งปันข้อมูลภัยคุกคาม
MTTD / MTTR	เวลาเฉลี่ยในการตรวจพบ / ในการแก้ไขเหตุ
NAS	อุปกรณ์จัดเก็บข้อมูลที่ต่อกับเครือข่าย มักใช้เก็บ Backup จึงต้องแยกจากโดเมน
NCSA Blacklist Feed	รายการ IP โดเมน และค่าแฮชที่ สกมช. รวบรวมและเผยแพร่ให้ใช้ฟรี (บทที่ 15)
NDR	ระบบตรวจจับภัยจากการวิเคราะห์ทราฟฟิกเครือข่าย
NIS2	ระเบียบความมั่นคงปลอดภัยไซเบอร์ของสหภาพยุโรปฉบับปรับปรุง ครอบคลุมภาคสุขภาพ
NIST	สถาบันมาตรฐานและเทคโนโลยีแห่งชาติของสหรัฐฯ ผู้ออก CSF และเอกสารชุด SP 800
NTP	โปรโตคอลตั้งเวลาให้ทุกอุปกรณ์ตรงกัน จำเป็นต่อการเทียบ Log จากหลายแหล่ง
NVR	เครื่องบันทึกภาพกล้องวงจรปิดผ่านเครือข่าย
OP01	แบบขอรับการทดสอบความมั่นคงปลอดภัยของระบบเครื่องแม่ข่ายและเว็บไซต์จาก ศปช./สกมช.
OT	เทคโนโลยีปฏิบัติการ ระบบที่ควบคุมอุปกรณ์ทางกายภาพ เช่น ระบบอาคาร ไฟฟ้าสำรอง ก๊าซทางการแพทย์
OWASP	โครงการชุมชนด้านความปลอดภัยเว็บ ผู้จัดทำ OWASP Top 10 และ Core Rule Set (CRS) สำหรับ ModSecurity
PACS	ระบบจัดเก็บและส่งภาพทางการแพทย์ เช่น ภาพเอกซเรย์ CT และ MRI
PAM	การบริหารบัญชีสิทธิ์สูง
Passkey / FIDO2	การยืนยันตัวตนด้วยกุญแจเข้ารหัสที่ผูกกับโดเมนจริง ต้านฟิชชิงได้

คำ	ความหมาย
PDPA	พระราชบัญญัติคุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562
Pentest	การทดสอบเจาะระบบ
Phishing	การหลอกลวงให้กดลิงก์หรือให้ข้อมูล
Playbook	ขั้นตอนรับมือเหตุแต่ละประเภทที่เขียนไว้ล่วงหน้า ระบุว่าใครทำอะไรเมื่อไร (ภาคผนวก ช)
PQC	การเข้ารหัสหลังยุคควอนตัม (Post-Quantum Cryptography)
Pseudonymization	การแฝงข้อมูลให้ระบุตัวบุคคลไม่ได้โดยไม่มีข้อมูลเพิ่ม
RACI	ตารางบทบาท: ผู้ลงมือทำ (Responsible) ผู้รับผิดชอบสุดท้าย (Accountable) ผู้ให้คำปรึกษา (Consulted) และผู้ได้รับแจ้ง (Informed)
Ransomware	มัลแวร์เข้ารหัสไฟล์เพื่อเรียกค่าไถ่
RDP	โปรโตคอลควบคุมเครื่อง Windows ระยะไกล ห้ามเปิดสู่อินเทอร์เน็ตโดยตรง
ROPA	บันทึกรายการกิจกรรมการประมวลผลข้อมูลส่วนบุคคล
RPO / RTO	ข้อมูลที่ยอมให้สูญหายได้ (ช่วงเวลา) / เวลาที่ต้องกู้ระบบให้ได้
SASE / SSE	บริการเครือข่ายและความปลอดภัยบน Cloud ที่รวม ZTNA การกรองเว็บ และ CASB
SBOM	รายการส่วนประกอบซอฟต์แวร์ของผลิตภัณฑ์
SIEM	ระบบรวบรวมและวิเคราะห์ Log เพื่อตรวจจับภัย
SITREP	รายงานสถานการณ์ที่ส่งเป็นรอบระหว่างเกิดเหตุ
SLA	ข้อตกลงระดับบริการ เช่น เวลาตอบสนองและเวลาแก้ไขที่ Vendor ต้องทำได้
SMB	โปรโตคอลแชร์ไฟล์ของ Windows รุ่น SMBv1 มีช่องโหว่ร้ายแรงที่ WannaCry ใช้ ต้องปิด
SOAR	ระบบอัตโนมัติสำหรับงานตอบสนองเหตุตามสูตรที่กำหนด
SSH	โปรโตคอลเข้าควบคุมเครื่อง Linux และอุปกรณ์เครือข่ายระยะไกลแบบเข้ารหัส
STIX / TAXII	รูปแบบและโปรโตคอลแลกเปลี่ยนข้อมูลภัยคุกคาม
TCTI	Thailand Cyber Threat Intelligence แพลตฟอร์มแบ่งปันข่าวกรองภัยคุกคามของ สกมช.
Threat Hunting	การค้นหาร่องรอยผู้บุกรุกเชิงรุกจากสมมติฐาน โดยไม่รอการแจ้งเตือน
TLP	Traffic Light Protocol ป้ายสีบอกขอบเขตการส่งต่อข้อมูล (RED, AMBER+STRICT, AMBER, GREEN, CLEAR)

คำ	ความหมาย
TOR (การจัดซื้อ)	Terms of Reference เอกสารกำหนดคุณลักษณะและเงื่อนไขในการจัดซื้อจัดจ้าง
TOTP	รหัสใช้ครั้งเดียวที่เปลี่ยนตามเวลา สร้างจากแอป Authenticator
TTP	ยุทธวิธี เทคนิค และขั้นตอนของผู้โจมตี (Tactics, Techniques and Procedures)
UPS	เครื่องสำรองไฟฟ้า
VA	การประเมินช่องโหว่
Vishing	การหลอกลวงทางโทรศัพท์ เช่น อ้างเป็น IT หรือ Vendor เพื่อขอรหัสผ่าน OTP หรือให้ติดตั้งโปรแกรมรีโมต
VLAN	เครือข่ายเสมือนสำหรับแบ่งโซน
VPN	ช่องทางเชื่อมต่อเข้าเครือข่ายจากภายนอกแบบเข้ารหัส ต้องใช้ร่วมกับ MFA
WAF	ไฟร์วอลล์สำหรับเว็บแอปพลิเคชัน
Zero Trust	หลัก “ไม่เชื่อใจโดยปริยาย ตรวจสอบทุกครั้ง”
ZTMM	Zero Trust Maturity Model ของ CISA ใช้วัดระดับ Zero Trust ใน 5 เสาหลัก
ZTNA	การเข้าถึงเฉพาะแอปที่ได้รับอนุญาตหลังตรวจตัวตนและสภาพเครื่อง ใช้แทน VPN

ตัวย่อภาษาไทยที่ใช้ในเล่ม

ตัวย่อ	ชื่อเต็ม
กมช.	คณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
สกมช.	สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ (NCSA)
ศปช.	ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ ภายใต้ สกมช.
สคส.	สำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล (PDPC)
สป.สธ.	สำนักงานปลัดกระทรวงสาธารณสุข
ศทส.สป.สธ.	ศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร สำนักงานปลัดกระทรวงสาธารณสุข ผู้ดำเนินการ Health CERT
สสจ. / นพ.สสจ.	สำนักงานสาธารณสุขจังหวัด / นายแพทย์สาธารณสุขจังหวัด
สสอ.	สำนักงานสาธารณสุขอำเภอ
รพศ. / รพท. / รพช.	โรงพยาบาลศูนย์ / โรงพยาบาลทั่วไป / โรงพยาบาลชุมชน
รพ.สต.	โรงพยาบาลส่งเสริมสุขภาพตำบล

ตัวย่อ	ชื่อเต็ม
สบส.	กรมสนับสนุนบริการสุขภาพ
อย.	สำนักงานคณะกรรมการอาหารและยา
สปสช.	สำนักงานหลักประกันสุขภาพแห่งชาติ
สรพ.	สถาบันรับรองคุณภาพสถานพยาบาล (องค์การมหาชน)
สพร.	สำนักงานพัฒนารัฐบาลดิจิทัล (องค์การมหาชน) (DGA)
สพธอ.	สำนักงานพัฒนาธุรกรรมทางอิเล็กทรอนิกส์ (ETDA)

ภาคผนวก ฉ แบบประเมินระดับวุฒิภาวะด้วยตนเอง (Maturity Self-Assessment)

แบบประเมินนี้ใช้ดูภาพรวมว่าหน่วยงาน “ทำได้ดีแค่ไหน” ในแต่ละด้าน ต่างจาก Checklist CTAM+ (ภาคผนวก ก) ที่ตอบว่า “ผ่าน/ไม่ผ่าน” ใช้ประเมินปีละ 1–2 ครั้ง เพื่อวางแผนงบประมาณและติดตามความก้าวหน้า



▲ ภาพที่ ฉ.1 ระดับวุฒิภาวะ 0–4 ใช้ร่วมกับทุกด้านในแบบประเมิน

ฉ.1 วิธีใช้

1. ตั้งทีมประเมิน 3–5 คน ได้แก่ CISO/ผู้รับผิดชอบ IT ตัวแทนพยาบาล งานช่าง/พัสดุ และผู้บริหาร
2. อ่านเกณฑ์ของแต่ละด้านในตาราง ฉ.2 แล้วเลือกระดับที่ **ทำได้ครบทุกข้อ** ถ้าทำได้บางส่วนของระดับถัดไป ให้ใช้ระดับที่ต่ำกว่า
3. แนบหลักฐานสั้น ๆ ทุกด้าน เช่น ชื่อไฟล์ ภาพหน้าจอ บันทึกการประชุม ไม่มีหลักฐานให้ถือว่ายังไม่ถึงระดับนั้น
4. หาค่าเฉลี่ย 10 ด้าน แล้วแปลผลตามตาราง ฉ.4
5. เลือก 3 ด้านที่คะแนนต่ำและเสี่ยงต่อผู้ป่วยมากที่สุด ตั้งเป้าเพิ่ม 1 ระดับภายใน 12 เดือน และเขียนลงแผนปฏิบัติการ (บทที่ 19)
6. ประเมินซ้ำทุก 6–12 เดือน และรายงานผลต่อผู้บริหาร

💡 Toolkit ที่มากับหนังสือมีแบบประเมินนี้ในไฟล์ Excel ที่คำนวณคะแนนเฉลี่ยและแปลผลให้อัตโนมัติ

ฉ.2 เกณฑ์รายด้าน

ระดับ 0 = ยังไม่มีการทำในด้านนั้น ตารางจึงแสดงเฉพาะระดับ 1–4

ด้าน (CSF 2.0)	ระดับ 1 เริ่มต้น	ระดับ 2 ทำซ้ำได้	ระดับ 3 เป็นระบบ	ระดับ 4 วัดผลและปรับปรุง
D1 ธรรมาภิบาลและนโยบาย (GV)	มีผู้รับผิดชอบด้าน IT แต่ไม่มีนโยบาย	มีนโยบายที่ผู้บริหารลงนาม และแต่งตั้ง CISO	มีคณะทำงาน ประชุมสม่ำเสมอ มีงบประมาณประจำปี	ผู้บริหารติดตามตัวชี้วัดรายไตรมาส และทบทวนนโยบายทุกปี
D2 ทะเบียนทรัพย์สินและความเสี่ยง (ID)	รู้จำนวนเครื่องคร่าว ๆ	มีทะเบียนทรัพย์สินและ Risk Register	ทะเบียนครอบคลุมเครื่องมือแพทย์และ OT อัปเดตเมื่อมีการเปลี่ยนแปลง	ทะเบียนเชื่อมกับการสแกนอัตโนมัติ และใช้จัดลำดับงบประมาณ
D3 ตัวตนและสิทธิ์ (PR.AA)	ทุกคนมีบัญชี แต่ใช้รหัสร่วมกันบางจุด	บัญชีรายบุคคล ปิดบัญชีคนลาออกภายใน 1 วัน	MFA สำหรับผู้ดูแลระบบและการเข้าจากภายนอก ทบทวนสิทธิ์ทุก 6 เดือน	PAM/LAPS ครบ ตรวจจับการใช้สิทธิ์ผิดปกติอัตโนมัติ
D4 เครือข่ายและเครื่องลูกข่าย (PR.PS, PR.IR)	มี Firewall และ Antivirus	แยก VLAN ผู้ใช้ เซิร์ฟเวอร์ และ Guest	แยกโซนเครื่องมือแพทย์และ OT, Hardening ตามมาตรฐาน	EDR ครบทุกเครื่อง ตรวจการตั้งค่าเทียบมาตรฐานอัตโนมัติ
D5 ช่องโหว่และ Patch (ID.RA, PR.PS)	อัปเดตเมื่อมีปัญหา	มีรอบ Patch รายเดือน และสแกนช่องโหว่ปีละครั้ง	สแกนทุกไตรมาส ติดตาม CISA KEV ปิดช่องโหว่วิกฤติภายใน 72 ชม. และระดับสูงภายใน 14 วัน (หัวข้อ 24.4)	วัดเวลาปิดช่องโหว่ (MTTR) และรายงานแนวโน้ม
D6 สำรองและกู้คืน (PR.DS, RC)	สำรองข้อมูลบางระบบ	สำรองตามหลัก 3-2-1 สำหรับ HIS	มีชุดสำรองแบบ Offline/Immutable ทดสอบกู้คืนทุกไตรมาส	วัด RTO/RPO จริงเทียบเป้า และซ้อม Downtime ทั้ง รพ.
D7 เฝ้าระวังและ Log (DE)	เก็บ Log บนเครื่อง	รวม Log สำคัญไว้ที่ Wazuh/SIEM เก็บ ≥ 90 วัน	มีกฎแจ้งเตือนและคนตรวจทุกวัน เชื่อม Threat Intelligence	ทำ Threat Hunting สม่ำเสมอ วัด MTTD
D8 รับมือเหตุการณ์ (RS)	แก้ไขตามที่เจอ	มีแผนรับมือ ผังแจ้งเหตุและช่องทาง Health CERT	ซ้อม Tabletop ปีละ ≥ 1 ครั้ง ทำ AAR หลังเหตุทุกครั้ง	ซ้อมร่วมกับเครือข่ายจังหวัด/เขต และนำบทเรียนไปปรับแผน
D9 ความตระหนักรู้ (PR.AT)	แจ้งเตือนผ่านกลุ่มไลน์เป็นครั้งคราว	อบรมบุคลากรใหม่และประจำปี	ทดสอบ Phishing จำลอง และอบรมเฉพาะกลุ่มเสี่ยง	วัดอัตราการรายงานอีเมลน่าสงสัย และปรับเนื้อหาตามผล
D10 คู่ค้า เครื่องมือแพทย์ และ OT (GV.SC)	รู้ว่ามีผู้รับเหมาเข้ามาดูแล	สัญญามีข้อรักษาความลับ (NDA) และรายชื่อผู้รับเหมา	ข้อกำหนดความปลอดภัยใน TOR, รีโมตผ่านช่องทางเดียวพร้อม MFA	ประเมินคู่ค้าประจำปี และใช้ SBOM/MDS2 ในการตัดสินใจจัดซื้อ

ฉ.3 แบบบันทึกคะแนน

ด้าน	คะแนน (0–4)	หลักฐานอ้างอิง	เป้าหมาย 12 เดือน	ผู้รับผิดชอบ
D1 ธรรมาภิบาลและนโยบาย				

ด้าน	คะแนน (0–4)	หลักฐานอ้างอิง	เป้าหมาย 12 เดือน	ผู้รับผิดชอบ
D2 ทะเบียนทรัพย์สินและความเสี่ยง				
D3 ตัวตนและสิทธิ์				
D4 เครือข่ายและเครื่องลูกข่าย				
D5 ช่องโหว่และ Patch				
D6 สำรองและกู้คืน				
D7 เฝ้าระวังและ Log				
D8 รับมือเหตุการณ์				
D9 ความตระหนักรู้				
D10 คู่ค้า เครื่องมือแพทย์ และ OT				
ค่าเฉลี่ย	....		....	

ฉ.4 การแปลผล

ค่าเฉลี่ย	ความหมาย	เทียบ NIST CSF Tier (โดยประมาณ)	สิ่งที่ควรทำต่อ
0.0–1.0	พื้นฐานยังไม่ครบ เสี่ยงสูงมาก	Tier 1 Partial	ทำ “สิบจุดตัดวงจร” (หัวข้อ 23.12) และ Backup แบบ Offline ทันที
1.1–2.0	ทำได้บางส่วน ขึ้นกับตัวบุคคล	Tier 2 Risk Informed	เขียนขั้นตอนและหลักฐานให้ครบตาม CTAM+
2.1–3.0	เป็นระบบในหลายด้าน	Tier 3 Repeatable	เพิ่ม MFA/EDR ให้ครบ ซ้อมรับมือ และเชื่อมเครือข่ายจังหวัด
3.1–4.0	วัดผลและปรับปรุงต่อเนื่อง	Tier 4 Adaptive	เป็นพี่เลี้ยงให้หน่วยบริการอื่น และแบ่งปันบทเรียน (บทที่ 24)

⚠️ NIST CSF Tier ใช้บอกความเข้มข้นของการบริหารความเสี่ยง ไม่ใช่คะแนนวุฒิภาวะโดยตรง ตารางนี้เทียบไว้เพื่อสื่อสารกับผู้บริหารเท่านั้น และคะแนนนี้ไม่ใช่ผลการประเมิน CTAM+ อย่างเป็นทางการ

ภาคผนวก ช Playbook การ์ดหน้าเดียว (6 เหตุการณ์)

การ์ดในภาคผนวกนี้ย่อ Playbook จากบทที่ 17 ให้อยู่ในหน้าเดียว และเพิ่มเหตุที่พบบ่อยในหน่วยบริการอีก 3 แบบ ใช้ตอนเกิดเหตุจริงเมื่อไม่มีเวลาอ่านทั้งบท พิมพ์ติดห้อง IT ห้องผู้บริหาร และจุดที่เจ้าหน้าที่เห็นง่าย

วิธีอ่านการ์ด อ่านจากบนลงล่างตามแถบเวลาด้านซ้าย ในแต่ละแถวทำจากซ้ายไปขวา กล่องรูปข้าวหลามตัดคือจุดตัดสินใจ กล่องสีเขียวคือผลลัพธ์ที่ปลอดภัย กล่องสีเทาคือลำดับงานหรือการส่งต่อไปการ์ดอื่น และแผงสีแดงด้านขวาคือสิ่งที่ห้ามทำ

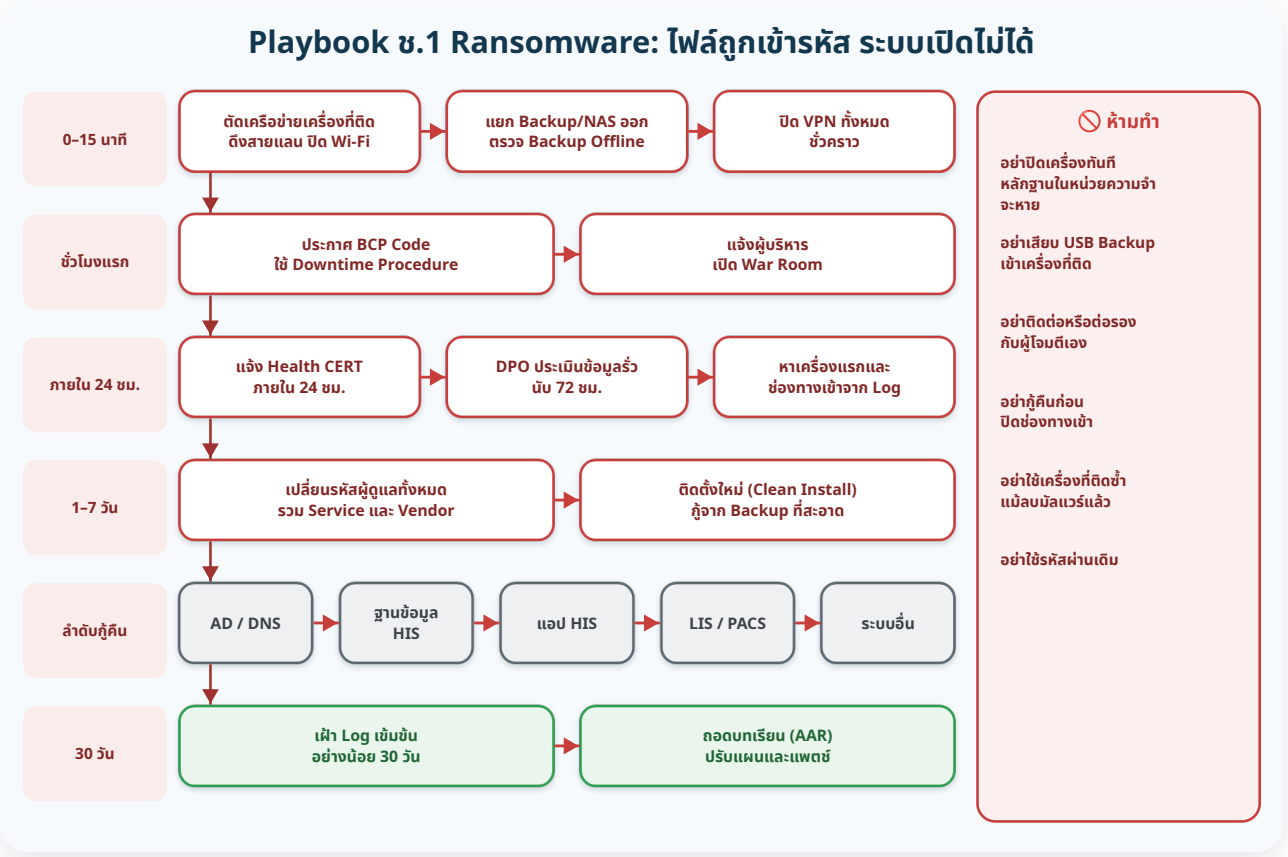
ก่อนพิมพ์ เติมรายชื่อผู้ติดต่อของหน่วยงานในตารางนี้ และทบทวนทุกครั้งที่มีคนย้ายงาน

บทบาท	ชื่อ / ตำแหน่ง	เบอร์ภายใน / มือถือ
หัวหน้างาน IT (ผู้รับแจ้งเหตุ)		
ผู้ดูแลระบบสำรอง (นอกเวลา)		
ผู้บริหารที่สั่งการ (CIO / ผู้อำนวยการ)		
DPO		
บริษัทผู้ดูแล HIS / Vendor		
Health CERT ศทส.สป.สธ.	ช่องทางทางการ	`health-cirt.moph.go.th` · `health-cirt@moph.go.th` · LINE `@health-cirt`

⚠️ ทุกการ์ดจบด้วยการบันทึกเหตุในทะเบียน (แผ่น “บันทึกเหตุการณ์” ใน Toolkit Excel นับเวลาแจ้ง Health CERT 24 ชม. และ สคส. 72 ชม. ให้อัตโนมัติ) และถอดบทเรียนด้วยแบบ AAR ภายใน 2 สัปดาห์ (หัวข้อ 17.12)

ช.1 Ransomware: ไฟล์ถูกเข้ารหัส ระบบเปิดไม่ได้

สัญญาณ ไฟล์เปลี่ยนนามสกุลพร้อมกันจำนวนมาก มีไฟล์ข้อความเรียกค่าไถ่ HIS เชื่อมต่อฐานข้อมูลไม่ได้ Wazuh แจ้งไฟล์เปลี่ยนแปลงจำนวนมาก (FIM) หรือ CPU และ Disk สูงผิดปกติหลายเครื่องพร้อมกัน



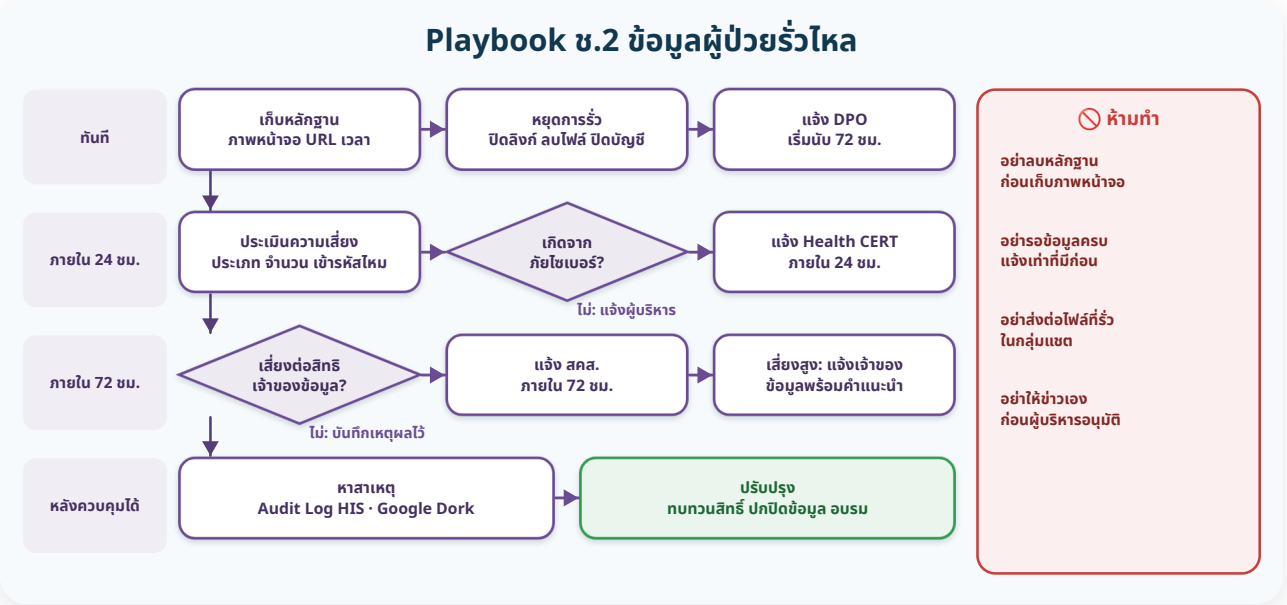
▲ ภาพที่ ช.1 Playbook Ransomware

ใคร	ทำอะไรในการ์ดนี้
ผู้ใช้ที่พบเหตุ	ดึงสายแลน ปิด Wi-Fi ไม่ปิดเครื่อง แจ้ง IT ทันที
IT / ทีมรับมือ	ตัดเครือข่ายและ VPN ปกป้อง Backup หาเครื่องแรกและช่องทางเข้า กู้คืนตามลำดับ
ผู้บริหาร	ประกาศ BCP Code ให้ใช้ Downtime Procedure เปิด War Room อนุมัติการสื่อสาร
DPO	ประเมินว่าข้อมูลถูกขโมยออกไปก่อนเข้ารหัสหรือไม่ (Double Extortion) และนับ 72 ชม.

อ่านละเอียด: หัวข้อ 17.6, แผน BCP และลำดับกู้คืนในบทที่ 13, ลำดับเหตุการณ์ Ransomware จำลอง 14 วันในบทที่ 23

ช.2 ข้อมูลผู้ป่วยรั่วไหล

สัญญาณ พบข้อมูลผู้ป่วยในกลุ่มโซเชียลหรือเว็บใต้ดิน ได้รับแจ้งจากผู้ป่วยหรือสื่อ Log แสดงการส่งออกข้อมูลจำนวนมาก หรือพบเอกสารเปิดสาธารณะในไดรฟ์แชร์และเว็บไซต์



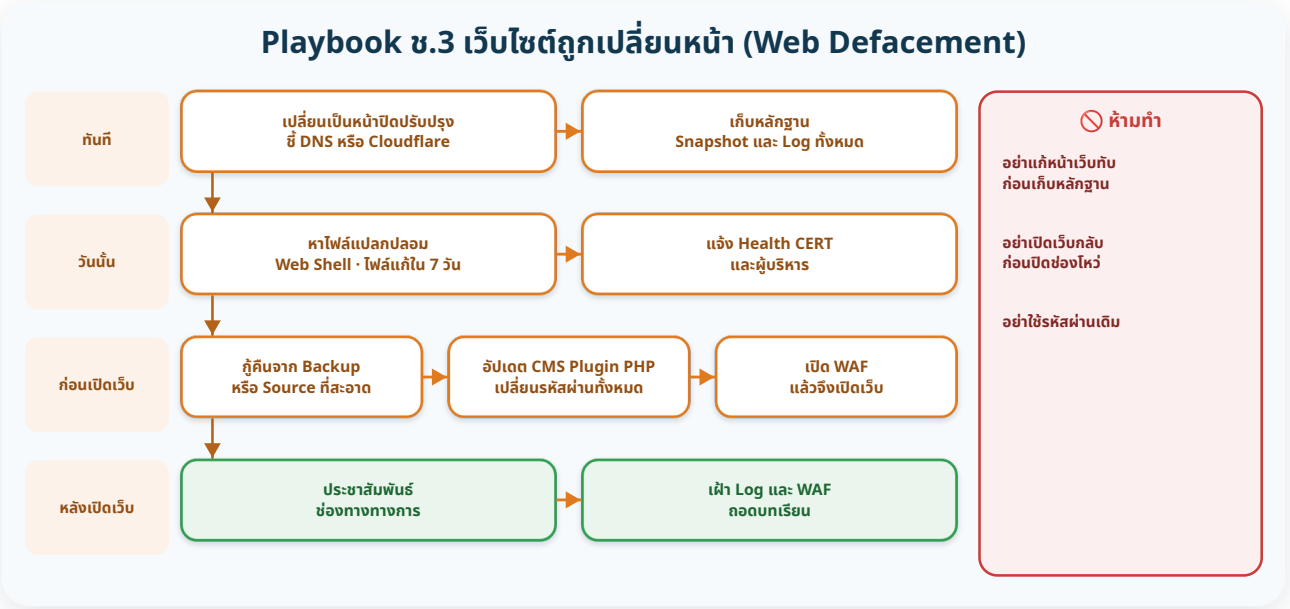
▲ ภาพที่ ช.2 Playbook ข้อมูลผู้ป่วยรั่วไหล

ใคร	ทำอะไรในการ์ดนี้
ผู้พบเหตุ / หน่วยงานเจ้าของข้อมูล	เก็บภาพหน้าจอพร้อม URL และเวลา แจ้ง DPO ทันที
IT	ปิดลิงก์แชร์ ลบไฟล์ ปิดบัญชีที่เกี่ยวข้อง ดึง Audit Log
DPO	ประเมินความเสี่ยง แจ้ง สคส. ภายใน 72 ชม. และแจ้งเจ้าของข้อมูลเมื่อเสี่ยงสูง
ผู้บริหาร / ประชาสัมพันธ์	อนุมัติข้อความถึงผู้ป่วยและสื่อ ไม่ให้ข่าวก่อนมีข้อเท็จจริง

อ่านละเอียด: หัวข้อ 17.7, การแจ้ง สคส. หัวข้อ 4.7, Audit Log ของ HIS ในบทที่ 12

ช.3 เว็บไซต์ถูกเปลี่ยนหน้า (Web Defacement)

สัญญาณ หน้าเว็บเปลี่ยนไปจากเดิม มีลิงก์เว็บพนันแฝงในหน้าเว็บ ผลค้นหาใน Google แสดงข้อความแปลก หรือมีผู้แจ้งว่าเปิดเว็บแล้วถูกพาไปเว็บอื่น



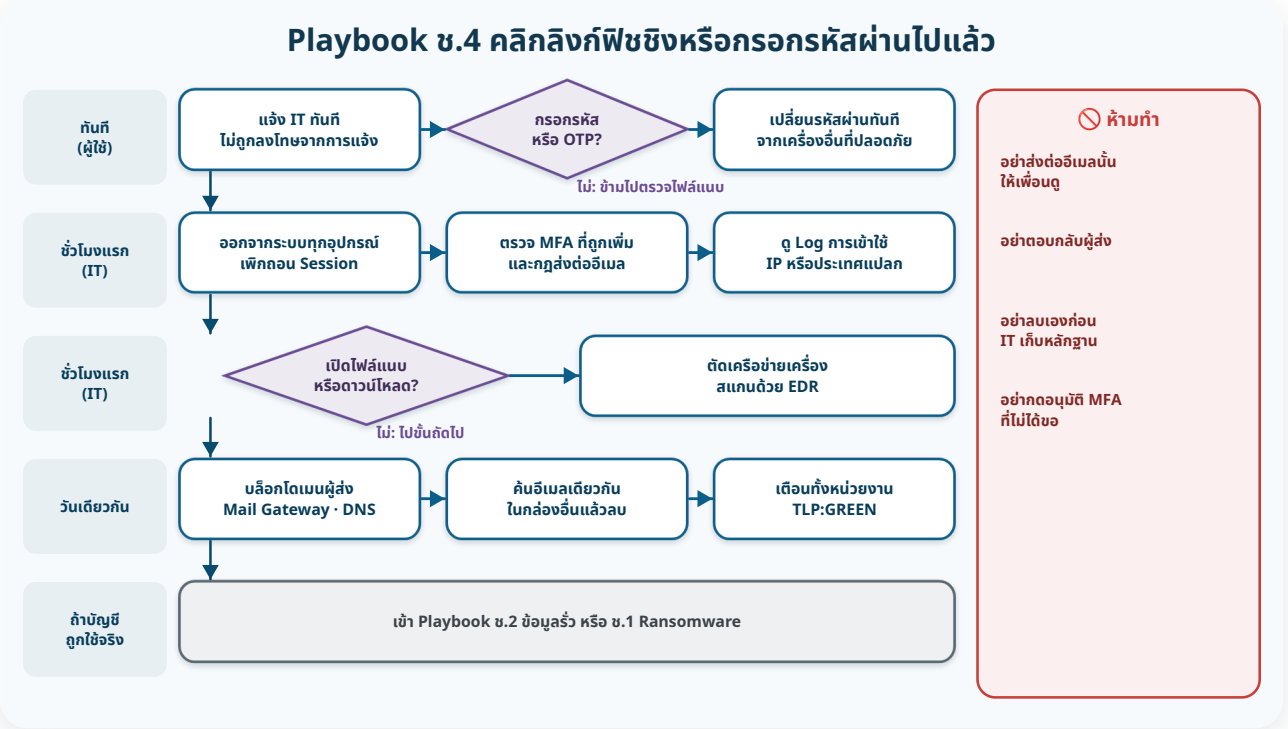
▲ ภาพที่ ช.3 Playbook เว็บไซต์ถูกเปลี่ยนหน้า

ใคร	ทำอะไรในการ์ดนี้
ผู้ดูแลเว็บ / IT	ปิดเว็บหรือชี้ไปหน้าปิดปรับปรุง เก็บหลักฐาน หา Web Shell กู้คืน อัปเดต และเปิด WAF
Vendor ผู้พัฒนาเว็บ	ตรวจ Source Code และ Plugin ที่มีช่องโหว่
งานประชาสัมพันธ์	แจ้งช่องทางทางการให้ผู้รับบริการระหว่างปิดเว็บ

อ่านละเอียด: หัวข้อ 17.8 (มีคำสั่งค้นหา Web Shell), WAF ในบทที่ 11, การกู้คืนในบทที่ 13

ช.4 คลิกลิงก์ฟิชชิงหรือกรอกรหัสผ่านไปแล้ว

สัญญาณ เพิ่งกรอกรหัสผ่านในหน้าที่ดูแปลก ได้รับคำขอยืนยัน MFA ที่ไม่ได้กดเอง มีอีเมลตีกลับหรือคำตอบแปลก ๆ จากอีเมลที่ตัวเองไม่ได้ส่ง หรือเปิดไฟล์แนบแล้วไม่มีอะไรเกิดขึ้น



▲ ภาพที่ ช.4 Playbook คลิกลิงก์ฟิชชิงหรือกรอกรหัสผ่านไปแล้ว

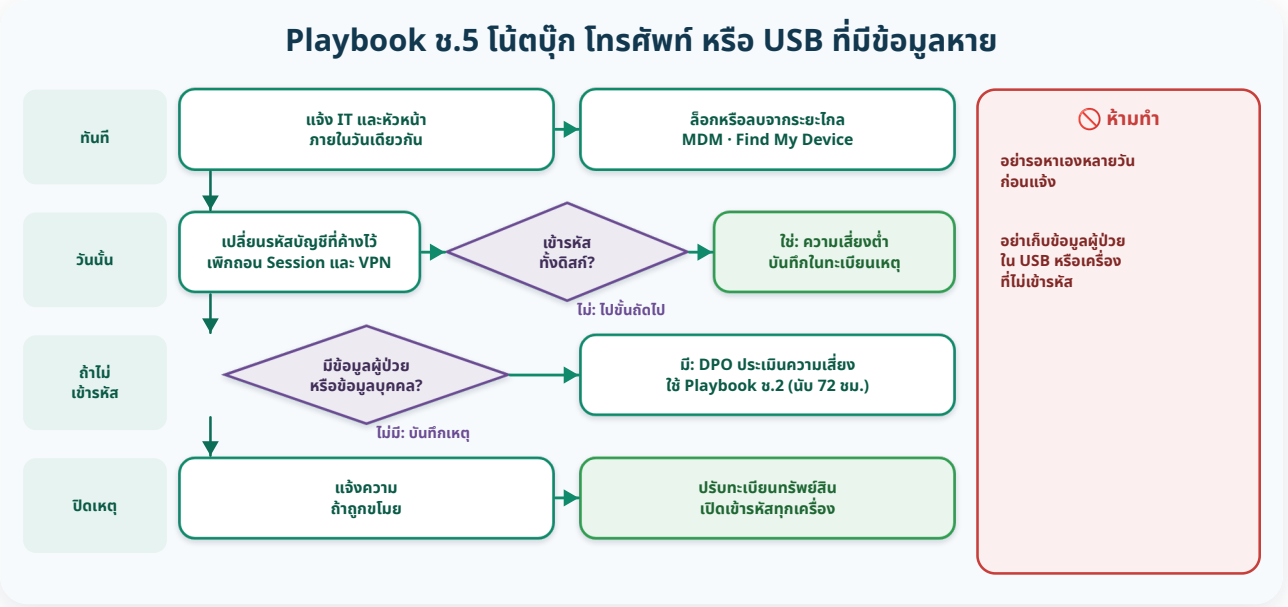
ใคร	ทำอะไรในการ์ดนี้
ผู้ใช้	แจ้ง IT ทันทีและบอกตามจริงว่าทำอะไรไปแล้ว เปลี่ยนรหัสผ่านจากเครื่องอื่นที่ปลอดภัย
IT	ออกจากระบบทุกอุปกรณ์ ตรวจ MFA และกฎส่งต่ออีเมลที่ถูกเพิ่ม ดู Log การเข้าใช้ ค้นอีเมลเดียวกันในกล่องอื่น บล็อกโดเมนผู้ส่ง
หัวหน้างาน	ชื่นชมการแจ้งเร็ว ไม่ลงโทษ เพื่อให้คนกล้าแจ้งครั้งต่อไป

💡 ยิ่งผู้ใช้แจ้งเร็ว ยิ่งมีโอกาสจบได้ตั้งแต่แถวแรกของการ์ด ถ้าบัญชีถูกใช้ส่งอีเมลหรือดึงข้อมูลไปแล้ว ให้ย้ายไปการ์ด ช.2 หรือ ช.1 ตามอาการ

อ่านละเอียด: บทที่ 18 (กลลวงและวัฒนธรรมการแจ้งเหตุ), MFA หัวข้อ 8.5 และ 25.3, การป้องกันฝั่งผู้รับอีเมลหัวข้อ 21.5

ช.5 โน้ตบุ๊ก โทรศัพท์ หรือ USB ที่มีข้อมูลหาย

สัญญาณ โน้ตบุ๊กของหน่วยงาน โทรศัพท์ที่ใช้อีเมลหรือกลุ่มไลน์งาน หรือ USB ที่มีไฟล์ข้อมูลผู้ป่วย หายหรือถูกขโมย ทั้งในและนอกโรงพยาบาล



▲ ภาพที่ ช.5 Playbook อุปกรณ์ที่มีข้อมูลหาย

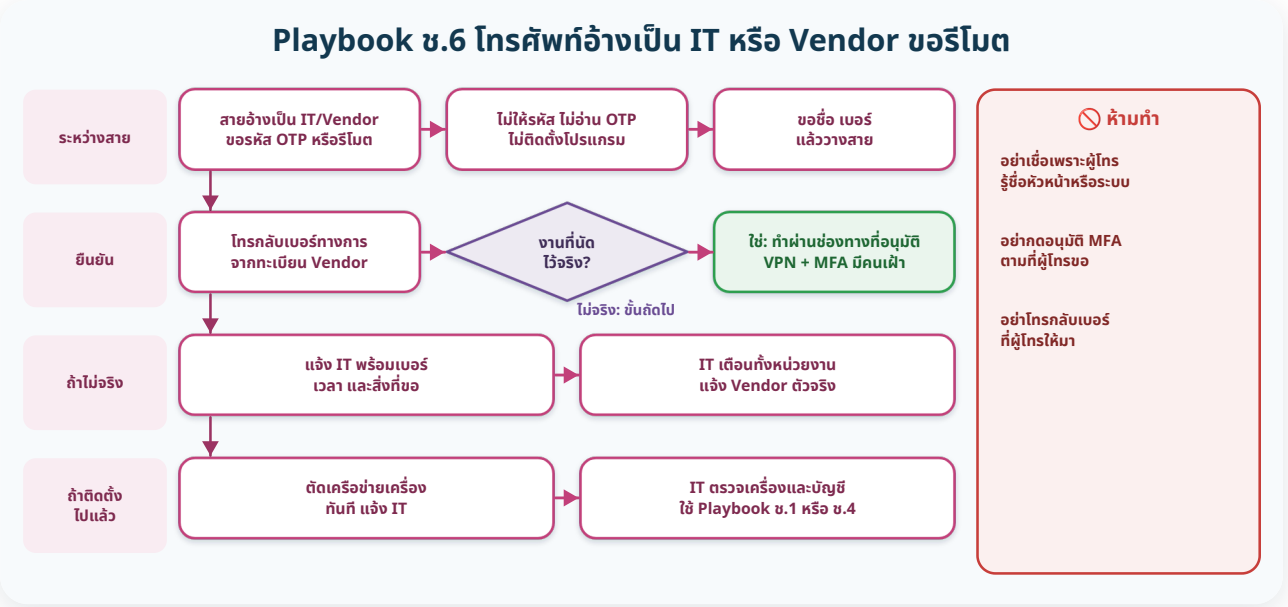
ใคร	ทำอะไรในการ์ดนี้
เจ้าของเครื่อง	แจ้ง IT และหัวหน้าภายในวันเดียวกัน บอกว่ามีข้อมูลอะไรอยู่ในเครื่อง
IT	ล็อกหรือลบข้อมูลจากระยะไกล เปลี่ยนรหัสบัญชีที่ค้างอยู่ ตรวจว่าเครื่องเข้ารหัสทั้งดิสก์หรือไม่จากทะเบียนทรัพย์สิน
DPO	ถ้าเครื่องไม่เข้ารหัสและมีข้อมูลบุคคล ให้ประเมินความเสี่ยงและเริ่มนับ 72 ชม. ตามการ์ด ช.2

💡 การ์ดนี้แสดงว่าการเปิด BitLocker หรือ FileVault ไว้ก่อน (หัวข้อ 10.3) เปลี่ยนเหตุใหญ่ให้เป็นเพียงการบันทึกในทะเบียน

อ่านละเอียด: Hardening และการเข้ารหัสดิสก์หัวข้อ 10.3, ทะเบียนทรัพย์สินหัวข้อ 7.2, การแจ้ง สคส. หัวข้อ 4.7

ช.6 โทรศัพท์อ้างเป็น IT หรือ Vendor ขอรีโมต

สัญญาณ มีคนโทรมาอ้างเป็นงาน IT บริษัทผู้ดูแล HIS หรือผู้บริหาร ขอรหัสผ่าน ขอรหัส OTP ขอให้ติดตั้งโปรแกรมควบคุมเครื่องระยะไกล หรือเร่งให้ทำทันทีโดยอ้างว่าระบบจะล่ม เสียงอาจเหมือนคนที่รู้จักเพราะใช้ AI ปลอมเสียงได้



▲ ภาพที่ ช.6 Playbook โทรศัพท์อ้างเป็น IT หรือ Vendor

ใคร	ทำอะไรในการ์ดนี้
ผู้รับสาย	ไม่ให้รหัสและ OTP ไม่ติดตั้งโปรแกรม ขอชื่อและเบอร์แล้ววางสาย โทรกลับเบอร์ทางการเพื่อยืนยัน
IT	เตือนทั้งหน่วยงาน แจ้ง Vendor ตัวจริง ตรวจเครื่องและบัญชีถ้ามีการติดตั้งไปแล้ว
Vendor ตัวจริง	เข้าระบบผ่านช่องทางที่อนุมัติเท่านั้น คือ VPN + MFA มีคนเฝ้าและบันทึก

อ่านละเอียด: บทที่ 18, Remote Access ของบริษัทผู้ดูแลระบบหัวข้อ 8.6, Deepfake หัวข้อ 25.9

ภาคผนวก ซ แนวคำตอบคำถามทบทวนท้ายบท

แนวคำตอบนี้ใช้สำหรับผู้อ่านตรวจความเข้าใจด้วยตนเอง และสำหรับวิทยากรที่ใช้หนังสือเป็นเอกสารประกอบการอบรม คำถามที่ให้ลงมือทำกับหน่วยงานของผู้อ่านไม่มีคำตอบเดียว แนวคำตอบจึงบอกสิ่งที่ควรเห็นในคำตอบที่ดี และบทหรือหัวข้อที่ควรกลับไปอ่าน

บทที่ 1 ทำไมระบบสุขภาพจึงตกเป็นเป้าหมาย

1. ตัวอย่าง: HIS (ลงทะเบียน สั่งยา และไม่เห็นประวัติแพ้ยา) LIS (ผลแล็บล่าช้า) PACS (อ่านภาพไม่ได้ อาจต้องส่งต่อผู้ป่วย) ระบบเบิกจ่าย (รายได้หยุด) และระบบคิวหรือนัดหมาย จุดสำคัญคือคิดผลต่อผู้ป่วย ไม่ใช่แค่ผลต่องาน IT
2. เพื่อกดดันสองชั้น แม้หน่วยงานกู้จาก Backup ได้ ผู้โจมตีก็ยังขู่เผยแพร่ข้อมูล (Double Extortion) และข้อมูลสุขภาพยังนำไปใช้หลอกลวงผู้ป่วยต่อได้
3. การแพตช์ระบบปฏิบัติการตามรอบ ซึ่งผู้ผลิตออกแพตช์ไว้ก่อนเหตุหลายสัปดาห์ ร่วมกับปิด SMBv1 ไม่เปิดพอร์ตแชร์ไฟล์สู่อินเทอร์เน็ต แยกเครือข่าย และเลิกใช้ระบบปฏิบัติการหมดอายุ (บทที่ 10)

บทที่ 2 แนวคิดพื้นฐานที่ต้องรู้

1. ตัวอย่าง: Asset ฐานข้อมูล HIS, Threat Ransomware, Vulnerability RDP เปิดสู่อินเทอร์เน็ตและไม่มี MFA, Risk โอกาส 4 × ผลกระทบ 5 = 20 (เทียบ R01 หัวข้อ 7.6)
2. Wazuh → DETECT, Backup 3-2-1 → PROTECT (การมีสำเนา) และ RECOVER (การกู้คืน), คำสั่งแต่งตั้ง CISO → GOVERN, Asset Inventory → IDENTIFY, IR Playbook → RESPOND

บทที่ 3 พ.ร.บ.ไซเบอร์ 2562 และ CII ด้านสาธารณสุข

1. หน่วยบริการที่ให้บริการจริง เช่น โรงพยาบาลและ รพ.สต. เป็น Operator ส่วนหน่วยงานกำกับคือกระทรวงสาธารณสุขและ Regulator เฉพาะด้าน เช่น สบส. และ อย. เหตุภัยไซเบอร์รายงานไปที่ Health CERT ศทส.สป.สธ. ภายใน 24 ชั่วโมงผ่านช่องทางทางการ
2. ร้ายแรง เพราะปัจจัยระบบงาน บริการหลักคือผลแล็บทำงานไม่ได้จนต้องใช้มือ และให้ถือระดับสูงสุดของ 4 ปัจจัย ถ้ากู้คืนไม่ได้หรือลามไปหน่วยงานอื่นต้องพิจารณาระดับวิกฤติ ส่วนการทำงานภายในใช้ Priority P1 หรือ P2

บทที่ 4 PDPA สำหรับสถานพยาบาล และธรรมาภิบาลข้อมูล

1. ควรเห็น Privacy Notice ที่มีชื่อหน่วยงาน ติดที่จุดลงทะเบียน เว็บไซต์ และช่องทางออนไลน์ โดยใช้แม่แบบจาก pdpa.moph.go.th
2. ตัวอย่างผู้ประมวลผล: บริษัทผู้ดูแล HIS ผู้ให้บริการ Cloud บริษัทส่ง SMS นัดหมาย และบริษัททำลายเอกสาร ทุกรายต้องมี DPA ที่ระบุมาตรการความปลอดภัยและหน้าที่แจ้งเหตุ

บทที่ 5 นโยบายและมาตรฐานของกระทรวงสาธารณสุข

1. ผู้บริหารระดับสูงสุดของหน่วยงานเป็นผู้รับผิดชอบ (ข้อ 6) และต้องให้ผู้ตรวจสอบภายในหรือผู้ตรวจสอบอิสระภายนอกประเมินความเสี่ยงอย่างน้อยปีละหนึ่งครั้ง (ข้อ 5)
2. ไม่ต้อง ให้ประกาศรับนโยบายของกระทรวงมาใช้ แล้วเพิ่มเฉพาะส่วนที่เป็นของหน่วยงาน เช่น ผู้รับผิดชอบ ระบบสำคัญ ช่องทางติดต่อ และทบทวนปีละครั้งพร้อมเก็บรายงานการประชุม
3. ครบทั้ง 4 ชั้นในภาพที่ 5.1 คือ นโยบายที่ผู้บริหารลงนาม แนวปฏิบัติหมวด 2 SOP ขั้นตอนสำรองและกู้คืน และบันทึกจริง เช่น Backup Log และแบบบันทึกการทดสอบกู้คืน (ภาคผนวก ข.5) ชั้นล่างสุดคือสิ่งที่พิสูจน์ว่าทำจริง
4. คำตอบขึ้นกับหน่วยงาน ตัวอย่างที่ดีคือทะเบียนความเสี่ยงฉบับเดียวใช้ตอบ HA, HAIT และ CTAM+ หรือ Backup Log ใช้ตอบ CTAM+ ตัวชี้วัด v2.1 และ ISO 27001 พร้อมกัน จุดที่ควรเห็นคือการจัดเก็บแบบเดียวแล้วใช้ซ้ำ

บทที่ 6 CTAM+ ฉบับลงมือทำ

1. 17 ข้อ และต้องผ่านครบทุกข้อจึงได้ระดับสูง คะแนน Dashboard แบ่งเป็นเชิงปริมาณ 70% (สัดส่วนข้อที่มีสถานะ “มี”) และเชิงผลกระทบ 30% (ไม่มีเหตุภัยคุกคามและไม่มีข้อมูลรั่วไหล)
2. โรงพยาบาล → สสจ. → เขตสุขภาพ → ศทส.สป.สธ. ตามภาพที่ 6.1 แต่ละระดับตรวจและอนุมัติก่อนส่งต่อ
3. เริ่มจากงานที่ไม่ใช้งบและเห็นผลเร็ว เช่น เปลี่ยนรหัส Default ปิดบัญชีที่ไม่ใช้ ทำทะเบียนทรัพย์สิน และเริ่มเก็บ Log ให้เร็วที่สุด เพราะ Log ต้องสะสมย้อนหลังจึงใช้เป็นหลักฐานได้
4. คำตอบขึ้นกับหน่วยงาน ควรระบุหลักฐานที่จับต้องได้ (ภาพหน้าจอ Log รายงาน คำสั่ง) ไม่ใช่แค่ “ทำแล้ว” และนำข้อที่ค้างเข้า Excel แผ่น “ติดตาม CTAM+” ใน Toolkit

บทที่ 7 บัญชีทรัพย์สินและการบริหารความเสี่ยงไซเบอร์

1. ได้ 4 × 5 = 20 คะแนน เกินเกณฑ์ ≥ 10 จึงต้องจัดการ และอยู่ในโซนสูงมาก (16–25) บน Heat Map ตามภาพที่ 7.2
2. ลด (เช่น เปิด MFA ทำ Backup Offline) หลีกเลี่ยง (เลิกใช้ระบบที่เสี่ยง) ถ่ายโอน (ทำสัญญาให้ Vendor รับผิดชอบหรือทำประกัน) และยอมรับ (ผู้บริหารลงนามรับความเสี่ยงที่เหลือ เช่น เครื่อง X-ray ที่ใช้ OS เก่า)
3. ตามหาเจ้าของ บันทึกในทะเบียนทรัพย์สิน ถ้าไม่มีผู้ใช้ให้ปิดตามขั้นตอน System Termination (หัวข้อ 7.4) คือแจ้งล่วงหน้า สำรองข้อมูล ปิดชั่วคราวเพื่อดูผลกระทบ แล้วจึงปลดระวางพร้อมบันทึก
4. ควรมีสาเหตุที่ชัด มาตรการที่ทำได้จริง ผู้รับผิดชอบเป็นตำแหน่ง และกำหนดเสร็จ คะแนนหลังจัดการต้องลดลงอย่างมีเหตุผล เทียบตัวอย่าง R01–R04 ในหัวข้อ 7.6

บทที่ 8 การยืนยันตัวตนและการจัดการสิทธิ์

1. อย่างน้อย 12 ตัวอักษร ล็อกบัญชีเมื่อใส่ผิดซ้ำ และบัญชีที่ไม่ได้ใช้เกิน 90 วันให้ปิดในรอบทบทวนรายไตรมาส
2. 5 จุด คือ VPN, อุปกรณ์เครือข่าย, อุปกรณ์ Security (Firewall, WAF), Hypervisor และระบบปฏิบัติการ

3. ขั้นย้ายงาน (Mover) ตามภาพที่ 8.1 งานบุคคลไม่ได้แจ้ง IT หรือ IT เพิ่มสิทธิ์ใหม่โดยไม่ถอดสิทธิ์เดิม แก้โดยกำหนดให้แจ้งภายในวันเดียวกัน ปรับสิทธิ์ตาม Access Rights Matrix และให้หัวหน้างานยืนยันรายชื่อทุกไตรมาส
4. คำตอบขึ้นกับหน่วยงาน เป้าหมายคือบัญชีผู้ดูแลระบบและบัญชีที่เข้าจากภายนอกใช้วิธีที่ต้านฟิชชิงได้ เช่น Passkey/FIDO2 (หัวข้อ 25.3) ส่วนผู้ใช้ทั่วไปอย่างน้อยใช้แอป Authenticator แทน SMS

บทที่ 9 ความปลอดภัยเครือข่ายและไฟร์วอลล์

1. Default Deny คือปิดทุกอย่างแล้วเปิดเฉพาะที่จำเป็น ส่วน Policy บล็อกต้องอยู่บนสุดเพราะ Firewall ส่วนใหญ่อ่านกฎจากบนลงล่าง ถ้ากฎอนุญาตอยู่ก่อน ทราฟฟิกอันตรายจะผ่านไปก่อนถึงกฎบล็อก
2. อย่างน้อย Server, Client, Medical IoT และ Guest โดยให้ Firewall ควบคุมการข้ามโซนทุกครั้ง และเปิด Log ทุก Policy
3. LINE Notify ปิดให้บริการแล้วตั้งแต่ 31 มีนาคม 2568 ต้องย้ายไปช่องทางอื่น เช่น LINE Messaging API, Telegram, อีเมล หรือส่งเข้า Wazuh แล้วแจ้งเตือนจากที่นั่น
4. คำตอบขึ้นกับหน่วยงาน ควรระบุ Policy ที่ไม่มี Hit Count ในรอบ 90 วัน กฎที่เปิดกว้างเกินจำเป็น และพอร์ตบริหารจัดการที่เปิดสู่อินเทอร์เน็ต พร้อมขอปิดผ่าน Change Request

บทที่ 10 ความปลอดภัยเครื่องลูกข่ายและเซิร์ฟเวอร์

1. ระบบที่เปิดสู่อินเทอร์เน็ตภายใน 72 ชั่วโมง ระบบภายในภายใน 7 วัน ตามตารางกรอบเวลาในหัวข้อ 10.1
2. ใช้มาตรการชดเชยตามภาพที่ 10.1 เช่น จำกัดการเข้าถึงด้วย Firewall/VLAN ทำ Virtual Patching ด้วย WAF เพิ่มกฎเฝ้าระวังใน Wazuh แล้วให้ผู้บริหารลงนามยอมรับความเสี่ยงที่เหลือในทะเบียนความเสี่ยง
3. แยกไว้ใน VLAN Medical ห้ามออกอินเทอร์เน็ต อนุญาตเฉพาะการเชื่อมต่อไป PACS ที่จำเป็น ปิดพอร์ต USB ที่ไม่ใช้ เฝ้าระวังทราฟฟิกที่ Firewall และบันทึกการยอมรับความเสี่ยง (หัวข้อ 10.4 และบทที่ 22)
4. คำตอบขึ้นกับหน่วยงาน ตัวอย่างข้อที่มักไม่ผ่าน ได้แก่ SMBv1 ยังเปิด ไม่ได้เข้ารหัสดิสก์ บัญชี Administrator เดิมยังใช้ได้ และไม่มี Host Firewall ใช้ `lynis audit system` บน Linux ช่วยตรวจได้

บทที่ 11 ความปลอดภัยเว็บแอปพลิเคชันและ WAF

1. เพื่อเก็บ Log 1–2 สัปดาห์ดูว่ากฎไปบล็อกการใช้งานจริงตรงไหน (False Positive) แล้วปรับกฎก่อน ถ้าเปิดบล็อกทันทีเว็บอาจใช้งานไม่ได้และผู้ใช้จะขอให้ปิด WAF
2. HTTPS พร้อม Security Headers, CMS และ Plugin ที่อัปเดต, ปิด Directory Listing และอยู่หลัง WAF ตาม CTAM+ ข้อ 8
3. เว็บถูกฝังหน้าซ่อนหรือสคริปต์ที่แสดงเนื้อหาต่างกันกับบอตค้นหา (Cloaking) ซึ่งมักมาจาก Web Shell หรือ Plugin ที่มีช่องโหว่ ให้ทำตาม Playbook ภาคผนวก ช.3 และหัวข้อ 11.3
4. คำตอบขึ้นกับหน่วยงาน ควรตรวจว่าใบรับรองยังไม่หมดอายุ ปิด TLS เวอร์ชันเก่า และมี Header สำคัญ เช่น HSTS, X-Content-Type-Options, Content-Security-Policy

บทที่ 12 ความปลอดภัยระบบ HIS และฐานข้อมูล

1. เพราะถ้าเครื่องใดถูกยึด ผู้โจมตีจะได้สิทธิ์เต็มต่อฐานข้อมูลทั้งหมด และ Audit Log จะแยกไม่ได้ว่าใครทำอะไร ต้องจำกัดเครือข่ายที่เข้าถึงฐานข้อมูลได้และใช้บัญชีแยกตามบทบาท
2. ใช้ตรวจย้อนว่าใครเปิดดูหรือส่งออกข้อมูลผู้ป่วยรายใด เมื่อใด เป็นหลักฐานเมื่อเกิดเหตุละเมิด และใช้ตรวจการเข้าถึงที่ไม่เกี่ยวกับการรักษา เช่น การเปิดดูประวัติคนดัง
3. ต้องมีคำขอและการอนุมัติตามลำดับชั้น มี DSA ส่งเฉพาะคอลัมน์ที่จำเป็น ทำ Pseudonymization (ตัวอย่าง SQL หัวข้อ 4.5) ส่งผ่านช่องทางที่เข้ารหัส และบันทึกการเปิดเผยข้อมูล
4. คำตอบขึ้นกับหน่วยงาน ใช้คำสั่ง `SELECT user, host FROM mysql.user` บัญชีที่ host เป็น `%` หรือมีสิทธิ์ ALL PRIVILEGES โดยไม่จำเป็นควรจำกัดลง

บทที่ 13 การสำรองข้อมูล 3-2-1 และ BCP/DRP

1. ข้อมูล 3 ชุด เก็บบนสื่อ 2 แบบ 1 ชุดอยู่นอกสถานที่ 1 ชุด Offline หรือ Immutable ที่ผู้โจมตีลบไม่ได้ และ 0 ข้อผิดพลาดเมื่อทดสอบกู้คืน
2. RPO คือข้อมูลที่ยอมให้หายย้อนหลังได้มากที่สุด เช่น RPO 24 ชม. ต้องสำรองอย่างน้อยวันละครั้ง ส่วน RTO คือเวลาที่ต้องกู้ระบบให้กลับมาใช้ได้
3. แยก NAS ออกจากโดเมนและใช้บัญชีเฉพาะ เพิ่มชุดสำรองแบบ Offline หรือ Immutable (เช่น Snapshot ที่ลบไม่ได้ หรือเทปและดิสก์ที่ถอดออก) เข้ารหัส Backup ที่ออกนอกสถานที่ และทดสอบกู้คืนทุกเดือน
4. คำตอบขึ้นกับหน่วยงาน บันทึกลงแบบภาคผนวก ข.5 ถ้าเวลาที่ใช้เกิน RTO ต้องปรับวิธีสำรองหรือปรับ RTO ร่วมกับผู้บริหาร

บทที่ 14 Log Management และ SIEM ด้วย Wazuh

1. System, Access, Authentication, Authorization, Error และ Application Logs เก็บไม่น้อยกว่า 90 วันตาม พ.ร.บ.คอมพิวเตอร์ (แนะนำ 120–180 วัน)
2. เพื่อให้เรียงลำดับเหตุการณ์จากหลายแหล่งได้ถูกต้องตอนสืบสวน ถ้าเวลาไม่ตรงกันจะเชื่อม Log Firewall, VPN และเครื่องลูกข่ายเข้าด้วยกันไม่ได้ และหลักฐานอ่อนลง
3. คัดกรองตามภาพที่ 14.2 ตรวจบริบทว่าบัญชีใด สำเร็จหรือไม่ ถ้ามีบัญชีที่ Login สำเร็จให้ถือเป็น P1/P2 ปิดบัญชี เปลี่ยนรหัส ตรวจ MFA และเปิดเหตุตามบทที่ 17 ถ้าไม่สำเร็จให้บล็อก IP และตรวจว่าจำกัดประเทศที่ VPN แล้วหรือยัง
4. คำตอบขึ้นกับหน่วยงาน ภาพหน้าจอต้องเห็นเวลา ชื่อเครื่อง และระดับของ Alert ใช้เป็นหลักฐาน CTAM+ ได้หลายข้อพร้อมกัน

บทที่ 15 Threat Intelligence ด้วย NCSA Blacklist

1. เชิงป้องกัน คือนำ IOC ไปบล็อกที่ Firewall, DNS หรือ WAF และเชิงตรวจจับ คือค้น Log ย้อนหลังว่าเคยมีเครื่องใดติดต่อ IOC เหล่านั้นแล้วหรือไม่
2. IOC บางรายการอาจเป็น IP หรือโดเมนที่ใช้ร่วมกันกับบริการปกติ เช่น Cloud หรือ CDN การบล็อกทันทีอาจทำให้ระบบงานหยุด ควรตรวจแหล่งที่มา อายุของข้อมูล และทดสอบก่อน

3. ถือเป็นสัญญาณที่ต้องสืบต่อ ตรวจเครื่องนั้นด้วย EDR ดูโปรเซสและการเชื่อมต่อ ตรวจบัญชีที่ใช้บนเครื่อง ถ้าพบร่องรอยมัลแวร์ให้ตัดเครือข่ายและเปิดเหตุตามบทที่ 17 แล้วแจ้ง Health CERT
4. คำตอบขึ้นกับหน่วยงาน ควรอัปเดตอัตโนมัติอย่างน้อยวันละครั้ง วาง Policy บล็อกไว้บนสุด และเก็บ Log การบล็อกไว้ตรวจย้อน

บทที่ 16 Vulnerability Assessment และ Penetration Testing

1. VA คือสแกนหาช่องโหว่ที่รู้จักแบบอัตโนมัติ ทำเองได้บ่อย เช่น รายเดือน ส่วน Pentest คือผู้ทดสอบพยายามเจาะจริงเพื่อพิสูจน์ผลกระทบ ทำปีละครั้งโดยผู้ทดสอบที่ได้รับอนุญาตเป็นลายลักษณ์อักษร
2. ช่องโหว่ที่อยู่ใน CISA KEV (ถูกใช้โจมตีจริงแล้ว) และช่องโหว่บนระบบที่เปิดสู่อินเทอร์เน็ต โดยไม่ต้องดูคะแนน CVSS เพียงอย่างเดียว
3. แจ้งผู้ประสานงานของผู้ทดสอบให้หยุดชั่วคราวทันทีตามช่องทางที่ตกลงไว้ ก่อนทดสอบควรระบุ HIS Production ช่วงกลางวันเป็นส่วนที่ไม่ให้ทดสอบ กำหนดวันเวลาให้ชัด และสำรองข้อมูลก่อนวันทดสอบ (หัวข้อ 16.8)
4. คำตอบขึ้นกับหน่วยงาน สแกนเฉพาะระบบของตนที่อยู่ในทะเบียน ระวังอุปกรณ์การแพทย์ และงานจะจบเมื่อ Rescan ยืนยันว่าปิดแล้วเท่านั้น

บทที่ 17 การรับมือเหตุการณ์และการแจ้งเหตุ

1. Health CERT ภายใน 24 ชั่วโมง และ สคส. ภายใน 72 ชั่วโมงนับแต่ทราบเหตุ ถ้าเหตุนั้นเกี่ยวกับข้อมูลส่วนบุคคลและมีความเสี่ยงต่อสิทธิของเจ้าของข้อมูล
2. เพราะหลักฐานในหน่วยความจำ เช่น โปรเซสและการเชื่อมต่อของมัลแวร์ จะหายไป ให้ตัดเครือข่ายแทนแล้วปรึกษาผู้เชี่ยวชาญก่อน หลักฐานที่ไวที่สุดคือ RAM ต้องเก็บก่อน (หัวข้อ 17.9)
3. P2 High เพราะบัญชีถูกเข้าถึงโดยไม่ได้รับอนุญาต ใช้การ์ด ช.4 และถ้าพบว่ามีข้อมูลผู้ป่วยถูกส่งออกไปให้ใช้การ์ด ช.2 ด้วย
4. คำตอบขึ้นกับหน่วยงาน ใช้รูปแบบหัวข้อ 17.11 และสรุปผลด้วยแบบ AAR ใน Toolkit จุดที่มักพบคือไม่มีรายชื่อติดต่อฉบับกระดาษ และไม่รู้ว่าใครมีอำนาจสั่งตัดเครือข่าย

บทที่ 18 Security Awareness สำหรับบุคลากรสาธารณสุข

1. ใครส่งมาและคาดว่าจะได้รับหรือไม่ เร่งหรือข่มขู่หรือไม่ ลิงก์ชี้ไปที่ไหน และขอรหัสผ่าน OTP ข้อมูลผู้ป่วยหรือให้ติดตั้งโปรแกรมหรือไม่
2. เพราะสะท้อนว่าบุคลากรเป็นแนวป้องกันที่ช่วยแจ้งเหตุได้ ยิ่งมีคนแจ้งเร็ว IT ยิ่งบล็อกและเตือนคนอื่นทัน ส่วนอัตราการคลิกไม่มีวันเป็นศูนย์
3. ย้ำว่าการแจ้งเร็วไม่ถูกลงโทษจากการแจ้ง และชื่นชมผู้ที่แจ้ง เพราะความเสียหายเกิดจากการแจ้งช้า ไม่ใช่จากการคลิก ใช้หลักวัฒนธรรมการแจ้งเหตุโดยไม่กล่าวโทษในหัวข้อ 18.8
4. คำตอบขึ้นกับหน่วยงาน ควรใช้ตัวอย่างข้อความหลอกที่เจอจริงในหน่วยงาน มีแบบทดสอบสั้นก่อนและหลัง (Toolkit แบบที่ 06) และบอกช่องทางแจ้ง IT ที่ชัดเจน

บทที่ 19 ธรรมาภิบาลและแผนยกระดับระดับจังหวัด/เขต

1. ผู้บริหารสูงสุดเป็นเจ้าของความเสี่ยง CISO ขับเคลื่อนงานความมั่นคงปลอดภัย และ DPO ดูแลด้านข้อมูลส่วนบุคคล
2. DPA ตาม PDPA การเข้าถึงระยะไกลผ่าน VPN + MFA ที่หน่วยงานควบคุมและบันทึก หน้าที่แจ้งเหตุภายในเวลาที่กำหนด การแพตช์และรองรับ OS ที่ยังได้รับการสนับสนุน และการคืนหรือทำลายข้อมูลเมื่อสิ้นสัญญา
3. ทำเป็นบริการร่วมระดับจังหวัด เช่น Wazuh กลาง Backup ร่วม Firewall Template มาตรฐาน และทีมตอบสนองเหตุที่ไปช่วยได้ ตามโมเดล สสจ. ดูแลหน่วยบริการในบทนี้
4. คำตอบขึ้นกับหน่วยงาน ควรมี Heat Map 5 อันดับแรก สิ่งที่ทำเสร็จ สถานะ CTAM+ แบบสีเขียว เหลือง แดง และเรื่องที่ต้องให้ผู้บริหารตัดสินใจ

บทที่ 20 มาตรฐานสากลและบทเรียนต่างประเทศสำหรับสุขภาพดิจิทัล

1. อีเมลฟิชชิง, Ransomware, อุปกรณ์หรือข้อมูลสูญหายหรือถูกขโมย, ภัยจากคนในทั้งตั้งใจและพลั้งเผลอ และการโจมตีอุปกรณ์การแพทย์ที่เชื่อมเครือข่าย
2. Volume 1 สำหรับองค์กรขนาดเล็ก Volume 2 สำหรับองค์กรขนาดกลางถึงใหญ่ ทั้งสองเล่มใช้ 10 แนวปฏิบัติชุดเดียวกันแต่ลึกต่างกัน โรงพยาบาลชุมชนเริ่มจาก Volume 1 ได้
3. ข้อมูลเก็บที่ใด เข้ารหัสหรือไม่ การยืนยันตัวตนแพทย์และผู้ป่วย การบันทึก Log DPA ตาม PDPA การแจ้งเหตุจากผู้ให้บริการ และการคืนข้อมูลเมื่อเลิกใช้ ตามหัวข้อ 20.6
4. คำตอบขึ้นกับหน่วยงาน ตัวอย่างเช่น MFA (CTAM+ ข้อ 7 และ PR.AA) Backup (CTAM+ และ PR.DS/RC) และแผนรับมือเหตุ (CTAM+ และ RS)

บทที่ 21 ความปลอดภัยอีเมล โดเมน และ Cloud Workspace

1. SPF ระบุว่าเซิร์ฟเวอร์ใดส่งอีเมลในนามโดเมนได้ DKIM ลงลายมือชื่อดิจิทัลให้ตรวจว่าอีเมลไม่ถูกแก้ ส่วน DMARC บอกผู้รับว่าจะทำอย่างไรกับอีเมลที่ไม่ผ่าน และส่งรายงานกลับมาให้เจ้าของโดเมน
2. เพราะอาจมีระบบที่ส่งอีเมลในนามโดเมนแต่ยังไม่ผ่าน SPF/DKIM เช่น ระบบนัดหมายที่ Vendor ส่งแทน อีเมลจริงจะหาย ต้องเริ่มจาก p=none อ่านรายงาน 2–4 สัปดาห์ แล้วค่อยเพิ่มเป็น quarantine และ reject ตามภาพที่ 21.2
3. ประกาศว่าไม่มีใครส่งได้ด้วย SPF `v=spf1 -all` และ DMARC `v=DMARC1; p=reject` ตามขั้น 6 ในหัวข้อ 21.4 เพื่อไม่ให้ถูกปลอมเป็นผู้ส่ง
4. คำตอบขึ้นกับหน่วยงาน ตรวจด้วยคำสั่ง `dig TXT` หรือ `nslookup -type=TXT` และระวังจำนวนการค้น DNS ใน SPF รวมไม่เกิน 10 ครั้ง

บทที่ 22 ความปลอดภัยอุปกรณ์การแพทย์ PACS การเชื่อมต่อ HL7 และระบบอาคาร

1. เพราะโดยทั่วไปส่งข้อมูลผู้ป่วยโดยไม่เข้ารหัสและยืนยันตัวตนน้อย ใครเข้าถึงพอร์ตได้ก็อาจดึงหรือแก้ข้อมูลได้ ต้องจำกัดผู้เชื่อมต่อเฉพาะเครื่องที่อนุญาตและแยกเครือข่าย
2. MDS2 และ SBOM ของซอฟต์แวร์ในเครื่อง ระยะเวลาที่ผู้ผลิตจะออกแพตช์และรองรับ OS วิธีเข้าถึงระยะไกลที่ควบคุมได้ และการเปลี่ยนรหัส Default ตามหัวข้อ 22.6

3. ย้ายไปโซน OT แยกจากเครือข่ายสำนักงาน เปลี่ยนรหัส Default ให้ Vendor เข้าผ่านช่องทางที่อนุมัติเท่านั้น บันทึกในทะเบียน และเตรียมวิธีควบคุมด้วยมือเมื่อระบบใช้ไม่ได้ (หัวข้อ 22.9)
4. คำตอบขึ้นกับหน่วยงาน ใช้คอลัมน์ตามหัวข้อ 22.2 และระบุผู้รับผิดชอบตามตาราง RACI หัวข้อ 22.7

บทที่ 23 ผู้โจมตีเจาะระบบโรงพยาบาลอย่างไร: รู้ทันยุทธวิธีเพื่อป้องกัน

1. ผู้โจมตีต้องสำเร็จทุกขั้นของวงจร แต่ผู้ป้องกันตรวจพบขั้นเดียวก็หยุดได้ เช่น วันที่ 0 แจ้งเตือนการล็อกอิน VPN ที่ไม่มี MFA จากต่างประเทศ วันที่ 2–5 ตรวจจับการขโมยรหัสผ่านจากหน่วยความจำ หรือวันที่ 10–13 เห็นการอัปโหลดข้อมูลปริมาณมากที่ Firewall
2. คำตอบขึ้นกับหน่วยงาน ช่องทางที่พบบ่อยคือ VPN หรือ Remote Access ที่ไม่มี MFA, ช่องโหว่อุปกรณ์ที่เปิดสู่อินเทอร์เน็ต และฟิชชิง ให้ตรวจกับตารางหัวข้อ 23.6
3. คำตอบขึ้นกับหน่วยงาน ทดสอบด้วยวิธี Purple Team (หัวข้อ 23.10) บนเครื่องทดสอบ และบันทึกเทคนิคที่ยังไม่มี Alert เพื่อเพิ่มกฎ
4. ไม่รีเซ็ตทันทีทางโทรศัพท์ ให้โทรกลับเบอร์ที่อยู่ในทะเบียน ยืนยันกับหัวหน้างานหรือให้แสดงตัวต่อหน้า และการรีเซ็ต MFA ต้องยืนยันเข้มกว่ารีเซ็ตรหัสผ่าน บันทึกทุกคำขอ
5. ควรมีเหตุตั้งต้นที่สมจริง Inject ที่ทำให้ต้องตัดสินใจ เช่น Backup ถูกลบ สื่อโทรมา หรือผู้โจมตีขู่เผยแพร่ข้อมูล และกำหนดผู้สังเกตการณ์บันทึกจุดที่ทำไม่ได้

บทที่ 24 ระบบโฟลว์การประสานข้อมูลและแบ่งปันความรู้ด้านไซเบอร์

1. คำตอบขึ้นกับจังหวัด ควรเห็นเส้นทาง รพ.สต. → รพ./สสจ. → เขต → Health CERT → สกมช. และใช้เฉพาะช่องทางทางการ เช่น health-cirt.moph.go.th
2. ควรมีระดับความเร่งด่วน ระบบที่กระทบ สิ่งที่ต้องทำและกำหนดเวลา วิธีตรวจว่าได้รับผลกระทบหรือไม่ ป้าย TLP และช่องทางรายงานกลับ
3. ผลสแกนช่องโหว่ของ รพ. → TLP:AMBER หรือ AMBER+STRICT, อีเมลฟิชชิงที่กำลังระบาด → TLP:GREEN, คู่มือตั้งค่า MFA → TLP:CLEAR
4. เพราะผู้โจมตีเปลี่ยนค่าแฮชไฟล์ได้ง่ายมาก แต่เปลี่ยนพฤติกรรมและเครื่องมือที่ใช้ได้ยาก ข้อมูลระดับบนของ Pyramid of Pain จึงใช้ตรวจจับได้นานกว่า
5. คำตอบขึ้นกับจังหวัด ควรมีวาระทบทวนเหตุที่เกิดจริง แบ่งปันกฎตรวจจับ ติดตามคำเตือนค้าง และผู้รับผิดชอบสรุปบทเรียนลงคลังความรู้

บทที่ 25 เทคโนโลยีใหม่ที่ช่วยป้องกันการเจาะระบบ

1. คำตอบขึ้นกับเทคโนโลยีที่เลือก ข้อที่มักถูกมองข้ามคือใครจะดูการแจ้งเตือนทุกวันรวมวันหยุด และค่าใช้จ่ายต่อปีหลังปีแรก
2. คำตอบขึ้นกับหน่วยงาน หน่วยบริการส่วนใหญ่ควรเริ่มที่เสาตัวตน (MFA) และเสาเครือข่าย (แบ่งโซนและเลิกเปิด VPN ให้ทุกคน)
3. OTP เป็นรหัสที่ผู้ใช้พิมพ์เอง จึงถูกหลอกให้กรอกในเว็บปลอมได้ ส่วน Passkey ผูกกับโดเมนจริงและไม่มีรหัสให้กรอก เว็บปลอมจึงขอการยืนยันไม่ได้

4. ตัวอย่าง: บัญชีล่อใน AD ไฟล์ล่อบน File Server และเครื่องล่อ OpenCanary ใน Server Zone ทุกแบบต้องแจ้งเตือนถึงผู้รับผิดชอบทันที เพราะไม่มีใครควรแตะต้อง
5. คำสั่งโอนเงินเร่งด่วนต้องยืนยันโดยโทรกลับเบอร์ที่อยู่ในทะเบียน ใช้รหัสยืนยันที่ตกลงกันล่วงหน้า และต้องมีผู้อนุมัติสองคน ไม่ว่าเสียงหรือวิดีโอจะเหมือนผู้บริหารแค่ไหน

บรรณานุกรมและแหล่งอ้างอิง

ลิงก์ตรวจสอบ ณ เดือนตุลาคม 2569 เว็บไซต์อาจเปลี่ยนโครงสร้างหรือเลขหน้า หากเปิดไม่ได้ให้ค้นจากชื่อเอกสาร ตัวเลขสถิติที่มาจากรายงานข่าวควรตรวจกับรายงานฉบับทางการของหน่วยงานก่อนนำไปอ้างอิงในเอกสารราชการ

ก. กฎหมาย ประกาศ และเอกสารของหน่วยงานไทย

กฎหมายและประกาศ

1. พระราชบัญญัติการรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562 — ราชกิจจานุเบกษา, `ratchakitcha.soc.go.th`
2. พระราชบัญญัติคุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 — ราชกิจจานุเบกษา
3. พระราชบัญญัติว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. 2550 และที่แก้ไขเพิ่มเติม (ฉบับที่ 2) พ.ศ. 2560
4. พระราชบัญญัติการบริหารงานและการให้บริการภาครัฐผ่านระบบดิจิทัล พ.ศ. 2562
5. พระราชบัญญัติสุขภาพแห่งชาติ พ.ศ. 2550
6. ประกาศคณะกรรมการกำกับดูแลด้านความมั่นคงปลอดภัยไซเบอร์ เรื่อง ประมวลแนวทางปฏิบัติและกรอบมาตรฐานด้านการรักษาความมั่นคงปลอดภัยไซเบอร์สำหรับหน่วยงานของรัฐและหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ พ.ศ. 2564
7. ประกาศคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ เรื่อง ลักษณะภัยคุกคามทางไซเบอร์ มาตรการป้องกัน รับมือ ประเมิน ปราบปราม และระงับภัยคุกคามทางไซเบอร์แต่ละระดับ พ.ศ. 2564
8. ประกาศคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล เรื่อง หลักเกณฑ์และวิธีการในการแจ้งเหตุการละเมิดข้อมูลส่วนบุคคล พ.ศ. 2565 — `pdpc.or.th`

กระทรวงสาธารณสุข

9. ประกาศกระทรวงสาธารณสุข เรื่อง นโยบายและแนวปฏิบัติในการรักษาความมั่นคงปลอดภัยด้านสารสนเทศของกระทรวงสาธารณสุข พ.ศ. 2565
10. ศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร สป.สธ. เกณฑ์ CTAM+ ปีงบประมาณ 2569 (Version 25681125) และคู่มือการใช้งานระบบ CTAM+ — `cyber.moph.go.th`
11. ศทส.สป.สธ. เกณฑ์ CTAM V4 (20241122)
12. ศทส.สป.สธ. ตัวชี้วัด Cybersecurity Version 2.1

13. ศทส.สป.สธ. แนวทางการจัดทำแผนบริหารความเสี่ยง งบประมาณ บุคลากร และแนวปฏิบัติด้านความมั่นคงปลอดภัยไซเบอร์ ปี 2566–2568
14. ศทส.สป.สธ. ตัวอย่าง Flow การแจ้งเหตุการณ์ภัยคุกคามไซเบอร์ของหน่วยงานในสังกัดกระทรวงสาธารณสุข
15. คำสั่งสำนักงานปลัดกระทรวงสาธารณสุข ที่ 1189/2565 (เจ้าหน้าที่คุ้มครองข้อมูลส่วนบุคคล) และที่ 1480/2565 (เจ้าหน้าที่ประสานงานคุ้มครองข้อมูลส่วนบุคคล)
16. เอกสารชี้แจงการดำเนินงานตามกฎหมาย PDPA และ Cyber ของ สป.สธ. และเว็บไซต์ `pdpa.moph.go.th`
17. แนวทางการดำเนินงานธรรมาภิบาลข้อมูล (Data Governance) กระทรวงสาธารณสุข
18. Health CERT ศทส.สป.สธ. — `health-cirt.moph.go.th`
19. สถาบันรับรองคุณภาพสถานพยาบาล (สรพ.) มาตรฐาน HAIT

หน่วยงานอื่น

20. สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ (สกมช.) — `ncsa.or.th`; ThaiCERT — `thaicert.or.th`
21. สกมช. แบบขอรับการทดสอบความมั่นคงปลอดภัยของระบบเครื่องแม่ข่ายและเว็บไซต์ (OP01)
22. สกมช. คู่มือ Cyber Security สำหรับประชาชน
23. สกมช. คู่มือกรณีศึกษาจากการดำเนินการตาม พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562 (กันยายน 2566)
24. สำนักงานพัฒนารัฐบาลดิจิทัล (สพร.) มาตรฐานและร่างมาตรฐานรัฐบาลดิจิทัล — `standard.dga.or.th`
25. สำนักงานพัฒนาธุรกรรมทางอิเล็กทรอนิกส์ (สพธอ.) — `etda.or.th`
26. สำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล (สคส.) — `pdpc.or.th`

รายงานข่าวที่อ้างอิงในหนังสือ

27. Thai PBS. “PDPA กับข้อคิดองค์กร กรณีสั่งปรับเอกชน 7 ล้านบาท” (สิงหาคม 2567) — https://www.thaipbs.or.th/now/content/1538
28. InfoQuest. “สคส.ประเดิมสั่งปรับ 7 ลบ.บริษัทเอกชนปล่อยข้อมูลลูกค้ากว่าแสนรายรั่วไปถึงแก๊งคอลเซ็นเตอร์” — https://www.infoquest.co.th/?p=423053
29. Thai PBS. “สธ.ยืนยันข้อมูลไม่หลุด แจงมีขั้นตอนตรวจสอบ 3 ชั้น” (มีนาคม 2567) — https://www.thaipbs.or.th/news/content/338248
30. รายงานข่าวอ้างอิงข้อมูล สกมช. เรื่องสถิติเหตุการณ์ภัยคุกคามไซเบอร์ปี 2567 และผลประเมินหน่วยงานภาครัฐปี 2568 (ฐานเศรษฐกิจ, ไทยรัฐ, กรุงเทพธุรกิจ) — ควรตรวจกับรายงานประจำปีของ สกมช.

ข. แนวทางและรายงานต่างประเทศ

สหรัฐอเมริกา

31. NIST. *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29, February 2024 — https://www.nist.gov/cyberframework
32. NIST. *SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management*, April 2025 — https://csrc.nist.gov/pubs/sp/800/61/r3/final
33. NIST. *SP 800-66 Rev. 2: Implementing the HIPAA Security Rule: A Cybersecurity Resource Guide*, February 2024 — https://csrc.nist.gov/pubs/sp/800/66/r2/final
34. NIST. *SP 800-207: Zero Trust Architecture*, 2020 — https://csrc.nist.gov/pubs/sp/800/207/final
35. HHS 405(d) Program. *Health Industry Cybersecurity Practices (HICP): Managing Threats and Protecting Patients, 2023 Edition* และ Technical Volumes 1–2 — https://405d.hhs.gov
36. HHS. *Healthcare and Public Health Sector-Specific Cybersecurity Performance Goals* (2024) — https://asprtracie.hhs.gov/technical-resources/resource/12863/healthcare-and-public-health-sector-specific-cybersecurity-performance-goals
37. CISA. *Known Exploited Vulnerabilities Catalog* — https://www.cisa.gov/known-exploited-vulnerabilities-catalog
38. CISA. *Binding Operational Directive 18-01: Enhance Email and Web Security* — https://www.cisa.gov/binding-operational-directive-18-01
39. CISA. *DMARC for Healthcare Delivery Organizations* — https://www.cisa.gov/sites/default/files/publications/CISA%20DMARC%20HDO_040721_508.pdf
40. U.S. FDA. *Cybersecurity in Medical Devices: Quality System Considerations and Content of Premarket Submissions* และข้อกำหนดมาตรา 524B — https://www.fda.gov/medical-devices/digital-health-center-excellence/cybersecurity
41. Infosecurity Magazine. “Change Healthcare Breach Almost Doubles in Size to 190 Million Victims” (2025) — https://www.infosecurity-magazine.com/news/change-healthcare-breach-doubles/

ยุโรปและนานาชาติ

42. ENISA. *ENISA Threat Landscape: Health Sector* (July 2023) — https://www.enisa.europa.eu/sites/default/files/publications/Health%20Threat%20Landscape.pdf
43. ENISA. Cybersecurity of critical sectors: Health — https://www.enisa.europa.eu/topics/cybersecurity-of-critical-sectors/health
44. WHO. “WHO Director-General’s remarks at meeting of the UN Security Council on threats posed by ransomware attacks” (8 November 2024) — https://www.who.int/news-room/speeches/item/who-director-general-s-remarks-at-meeting-of-the-un-security-council-on-threats-posed-by-ransomware-attacks

45. WHO. “WHO Director-General briefs the UN Security Council on ransomware attacks on healthcare” — https://www.who.int/news/item/26-11-2024-who-director-general-briefs-the-un-security-council-on-ransomware-attacks-on-healthcare
46. United Nations Security Council. Meeting record S/PV.9779 — https://digitallibrary.un.org/record/4066634
47. WHO. *Global Strategy on Digital Health 2020–2025* — https://www.who.int/publications/i/item/9789240020924
48. ISO/IEC 27001:2022, ISO 27799:2016, IEC 80001-1:2021, IEC 81001-5-1:2021 (มาตรฐานที่ต้องซื้อจาก ISO/IEC หรือ สมอ.)

อุปกรณ์การแพทย์และ PACS

49. Trend Micro. “A Hidden Vulnerability in Healthcare: Exposed DICOM Servers and the Risk to Patient Data” — https://www.trendmicro.com/vinfo/gb/security/news/cybercrime-and-digital-threats/a-hidden-vulnerability-in-healthcare-exposed-dicom-servers-and-the-risk-to-patient-data
50. ITPro. “Researchers find 45 million medical images exposed online” (CybelAngel, 2024) — https://itpro.com/security/cyber-security/358174/researchers-find-45-million-medical-images-exposed-online
51. TechCrunch. “Medical scans, health records exposed via DICOM/PACS” (December 2023) — https://techcrunch.com/2023/12/06/medical-scans-health-records-dicom-pacs-security
52. NEMA. *Manufacturer Disclosure Statement for Medical Device Security (MDS2)* — https://www.nema.org

ค. เครื่องมือและเอกสารทางเทคนิค

53. OWASP Top 10 (2021) — https://owasp.org/Top10/
54. OWASP API Security Top 10 (2023) — https://owasp.org/API-Security/
55. OWASP MASVS — https://mas.owasp.org/MASVS/
56. OWASP ModSecurity — https://github.com/owasp-modsecurity/ModSecurity ; OWASP Core Rule Set — https://coreruleset.org
57. Wazuh Documentation — https://documentation.wazuh.com
58. Greenbone Community Edition Documentation — https://greenbone.github.io/docs/
59. ProjectDiscovery Nuclei — https://github.com/projectdiscovery/nuclei
60. OWASP ZAP — https://www.zaproxy.org
61. Nmap Reference Guide — https://nmap.org/book/man.html
62. ClamAV Documentation — https://docs.clamav.net
63. Cloudflare Tunnel (cloudflared) — https://developers.cloudflare.com/cloudflare-one/connections/connect-networks/

64. Let’s Encrypt / Certbot — https://certbot.eff.org
65. DCMTK (DICOM Toolkit) — https://dicom.offis.de/dcmtk
66. dnstwist — https://github.com/elceef/dnstwist
67. GoPhish — https://getgophish.com
68. NCSA Blacklist SOC Dashboard (โอเพนซอร์ส, กลุ่มงานสุขภาพดิจิทัล สสจ.มุกดาหาร) — https://github.com/thering999/ncsa-blacklist

ง. เอกสารประกอบการบรรยายและอบรมที่ใช้เป็นข้อมูล

69. เอกสารนำเสนอ Cyber Security in Healthcare / Cyber in Public Health / Hospital IT Risk Management (การประชุมวิชาการและการอบรมของกระทรวงสาธารณสุข)
70. เอกสารอบรม Cybersecurity Awareness สำหรับบุคลากร
71. เอกสาร Overview บริการ CO-CSIRT/CSOC สำหรับโรงพยาบาลในสังกัดกระทรวงสาธารณสุข (บริษัท อินเทอร์เน็ตประเทศไทย จำกัด (มหาชน)) — ภาพในหนังสือวาดใหม่และอ้างอิงที่มา
72. เอกสารอบรม Health Information Security with Cyber Attack Incident Response (มิถุนายน 2566)
73. Microsoft. Zero Trust in Action (เอกสารบรรยาย, พฤษภาคม 2566)
74. คู่มือตั้งค่าความปลอดภัย Firewall และเอกสารแบ่งปันประสบการณ์ของโรงพยาบาลในสังกัด
75. แนวทางการพัฒนาเว็บแอปพลิเคชันภาครัฐ 2566 และคำแนะนำการป้องกันและแก้ไขเว็บไซต์จากภัยคุกคาม
76. เอกสารแผน IT Contingency, BCP และ DRP ของหน่วยงานในสังกัด

จ. ยุทธวิธีผู้โจมตี การแบ่งปันข้อมูล และเทคโนโลยีป้องกันยุคใหม่ (ภาค 7)

ยุทธวิธีผู้โจมตีและรายงานสถานการณ์ภัย

77. MITRE. *ATT&CK Enterprise* และบันทึกการปรับปรุง v19 (เมษายน 2569) และ v20 (ตุลาคม 2569) — https://attack.mitre.org/resources/updates/
78. MITRE. *D3FEND: A Knowledge Graph of Cybersecurity Countermeasures* — https://d3fend.mitre.org
79. MITRE. *ATT&CK Navigator* — https://mitre-attack.github.io/attack-navigator/
80. Lockheed Martin. *The Cyber Kill Chain* — https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html
81. Verizon. *2026 Data Breach Investigations Report* (ตัวเลขภาคสุขภาพอ้างจากบทสรุปของสื่อเฉพาะทาง) — https://www.verizon.com/business/resources/reports/dbir/
82. Sophos. *The State of Ransomware in Healthcare 2025* — https://www.sophos.com/en-us/blog/the-state-of-ransomware-in-healthcare-2025
83. Google Cloud / Mandiant. *M-Trends 2026* — https://cloud.google.com/security/resources/m-trends

84. CrowdStrike. *2026 Global Threat Report* (ข่าวประชาสัมพันธ์ 24 กุมภาพันธ์ 2569) — https://www.crowdstrike.com/en-us/press-releases/2026-crowdstrike-global-threat-report/
85. Health-ISAC. *2026 Global Health Sector Threat Landscape Report* — https://health-isac.org/annual-threat-report-health-sector-2026/
86. CNN. "Finance worker pays out $25 million after video call with deepfake 'chief financial officer'" (กุมภาพันธ์ 2567) — https://edition.cnn.com/2024/02/04/asia/deepfake-cfo-scam-hong-kong-intl-hnk/index.html

การแบ่งปันข้อมูลภัยคุกคาม

87. NIST. *SP 800-150: Guide to Cyber Threat Information Sharing*, 2016 — https://csrc.nist.gov/pubs/sp/800/150/final
88. FIRST. *Traffic Light Protocol (TLP) Version 2.0* — https://www.first.org/tlp/
89. OASIS. *STIX Version 2.1* และ *TAXII Version 2.1* — https://oasis-open.github.io/cti-documentation/
90. MISP Project. *MISP Open Source Threat Intelligence Platform* — https://www.misp-project.org
91. ThaiCERT / สกมช. *Thailand Cyber Threat Intelligence (TCTI)* — https://www.thaicert.or.th/en/tcti
92. Bianco, D. "The Pyramid of Pain" (2013) — https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html
93. LINE. ประกาศยุติบริการ LINE Notify (31 มีนาคม 2568) — https://notify-bot.line.me

เทคโนโลยีป้องกันยุคใหม่

94. NIST NCCoE. *SP 1800-35: Implementing a Zero Trust Architecture*, June 2025 — https://www.nccoe.nist.gov/zerotrust
95. CISA. *Zero Trust Maturity Model Version 2.0*, April 2023 — https://www.cisa.gov/zero-trust-maturity-model
96. CISA. *Implementing Phishing-Resistant MFA* (Fact Sheet) และแนวทาง MFA — https://www.cisa.gov/mfa
97. Meyer, L. A. et al. (Microsoft). "How effective is multifactor authentication at deterring cyberattacks?" arXiv:2305.00945, 2023 — https://arxiv.org/abs/2305.00945
98. OWASP GenAI Security Project. *OWASP Top 10 for LLM Applications 2025* — https://genai.owasp.org/llm-top-10/
99. NIST. *FIPS 203, FIPS 204, FIPS 205* (August 2024) และ *IR 8547: Transition to Post-Quantum Cryptography Standards* — https://csrc.nist.gov/projects/post-quantum-cryptography
100. Microsoft. *Windows LAPS overview* — https://learn.microsoft.com/windows-server/identity/laps/laps-overview
101. Thinkst. *OpenCanary* — https://github.com/thinkst/opencanary
102. Red Canary. *Atomic Red Team* — https://github.com/redcanaryco/atomic-red-team
103. MITRE. *Caldera* — https://caldera.mitre.org

104. Wazuh. *Wazuh Documentation* (Ruleset, MITRE ATT&CK module, Active Response) — https://documentation.wazuh.com

> ข้อมูลที่ระบุตัวบุคคล IP Address ภายใน รหัสผ่าน และผลการประเมินรายหน่วยงานจากเอกสารต้นฉบับ ไม่ได้นำมาเผยแพร่ในหนังสือเล่มนี้

ดัชนีคำค้น

เลขหน้าอ้างอิงตามฉบับ PDF แสดงหน้าที่กล่าวถึงคำนั้นมากที่สุดไม่เกิน 8 ตำแหน่ง

0–9

3-2-1 (หลักการสำรองข้อมูล) 13, 16, 34, 41, 53, 97–98, 104

A

AAR (After Action Review) 200, 202, 232, 234–235, 245

Active Directory 60, 195

AE Title 168, 170

AI (ปัญญาประดิษฐ์) 152, 156, 179, 205–206, 213–214, 217

API 49, 67, 71, 82, 89, 108, 156, 203

ASM / CTEM 178, 213, 225

ATT&CK (MITRE) 176, 178–179, 182–184, 186–187

B

BCP / DRP 34, 42, 97, 101–102, 104, 218, 235

BMS / HVAC 172–174, 225

C

CIA Triad 14, 18, 225

CII (โครงสร้างพื้นฐานสำคัญทางสารสนเทศ) 16, 19–21, 23–24, 155, 225

CISA KEV 74–75, 124, 193–194, 202–203, 206

CISO 17–18, 25, 36, 39–40, 45, 146

Cloudflare 18, 43, 64–65, 68, 70, 72, 89

CSF (NIST Cybersecurity Framework) 14, 17–18, 129, 145, 154, 157, 233

CTAM+ 17, 35, 38–39, 146, 149, 157, 242

CVE / CVSS 74, 121, 123–124, 194, 225, 245

D

Deception / Honeypot 205–206, 211–213, 216–217, 225

Deepfake 214, 217, 240

Defacement 10, 82, 84, 128, 132–133, 184, 237

DICOM 66, 68, 80, 167–170, 174

DMARC / DKIM / SPF 159–162, 165–166, 226, 246

DNSSEC 65, 72, 89, 164, 226

Downtime Procedure 102, 104, 129–130, 132, 146, 171, 235

E

EDR / XDR 34, 41, 66, 77, 206, 209–210, 216

F

FHIR 152, 156, 158, 170, 226

Firewall 42, 66–67, 71, 73, 75, 111, 243

G

Google Workspace 148, 159, 163

H

Health CERT 22, 25, 75, 131, 191–192, 224, 234

Heat Map 53–54, 187, 242, 246

HIS (ระบบสารสนเทศโรงพยาบาล) 15, 24, 59, 91, 96, 99, 220–221

HL7 151, 156, 167–170, 174, 226

I

IEC 62443 167, 173

IoC (Indicator of Compromise) 42, 71, 116, 119–120, 196, 198, 244

IoMT 156, 158, 167, 226

ISO/IEC 27001 32, 34–37, 52, 66, 157

L

LAPS 59, 178, 181, 183, 188, 206, 215–216

Least Privilege 18, 58, 91, 93, 227

Living off the Land 182, 227

M

MDR 205–206, 209–210, 216, 227

MFA / 2FA 61, 66, 163, 165, 180, 208, 238, 247
Microsoft 365 148, 159–161, 163
MISP / TCTI 119, 191, 196, 199–200, 204, 206, 216
MySQL / MariaDB 28, 60, 76, 91–93, 99, 223

N

NDR 173, 206, 209–210, 216, 227
Nmap 51, 54–55, 112, 121–122, 168, 223

O

OT (เทคโนโลยีปฏิบัติการ) 34, 67, 167, 172–174, 227, 232
OWASP 43–44, 82, 86–87, 89, 123, 227

P

PACS 12, 50, 66, 167–170, 174
PAM 36, 41–42, 58, 66, 149, 218, 227
Passkey / FIDO2 61, 206, 208–209, 216–217, 227, 243
Patch 41–42, 66, 74–75, 149, 171, 218
PDPA 26, 35, 44, 96, 117, 142, 224, 246
Pentest 37, 44, 89, 121, 126, 149, 219, 245
Phishing 10, 69, 133, 139, 141–143, 149
Playbook 132–133, 136–137, 201, 238–240
PQC (การเข้ารหัสหลังควอนตัม) 206, 215–217, 228
Purple Team 187, 213, 247

R

RACI 148, 171, 192, 204, 228, 247
Ransomware 11–12, 34, 77, 152, 177, 181, 235
RDP 10, 53, 68, 178, 180, 182–183, 188
RPO / RTO 34, 97, 99–101, 103–104, 244

S

SASE / SSE 206, 211, 216, 228
SBOM / MDS2 80, 147, 156, 170, 216, 227, 232, 246
SIEM 13, 17, 43, 66, 106, 128, 199, 207
SITREP 135, 195, 228
SOAR 205–206, 209–211, 216, 228
SOC / CSOC 22, 117, 120, 148, 191, 206, 210, 225
SQL Injection 35, 82, 84–85, 88, 106
SSH 10, 58–59, 61–62, 68, 111–112
STIX / TAXII 117, 119, 199, 228
Sysmon 110, 178, 181, 183–184, 188, 206, 209

T

Tabletop Exercise 104, 130, 135, 137, 142, 148–149, 189
Telemedicine 152, 155, 158
Threat Hunting 176, 186, 201, 216, 228, 232
Threat Intelligence 105, 116, 119–120, 148, 199, 207, 209
TLP (Traffic Light Protocol) 119, 190, 193–194, 198, 200, 204, 247
TLS / HTTPS 68, 85, 89, 93, 95, 118, 170, 226
TOR (ข้อกำหนดการจัดซื้อ) 80, 89, 147, 156, 170–171, 173–174

V

VLAN 34, 66–67, 73, 75, 92, 169, 171
VPN 42, 53, 61, 68, 70, 170, 181, 247

W

WAF / ModSecurity 43, 82, 85–87, 89, 237, 243
Wazuh 107–108, 114–115, 117, 119, 186, 210

Z

Zero Trust 17–18, 72, 205–207, 217, 229
ZTNA 172–173, 180, 206–208, 211, 216

ก

กู้คืนข้อมูล 17, 23–24, 98, 101, 103, 235, 237

ข

ข้อมูลส่วนบุคคล 26–27, 30, 49, 53, 131, 192, 195

ค

ความตระหนักรู้ 33–34, 232–233
เครื่องมือแพทย์ 80, 147, 156, 167, 169, 174, 210, 246

จ

แจ้งเหตุ 22, 29–30, 128, 131, 143, 154, 245

ท

ทะเบียนทรัพย์สิน 49, 122, 194, 202, 208, 232, 239, 242

ธ

ธรรมาภิบาล 19, 22, 25–26, 31, 145–146, 232

บ

แบ่งปันข้อมูลภัยคุกคาม 190, 192–193, 196, 198–200, 204

ป

ประเมินความเสี่ยง / Risk Register 12, 14, 17, 21, 25, 32, 35, 37

ผ

ผู้รับเหมา / Vendor 60, 147, 150, 167, 169, 173, 180, 240

แผนรับมือเหตุการณ์ (Incident Response) 21, 33, 117, 119, 128, 152, 176, 232

พ

พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ 19–20, 36, 128, 147, 152, 154–155

ร

รหัสผ่าน 10, 57, 93, 108, 140–141, 179, 238

ว

วุฒิภาวะ (Maturity) 205, 207, 227, 229, 231, 233

ศ

ศทส.สป.สธ. 22, 25, 38–40, 46, 191, 224

ส

สกมช. 11, 21, 116, 121, 125–126, 191, 194

สคส. 26, 28–30, 131, 136, 195, 236

เมื่อระบบสุขภาพเป็นดิจิทัล
ความปลอดภัยไซเบอร์คือความปลอดภัยของผู้ป่วย

หนังสือเล่มนี้รวบรวมกฎหมาย มาตรฐาน และขั้นตอนลงมือทำ ที่หน่วยงานสาธารณสุขไทยต้องใช้จริง ตั้งแต่การวางนโยบายระดับผู้บริหาร ไปจนถึงการตั้งค่าไฟร์วอลล์ SIEM การกู้ระบบหลังถูกแรนซัมแวร์ การประสานข้อมูลภัยในเครือข่ายสาธารณสุข และเทคโนโลยีป้องกันยุคใหม่ โดยเทียบกับแนวทางสากลด้านสุขภาพดิจิทัล

🎯
อ่านแล้วทำตามได้
ทุกบทมีขั้นตอน คำสั่ง ไฟล์ตั้งค่า และหลักฐานที่ต้องเก็บ

✅
ตรงเกณฑ์ CTAM+
ครอบคลุม 17 เกณฑ์ ปี 2569 พร้อม Checklist พิมพ์ใช้ได้ทันที

⚖️
ถูกต้องตามกฎหมาย
พ.ร.บ.ไซเบอร์ 2562, PDPA, ประกาศ สคส. และนโยบาย สธ.

🧰
เครื่องมือโอเพนซอร์ส
Wazuh, ModSecurity, ClamAV, Greenbone, NCSA Blacklist

🚨
รู้ทันผู้โจมตี พร้อมรับมือ
MITRE ATT&CK, Threat Hunting, Playbook และโฟลว์ประสานข้อมูลภัย

🌍
สากลและเทคโนโลยีใหม่
NIST CSF 2.0, HHS 405(d), Zero Trust, XDR, AI และ PQC

เหมาะสำหรับ ผู้บริหาร CIO/CISO นักวิชาการคอมพิวเตอร์ DPO วิศวกรรมการแพทย์ และบุคลากรสาธารณสุขทุกระดับ
ข้อตกลง IP รหัสผ่าน และชื่อเครื่องในหนังสือเป็นค่าสมมติ ตรวจสอบกฎหมายและเกณฑ์ฉบับล่าสุดจากแหล่งทางการเสมอ